



MCP Security Audit Report

AgentSign

openclaw-lark

8 May 2026

Report ID: MCPS-MOVT68EJ

Executive Summary

FAIL

Risk Score



227
CRITICAL

35
HIGH

527
MEDIUM

506
LOW

SCAN SCOPE	LANGUAGES	MCPS SDK
384 files	javascript (191), typescript (190), json (3)	Not Found
44,005 lines		

Risk Comparison: WITHOUT MCPS vs WITH MCPS

CURRENT EXPOSURE			WITH MCPS PROTECTION		
MCP-01	Rug Pulls Vulnerable pattern detected, no mitigation	●	MITIGATED Passport identity binding — tools are tied to verified agent identity <code>createPassport()</code> , <code>signPassport()</code>		●
MCP-03	Privilege Escalation via Tool Composition No evidence of vulnerability or mitigation	●	MITIGATED Tool integrity signing — each tool definition is cryptographically signed <code>signTool()</code> , <code>verifyTool()</code>		●
MCP-04	Cross-Server Request Forgery Vulnerable pattern detected, no mitigation	●	MITIGATED Signed tool definitions prevent tampering during cross-server calls <code>signTool()</code> , <code>tool_hash</code>		●
MCP-06	Indirect Prompt Injection via MCP MCPS mitigation detected	●	MITIGATED Signed message envelopes — all MCP messages carry cryptographic signatures <code>signMessage()</code> , <code>verifyMessage()</code>		●
MCP-07	Resource Exhaustion & DoS No evidence of vulnerability or mitigation	●	MITIGATED Passport verification middleware — all requests require valid signed identity <code>secureMCP()</code> , <code>verifyPassport()</code>		●
MCP-08	Insufficient Logging & Audit Vulnerable pattern detected, no mitigation	●	MITIGATED Signed audit trail — every message exchange is logged with cryptographic proof <code>auditLog()</code> , <code>onAudit()</code>		●
MCP-09	Insecure MCP-to-MCP Communication MCPS mitigation detected	●	MITIGATED Origin binding — passports encode allowed origins, verified on each request <code>validateOrigin()</code> , <code>passport.origin</code>		●
MCP-10	Context Window Pollution MCPS mitigation detected	●	MITIGATED Envelope isolation — signed message boundaries prevent context pollution <code>signMessage()</code> , <code>envelope</code>		●
Risk Reduction					
100 --> 100					

OWASP MCP Top 10 Compliance

Coverage: 3/8 risks mitigated by MCPS

ID	Risk	Status	Current State	With MCPS
MCP-01	Rug Pulls	FAIL	Vulnerable pattern detected, no mitigation	Passport identity binding — tools are tied to verified agent identity
MCP-02	Tool Poisoning	N/A	Not applicable to code-level analysis	N/A — requires LLM-level defense
MCP-03	Privilege Escalation via Tool Composition	WARN	No evidence of vulnerability or mitigation	Tool integrity signing — each tool definition is cryptographically signed
MCP-04	Cross-Server Request Forgery	FAIL	Vulnerable pattern detected, no mitigation	Signed tool definitions prevent tampering during cross-server calls
MCP-05	Sampling Manipulation	N/A	Not applicable to code-level analysis	N/A — requires client-level defense
MCP-06	Indirect Prompt Injection via MCP	PASS	MCPS mitigation detected	Signed message envelopes — all MCP messages carry cryptographic signatures
MCP-07	Resource Exhaustion & DoS	WARN	No evidence of vulnerability or mitigation	Passport verification middleware — all requests require valid signed identity
MCP-08	Insufficient Logging & Audit	FAIL	Vulnerable pattern detected, no mitigation	Signed audit trail — every message exchange is logged with cryptographic proof
MCP-09	Insecure MCP-to-MCP Communication	PASS	MCPS mitigation detected	Origin binding — passports encode allowed origins, verified on each request
MCP-10	Context Window Pollution	PASS	MCPS mitigation detected	Envelope isolation — signed message boundaries prevent context pollution

Quick Fix `npm install mcp-secure`

Add MCPS to your MCP server to automatically mitigate the risks marked FAIL above.

OWASP Agentic AI Top 10 Coverage

12 rules checked | 1295 findings

Rule	OWASP	MITRE	STRIDE	Severity	Findings	Status
AS-001	AA-03	T1059	Elevation of Privilege	CRITICAL	219	
AS-002	AA-05	T1552	Information Disclosure	HIGH	33	
AS-003	AA-04	T1078	Elevation of Privilege	MEDIUM	225	
AS-004	AA-02	T1190	Tampering	HIGH	0	
AS-005	AA-02	T1055	Tampering	CRITICAL	8	
AS-006	AA-09	T1610	Elevation of Privilege	HIGH	2	
AS-007	AA-06	T1195	Tampering	LOW	506	
AS-008	AA-01	T1548	Elevation of Privilege	HIGH	0	
AS-009	AA-07	T1059.007	Tampering	MEDIUM	0	
AS-010	AA-08	T1562.002	Repudiation	MEDIUM	302	
AS-011	AA-10	T1041	Information Disclosure	HIGH	0	
AS-012	MCP-07	T1078.004	Spoofing	HIGH	0	

Detailed Findings

#1 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[bin/openclaw-lark.js:6](#)

Dependency without integrity verification

```
4 |  
> 5 | const mod = ['child', 'process'].join('_');  
6 | const { execFileSync } = createRequire(import.meta.url)(`node:${mod}`);  
7 | ...  
8 | // --tools-version <ver> lets the user pin a specific version
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#2 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[bin/openclaw-lark.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | #!/usr/bin/env node  
2 | import { createRequire } from 'node:module';  
3 | import { dirname, join } from 'node:path';
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#3 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[index.js:32](#)

Dangerous execution: Object.defineProperty(exports, "monitorFeishuProvider", { enumerable: true, get:

```
30 | // -----  
31 | var monitor_1 = require("./src/channel/monitor.js");  
> 32 | Object.defineProperty(exports, "monitorFeishuProvider", { enumerable: true, get: function ()  
{ return monitor_1.monitorFeishuProvider; } });  
33 | var send_1 = require("./src/messaging/outbound/send.js");  
34 | Object.defineProperty(exports, "sendMessageFeishu", { enumerable: true, get: function () { return  
send_1.sendMessageFeishu; } });
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#4 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[index.js:34](#)

Dangerous execution: Object.defineProperty(exports, "sendMessageFeishu", { enumerable: true, get: fun

```
32 | Object.defineProperty(exports, "monitorFeishuProvider", { enumerable: true, get: function ()
{ return monitor_1.monitorFeishuProvider; } });
33 | var send_1 = require("../src/messaging/outbound/send.js");
> 34 | Object.defineProperty(exports, "sendMessageFeishu", { enumerable: true, get: function () { return
send_1.sendMessageFeishu; } });
35 | Object.defineProperty(exports, "sendCardFeishu", { enumerable: true, get: function () { return
send_1.sendCardFeishu; } });
36 | Object.defineProperty(exports, "updateCardFeishu", { enumerable: true, get: function () { return...
send_1.updateCardFeishu; } });
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#5 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[index.js:35](#)

Dangerous execution: Object.defineProperty(exports, "sendCardFeishu", { enumerable: true, get: functi

```
33 | var send_1 = require("../src/messaging/outbound/send.js");
34 | Object.defineProperty(exports, "sendMessageFeishu", { enumerable: true, get: function () { return
send_1.sendMessageFeishu; } });
> 35 | Object.defineProperty(exports, "sendCardFeishu", { enumerable: true, get: function () { return
send_1.sendCardFeishu; } });
36 | Object.defineProperty(exports, "updateCardFeishu", { enumerable: true, get: function () { return
send_1.updateCardFeishu; } });
37 | Object.defineProperty(exports, "editMessageFeishu", { enumerable: true, get: function () { return
send_1.editMessageFeishu; } });
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#6 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[index.js:36](#)

Dangerous execution: Object.defineProperty(exports, "updateCardFeishu", { enumerable: true, get: func

```
34 | Object.defineProperty(exports, "sendMessageFeishu", { enumerable: true, get: function () { return
send_1.sendMessageFeishu; } });
35 | Object.defineProperty(exports, "sendCardFeishu", { enumerable: true, get: function () { return
send_1.sendCardFeishu; } });
> 36 | Object.defineProperty(exports, "updateCardFeishu", { enumerable: true, get: function () { return
send_1.updateCardFeishu; } });
37 | Object.defineProperty(exports, "editMessageFeishu", { enumerable: true, get: function () { return
send_1.editMessageFeishu; } });
38 | var fetch_1 = require("../src/messaging/outbound/fetch.js");
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#7 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[index.js:37](#)

Dangerous execution: `Object.defineProperty(exports, "editMessageFeishu", { enumerable: true, get: fun`

```
35 | Object.defineProperty(exports, "sendCardFeishu", { enumerable: true, get: function () { return
send_1.sendCardFeishu; } });
36 | Object.defineProperty(exports, "updateCardFeishu", { enumerable: true, get: function () { return
send_1.updateCardFeishu; } });
> 37 | Object.defineProperty(exports, "editMessageFeishu", { enumerable: true, get: function () { return
send_1.editMessageFeishu; } });
38 | var fetch_1 = require("../src/messaging/outbound/fetch.js");
39 | Object.defineProperty(exports, "getMessageFeishu", { enumerable: true, get: function () { return...
fetch_1.getMessageFeishu; } });
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#8 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[index.js:39](#)

Dangerous execution: `Object.defineProperty(exports, "getMessageFeishu", { enumerable: true, get: func`

```
37 | Object.defineProperty(exports, "editMessageFeishu", { enumerable: true, get: function () { return
send_1.editMessageFeishu; } });
38 | var fetch_1 = require("../src/messaging/outbound/fetch.js");
> 39 | Object.defineProperty(exports, "getMessageFeishu", { enumerable: true, get: function () { return
fetch_1.getMessageFeishu; } });
40 | var media_1 = require("../src/messaging/outbound/media.js");
41 | Object.defineProperty(exports, "uploadImageLark", { enumerable: true, get: function () { return
media_1.uploadImageLark; } });
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#9 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[index.js:41](#)

Dangerous execution: `Object.defineProperty(exports, "uploadImageLark", { enumerable: true, get: funct`

```
39 | Object.defineProperty(exports, "getMessageFeishu", { enumerable: true, get: function () { return
fetch_1.getMessageFeishu; } });
40 | var media_1 = require("../src/messaging/outbound/media.js");
> 41 | Object.defineProperty(exports, "uploadImageLark", { enumerable: true, get: function () { return
media_1.uploadImageLark; } });
42 | Object.defineProperty(exports, "uploadFileLark", { enumerable: true, get: function () { return
media_1.uploadFileLark; } });
43 | Object.defineProperty(exports, "sendImageLark", { enumerable: true, get: function () { return
media_1.sendImageLark; } });
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#10 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[index.js:42](#)

Dangerous execution: `Object.defineProperty(exports, "uploadFileLark", { enumerable: true, get: functi`

```
40 | var media_1 = require("../src/messaging/outbound/media.js");
41 | Object.defineProperty(exports, "uploadImageLark", { enumerable: true, get: function () { return
media_1.uploadImageLark; } });
> 42 | Object.defineProperty(exports, "uploadFileLark", { enumerable: true, get: function () { return
media_1.uploadFileLark; } });
43 | Object.defineProperty(exports, "sendImageLark", { enumerable: true, get: function () { return
media_1.sendImageLark; } });
44 | Object.defineProperty(exports, "sendFileLark", { enumerable: true, get: function () { return...
media_1.sendFileLark; } });
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#11 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[index.js:43](#)

Dangerous execution: `Object.defineProperty(exports, "sendImageLark", { enumerable: true, get: functio`

```
41 | Object.defineProperty(exports, "uploadImageLark", { enumerable: true, get: function () { return
media_1.uploadImageLark; } });
42 | Object.defineProperty(exports, "uploadFileLark", { enumerable: true, get: function () { return
media_1.uploadFileLark; } });
> 43 | Object.defineProperty(exports, "sendImageLark", { enumerable: true, get: function () { return
media_1.sendImageLark; } });
44 | Object.defineProperty(exports, "sendFileLark", { enumerable: true, get: function () { return
media_1.sendFileLark; } });
45 | Object.defineProperty(exports, "sendAudioLark", { enumerable: true, get: function () { return
media_1.sendAudioLark; } });
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#12 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[index.js:44](#)

Dangerous execution: `Object.defineProperty(exports, "sendFileLark", { enumerable: true, get: function`

```
42 | Object.defineProperty(exports, "uploadFileLark", { enumerable: true, get: function () { return
media_1.uploadFileLark; } });
43 | Object.defineProperty(exports, "sendImageLark", { enumerable: true, get: function () { return
media_1.sendImageLark; } });
> 44 | Object.defineProperty(exports, "sendFileLark", { enumerable: true, get: function () { return
media_1.sendFileLark; } });
45 | Object.defineProperty(exports, "sendAudioLark", { enumerable: true, get: function () { return
media_1.sendAudioLark; } });
46 | Object.defineProperty(exports, "uploadAndSendMediaLark", { enumerable: true, get: function ()
{ return media_1.uploadAndSendMediaLark; } });
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#13 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[index.js:45](#)

Dangerous execution: `Object.defineProperty(exports, "sendAudioLark", { enumerable: true, get: function`

```
43 | Object.defineProperty(exports, "sendImageLark", { enumerable: true, get: function () { return
media_1.sendImageLark; } });
44 | Object.defineProperty(exports, "sendFileLark", { enumerable: true, get: function () { return
media_1.sendFileLark; } });
> 45 | Object.defineProperty(exports, "sendAudioLark", { enumerable: true, get: function () { return
media_1.sendAudioLark; } });
46 | Object.defineProperty(exports, "uploadAndSendMediaLark", { enumerable: true, get: function ()
{ return media_1.uploadAndSendMediaLark; } });...
47 | var deliver_1 = require("../src/messaging/outbound/deliver.js");
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#14 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[index.js:46](#)

Dangerous execution: `Object.defineProperty(exports, "uploadAndSendMediaLark", { enumerable: true, get`

```
44 | Object.defineProperty(exports, "sendFileLark", { enumerable: true, get: function () { return
media_1.sendFileLark; } });
45 | Object.defineProperty(exports, "sendAudioLark", { enumerable: true, get: function () { return
media_1.sendAudioLark; } });
> 46 | Object.defineProperty(exports, "uploadAndSendMediaLark", { enumerable: true, get: function ()
{ return media_1.uploadAndSendMediaLark; } });
47 | var deliver_1 = require("../src/messaging/outbound/deliver.js");
48 | Object.defineProperty(exports, "sendTextLark", { enumerable: true, get: function () { return
deliver_1.sendTextLark; } });
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#15 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[index.js:48](#)

Dangerous execution: `Object.defineProperty(exports, "sendTextLark", { enumerable: true, get: function`

```
46 | Object.defineProperty(exports, "uploadAndSendMediaLark", { enumerable: true, get: function ()
{ return media_1.uploadAndSendMediaLark; } });
47 | var deliver_1 = require("../src/messaging/outbound/deliver.js");
> 48 | Object.defineProperty(exports, "sendTextLark", { enumerable: true, get: function () { return
deliver_1.sendTextLark; } });
49 | Object.defineProperty(exports, "sendCardLark", { enumerable: true, get: function () { return
deliver_1.sendCardLark; } });
50 | Object.defineProperty(exports, "sendMediaLark", { enumerable: true, get: function () { return
deliver_1.sendMediaLark; } });
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#16 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[index.js:49](#)

Dangerous execution: `Object.defineProperty(exports, "sendCardLark", { enumerable: true, get: function`

```
47 | var deliver_1 = require("./src/messaging/outbound/deliver.js");
48 | Object.defineProperty(exports, "sendTextLark", { enumerable: true, get: function () { return
deliver_1.sendTextLark; } });
> 49 | Object.defineProperty(exports, "sendCardLark", { enumerable: true, get: function () { return
deliver_1.sendCardLark; } });
50 | Object.defineProperty(exports, "sendMediaLark", { enumerable: true, get: function () { return
deliver_1.sendMediaLark; } });
51 | var probe_1 = require("./src/channel/probe.js");
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#17 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[index.js:50](#)

Dangerous execution: `Object.defineProperty(exports, "sendMediaLark", { enumerable: true, get: functio`

```
48 | Object.defineProperty(exports, "sendTextLark", { enumerable: true, get: function () { return
deliver_1.sendTextLark; } });
49 | Object.defineProperty(exports, "sendCardLark", { enumerable: true, get: function () { return
deliver_1.sendCardLark; } });
> 50 | Object.defineProperty(exports, "sendMediaLark", { enumerable: true, get: function () { return
deliver_1.sendMediaLark; } });
51 | var probe_1 = require("./src/channel/probe.js");
52 | Object.defineProperty(exports, "probeFeishu", { enumerable: true, get: function () { return
probe_1.probeFeishu; } });
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#18 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[index.js:52](#)

Dangerous execution: `Object.defineProperty(exports, "probeFeishu", { enumerable: true, get: function`

```
50 | Object.defineProperty(exports, "sendMediaLark", { enumerable: true, get: function () { return
deliver_1.sendMediaLark; } });
51 | var probe_1 = require("./src/channel/probe.js");
> 52 | Object.defineProperty(exports, "probeFeishu", { enumerable: true, get: function () { return
probe_1.probeFeishu; } });
53 | var reactions_1 = require("./src/messaging/outbound/reactions.js");
54 | Object.defineProperty(exports, "addReactionFeishu", { enumerable: true, get: function () { return
reactions_1.addReactionFeishu; } });
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#19 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[index.js:54](#)

Dangerous execution: `Object.defineProperty(exports, "addReactionFeishu", { enumerable: true, get: fun`

```
52 | Object.defineProperty(exports, "probeFeishu", { enumerable: true, get: function () { return
probe_1.probeFeishu; } });
53 | var reactions_1 = require("../src/messaging/outbound/reactions.js");
> 54 | Object.defineProperty(exports, "addReactionFeishu", { enumerable: true, get: function () { return
reactions_1.addReactionFeishu; } });
55 | Object.defineProperty(exports, "removeReactionFeishu", { enumerable: true, get: function () { return
reactions_1.removeReactionFeishu; } });
56 | Object.defineProperty(exports, "listReactionsFeishu", { enumerable: true, get: function () { return...
reactions_1.listReactionsFeishu; } });
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#20 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[index.js:55](#)

Dangerous execution: `Object.defineProperty(exports, "removeReactionFeishu", { enumerable: true, get:`

```
53 | var reactions_1 = require("../src/messaging/outbound/reactions.js");
54 | Object.defineProperty(exports, "addReactionFeishu", { enumerable: true, get: function () { return
reactions_1.addReactionFeishu; } });
> 55 | Object.defineProperty(exports, "removeReactionFeishu", { enumerable: true, get: function () { return
reactions_1.removeReactionFeishu; } });
56 | Object.defineProperty(exports, "listReactionsFeishu", { enumerable: true, get: function () { return
reactions_1.listReactionsFeishu; } });
57 | Object.defineProperty(exports, "FeishuEmoji", { enumerable: true, get: function () { return
reactions_1.FeishuEmoji; } });
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#21 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[index.js:56](#)

Dangerous execution: `Object.defineProperty(exports, "listReactionsFeishu", { enumerable: true, get: f`

```
54 | Object.defineProperty(exports, "addReactionFeishu", { enumerable: true, get: function () { return
reactions_1.addReactionFeishu; } });
55 | Object.defineProperty(exports, "removeReactionFeishu", { enumerable: true, get: function () { return
reactions_1.removeReactionFeishu; } });
> 56 | Object.defineProperty(exports, "listReactionsFeishu", { enumerable: true, get: function () { return
reactions_1.listReactionsFeishu; } });
57 | Object.defineProperty(exports, "FeishuEmoji", { enumerable: true, get: function () { return
reactions_1.FeishuEmoji; } });
58 | Object.defineProperty(exports, "VALID_FEISHU_EMOJI_TYPES", { enumerable: true, get: function ()
{ return reactions_1.VALID_FEISHU_EMOJI_TYPES; } });
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#22 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[index.js:57](#)

Dangerous execution: `Object.defineProperty(exports, "FeishuEmoji", { enumerable: true, get: function`

```
55 | Object.defineProperty(exports, "removeReactionFeishu", { enumerable: true, get: function () { return
    reactions_1.removeReactionFeishu; } });
56 | Object.defineProperty(exports, "listReactionsFeishu", { enumerable: true, get: function () { return
    reactions_1.listReactionsFeishu; } });
> 57 | Object.defineProperty(exports, "FeishuEmoji", { enumerable: true, get: function () { return
    reactions_1.FeishuEmoji; } });
    58 | Object.defineProperty(exports, "VALID_FEISHU_EMOJI_TYPES", { enumerable: true, get: function ()
    { return reactions_1.VALID_FEISHU_EMOJI_TYPES; } });...
    59 | var forward_1 = require("./src/messaging/outbound/forward.js");
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#23 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[index.js:58](#)

Dangerous execution: `Object.defineProperty(exports, "VALID_FEISHU_EMOJI_TYPES", { enumerable: true, g`

```
56 | Object.defineProperty(exports, "listReactionsFeishu", { enumerable: true, get: function () { return
    reactions_1.listReactionsFeishu; } });
57 | Object.defineProperty(exports, "FeishuEmoji", { enumerable: true, get: function () { return
    reactions_1.FeishuEmoji; } });
> 58 | Object.defineProperty(exports, "VALID_FEISHU_EMOJI_TYPES", { enumerable: true, get: function ()
    { return reactions_1.VALID_FEISHU_EMOJI_TYPES; } });
    59 | var forward_1 = require("./src/messaging/outbound/forward.js");
    60 | Object.defineProperty(exports, "forwardMessageFeishu", { enumerable: true, get: function () { return
    forward_1.forwardMessageFeishu; } });
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#24 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[index.js:60](#)

Dangerous execution: `Object.defineProperty(exports, "forwardMessageFeishu", { enumerable: true, get:`

```
58 | Object.defineProperty(exports, "VALID_FEISHU_EMOJI_TYPES", { enumerable: true, get: function ()
    { return reactions_1.VALID_FEISHU_EMOJI_TYPES; } });
59 | var forward_1 = require("./src/messaging/outbound/forward.js");
> 60 | Object.defineProperty(exports, "forwardMessageFeishu", { enumerable: true, get: function () { return
    forward_1.forwardMessageFeishu; } });
    61 | var chat_manage_1 = require("./src/messaging/outbound/chat-manage.js");
    62 | Object.defineProperty(exports, "updateChatFeishu", { enumerable: true, get: function () { return
    chat_manage_1.updateChatFeishu; } });
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#25 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[index.js:62](#)

Dangerous execution: `Object.defineProperty(exports, "updateChatFeishu", { enumerable: true, get: func`

```
60 | Object.defineProperty(exports, "forwardMessageFeishu", { enumerable: true, get: function () { return
forward_1.forwardMessageFeishu; } });
61 | var chat_manage_1 = require("../src/messaging/outbound/chat-manage.js");
> 62 | Object.defineProperty(exports, "updateChatFeishu", { enumerable: true, get: function () { return
chat_manage_1.updateChatFeishu; } });
63 | Object.defineProperty(exports, "addChatMembersFeishu", { enumerable: true, get: function () { return
chat_manage_1.addChatMembersFeishu; } });
64 | Object.defineProperty(exports, "removeChatMembersFeishu", { enumerable: true, get: function ()...
{ return chat_manage_1.removeChatMembersFeishu; } });
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#26 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[index.js:63](#)

Dangerous execution: `Object.defineProperty(exports, "addChatMembersFeishu", { enumerable: true, get:`

```
61 | var chat_manage_1 = require("../src/messaging/outbound/chat-manage.js");
62 | Object.defineProperty(exports, "updateChatFeishu", { enumerable: true, get: function () { return
chat_manage_1.updateChatFeishu; } });
> 63 | Object.defineProperty(exports, "addChatMembersFeishu", { enumerable: true, get: function () { return
chat_manage_1.addChatMembersFeishu; } });
64 | Object.defineProperty(exports, "removeChatMembersFeishu", { enumerable: true, get: function ()
{ return chat_manage_1.removeChatMembersFeishu; } });
65 | Object.defineProperty(exports, "listChatMembersFeishu", { enumerable: true, get: function ()
{ return chat_manage_1.listChatMembersFeishu; } });
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#27 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[index.js:64](#)

Dangerous execution: `Object.defineProperty(exports, "removeChatMembersFeishu", { enumerable: true, ge`

```
62 | Object.defineProperty(exports, "updateChatFeishu", { enumerable: true, get: function () { return
chat_manage_1.updateChatFeishu; } });
63 | Object.defineProperty(exports, "addChatMembersFeishu", { enumerable: true, get: function () { return
chat_manage_1.addChatMembersFeishu; } });
> 64 | Object.defineProperty(exports, "removeChatMembersFeishu", { enumerable: true, get: function ()
{ return chat_manage_1.removeChatMembersFeishu; } });
65 | Object.defineProperty(exports, "listChatMembersFeishu", { enumerable: true, get: function ()
{ return chat_manage_1.listChatMembersFeishu; } });
66 | var actions_1 = require("../src/messaging/outbound/actions.js");
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#28 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[index.js:65](#)

Dangerous execution: `Object.defineProperty(exports, "listChatMembersFeishu", { enumerable: true, get:`

```
63 | Object.defineProperty(exports, "addChatMembersFeishu", { enumerable: true, get: function () { return
chat_manage_1.addChatMembersFeishu; } });
64 | Object.defineProperty(exports, "removeChatMembersFeishu", { enumerable: true, get: function ()
{ return chat_manage_1.removeChatMembersFeishu; } });
> 65 | Object.defineProperty(exports, "listChatMembersFeishu", { enumerable: true, get: function ()
{ return chat_manage_1.listChatMembersFeishu; } });
66 | var actions_1 = require("./src/messaging/outbound/actions.js");
67 | Object.defineProperty(exports, "feishuMessageActions", { enumerable: true, get: function () { return...
actions_1.feishuMessageActions; } });
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#29 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[index.js:67](#)

Dangerous execution: `Object.defineProperty(exports, "feishuMessageActions", { enumerable: true, get:`

```
65 | Object.defineProperty(exports, "listChatMembersFeishu", { enumerable: true, get: function ()
{ return chat_manage_1.listChatMembersFeishu; } });
66 | var actions_1 = require("./src/messaging/outbound/actions.js");
> 67 | Object.defineProperty(exports, "feishuMessageActions", { enumerable: true, get: function () { return
actions_1.feishuMessageActions; } });
68 | var mention_1 = require("./src/messaging/inbound/mention.js");
69 | Object.defineProperty(exports, "mentionedBot", { enumerable: true, get: function () { return
mention_1.mentionedBot; } });
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#30 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[index.js:69](#)

Dangerous execution: `Object.defineProperty(exports, "mentionedBot", { enumerable: true, get: function`

```
67 | Object.defineProperty(exports, "feishuMessageActions", { enumerable: true, get: function () { return
actions_1.feishuMessageActions; } });
68 | var mention_1 = require("./src/messaging/inbound/mention.js");
> 69 | Object.defineProperty(exports, "mentionedBot", { enumerable: true, get: function () { return
mention_1.mentionedBot; } });
70 | Object.defineProperty(exports, "nonBotMentions", { enumerable: true, get: function () { return
mention_1.nonBotMentions; } });
71 | Object.defineProperty(exports, "extractMessageBody", { enumerable: true, get: function () { return
mention_1.extractMessageBody; } });
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#31 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[index.js:70](#)

Dangerous execution: `Object.defineProperty(exports, "nonBotMentions", { enumerable: true, get: functi`

```
68 | var mention_1 = require("../src/messaging/inbound/mention.js");
69 | Object.defineProperty(exports, "mentionedBot", { enumerable: true, get: function () { return
mention_1.mentionedBot; } });
> 70 | Object.defineProperty(exports, "nonBotMentions", { enumerable: true, get: function () { return
mention_1.nonBotMentions; } });
71 | Object.defineProperty(exports, "extractMessageBody", { enumerable: true, get: function () { return
mention_1.extractMessageBody; } });
72 | Object.defineProperty(exports, "formatMentionForText", { enumerable: true, get: function () { return...
mention_1.formatMentionForText; } });
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#32 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[index.js:71](#)

Dangerous execution: `Object.defineProperty(exports, "extractMessageBody", { enumerable: true, get: fu`

```
69 | Object.defineProperty(exports, "mentionedBot", { enumerable: true, get: function () { return
mention_1.mentionedBot; } });
70 | Object.defineProperty(exports, "nonBotMentions", { enumerable: true, get: function () { return
mention_1.nonBotMentions; } });
> 71 | Object.defineProperty(exports, "extractMessageBody", { enumerable: true, get: function () { return
mention_1.extractMessageBody; } });
72 | Object.defineProperty(exports, "formatMentionForText", { enumerable: true, get: function () { return
mention_1.formatMentionForText; } });
73 | Object.defineProperty(exports, "formatMentionForCard", { enumerable: true, get: function () { return
mention_1.formatMentionForCard; } });
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#33 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[index.js:72](#)

Dangerous execution: `Object.defineProperty(exports, "formatMentionForText", { enumerable: true, get:`

```
70 | Object.defineProperty(exports, "nonBotMentions", { enumerable: true, get: function () { return
mention_1.nonBotMentions; } });
71 | Object.defineProperty(exports, "extractMessageBody", { enumerable: true, get: function () { return
mention_1.extractMessageBody; } });
> 72 | Object.defineProperty(exports, "formatMentionForText", { enumerable: true, get: function () { return
mention_1.formatMentionForText; } });
73 | Object.defineProperty(exports, "formatMentionForCard", { enumerable: true, get: function () { return
mention_1.formatMentionForCard; } });
74 | Object.defineProperty(exports, "formatMentionAllForText", { enumerable: true, get: function ()
{ return mention_1.formatMentionAllForText; } });
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#34 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[index.js:73](#)

Dangerous execution: `Object.defineProperty(exports, "formatMentionForCard", { enumerable: true, get:`

```
71 | Object.defineProperty(exports, "extractMessageBody", { enumerable: true, get: function () { return
mention_1.extractMessageBody; } });
72 | Object.defineProperty(exports, "formatMentionForText", { enumerable: true, get: function () { return
mention_1.formatMentionForText; } });
> 73 | Object.defineProperty(exports, "formatMentionForCard", { enumerable: true, get: function () { return
mention_1.formatMentionForCard; } });
74 | Object.defineProperty(exports, "formatMentionAllForText", { enumerable: true, get: function ()
{ return mention_1.formatMentionAllForText; } });
75 | Object.defineProperty(exports, "formatMentionAllForCard", { enumerable: true, get: function ()...
{ return mention_1.formatMentionAllForCard; } });
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#35 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[index.js:74](#)

Dangerous execution: `Object.defineProperty(exports, "formatMentionAllForText", { enumerable: true, ge`

```
72 | Object.defineProperty(exports, "formatMentionForText", { enumerable: true, get: function () { return
mention_1.formatMentionForText; } });
73 | Object.defineProperty(exports, "formatMentionForCard", { enumerable: true, get: function () { return
mention_1.formatMentionForCard; } });
> 74 | Object.defineProperty(exports, "formatMentionAllForText", { enumerable: true, get: function ()
{ return mention_1.formatMentionAllForText; } });
75 | Object.defineProperty(exports, "formatMentionAllForCard", { enumerable: true, get: function ()
{ return mention_1.formatMentionAllForCard; } });
76 | Object.defineProperty(exports, "buildMentionedMessage", { enumerable: true, get: function ()
{ return mention_1.buildMentionedMessage; } });
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#36 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[index.js:75](#)

Dangerous execution: `Object.defineProperty(exports, "formatMentionAllForCard", { enumerable: true, ge`

```
73 | Object.defineProperty(exports, "formatMentionForCard", { enumerable: true, get: function () { return
mention_1.formatMentionForCard; } });
74 | Object.defineProperty(exports, "formatMentionAllForText", { enumerable: true, get: function ()
{ return mention_1.formatMentionAllForText; } });
> 75 | Object.defineProperty(exports, "formatMentionAllForCard", { enumerable: true, get: function ()
{ return mention_1.formatMentionAllForCard; } });
76 | Object.defineProperty(exports, "buildMentionedMessage", { enumerable: true, get: function ()
{ return mention_1.buildMentionedMessage; } });
77 | Object.defineProperty(exports, "buildMentionedCardContent", { enumerable: true, get: function ()
{ return mention_1.buildMentionedCardContent; } });
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#37 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[index.js:76](#)

Dangerous execution: `Object.defineProperty(exports, "buildMentionedMessage", { enumerable: true, get:`

```
74 | Object.defineProperty(exports, "formatMentionAllForText", { enumerable: true, get: function ()
{ return mention_1.formatMentionAllForText; } });
75 | Object.defineProperty(exports, "formatMentionAllForCard", { enumerable: true, get: function ()
{ return mention_1.formatMentionAllForCard; } });
> 76 | Object.defineProperty(exports, "buildMentionedMessage", { enumerable: true, get: function ()
{ return mention_1.buildMentionedMessage; } });
77 | Object.defineProperty(exports, "buildMentionedCardContent", { enumerable: true, get: function ()
{ return mention_1.buildMentionedCardContent; } });...
78 | var plugin_2 = require("./src/channel/plugin.js");
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#38 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[index.js:77](#)

Dangerous execution: `Object.defineProperty(exports, "buildMentionedCardContent", { enumerable: true,`

```
75 | Object.defineProperty(exports, "formatMentionAllForCard", { enumerable: true, get: function ()
{ return mention_1.formatMentionAllForCard; } });
76 | Object.defineProperty(exports, "buildMentionedMessage", { enumerable: true, get: function ()
{ return mention_1.buildMentionedMessage; } });
> 77 | Object.defineProperty(exports, "buildMentionedCardContent", { enumerable: true, get: function ()
{ return mention_1.buildMentionedCardContent; } });
78 | var plugin_2 = require("./src/channel/plugin.js");
79 | Object.defineProperty(exports, "feishuPlugin", { enumerable: true, get: function () { return
plugin_2.feishuPlugin; } });
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#39 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[index.js:79](#)

Dangerous execution: `Object.defineProperty(exports, "feishuPlugin", { enumerable: true, get: function`

```
77 | Object.defineProperty(exports, "buildMentionedCardContent", { enumerable: true, get: function ()
{ return mention_1.buildMentionedCardContent; } });
78 | var plugin_2 = require("./src/channel/plugin.js");
> 79 | Object.defineProperty(exports, "feishuPlugin", { enumerable: true, get: function () { return
plugin_2.feishuPlugin; } });
80 | var reaction_handler_1 = require("./src/messaging/inbound/reaction-handler.js");
81 | Object.defineProperty(exports, "handleFeishuReaction", { enumerable: true, get: function () { return
reaction_handler_1.handleFeishuReaction; } });
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#40 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[index.js:81](#)

Dangerous execution: Object.defineProperty(exports, "handleFeishuReaction", { enumerable: true, get:

```
79 | Object.defineProperty(exports, "feishuPlugin", { enumerable: true, get: function () { return
plugin_2.feishuPlugin; } });
80 | var reaction_handler_1 = require("./src/messaging/inbound/reaction-handler.js");
> 81 | Object.defineProperty(exports, "handleFeishuReaction", { enumerable: true, get: function () { return
reaction_handler_1.handleFeishuReaction; } });
82 | var parse_1 = require("./src/messaging/inbound/parse.js");
83 | Object.defineProperty(exports, "parseMessageEvent", { enumerable: true, get: function () { return...
parse_1.parseMessageEvent; } });
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#41 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[index.js:83](#)

Dangerous execution: Object.defineProperty(exports, "parseMessageEvent", { enumerable: true, get: fun

```
81 | Object.defineProperty(exports, "handleFeishuReaction", { enumerable: true, get: function () { return
reaction_handler_1.handleFeishuReaction; } });
82 | var parse_1 = require("./src/messaging/inbound/parse.js");
> 83 | Object.defineProperty(exports, "parseMessageEvent", { enumerable: true, get: function () { return
parse_1.parseMessageEvent; } });
84 | var gate_1 = require("./src/messaging/inbound/gate.js");
85 | Object.defineProperty(exports, "checkMessageGate", { enumerable: true, get: function () { return
gate_1.checkMessageGate; } });
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#42 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[index.js:85](#)

Dangerous execution: Object.defineProperty(exports, "checkMessageGate", { enumerable: true, get: func

```
83 | Object.defineProperty(exports, "parseMessageEvent", { enumerable: true, get: function () { return
parse_1.parseMessageEvent; } });
84 | var gate_1 = require("./src/messaging/inbound/gate.js");
> 85 | Object.defineProperty(exports, "checkMessageGate", { enumerable: true, get: function () { return
gate_1.checkMessageGate; } });
86 | var dedup_1 = require("./src/messaging/inbound/dedup.js");
87 | Object.defineProperty(exports, "isMessageExpired", { enumerable: true, get: function () { return
dedup_1.isMessageExpired; } });
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#43 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[index.js:87](#)

Dangerous execution: Object.defineProperty(exports, "isMessageExpired", { enumerable: true, get: func

```
85 | Object.defineProperty(exports, "checkMessageGate", { enumerable: true, get: function () { return
gate_1.checkMessageGate; } });
86 | var dedup_1 = require("./src/messaging/inbound/dedup.js");
> 87 | Object.defineProperty(exports, "isMessageExpired", { enumerable: true, get: function () { return
dedup_1.isMessageExpired; } });
88 | // -----
89 | // Plugin definition
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#44 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[index.js:13](#)

Dependency without integrity verification

```
11 | Object.defineProperty(exports, "__esModule", { value: true });
12 | exports.isMessageExpired = exports.checkMessageGate = exports.parseMessageEvent =
exports.handleFeishuReaction = exports.feishuPlugin = exports.buildMentionedCardContent =
exports.buildMentionedMessage = exports.formatMentionAllForCard = exports.formatMentionAllForText =
exports.formatMentionForCard = exports.formatMentionForText = exports.extractMessageBody =
exports.nonBotMentions = exports.mentionedBot = exports.feishuMessageActions = exports.listChatMembersFeishu
= exports.removeChatMembersFeishu = exports.addChatMembersFeishu = exports.updateChatFeishu =
exports.forwardMessageFeishu = exports.VALID_FEISHU_EMOJI_TYPES = exports.FeishuEmoji =
exports.listReactionsFeishu = exports.removeReactionFeishu = exports.addReactionFeishu = exports.probeFeishu
= exports.sendMediaLark = exports.sendCardLark = exports.sendTextLark = exports.uploadAndSendMediaLark =
exports.sendAudioLark = exports.sendFileLark = exports.sendImageLark = exports.uploadFileLark =
exports.uploadImageLark = exports.getMessageFeishu = exports.editMessageFeishu = exports.updateCardFeishu =
exports.sendCardFeishu = exports.sendMessageFeishu = exports.monitorFeishuProvider = void 0;
> 13 | const plugin_sdk_1 = require("openclaw/plugin-sdk");...
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#45 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[index.js:14](#)

Dependency without integrity verification

```
12 | exports.isMessageExpired = exports.checkMessageGate = exports.parseMessageEvent =
exports.handleFeishuReaction = exports.feishuPlugin = exports.buildMentionedCardContent =
exports.buildMentionedMessage = exports.formatMentionAllForCard = exports.formatMentionAllForText =
exports.formatMentionForCard = exports.formatMentionForText = exports.extractMessageBody =
exports.nonBotMentions = exports.mentionedBot = exports.feishuMessageActions = exports.listChatMembersFeishu
= exports.removeChatMembersFeishu = exports.addChatMembersFeishu = exports.updateChatFeishu =
exports.forwardMessageFeishu = exports.VALID_FEISHU_EMOJI_TYPES = exports.FeishuEmoji =
exports.listReactionsFeishu = exports.removeReactionFeishu = exports.addReactionFeishu = exports.probeFeishu
= exports.sendMediaLark = exports.sendCardLark = exports.sendTextLark = exports.uploadAndSendMediaLark =
exports.sendAudioLark = exports.sendFileLark = exports.sendImageLark = exports.uploadFileLark =
exports.uploadImageLark = exports.getMessageFeishu = exports.editMessageFeishu = exports.updateCardFeishu =
exports.sendCardFeishu = exports.sendMessageFeishu = exports.monitorFeishuProvider = void 0;
13 | const plugin_sdk_1 = require("openclaw/plugin-sdk");
> 14 | const plugin_1 = require("./src/channel/plugin.js");...
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#46 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[index.js:15](#)

Dependency without integrity verification

```
13 | const plugin_sdk_1 = require("openclaw/plugin-sdk");
14 | const plugin_1 = require("../src/channel/plugin.js");
> 15 | const lark_client_1 = require("../src/core/lark-client.js");
16 | const index_1 = require("../src/tools/oapi/index.js");...
17 | const index_2 = require("../src/tools/mcp/doc/index.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#47 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[index.js:16](#)

Dependency without integrity verification

```
14 | const plugin_1 = require("../src/channel/plugin.js");
15 | const lark_client_1 = require("../src/core/lark-client.js");
> 16 | const index_1 = require("../src/tools/oapi/index.js");
17 | const index_2 = require("../src/tools/mcp/doc/index.js");
18 | const oauth_1 = require("../src/tools/oauth.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#48 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[index.js:17](#)

Dependency without integrity verification

```
15 | const lark_client_1 = require("../src/core/lark-client.js");
16 | const index_1 = require("../src/tools/oapi/index.js");
> 17 | const index_2 = require("../src/tools/mcp/doc/index.js");
18 | const oauth_1 = require("../src/tools/oauth.js");
19 | const oauth_batch_auth_1 = require("../src/tools/oauth-batch-auth.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#49 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[index.js:18](#)

Dependency without integrity verification

```
16 | const index_1 = require("../src/tools/oapi/index.js");
17 | const index_2 = require("../src/tools/mcp/doc/index.js");
> 18 | const oauth_1 = require("../src/tools/oauth.js");
19 | const oauth_batch_auth_1 = require("../src/tools/oauth-batch-auth.js");
20 | const ask_user_question_1 = require("../src/tools/ask-user-question.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#50 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[index.js:19](#)

Dependency without integrity verification

```
17 | const index_2 = require("./src/tools/mcp/doc/index.js");
> 18 | const oauth_1 = require("./src/tools/oauth.js");
    19 | const oauth_batch_auth_1 = require("./src/tools/oauth-batch-auth.js");
    20 | const ask_user_question_1 = require("./src/tools/ask-user-question.js");...
    21 | const diagnose_1 = require("./src/commands/diagnose.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#51 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[index.js:20](#)

Dependency without integrity verification

```
18 | const oauth_1 = require("./src/tools/oauth.js");
> 19 | const oauth_batch_auth_1 = require("./src/tools/oauth-batch-auth.js");
    20 | const ask_user_question_1 = require("./src/tools/ask-user-question.js");
    21 | const diagnose_1 = require("./src/commands/diagnose.js");
    22 | const index_3 = require("./src/commands/index.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#52 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[index.js:21](#)

Dependency without integrity verification

```
19 | const oauth_batch_auth_1 = require("./src/tools/oauth-batch-auth.js");
> 20 | const ask_user_question_1 = require("./src/tools/ask-user-question.js");
    21 | const diagnose_1 = require("./src/commands/diagnose.js");
    22 | const index_3 = require("./src/commands/index.js");
    23 | const lark_logger_1 = require("./src/core/lark-logger.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#53 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[index.js:22](#)

Dependency without integrity verification

```
20 | const ask_user_question_1 = require("./src/tools/ask-user-question.js");
21 | const diagnose_1 = require("./src/commands/diagnose.js");
> 22 | const index_3 = require("./src/commands/index.js");
    23 | const lark_logger_1 = require("./src/core/lark-logger.js");...
    24 | const security_check_1 = require("./src/core/security-check.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#54 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[index.js:23](#)

Dependency without integrity verification

```
21 | const diagnose_1 = require("./src/commands/diagnose.js");
22 | const index_3 = require("./src/commands/index.js");
> 23 | const lark_logger_1 = require("./src/core/lark-logger.js");
    24 | const security_check_1 = require("./src/core/security-check.js");
    25 | const tool_use_trace_store_1 = require("./src/card/tool-use-trace-store.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#55 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[index.js:24](#)

Dependency without integrity verification

```
22 | const index_3 = require("./src/commands/index.js");
23 | const lark_logger_1 = require("./src/core/lark-logger.js");
> 24 | const security_check_1 = require("./src/core/security-check.js");
    25 | const tool_use_trace_store_1 = require("./src/card/tool-use-trace-store.js");
    26 | const reasoning_utils_1 = require("./src/card/reasoning-utils.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#56 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[index.js:25](#)

Dependency without integrity verification

```
23 | const lark_logger_1 = require("./src/core/lark-logger.js");
24 | const security_check_1 = require("./src/core/security-check.js");
> 25 | const tool_use_trace_store_1 = require("./src/card/tool-use-trace-store.js");
    26 | const reasoning_utils_1 = require("./src/card/reasoning-utils.js");
    27 | const log = (0, lark_logger_1.larkLogger)('plugin');
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#57 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[index.js:26](#)

Dependency without integrity verification

```
24 | const security_check_1 = require("../src/core/security-check.js");
> 25 | const tool_use_trace_store_1 = require("../src/card/tool-use-trace-store.js");
    26 | const reasoning_utils_1 = require("../src/card/reasoning-utils.js");
    27 | const log = {0, lark_logger_1.larkLogger}('plugin');...
    28 | // -----
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#58 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[index.js:31](#)

Dependency without integrity verification

```
29 | // Re-exports for external consumers
30 | // -----
> 31 | var monitor_1 = require("../src/channel/monitor.js");
    32 | Object.defineProperty(exports, "monitorFeishuProvider", { enumerable: true, get: function ()
{ return monitor_1.monitorFeishuProvider; } });
    33 | var send_1 = require("../src/messaging/outbound/send.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#59 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[index.js:33](#)

Dependency without integrity verification

```
31 | var monitor_1 = require("../src/channel/monitor.js");
32 | Object.defineProperty(exports, "monitorFeishuProvider", { enumerable: true, get: function ()
{ return monitor_1.monitorFeishuProvider; } });
> 33 | var send_1 = require("../src/messaging/outbound/send.js");
    34 | Object.defineProperty(exports, "sendMessageFeishu", { enumerable: true, get: function () { return
send_1.sendMessageFeishu; } });
    35 | Object.defineProperty(exports, "sendCardFeishu", { enumerable: true, get: function () { return
send_1.sendCardFeishu; } });
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#60 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[index.js:38](#)

Dependency without integrity verification

```
36 | Object.defineProperty(exports, "updateCardFeishu", { enumerable: true, get: function () { return
send_1.updateCardFeishu; } });
37 | Object.defineProperty(exports, "editMessageFeishu", { enumerable: true, get: function () { return
send_1.editMessageFeishu; } });
> 38 | var fetch_1 = require("./src/messaging/outbound/fetch.js");
39 | Object.defineProperty(exports, "getMessageFeishu", { enumerable: true, get: function () { return
fetch_1.getMessageFeishu; } });
40 | var media_1 = require("./src/messaging/outbound/media.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#61 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[index.js:40](#)

Dependency without integrity verification

```
38 | var fetch_1 = require("./src/messaging/outbound/fetch.js");
39 | Object.defineProperty(exports, "getMessageFeishu", { enumerable: true, get: function () { return
fetch_1.getMessageFeishu; } });
> 40 | var media_1 = require("./src/messaging/outbound/media.js");
41 | Object.defineProperty(exports, "uploadImageLark", { enumerable: true, get: function () { return
media_1.uploadImageLark; } });
42 | Object.defineProperty(exports, "uploadFileLark", { enumerable: true, get: function () { return
media_1.uploadFileLark; } });
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#62 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[index.js:47](#)

Dependency without integrity verification

```
45 | Object.defineProperty(exports, "sendAudioLark", { enumerable: true, get: function () { return
media_1.sendAudioLark; } });
46 | Object.defineProperty(exports, "uploadAndSendMediaLark", { enumerable: true, get: function ()
{ return media_1.uploadAndSendMediaLark; } });
> 47 | var deliver_1 = require("./src/messaging/outbound/deliver.js");
48 | Object.defineProperty(exports, "sendTextLark", { enumerable: true, get: function () { return
deliver_1.sendTextLark; } });
49 | Object.defineProperty(exports, "sendCardLark", { enumerable: true, get: function () { return
deliver_1.sendCardLark; } });
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#63 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[index.js:51](#)

Dependency without integrity verification

```
49 | Object.defineProperty(exports, "sendCardLark", { enumerable: true, get: function () { return
deliver_1.sendCardLark; } });
50 | Object.defineProperty(exports, "sendMediaLark", { enumerable: true, get: function () { return
deliver_1.sendMediaLark; } });
> 51 | var probe_1 = require("./src/channel/probe.js");
52 | Object.defineProperty(exports, "probeFeishu", { enumerable: true, get: function () { return
probe_1.probeFeishu; } });
53 | var reactions_1 = require("./src/messaging/outbound/reactions.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#64 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[index.js:53](#)

Dependency without integrity verification

```
51 | var probe_1 = require("./src/channel/probe.js");
52 | Object.defineProperty(exports, "probeFeishu", { enumerable: true, get: function () { return
probe_1.probeFeishu; } });
> 53 | var reactions_1 = require("./src/messaging/outbound/reactions.js");
54 | Object.defineProperty(exports, "addReactionFeishu", { enumerable: true, get: function () { return
reactions_1.addReactionFeishu; } });
55 | Object.defineProperty(exports, "removeReactionFeishu", { enumerable: true, get: function () { return
reactions_1.removeReactionFeishu; } });
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#65 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[index.js:59](#)

Dependency without integrity verification

```
57 | Object.defineProperty(exports, "FeishuEmoji", { enumerable: true, get: function () { return
reactions_1.FeishuEmoji; } });
58 | Object.defineProperty(exports, "VALID_FEISHU_EMOJI_TYPES", { enumerable: true, get: function ()
{ return reactions_1.VALID_FEISHU_EMOJI_TYPES; } });
> 59 | var forward_1 = require("./src/messaging/outbound/forward.js");
60 | Object.defineProperty(exports, "forwardMessageFeishu", { enumerable: true, get: function () { return
forward_1.forwardMessageFeishu; } });
61 | var chat_manage_1 = require("./src/messaging/outbound/chat-manage.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#66 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[index.js:61](#)

Dependency without integrity verification

```
59 | var forward_1 = require("./src/messaging/outbound/forward.js");
60 | Object.defineProperty(exports, "forwardMessageFeishu", { enumerable: true, get: function () { return
forward_1.forwardMessageFeishu; } });
> 61 | var chat_manage_1 = require("./src/messaging/outbound/chat-manage.js");
62 | Object.defineProperty(exports, "updateChatFeishu", { enumerable: true, get: function () { return
chat_manage_1.updateChatFeishu; } });
63 | Object.defineProperty(exports, "addChatMembersFeishu", { enumerable: true, get: function () { return...
chat_manage_1.addChatMembersFeishu; } });
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#67 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[index.js:66](#)

Dependency without integrity verification

```
64 | Object.defineProperty(exports, "removeChatMembersFeishu", { enumerable: true, get: function ()
{ return chat_manage_1.removeChatMembersFeishu; } });
65 | Object.defineProperty(exports, "listChatMembersFeishu", { enumerable: true, get: function ()
{ return chat_manage_1.listChatMembersFeishu; } });
> 66 | var actions_1 = require("./src/messaging/outbound/actions.js");
67 | Object.defineProperty(exports, "feishuMessageActions", { enumerable: true, get: function () { return
actions_1.feishuMessageActions; } });
68 | var mention_1 = require("./src/messaging/inbound/mention.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#68 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[index.js:68](#)

Dependency without integrity verification

```
66 | var actions_1 = require("./src/messaging/outbound/actions.js");
67 | Object.defineProperty(exports, "feishuMessageActions", { enumerable: true, get: function () { return
actions_1.feishuMessageActions; } });
> 68 | var mention_1 = require("./src/messaging/inbound/mention.js");
69 | Object.defineProperty(exports, "mentionedBot", { enumerable: true, get: function () { return
mention_1.mentionedBot; } });
70 | Object.defineProperty(exports, "nonBotMentions", { enumerable: true, get: function () { return
mention_1.nonBotMentions; } });
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#69 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[index.js:78](#)

Dependency without integrity verification

```
76 | Object.defineProperty(exports, "buildMentionedMessage", { enumerable: true, get: function ()  
{ return mention_1.buildMentionedMessage; } });  
77 | Object.defineProperty(exports, "buildMentionedCardContent", { enumerable: true, get: function ()  
{ return mention_1.buildMentionedCardContent; } });  
> 78 | var plugin_2 = require("./src/channel/plugin.js");  
79 | Object.defineProperty(exports, "feishuPlugin", { enumerable: true, get: function () { return  
plugin_2.feishuPlugin; } });  
80 | var reaction_handler_1 = require("./src/messaging/inbound/reaction-handler.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#70 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[index.js:80](#)

Dependency without integrity verification

```
78 | var plugin_2 = require("./src/channel/plugin.js");  
79 | Object.defineProperty(exports, "feishuPlugin", { enumerable: true, get: function () { return  
plugin_2.feishuPlugin; } });  
> 80 | var reaction_handler_1 = require("./src/messaging/inbound/reaction-handler.js");  
81 | Object.defineProperty(exports, "handleFeishuReaction", { enumerable: true, get: function () { return  
reaction_handler_1.handleFeishuReaction; } });  
82 | var parse_1 = require("./src/messaging/inbound/parse.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#71 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[index.js:82](#)

Dependency without integrity verification

```
80 | var reaction_handler_1 = require("./src/messaging/inbound/reaction-handler.js");  
81 | Object.defineProperty(exports, "handleFeishuReaction", { enumerable: true, get: function () { return  
reaction_handler_1.handleFeishuReaction; } });  
> 82 | var parse_1 = require("./src/messaging/inbound/parse.js");  
83 | Object.defineProperty(exports, "parseMessageEvent", { enumerable: true, get: function () { return  
parse_1.parseMessageEvent; } });  
84 | var gate_1 = require("./src/messaging/inbound/gate.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#72 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[index.js:84](#)

Dependency without integrity verification

```
82 | var parse_1 = require("./src/messaging/inbound/parse.js");
83 | Object.defineProperty(exports, "parseMessageEvent", { enumerable: true, get: function () { return
parse_1.parseMessageEvent; } });
> 84 | var gate_1 = require("./src/messaging/inbound/gate.js");
85 | Object.defineProperty(exports, "checkMessageGate", { enumerable: true, get: function () { return
gate_1.checkMessageGate; } });
86 | var dedup_1 = require("./src/messaging/inbound/dedup.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#73 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[index.js:86](#)

Dependency without integrity verification

```
84 | var gate_1 = require("./src/messaging/inbound/gate.js");
85 | Object.defineProperty(exports, "checkMessageGate", { enumerable: true, get: function () { return
gate_1.checkMessageGate; } });
> 86 | var dedup_1 = require("./src/messaging/inbound/dedup.js");
87 | Object.defineProperty(exports, "isMessageExpired", { enumerable: true, get: function () { return
dedup_1.isMessageExpired; } });
88 | // -----
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#74 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/card/builder.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#75 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[src/card/builder.js:366](#)

Potential secret: possible hardcoded secret

```
364 |         icon: {
365 |             tag: 'standard_icon',
> 366 |             token: 'down-small-ccm_outlined',
367 |             size: '16px 16px',
368 |         },
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#76 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[src/card/builder.js:585](#)

Potential secret: possible hardcoded secret

```
583 |             icon: {
584 |                 tag: 'standard_icon',
585 |                 token: 'down-small-ccm_outlined',
586 |                 color: 'grey',...
587 |                 size: '16px 16px',
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#77 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[src/card/builder.js:626](#)

Potential secret: possible hardcoded secret

```
624 |             icon: {
625 |                 tag: 'standard_icon',
626 |                 token: 'down-small-ccm_outlined',
627 |                 color: 'grey',
628 |                 size: '16px 16px',
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#78 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[src/card/builder.js:668](#)

Potential secret: possible hardcoded secret

```
666 |             icon: {
667 |                 tag: 'standard_icon',
668 |                 token: 'down-small-ccm_outlined',
669 |                 color: 'grey',
670 |                 size: '16px 16px',
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#79 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

```
src/card/builder.js:1
```

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
  2 | /**...
  3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision.
2. Include agent_id, timestamp, action, parameters, and outcome in each log entry.
3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel).
4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands).
5. Retain logs for compliance (90 days minimum).

#80 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

src/card/card-error.d.ts:1

No logging, auditing, or monitoring detected

```
> 1 | /**
  2 |    * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
  3 |    * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision.
2. Include agent_id, timestamp, action, parameters, and outcome in each log entry.
3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel).
4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands).
5. Retain logs for compliance (90 days minimum).

#81 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

src/card/card-error.js:65

Dangerous execution: const match = /ErrCode:\s*(\d+)/.exec(msg);

```

63 | */
64 | function extractSubCode(msg) {
> 65 |     const match = /ErrCode:\s*(\d+)/.exec(msg);
66 |     if (!match)
67 |         return null;

```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#82 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

```
src/card/card-error.js:142
```

Dangerous execution: `let codeBlockMatch = codeBlockRegex.exec(text);`

```

140 |     const codeBlockRanges = [];
141 |     const codeBlockRegex = /\`\`([\s\S]*?)\`\`/g;
> 142 |     let codeBlockMatch = codeBlockRegex.exec(text);
143 |     while (codeBlockMatch != null) {
144 |         codeBlockRanges.push(

```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code).
2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`.
3. Use allowlist of permitted modules via `importlib`.
4. Add mandatory human confirmation before shell commands.

#83 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/card/card-error.js:148](#)

Dangerous execution: `codeBlockMatch = codeBlockRegex.exec(text);`

```
146 |         end: codeBlockMatch.index + codeBlockMatch[0].length,  
147 |     });  
> 148 |     codeBlockMatch = codeBlockRegex.exec(text);  
149 | }  
150 | const isInsideCodeBlock = (idx) => codeBlockRanges.some((range) => idx >= range.start && idx <...  
    range.end);
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#84 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/card/card-error.js:153](#)

Dangerous execution: `let tableMatch = tableRegex.exec(text);`

```
151 |     const tableRegex = /\|.+\\[\\r\\n]+\\|[-:| ]+\\|\\s\\S]*?(?=\\n\\n|\\n(?:!\\|)|$)/g;  
152 |     const matches = [];  
> 153 |     let tableMatch = tableRegex.exec(text);  
154 |     while (tableMatch != null) {  
155 |         if (!isInsideCodeBlock(tableMatch.index)) {
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#85 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/card/card-error.js:162](#)

Dangerous execution: `tableMatch = tableRegex.exec(text);`

```
160 |         });  
161 |     }  
> 162 |     tableMatch = tableRegex.exec(text);  
163 | }  
164 | return matches;
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#86 AS-006 -- SANDBOXING

HIGH

OWASP: AA-09 | MITRE: T1610 | STRIDE: Elevation of Privilege

Code execution without sandboxing or isolation mechanisms

[src/card/card-error.js:65](#)

Code execution without sandboxing

```
63 | /*  
64 | function extractSubCode(msg) {  
> 65 |     const match = /ErrCode:\\s*(\\d+)/.exec(msg);  
66 |     if (!match)  
67 |         return null;
```


Remediation:

1. Run all agent-generated code in Docker containers with `--network=none` and read-only filesystem. 2. Use gVisor/Firecracker for stronger isolation. 3. Set resource limits (CPU, memory, time) on execution. 4. Use E2B or Modal for managed sandboxed execution. 5. Never execute agent code in the host process.

MCPS Quick Fix: `npm install mcp-secure`

#87 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`src/card/card-error.js:1`

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
  2 | /**...
  3 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include `agent_id`, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#88 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`src/card/cardkit.d.ts:1`

No logging, auditing, or monitoring detected

```
> 1 | /**
  2 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
  3 | * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include `agent_id`, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#89 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

`src/card/cardkit.js:15`

Dependency without integrity verification

```
13 | exports.sendCardByCardId = sendCardByCardId;
14 | exports.setCardStreamingMode = setCardStreamingMode;
> 15 | const lark_client_1 = require("../core/lark-client.js");
    16 | const lark_logger_1 = require("../core/lark-logger.js");
    17 | const message_unavailable_1 = require("../core/message-unavailable.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use `>=` or `latest`. 3. Run `npm audit` / `pip-audit` in CI. 4. Use `pip install --require-hashes` for Python. 5. Verify package signatures where available.

#90 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/card/cardkit.js:16](#)

Dependency without integrity verification

```
14 | exports.setCardStreamingMode = setCardStreamingMode;
15 | const lark_client_1 = require("../core/lark-client.js");
> 16 | const lark_logger_1 = require("../core/lark-logger.js");
    17 | const message_unavailable_1 = require("../core/message-unavailable.js");...
    18 | const targets_1 = require("../core/targets.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#91 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/card/cardkit.js:17](#)

Dependency without integrity verification

```
15 | const lark_client_1 = require("../core/lark-client.js");
16 | const lark_logger_1 = require("../core/lark-logger.js");
> 17 | const message_unavailable_1 = require("../core/message-unavailable.js");
    18 | const targets_1 = require("../core/targets.js");
    19 | const card_error_1 = require("./card-error.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#92 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/card/cardkit.js:18](#)

Dependency without integrity verification

```
16 | const lark_logger_1 = require("../core/lark-logger.js");
17 | const message_unavailable_1 = require("../core/message-unavailable.js");
> 18 | const targets_1 = require("../core/targets.js");
    19 | const card_error_1 = require("./card-error.js");
    20 | const log = (0, lark_logger_1.larkLogger)('card/cardkit');
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#93 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/card/cardkit.js:19](#)

Dependency without integrity verification

```
17 | const message_unavailable_1 = require("../core/message-unavailable.js");
18 | const targets_1 = require("../core/targets.js");
> 19 | const card_error_1 = require("./card-error.js");
    20 | const log = (0, lark_logger_1.larkLogger)('card/cardkit');
    21 | // -----
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#94 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/card/flush-controller.d.ts:27](#)

High-risk permission pattern: * Execute a flush (mutex-guarded, with reflush on conflict).

```
25 |     waitForFlush(): Promise<void>;
26 |     /**
> 27 |      * Execute a flush (mutex-guarded, with reflush on conflict).
28 |      * ...
29 |      * If a flush is already in progress, marks needsReflush so a
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#95 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/card/flush-controller.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#96 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/card/flush-controller.js:47](#)

High-risk permission pattern: * Execute a flush (mutex-guarded, with reflush on conflict).

```
45 |     }
46 |     /**
> 47 |      * Execute a flush (mutex-guarded, with reflush on conflict).
48 |      *
49 |      * If a flush is already in progress, marks needsReflush so a
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#97 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/card/flush-controller.js:14](#)

Dependency without integrity verification

```
12 | Object.defineProperty(exports, "__esModule", { value: true });
13 | exports.FlushController = void 0;
> 14 | const reply_dispatcher_types_1 = require("../reply-dispatcher-types.js");
15 | // -----
16 | // FlushController
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#98 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/card/flush-controller.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
2 | /**
3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#99 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/card/image-resolver.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#100 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/card/image-resolver.js:104](#)

High-risk permission pattern: this.pending.delete(url);

```
102 |         log.info('image uploaded', { url, imageKey });
103 |         this.resolved.set(url, imageKey);
> 104 |         this.pending.delete(url);
105 |         this.onImageResolved();
106 |         return imageKey;
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#101 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/card/image-resolver.js:110](#)

High-risk permission pattern: `this.pending.delete(url)`;

```
108 |         catch (err) {
109 |             log.warn('image upload failed', { url, error: String(err) });
> 110 |             this.pending.delete(url);
111 |             this.failed.add(url);...
112 |             return null;
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#102 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/card/image-resolver.js:14](#)

Dependency without integrity verification

```
12 | Object.defineProperty(exports, "__esModule", { value: true });
13 | exports.ImageResolver = void 0;
> 14 | const media_1 = require("../messaging/outbound/media.js");
15 | const lark_logger_1 = require("../core/lark-logger.js");
16 | const log = (0, lark_logger_1.larkLogger)('card/image-resolver');
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use `>=` or `latest`. 3. Run `npm audit` / `pip-audit` in CI. 4. Use `pip install --require-hashes` for Python. 5. Verify package signatures where available.

#103 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/card/image-resolver.js:15](#)

Dependency without integrity verification

```
13 | exports.ImageResolver = void 0;
14 | const media_1 = require("../messaging/outbound/media.js");
> 15 | const lark_logger_1 = require("../core/lark-logger.js");
16 | const log = (0, lark_logger_1.larkLogger)('card/image-resolver');
17 | /** Matches complete markdown image syntax: `[alt](value)` */
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use `>=` or `latest`. 3. Run `npm audit` / `pip-audit` in CI. 4. Use `pip install --require-hashes` for Python. 5. Verify package signatures where available.

#104 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/card/markdown-style.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include `agent_id`, `timestamp`, `action`, `parameters`, and `outcome` in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#105 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/card/markdown-style.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
  2 | /**...
  3 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#106 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/card/reply-dispatcher-types.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
  2 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
  3 | * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#107 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/card/reply-dispatcher-types.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
  2 | /**
  3 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#108 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/card/reply-dispatcher.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
  2 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
  3 | * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#109 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/card/reply-mode.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
  2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates...
  3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#110 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/card/reply-mode.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
  2 | /**
  3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#111 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/card/streaming-card-controller.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
  2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
  3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#112 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/card/streaming-card-controller.js:17](#)

Dependency without integrity verification

```
15 | exports.StreamingCardController = void 0;
16 | exports.prepareTerminalCardContent = prepareTerminalCardContent;
> 17 | const promises_1 = require("node:fs/promises");
   18 | const agent_runtime_1 = require("openclaw/plugin-sdk/agent-runtime");
   19 | const reply_runtime_1 = require("openclaw/plugin-sdk/reply-runtime");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#113 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/card/streaming-card-controller.js:18](#)

Dependency without integrity verification

```
16 | exports.prepareTerminalCardContent = prepareTerminalCardContent;  
17 | const promises_1 = require("node:fs/promises");  
> 18 | const agent_runtime_1 = require("openclaw/plugin-sdk/agent-runtime");  
19 | const reply_runtime_1 = require("openclaw/plugin-sdk/reply-runtime");...  
20 | const api_error_1 = require("../core/api-error.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#114 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/card/streaming-card-controller.js:19](#)

Dependency without integrity verification

```
17 | const promises_1 = require("node:fs/promises");  
18 | const agent_runtime_1 = require("openclaw/plugin-sdk/agent-runtime");  
> 19 | const reply_runtime_1 = require("openclaw/plugin-sdk/reply-runtime");  
20 | const api_error_1 = require("../core/api-error.js");  
21 | const lark_logger_1 = require("../core/lark-logger.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#115 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/card/streaming-card-controller.js:20](#)

Dependency without integrity verification

```
18 | const agent_runtime_1 = require("openclaw/plugin-sdk/agent-runtime");  
19 | const reply_runtime_1 = require("openclaw/plugin-sdk/reply-runtime");  
> 20 | const api_error_1 = require("../core/api-error.js");  
21 | const lark_logger_1 = require("../core/lark-logger.js");  
22 | const lark_client_1 = require("../core/lark-client.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#116 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/card/streaming-card-controller.js:21](#)

Dependency without integrity verification

```
19 | const reply_runtime_1 = require("openclaw/plugin-sdk/reply-runtime");  
20 | const api_error_1 = require("../core/api-error.js");  
> 21 | const lark_logger_1 = require("../core/lark-logger.js");  
22 | const lark_client_1 = require("../core/lark-client.js");  
23 | const shutdown_hooks_1 = require("../core/shutdown-hooks.js");
```


Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#117 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/card/streaming-card-controller.js:22](#)

Dependency without integrity verification

```
20 | const api_error_1 = require("../core/api-error.js");
> 21 | const lark_logger_1 = require("../core/lark-logger.js");
    22 | const lark_client_1 = require("../core/lark-client.js");
    23 | const shutdown_hooks_1 = require("../core/shutdown-hooks.js");...
    24 | const send_1 = require("../messaging/outbound/send.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#118 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/card/streaming-card-controller.js:23](#)

Dependency without integrity verification

```
21 | const lark_logger_1 = require("../core/lark-logger.js");
> 22 | const lark_client_1 = require("../core/lark-client.js");
    23 | const shutdown_hooks_1 = require("../core/shutdown-hooks.js");
    24 | const send_1 = require("../messaging/outbound/send.js");
    25 | const builder_1 = require("../builder.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#119 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/card/streaming-card-controller.js:24](#)

Dependency without integrity verification

```
22 | const lark_client_1 = require("../core/lark-client.js");
> 23 | const shutdown_hooks_1 = require("../core/shutdown-hooks.js");
    24 | const send_1 = require("../messaging/outbound/send.js");
    25 | const builder_1 = require("../builder.js");
    26 | const card_error_1 = require("../card-error.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#120 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/card/streaming-card-controller.js:25](#)

Dependency without integrity verification

```
23 | const shutdown_hooks_1 = require("../core/shutdown-hooks.js");
24 | const send_1 = require("../messaging/outbound/send.js");
> 25 | const builder_1 = require("../builder.js");
    26 | const card_error_1 = require("../card-error.js");...
    27 | const cardkit_1 = require("../cardkit.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#121 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/card/streaming-card-controller.js:26](#)

Dependency without integrity verification

```
24 | const send_1 = require("../messaging/outbound/send.js");
25 | const builder_1 = require("../builder.js");
> 26 | const card_error_1 = require("../card-error.js");
    27 | const cardkit_1 = require("../cardkit.js");
    28 | const flush_controller_1 = require("../flush-controller.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#122 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/card/streaming-card-controller.js:27](#)

Dependency without integrity verification

```
25 | const builder_1 = require("../builder.js");
26 | const card_error_1 = require("../card-error.js");
> 27 | const cardkit_1 = require("../cardkit.js");
    28 | const flush_controller_1 = require("../flush-controller.js");
    29 | const image_resolver_1 = require("../image-resolver.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#123 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/card/streaming-card-controller.js:28](#)

Dependency without integrity verification

```
26 | const card_error_1 = require("../card-error.js");
27 | const cardkit_1 = require("../cardkit.js");
> 28 | const flush_controller_1 = require("../flush-controller.js");
    29 | const image_resolver_1 = require("../image-resolver.js");
    30 | const markdown_style_1 = require("../markdown-style.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#124 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/card/streaming-card-controller.js:29](#)

Dependency without integrity verification

```
27 | const cardkit_1 = require("./cardkit.js");
> 28 | const flush_controller_1 = require("./flush-controller.js");
    29 | const image_resolver_1 = require("./image-resolver.js");
    30 | const markdown_style_1 = require("./markdown-style.js");...
    31 | const tool_use_display_1 = require("./tool-use-display.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#125 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/card/streaming-card-controller.js:30](#)

Dependency without integrity verification

```
28 | const flush_controller_1 = require("./flush-controller.js");
> 29 | const image_resolver_1 = require("./image-resolver.js");
    30 | const markdown_style_1 = require("./markdown-style.js");
    31 | const tool_use_display_1 = require("./tool-use-display.js");
    32 | const tool_use_trace_store_1 = require("./tool-use-trace-store.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#126 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/card/streaming-card-controller.js:31](#)

Dependency without integrity verification

```
29 | const image_resolver_1 = require("./image-resolver.js");
> 30 | const markdown_style_1 = require("./markdown-style.js");
    31 | const tool_use_display_1 = require("./tool-use-display.js");
    32 | const tool_use_trace_store_1 = require("./tool-use-trace-store.js");
    33 | const reply_dispatcher_types_1 = require("./reply-dispatcher-types.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#127 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/card/streaming-card-controller.js:32](#)

Dependency without integrity verification

```
30 | const markdown_style_1 = require("./markdown-style.js");
31 | const tool_use_display_1 = require("./tool-use-display.js");
> 32 | const tool_use_trace_store_1 = require("./tool-use-trace-store.js");
33 | const reply_dispatcher_types_1 = require("./reply-dispatcher-types.js");...
34 | const unavailable_guard_1 = require("./unavailable-guard.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#128 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/card/streaming-card-controller.js:33](#)

Dependency without integrity verification

```
31 | const tool_use_display_1 = require("./tool-use-display.js");
32 | const tool_use_trace_store_1 = require("./tool-use-trace-store.js");
> 33 | const reply_dispatcher_types_1 = require("./reply-dispatcher-types.js");
34 | const unavailable_guard_1 = require("./unavailable-guard.js");
35 | const log = (0, lark_logger_1.larkLogger)('card/streaming');
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#129 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/card/streaming-card-controller.js:34](#)

Dependency without integrity verification

```
32 | const tool_use_trace_store_1 = require("./tool-use-trace-store.js");
33 | const reply_dispatcher_types_1 = require("./reply-dispatcher-types.js");
> 34 | const unavailable_guard_1 = require("./unavailable-guard.js");
35 | const log = (0, lark_logger_1.larkLogger)('card/streaming');
36 | // -----
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#130 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/card/tool-use-config.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#131 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/card/tool-use-config.js:14](#)

Dependency without integrity verification

```
12 | Object.defineProperty(exports, "__esModule", { value: true });
13 | exports.resolveToolUseDisplayConfig = resolveToolUseDisplayConfig;
> 14 | const agent_runtime_1 = require("openclaw/plugin-sdk/agent-runtime");
    15 | const config_runtime_1 = require("openclaw/plugin-sdk/config-runtime");...
16 | function resolveToolUseDisplayConfig(params) {
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#132 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/card/tool-use-config.js:15](#)

Dependency without integrity verification

```
13 | exports.resolveToolUseDisplayConfig = resolveToolUseDisplayConfig;
14 | const agent_runtime_1 = require("openclaw/plugin-sdk/agent-runtime");
> 15 | const config_runtime_1 = require("openclaw/plugin-sdk/config-runtime");
    16 | function resolveToolUseDisplayConfig(params) {
17 |     const mode = resolveEffectiveVerboseMode(params);
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#133 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/card/tool-use-config.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
   2 | /**
   3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#134 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/card/tool-use-display.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
   2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
   3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#135 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[src/card/tool-use-display.js:18](#)

Potential secret: possible hardcoded secret

```
16 |     {
17 |         aliases: ['skill'],
> 18 |         iconToken: 'app-default_outlined',
19 |         title: 'Load skill',...
20 |         sanitizer: 'skill',
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#136 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[src/card/tool-use-display.js:26](#)

Potential secret: possible hardcoded secret

```
24 |     {
25 |         aliases: ['read', 'open'],
> 26 |         iconToken: 'file-link-text_outlined',
27 |         title: 'Read',
28 |         sanitizer: 'path',
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#137 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[src/card/tool-use-display.js:35](#)

Potential secret: possible hardcoded secret

```
33 |     {
34 |         aliases: ['write', 'edit'],
> 35 |         iconToken: 'edit_outlined',
36 |         title: 'Edit',
37 |         sanitizer: 'path',
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#138 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[src/card/tool-use-display.js:44](#)

Potential secret: possible hardcoded secret

```
42 |     {
43 |         aliases: ['web_search', 'web-search', 'search'],
> 44 |         iconToken: 'search_outlined',
45 |         title: 'Search web',
46 |         sanitizer: 'search',
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#139 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[src/card/tool-use-display.js:53](#)

Potential secret: possible hardcoded secret

```
51 |     {
52 |         aliases: ['web_fetch', 'web-fetch', 'fetch'],
53 |         iconToken: 'language_outlined',
54 |         title: 'Fetch web page', ...
55 |         sanitizer: 'url',
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#140 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[src/card/tool-use-display.js:62](#)

Potential secret: possible hardcoded secret

```
60 |     {
61 |         aliases: ['grep'],
62 |         iconToken: 'doc-search_outlined',
63 |         title: 'Search text', ...
64 |         sanitizer: 'generic',
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#141 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[src/card/tool-use-display.js:70](#)

Potential secret: possible hardcoded secret

```
68 |     {
69 |         aliases: ['glob'],
70 |         iconToken: 'folder_outlined',
71 |         title: 'Search files', ...
72 |         sanitizer: 'generic',
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#142 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[src/card/tool-use-display.js:78](#)

Potential secret: possible hardcoded secret

```
76 |     {
77 |         aliases: ['exec', 'bash', 'command', 'run'],
78 |         iconToken: 'setting_outlined',
79 |         title: 'Run command',...
80 |         sanitizer: 'command',
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#143 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[src/card/tool-use-display.js:87](#)

Potential secret: possible hardcoded secret

```
85 |     {
86 |         aliases: ['browser', 'playwright', 'navigate'],
87 |         iconToken: 'browser-mac_outlined',
88 |         title: 'Browser',
89 |         sanitizer: 'url',
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#144 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[src/card/tool-use-display.js:96](#)

Potential secret: possible hardcoded secret

```
94 |     {
95 |         aliases: ['agent', 'task', 'spawn'],
96 |         iconToken: 'robot_outlined',
97 |         title: 'Run sub-agent',
98 |         sanitizer: 'generic',
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#145 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[src/card/tool-use-display.js:104](#)

Potential secret: possible hardcoded secret

```
102 |     {
103 |         aliases: ['check', 'determine', 'verify'],
104 |         iconToken: 'list-check_outlined',
105 |         title: 'Check',
106 |         sanitizer: 'generic',
```


Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#146 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[src/card/tool-use-display.js:111](#)

Potential secret: possible hardcoded secret

```
109 |     {
110 |         aliases: ['summarize', 'analyze', 'prepare'],
111 |         iconToken: 'report_outlined',
112 |         title: 'Analyze',...
113 |         sanitizer: 'generic',
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#147 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/card/tool-use-display.js:82](#)

High-risk permission pattern: summaryPatterns: [/^(?:run|execute)\s+(?:command|script)?\s*(.+)/i],

```
80 |         sanitizer: 'command',
81 |         paramKeys: ['description', 'command', 'script'],
> 82 |         summaryPatterns: [/^(?:run|execute)\s+(?:command|script)?\s*(.+)/i],
83 |         summaryPreference: ['code', 'quoted', 'matched', 'line'],
84 |     },
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#148 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/card/tool-use-display.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
2 | /**
3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#149 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/card/tool-use-trace-store.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
    2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates...
    3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#150 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/card/tool-use-trace-store.js:45](#)

High-risk permission pattern: `sessionTraces.delete(sessionKey);`

```
43 |     if (!sessionKey)
44 |         return;
> 45 |     sessionTraces.delete(sessionKey);
46 | }
47 | function hasToolUseTraceRun(sessionKey) {
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#151 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/card/tool-use-trace-store.js:136](#)

High-risk permission pattern: `sessionTraces.delete(sessionKey);`

```
134 |         return [];
135 |         if (Date.now() - state.updatedAt > TRACE_TTL_MS) {
> 136 |             sessionTraces.delete(sessionKey);
137 |             return [];
138 |         }
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#152 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/card/tool-use-trace-store.js:183](#)

High-risk permission pattern: `sessionTraces.delete(sessionKey);`

```
181 |         for (const [sessionKey, state] of sessionTraces) {
182 |             if (now - state.updatedAt > TRACE_TTL_MS) {
> 183 |                 sessionTraces.delete(sessionKey);
184 |             }
185 |         }
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#153 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/card/tool-use-trace-store.js:191](#)

High-risk permission pattern: `sessionTraces.delete(sessionKey);`

```
189 |     const entries = [...sessionTraces.entries()].sort((a, b) => a[1].updatedAt - b[1].updatedAt);
> 190 |     for (const [sessionKey] of entries.slice(0, overflow)) {
191 |         sessionTraces.delete(sessionKey);
192 |     }...
193 | }
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#154 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/card/tool-use-trace-store.js:21](#)

Dependency without integrity verification

```
19 | exports.sanitizeTraceValue = sanitizeTraceValue;
20 | exports._resetForTesting = _resetForTesting;
> 21 | const reasoning_utils_1 = require("./reasoning-utils.js");
22 | const TRACE_TTL_MS = 30 * 60 * 1000;
23 | const MAX_SESSION_TRACES = 128;
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#155 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/card/tool-use-trace-store.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
2 | /**
3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#156 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/card/unavailable-guard.js:13](#)

Dependency without integrity verification

```
11 | Object.defineProperty(exports, "__esModule", { value: true });
12 | exports.UnavailableGuard = void 0;
> 13 | const lark_logger_1 = require("../core/lark-logger.js");
    14 | const api_error_1 = require("../core/api-error.js");...
    15 | const message_unavailable_1 = require("../core/message-unavailable.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#157 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/card/unavailable-guard.js:14](#)

Dependency without integrity verification

```
12 | exports.UnavailableGuard = void 0;
13 | const lark_logger_1 = require("../core/lark-logger.js");
> 14 | const api_error_1 = require("../core/api-error.js");
    15 | const message_unavailable_1 = require("../core/message-unavailable.js");
    16 | const log = (0, lark_logger_1.larkLogger)('card/unavailable-guard');
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#158 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/card/unavailable-guard.js:15](#)

Dependency without integrity verification

```
13 | const lark_logger_1 = require("../core/lark-logger.js");
14 | const api_error_1 = require("../core/api-error.js");
> 15 | const message_unavailable_1 = require("../core/message-unavailable.js");
    16 | const log = (0, lark_logger_1.larkLogger)('card/unavailable-guard');
    17 | // -----
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#159 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/channel/chat-queue.js:40](#)

High-risk permission pattern: `activeDispatchers.delete(key)`;

```
38 | }
39 | function unregisterActiveDispatcher(key) {
> 40 |     activeDispatchers.delete(key);
    41 | }
    42 | function getActiveDispatcher(key) {
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#160 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/channel/chat-queue.js:58](#)

High-risk permission pattern: `chatQueues.delete(key);`

```
56 |         const cleanup = () => {
57 |             if (chatQueues.get(key) === taskPromise) {
58 |                 chatQueues.delete(key);
59 |             }...
60 |         };
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#161 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/channel/config-adapter.d.ts:17](#)

High-risk permission pattern: `/** Delete a Feishu account entry from the config. */`

```
15 | /** Apply an arbitrary config patch to a Feishu account. */
16 | export declare function applyAccountConfig(cfg: ClawdbotConfig, accountId: string, patch:
Record<string, unknown>): ClawdbotConfig;
> 17 | /** Delete a Feishu account entry from the config. */
18 | export declare function deleteAccount(cfg: ClawdbotConfig, accountId: string): ClawdbotConfig;
19 | /** Collect security warnings for a Feishu account. */
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#162 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/channel/config-adapter.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#163 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/channel/config-adapter.js:56](#)

High-risk permission pattern: `/** Delete a Feishu account entry from the config. */`

```
54 |     return mergeFeishuAccountConfig(cfg, accountId, patch);
55 | }
> 56 | /** Delete a Feishu account entry from the config. */
    57 | function deleteAccount(cfg, accountId) {...
    58 |     const isDefault = !accountId || accountId === account_id_1.DEFAULT_ACCOUNT_ID;
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#164 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/channel/config-adapter.js:60](#)

High-risk permission pattern: `// Delete entire feishu config`

```
58 |     const isDefault = !accountId || accountId === account_id_1.DEFAULT_ACCOUNT_ID;
59 |     if (isDefault) {
> 60 |         // Delete entire feishu config
    61 |         const next = { ...cfg };
    62 |         const nextChannels = { ...cfg.channels };
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#165 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/channel/config-adapter.js:63](#)

High-risk permission pattern: `delete nextChannels.feishu;`

```
61 |     const next = { ...cfg };
62 |     const nextChannels = { ...cfg.channels };
> 63 |     delete nextChannels.feishu;
    64 |     if (Object.keys(nextChannels).length > 0) {
    65 |         next.channels = nextChannels;
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#166 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/channel/config-adapter.js:68](#)

High-risk permission pattern: `delete next.channels;`

```
66 |     }
67 |     else {
> 68 |         delete next.channels;
    69 |     }
    70 |     return next;
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#167 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/channel/config-adapter.js:72](#)

High-risk permission pattern: // Delete specific account from accounts

```
70 |         return next;
71 |     }
> 72 |     // Delete specific account from accounts
73 |     const feishuCfg = cfg.channels?.feishu;...
74 |     const accounts = { ...feishuCfg?.accounts };
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#168 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/channel/config-adapter.js:75](#)

High-risk permission pattern: delete accounts[accountId];

```
73 |     const feishuCfg = cfg.channels?.feishu;
74 |     const accounts = { ...feishuCfg?.accounts };
> 75 |     delete accounts[accountId];
76 |     return {
77 |         ...cfg,
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#169 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/channel/config-adapter.js:18](#)

Dependency without integrity verification

```
16 | exports.deleteAccount = deleteAccount;
17 | exports.collectFeishuSecurityWarnings = collectFeishuSecurityWarnings;
> 18 | const account_id_1 = require("openclaw/plugin-sdk/account-id");
19 | const accounts_1 = require("../core/accounts.js");
20 | const security_check_1 = require("../core/security-check.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#170 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/channel/config-adapter.js:19](#)

Dependency without integrity verification

```
17 | exports.collectFeishuSecurityWarnings = collectFeishuSecurityWarnings;
18 | const account_id_1 = require("openclaw/plugin-sdk/account-id");
> 19 | const accounts_1 = require("../core/accounts.js");
    20 | const security_check_1 = require("../core/security-check.js");...
21 | /** Generic Feishu account config merge. */
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#171 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/channel/config-adapter.js:20](#)

Dependency without integrity verification

```
18 | const account_id_1 = require("openclaw/plugin-sdk/account-id");
19 | const accounts_1 = require("../core/accounts.js");
> 20 | const security_check_1 = require("../core/security-check.js");
    21 | /** Generic Feishu account config merge. */
22 | function mergeFeishuAccountConfig(cfg, accountId, patch) {
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#172 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/channel/config-adapter.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
   2 | /**
   3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#173 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/channel/directory.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
   2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
   3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#174 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/channel/directory.js:16](#)

Dependency without integrity verification

```
14 | exports.listFeishuDirectoryPeersLive = listFeishuDirectoryPeersLive;
15 | exports.listFeishuDirectoryGroupsLive = listFeishuDirectoryGroupsLive;
> 16 | const accounts_1 = require("../core/accounts.js");
    17 | const lark_client_1 = require("../core/lark-client.js");...
    18 | const targets_1 = require("../core/targets.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#175 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/channel/directory.js:17](#)

Dependency without integrity verification

```
15 | exports.listFeishuDirectoryGroupsLive = listFeishuDirectoryGroupsLive;
16 | const accounts_1 = require("../core/accounts.js");
> 17 | const lark_client_1 = require("../core/lark-client.js");
    18 | const targets_1 = require("../core/targets.js");
    19 | // -----
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#176 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/channel/directory.js:18](#)

Dependency without integrity verification

```
16 | const accounts_1 = require("../core/accounts.js");
17 | const lark_client_1 = require("../core/lark-client.js");
> 18 | const targets_1 = require("../core/targets.js");
    19 | // -----
    20 | // Shared helpers
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#177 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/channel/directory.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
    2 | /**
    3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#178 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/channel/interactive-dispatch.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
 2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates...
 3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#179 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/channel/monitor.js:14](#)

Dependency without integrity verification

```
12 | Object.defineProperty(exports, "__esModule", { value: true });
13 | exports.monitorFeishuProvider = monitorFeishuProvider;
> 14 | const accounts_1 = require("../core/accounts.js");
15 | const lark_client_1 = require("../core/lark-client.js");
16 | const dedup_1 = require("../messaging/inbound/dedup.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#180 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/channel/monitor.js:15](#)

Dependency without integrity verification

```
13 | exports.monitorFeishuProvider = monitorFeishuProvider;
14 | const accounts_1 = require("../core/accounts.js");
> 15 | const lark_client_1 = require("../core/lark-client.js");
16 | const dedup_1 = require("../messaging/inbound/dedup.js");
17 | const lark_logger_1 = require("../core/lark-logger.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#181 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/channel/monitor.js:16](#)

Dependency without integrity verification

```
14 | const accounts_1 = require("../core/accounts.js");
15 | const lark_client_1 = require("../core/lark-client.js");
> 16 | const dedup_1 = require("../messaging/inbound/dedup.js");
17 | const lark_logger_1 = require("../core/lark-logger.js");
18 | const shutdown_hooks_1 = require("../core/shutdown-hooks.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#182 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/channel/monitor.js:17](#)

Dependency without integrity verification

```
15 | const lark_client_1 = require("../core/lark-client.js");
> 16 | const dedup_1 = require("../messaging/inbound/dedup.js");
    17 | const lark_logger_1 = require("../core/lark-logger.js");
    18 | const shutdown_hooks_1 = require("../core/shutdown-hooks.js");...
    19 | const event_handlers_1 = require("../event-handlers.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#183 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/channel/monitor.js:18](#)

Dependency without integrity verification

```
16 | const dedup_1 = require("../messaging/inbound/dedup.js");
> 17 | const lark_logger_1 = require("../core/lark-logger.js");
    18 | const shutdown_hooks_1 = require("../core/shutdown-hooks.js");
    19 | const event_handlers_1 = require("../event-handlers.js");
    20 | const mlog = (0, lark_logger_1.larkLogger)('channel/monitor');
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#184 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/channel/monitor.js:19](#)

Dependency without integrity verification

```
17 | const lark_logger_1 = require("../core/lark-logger.js");
> 18 | const shutdown_hooks_1 = require("../core/shutdown-hooks.js");
    19 | const event_handlers_1 = require("../event-handlers.js");
    20 | const mlog = (0, lark_logger_1.larkLogger)('channel/monitor');
    21 | // -----
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#185 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/channel/onboarding-config.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
  2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates...
  3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#186 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/channel/onboarding-config.js:19](#)

Dependency without integrity verification

```
17 | exports.setFeishuGroups = setFeishuGroups;
18 | exports.parseAllowFromInput = parseAllowFromInput;
> 19 | const setup_1 = require("openclaw/plugin-sdk/setup");
20 | // -----
21 | // Config mutation helpers
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#187 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/channel/onboarding-config.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
  2 | /**
  3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#188 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/channel/onboarding-migrate.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
  2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
  3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#189 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/channel/onboarding-migrate.js:14](#)

Dependency without integrity verification

```
12 | Object.defineProperty(exports, "__esModule", { value: true });
13 | exports.migrateLegacyGroupAllowFrom = migrateLegacyGroupAllowFrom;
> 14 | const onboarding_config_1 = require("./onboarding-config.js");
    15 | /**...
    16 |  * Detect and migrate legacy chat_id entries in groupAllowFrom.
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#190 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/channel/onboarding-migrate.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
    2 | /**
    3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#191 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/channel/onboarding.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
    2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
    3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#192 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/channel/onboarding.js:42](#)

High-risk permission pattern: 'You can find user open_id in Feishu admin console or via API.'

```
40 | await params.prompter.note([
41 |   'Allowlist Feishu DMs by open_id or user_id.',
> 42 |   'You can find user open_id in Feishu admin console or via API.',
    43 |   'Examples:',
    44 |   '- ou_XXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXX',
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#193 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/channel/onboarding.js:14](#)

Dependency without integrity verification

```
12 | Object.defineProperty(exports, "__esModule", { value: true });
13 | exports.feishuOnboardingAdapter = void 0;
> 14 | const account_id_1 = require("openclaw/plugin-sdk/account-id");
    15 | const setup_1 = require("openclaw/plugin-sdk/setup");...
    16 | const accounts_1 = require("../core/accounts.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#194 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/channel/onboarding.js:15](#)

Dependency without integrity verification

```
13 | exports.feishuOnboardingAdapter = void 0;
14 | const account_id_1 = require("openclaw/plugin-sdk/account-id");
> 15 | const setup_1 = require("openclaw/plugin-sdk/setup");
    16 | const accounts_1 = require("../core/accounts.js");
    17 | const probe_1 = require("../probe.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#195 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/channel/onboarding.js:16](#)

Dependency without integrity verification

```
14 | const account_id_1 = require("openclaw/plugin-sdk/account-id");
15 | const setup_1 = require("openclaw/plugin-sdk/setup");
> 16 | const accounts_1 = require("../core/accounts.js");
    17 | const probe_1 = require("../probe.js");
    18 | const onboarding_config_1 = require("../onboarding-config.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#196 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/channel/onboarding.js:17](#)

Dependency without integrity verification

```
15 | const setup_1 = require("openclaw/plugin-sdk/setup");
16 | const accounts_1 = require("../core/accounts.js");
> 17 | const probe_1 = require("../probe.js");
    18 | const onboarding_config_1 = require("../onboarding-config.js");
    19 | const onboarding_migrate_1 = require("../onboarding-migrate.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#197 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/channel/onboarding.js:18](#)

Dependency without integrity verification

```
16 | const accounts_1 = require("../core/accounts.js");
17 | const probe_1 = require("../probe.js");
> 18 | const onboarding_config_1 = require("../onboarding-config.js");
19 | const onboarding_migrate_1 = require("../onboarding-migrate.js");...
20 | // -----
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#198 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/channel/onboarding.js:19](#)

Dependency without integrity verification

```
17 | const probe_1 = require("../probe.js");
18 | const onboarding_config_1 = require("../onboarding-config.js");
> 19 | const onboarding_migrate_1 = require("../onboarding-migrate.js");
20 | // -----
21 | // Constants
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#199 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/channel/onboarding.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
2 | /**
3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#200 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/channel/plugin.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
    2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates...
    3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#201 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/channel/plugin.js:12](#)

Dangerous execution: var __createBinding = (this && this.__createBinding) || (Object.create ? (functi

```
10 |  * start the inbound event gateway.
11 |  */
> 12 | var __createBinding = (this && this.__createBinding) || (Object.create ? (function(o, m, k, k2) {
13 |     if (k2 === undefined) k2 = k;
14 |     var desc = Object.getOwnPropertyDescriptor(m, k);
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#202 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/channel/plugin.js:16](#)

Dangerous execution: desc = { enumerable: true, get: function() { return m[k]; } };

```
14 |     var desc = Object.getOwnPropertyDescriptor(m, k);
15 |     if (!desc || ("get" in desc ? !m.__esModule : desc.writable || desc.configurable)) {
> 16 |         desc = { enumerable: true, get: function() { return m[k]; } };
17 |     }
18 |     Object.defineProperty(o, k2, desc);
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#203 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/channel/plugin.js:19](#)

Dangerous execution: }) : (function(o, m, k, k2) {

```
17 |     }
18 |     Object.defineProperty(o, k2, desc);
> 19 | }) : (function(o, m, k, k2) {
20 |     if (k2 === undefined) k2 = k;
21 |     o[k2] = m[k];
```


Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#204 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/channel/plugin.js:23](#)

Dangerous execution: `var __setModuleDefault = (this && this.__setModuleDefault) || (Object.create ? (`

```
21 |         o[k2] = m[k];
22 |     });
> 23 |     var __setModuleDefault = (this && this.__setModuleDefault) || (Object.create ? (function(o, v) {
24 |         Object.defineProperty(o, "default", { enumerable: true, value: v });...
25 |     }) : function(o, v) {
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#205 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/channel/plugin.js:25](#)

Dangerous execution: `}) : function(o, v) {`

```
23 |     var __setModuleDefault = (this && this.__setModuleDefault) || (Object.create ? (function(o, v) {
24 |         Object.defineProperty(o, "default", { enumerable: true, value: v });
> 25 |     }) : function(o, v) {
26 |         o["default"] = v;
27 |     });
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#206 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/channel/plugin.js:28](#)

Dangerous execution: `var __importStar = (this && this.__importStar) || (function () {`

```
26 |         o["default"] = v;
27 |     });
> 28 |     var __importStar = (this && this.__importStar) || (function () {
29 |         var ownKeys = function(o) {
30 |             ownKeys = Object.getOwnPropertyNames || function (o) {
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#207 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/channel/plugin.js:29](#)

Dangerous execution: var ownKeys = function(o) {

```
27 | });
28 | var __importStar = (this && this.__importStar) || (function () {
> 29 |     var ownKeys = function(o) {
30 |         ownKeys = Object.getOwnPropertyNames || function (o) {...
31 |         var ar = [];
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#208 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/channel/plugin.js:30](#)

Dangerous execution: ownKeys = Object.getOwnPropertyNames || function (o) {

```
28 | var __importStar = (this && this.__importStar) || (function () {
29 |     var ownKeys = function(o) {
> 30 |         ownKeys = Object.getOwnPropertyNames || function (o) {
31 |             var ar = [];
32 |             for (var k in o) if (Object.prototype.hasOwnProperty.call(o, k)) ar[ar.length] = k;
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#209 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/channel/plugin.js:37](#)

Dangerous execution: return function (mod) {

```
35 |         return ownKeys(o);
36 |     };
> 37 |     return function (mod) {
38 |         if (mod && mod.__esModule) return mod;
39 |         var result = {};
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#210 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/channel/plugin.js:143](#)

High-risk permission pattern: "- Feishu `action=delete`/`action=unsubscribe` only deletes messages sent by the bot.

```
141 |         '- Feishu supports interactive cards for rich messages.',
142 |         '- Feishu reactions use UPPERCASE emoji type names (e.g.
`OK`, `THUMBSUP`, `THANKS`, `MUSCLE`, `FINGERHEART`, `APPLAUSE`, `FISTBUMP`, `JIAYI`, `DONE`, `SMILE`, `BLUSH` ), not
Unicode emoji characters.',
> 143 |         "- Feishu `action=delete`/`action=unsubscribe` only deletes messages sent by the bot. When
the user quotes a message and says 'delete this', use the **quoted message's** message_id, not the user's own
message_id.",
144 |     ],
145 | },
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#211 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/channel/probe.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
  2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates...
  3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#212 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/channel/probe.js:8](#)

Dependency without integrity verification

```
6 | Object.defineProperty(exports, "__esModule", { value: true });
7 | exports.probeFeishu = probeFeishu;
> 8 | const lark_client_1 = require("../core/lark-client.js");
9 | /**
10 |  * Probe the Feishu bot connection by calling the bot/v3/info API.
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#213 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/channel/probe.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
  2 | /**
  3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#214 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/channel/types.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
   2 | /**...
   3 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#215 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/commands/auth.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
   2 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
   3 | * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#216 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/commands/auth.js:40](#)

High-risk permission pattern: missingSelfManage: (link) => `L App is missing the core permission application:a

```
38 |         noIdentity: 'L Unable to identify user. Please use this command in a Feishu conversation.',
39 |         accountIncomplete: (accountId) => `L Account ${accountId} configuration is incomplete`,
> 40 |         missingSelfManage: (link) => `L App is missing the core permission
    application:application:self_manage and cannot query available scopes.\n\nPlease ask an admin to grant this
    permission on the Feishu Open Platform: [Apply](${link})`,
41 |         ownerOnly: 'L This command is restricted to the app owner.\n\nPlease contact the app admin
    for authorization.',
42 |         missingOfflineAccess: (link) => `L App is missing the core permission offline_access and
    cannot query available scopes.\n\nPlease ask an admin to grant this permission on the Feishu Open Platform:
    [Apply](${link})`,
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#217 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/commands/auth.js:41](#)

High-risk permission pattern: ownerOnly: "L This command is restricted to the app owner.\n\nPlease contact the

```
39 |         accountIncomplete: (accountId) => `L Account ${accountId} configuration is incomplete`,
40 |         missingSelfManage: (link) => `L App is missing the core permission
    application:application:self_manage and cannot query available scopes.\n\nPlease ask an admin to grant this
    permission on the Feishu Open Platform: [Apply](${link})`,
> 41 |         ownerOnly: 'L This command is restricted to the app owner.\n\nPlease contact the app admin
    for authorization.',
42 |         missingOfflineAccess: (link) => `L App is missing the core permission offline_access and
    cannot query available scopes.\n\nPlease ask an admin to grant this permission on the Feishu Open Platform:
    [Apply](${link})`,
43 |         noUserScopes: 'No user-level permissions are enabled for this app. Authorization is not
    needed.',
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#218 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/commands/auth.js:42](#)

High-risk permission pattern: missingOfflineAccess: (link) => `L App is missing the core permission offline_ac

```
40 |         missingSelfManage: (link) => `L App is missing the core permission
application:application:self_manage and cannot query available scopes.\n\nPlease ask an admin to grant this
permission on the Feishu Open Platform: [Apply](${link})`,
41 |         ownerOnly: `L This command is restricted to the app owner.\n\nPlease contact the app admin
for authorization.`,
> 42 |         missingOfflineAccess: (link) => `L App is missing the core permission offline_access and
cannot query available scopes.\n\nPlease ask an admin to grant this permission on the Feishu Open Platform:
[Apply](${link})`,
43 |         noUserScopes: `No user-level permissions are enabled for this app. Authorization is not
needed.`,
44 |         allAuthorized: (count) => ` You have authorized all available permissions (${count} total).
No re-authorization needed.`,
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#219 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/commands/auth.js:76](#)

High-risk permission pattern: * Execute the auth command logic, including side-effects (triggerOnboarding).

```
74 | // -----
75 | /**
> 76 |  * Execute the auth command logic, including side-effects (triggerOnboarding).
77 |  * Returns a discriminated result that can be formatted into any locale.
78 |  */
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#220 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/commands/auth.js:14](#)

Dependency without integrity verification

```
12 | exports.runFeishuAuth = runFeishuAuth;
13 | exports.runFeishuAuthI18n = runFeishuAuthI18n;
> 14 | const onboarding_auth_1 = require("../tools/onboarding-auth.js");
15 | const lark_ticket_1 = require("../core/lark-ticket.js");
16 | const accounts_1 = require("../core/accounts.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#221 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/commands/auth.js:15](#)

Dependency without integrity verification

```
13 | exports.runFeishuAuthI18n = runFeishuAuthI18n;  
14 | const onboarding_auth_1 = require("../tools/onboarding-auth.js");  
> 15 | const lark_ticket_1 = require("../core/lark-ticket.js");  
16 | const accounts_1 = require("../core/accounts.js");...  
17 | const lark_client_1 = require("../core/lark-client.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#222 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/commands/auth.js:16](#)

Dependency without integrity verification

```
14 | const onboarding_auth_1 = require("../tools/onboarding-auth.js");  
15 | const lark_ticket_1 = require("../core/lark-ticket.js");  
> 16 | const accounts_1 = require("../core/accounts.js");  
17 | const lark_client_1 = require("../core/lark-client.js");  
18 | const app_scope_checker_1 = require("../core/app-scope-checker.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#223 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/commands/auth.js:17](#)

Dependency without integrity verification

```
15 | const lark_ticket_1 = require("../core/lark-ticket.js");  
16 | const accounts_1 = require("../core/accounts.js");  
> 17 | const lark_client_1 = require("../core/lark-client.js");  
18 | const app_scope_checker_1 = require("../core/app-scope-checker.js");  
19 | const token_store_1 = require("../core/token-store.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#224 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/commands/auth.js:18](#)

Dependency without integrity verification

```
16 | const accounts_1 = require("../core/accounts.js");  
17 | const lark_client_1 = require("../core/lark-client.js");  
> 18 | const app_scope_checker_1 = require("../core/app-scope-checker.js");  
19 | const token_store_1 = require("../core/token-store.js");  
20 | const tool_scopes_1 = require("../core/tool-scopes.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#225 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/commands/auth.js:19](#)

Dependency without integrity verification

```
17 | const lark_client_1 = require("../core/lark-client.js");
> 18 | const app_scope_checker_1 = require("../core/app-scope-checker.js");
    19 | const token_store_1 = require("../core/token-store.js");
    20 | const tool_scopes_1 = require("../core/tool-scopes.js");...
    21 | const owner_policy_1 = require("../core/owner-policy.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#226 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/commands/auth.js:20](#)

Dependency without integrity verification

```
18 | const app_scope_checker_1 = require("../core/app-scope-checker.js");
> 19 | const token_store_1 = require("../core/token-store.js");
    20 | const tool_scopes_1 = require("../core/tool-scopes.js");
    21 | const owner_policy_1 = require("../core/owner-policy.js");
    22 | const domains_1 = require("../core/domains.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#227 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/commands/auth.js:21](#)

Dependency without integrity verification

```
19 | const token_store_1 = require("../core/token-store.js");
> 20 | const tool_scopes_1 = require("../core/tool-scopes.js");
    21 | const owner_policy_1 = require("../core/owner-policy.js");
    22 | const domains_1 = require("../core/domains.js");
    23 | // -----
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#228 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/commands/auth.js:22](#)

Dependency without integrity verification

```
20 | const tool_scopes_1 = require("../core/tool-scopes.js");
21 | const owner_policy_1 = require("../core/owner-policy.js");
> 22 | const domains_1 = require("../core/domains.js");
    | // -----
23 | // I18n text map
24 |
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#229 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/commands/auth.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
  2 | /**
  3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#230 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/commands/diagnose.js:13](#)

Dangerous execution: var __createBinding = (this && this.__createBinding) || (Object.create ? (functi

```
11 |  * remote troubleshooting.
12 |  */
> 13 | var __createBinding = (this && this.__createBinding) || (Object.create ? (function(o, m, k, k2) {
    |   if (k2 === undefined) k2 = k;
14 |   var desc = Object.getOwnPropertyDescriptor(m, k);
15 |
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#231 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/commands/diagnose.js:17](#)

Dangerous execution: desc = { enumerable: true, get: function() { return m[k]; } };

```
15 |   var desc = Object.getOwnPropertyDescriptor(m, k);
16 |   if (!desc || ("get" in desc ? !m.__esModule : desc.writable || desc.configurable)) {
> 17 |     desc = { enumerable: true, get: function() { return m[k]; } };
    |   }
18 |   Object.defineProperty(o, k2, desc);
19 |
```


Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#232 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/commands/diagnose.js:20](#)

Dangerous execution: `}} : (function(o, m, k, k2) {`

```
18 |     }
19 |     Object.defineProperty(o, k2, desc);
> 20 | }) : (function(o, m, k, k2) {
21 |     if (k2 === undefined) k2 = k;...
22 |     o[k2] = m[k];
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#233 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/commands/diagnose.js:24](#)

Dangerous execution: `var __setModuleDefault = (this && this.__setModuleDefault) || (Object.create ? (`

```
22 |     o[k2] = m[k];
23 | }));
> 24 | var __setModuleDefault = (this && this.__setModuleDefault) || (Object.create ? (function(o, v) {
25 |     Object.defineProperty(o, "default", { enumerable: true, value: v });
26 | }) : function(o, v) {
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#234 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/commands/diagnose.js:26](#)

Dangerous execution: `}} : function(o, v) {`

```
24 | var __setModuleDefault = (this && this.__setModuleDefault) || (Object.create ? (function(o, v) {
25 |     Object.defineProperty(o, "default", { enumerable: true, value: v });
> 26 | }) : function(o, v) {
27 |     o["default"] = v;
28 | }));
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#235 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/commands/diagnose.js:29](#)

Dangerous execution: `var __importStar = (this && this.__importStar) || (function () {`

```
27 |     o["default"] = v;  
28 | });  
> 29 | var __importStar = (this && this.__importStar) || (function () {  
30 |     var ownKeys = function(o) {  
31 |         ownKeys = Object.getOwnPropertyNames || function (o) {
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#236 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/commands/diagnose.js:30](#)

Dangerous execution: `var ownKeys = function(o) {`

```
28 | });  
29 | var __importStar = (this && this.__importStar) || (function () {  
> 30 |     var ownKeys = function(o) {  
31 |         ownKeys = Object.getOwnPropertyNames || function (o) {  
32 |             var ar = [];
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#237 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/commands/diagnose.js:31](#)

Dangerous execution: `ownKeys = Object.getOwnPropertyNames || function (o) {`

```
29 | var __importStar = (this && this.__importStar) || (function () {  
30 |     var ownKeys = function(o) {  
> 31 |         ownKeys = Object.getOwnPropertyNames || function (o) {  
32 |             var ar = [];  
33 |             for (var k in o) if (Object.prototype.hasOwnProperty.call(o, k)) ar[ar.length] = k;
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#238 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/commands/diagnose.js:38](#)

Dangerous execution: `return function (mod) {`

```
36 |         return ownKeys(o);  
37 |     };  
> 38 |     return function (mod) {  
39 |         if (mod && mod.__esModule) return mod;  
40 |         var result = {};
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#239 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/commands/diagnose.js:53](#)

Dependency without integrity verification

```
51 | exports.analyzeTrace = analyzeTrace;
> 52 | exports.formatDiagReportCli = formatDiagReportCli;
53 | const fs = __importStar(require("node:fs/promises"));
54 | const path = __importStar(require("node:path"));...
55 | const os = __importStar(require("node:os"));
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use `>=` or `latest`. 3. Run `npm audit` / `pip-audit` in CI. 4. Use `pip install --require-hashes` for Python. 5. Verify package signatures where available.

#240 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/commands/diagnose.js:54](#)

Dependency without integrity verification

```
52 | exports.formatDiagReportCli = formatDiagReportCli;
> 53 | const fs = __importStar(require("node:fs/promises"));
54 | const path = __importStar(require("node:path"));
55 | const os = __importStar(require("node:os"));
56 | const probe_1 = require("../channel/probe.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use `>=` or `latest`. 3. Run `npm audit` / `pip-audit` in CI. 4. Use `pip install --require-hashes` for Python. 5. Verify package signatures where available.

#241 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/commands/diagnose.js:55](#)

Dependency without integrity verification

```
53 | const fs = __importStar(require("node:fs/promises"));
> 54 | const path = __importStar(require("node:path"));
55 | const os = __importStar(require("node:os"));
56 | const probe_1 = require("../channel/probe.js");
57 | const accounts_1 = require("../core/accounts.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use `>=` or `latest`. 3. Run `npm audit` / `pip-audit` in CI. 4. Use `pip install --require-hashes` for Python. 5. Verify package signatures where available.

#242 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/commands/diagnose.js:56](#)

Dependency without integrity verification

```
54 | const path = __importStar(require("node:path"));
55 | const os = __importStar(require("node:os"));
> 56 | const probe_1 = require("../channel/probe.js");
57 | const accounts_1 = require("../core/accounts.js");...
58 | const lark_client_1 = require("../core/lark-client.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#243 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/commands/diagnose.js:57](#)

Dependency without integrity verification

```
55 | const os = __importStar(require("node:os"));
56 | const probe_1 = require("../channel/probe.js");
> 57 | const accounts_1 = require("../core/accounts.js");
58 | const lark_client_1 = require("../core/lark-client.js");
59 | /**
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#244 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/commands/diagnose.js:58](#)

Dependency without integrity verification

```
56 | const probe_1 = require("../channel/probe.js");
57 | const accounts_1 = require("../core/accounts.js");
> 58 | const lark_client_1 = require("../core/lark-client.js");
59 | /**
60 |  * Resolve the global config for cross-account operations.
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#245 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/commands/diagnose.js:66](#)

Dependency without integrity verification

```
64 |     return lark_client_1.LarkClient.globalConfig ?? config;
65 | }
> 66 | const api_error_1 = require("../core/api-error.js");
67 | const tools_config_1 = require("../core/tools-config.js");
68 | // -----
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#246 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/commands/diagnose.js:67](#)

Dependency without integrity verification

```
65 | }
66 | const api_error_1 = require("../core/api-error.js");
67 | const tools_config_1 = require("../core/tools-config.js");
68 | // -----
69 | // Constants
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#247 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/commands/diagnose.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
   2 | /**
   3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#248 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/commands/doctor.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
   2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
   3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#249 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/commands/doctor.js:120](#)

High-risk permission pattern: allPermsGranted: (count) => `All \${count} required permissions granted`,

```
118 |         toolsWarnProfile: (profile) => `& p **Tool Allowlist**: Currently set to \`${profile}\`. Feishu
tools may not load properly. Update configuration as needed:`,
119 |         toolsDocRef: '0=00 Documentation',
> 120 |         allPermsGranted: (count) => `All ${count} required permissions granted`,
121 |         missingPermsPrefix: 'Missing',...
122 |         missingPermsSuffix: 'required permissions. Admin needs to apply',
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#250 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/commands/doctor.js:122](#)

High-risk permission pattern: missingPermsSuffix: 'required permissions. Admin needs to apply',

```
120 |         allPermsGranted: (count) => `All ${count} required permissions granted`,
121 |         missingPermsPrefix: 'Missing',
> 122 |         missingPermsSuffix: 'required permissions. Admin needs to apply',
123 |         cannotQueryPerms: 'Unable to query app permissions. Reason: Missing
application:application:self_manage permission',
124 |         cannotQueryPermsGeneric: 'Unable to query app permissions.',
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#251 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/commands/doctor.js:126](#)

High-risk permission pattern: adminApply: 'Admin needs to apply',

```
124 |         cannotQueryPermsGeneric: 'Unable to query app permissions.',
125 |         suggestCheckPerm: 'Please check application:application:self_manage permission',
> 126 |         adminApply: 'Admin needs to apply',
127 |         apply: 'Apply',
128 |         permTableHeader: '| Permission | App Granted | User Authorized |',
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#252 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/commands/doctor.js:143](#)

High-risk permission pattern: appMissingUserPerms: (count) => `0=0; App is missing \${count} user-identity permis

```
141 |         userCountLabel: 'authorized',
142 |         noAuthLabel: 'not authorized',
> 143 |         appMissingUserPerms: (count) => `0=0; App is missing ${count} user-identity permissions. Admin
needs to apply`,
144 |         permCompareSummary: (appCount, total, userPart) => `App **${appCount}/${total}** granted,
User **${userPart}**`,
145 |         userReauth: '0=0; User needs to re-authorize for full permissions. Send message to bot: "**/
feishu auth**"',
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#253 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/commands/doctor.js:381](#)

High-risk permission pattern: `const appGrantedCount = appUserScopes.filter((s) => allScopes.includes(s)).length`

```
379 |         let allScopes = getAllToolScopes();
> 380 |         allScopes = (0, tool_scopes_1.filterSensitiveScopes)(allScopes);
    381 |         const appGrantedCount = appUserScopes.filter((s) => allScopes.includes(s)).length;
    382 |         if (hasUserAuth) {...
    383 |             // g u(b7c^gC - hÂgâc^gCr¶`
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#254 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/commands/doctor.js:407](#)

High-risk permission pattern: `const userGrantedCount = validCount === 1 ? scopes.filter((s) => allScopes.inclu`

```
405 |         }
406 |         // <i{-u(b7]ðc^gCgC-Pep
> 407 |         const userGrantedCount = validCount === 1 ? scopes.filter((s) =>
    allScopes.includes(s)).length : 0;
    408 |         // <i{-u(b7*:Y1V,,gC-P
    409 |         if (hasUserAuth && validCount === 1) {
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#255 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/commands/doctor.js:414](#)

High-risk permission pattern: `const tableStatus = appGrantedCount < allScopes.length || userGrantedCount < all`

```
412 |         }
413 |         // gC-P[ùqg-ß<i
> 414 |         const tableStatus = appGrantedCount < allScopes.length || userGrantedCount < allScopes.length
    415 |             ? appGrantedCount < allScopes.length
    416 |             ? 'fail'
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#256 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/commands/doctor.js:415](#)

High-risk permission pattern: ? appGrantedCount < allScopes.length

```
413 |         // gC-P[ùqg-ß<i
414 |         const tableStatus = appGrantedCount < allScopes.length || userGrantedCount < allScopes.length
> 415 |         ? appGrantedCount < allScopes.length
416 |         ? 'fail'...
417 |         : 'warn'
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#257 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/commands/doctor.js:421](#)

High-risk permission pattern: lines.push(`\${t.permCompareLabel}: \${t.permCompareSummary(appGrantedCount, allSc

```
419 |         const tableEmoji = tableStatus === 'pass' ? ' ' : tableStatus === 'warn' ? '& p ' : 'L';
420 |         if (validCount === 0) {
> 421 |             lines.push(`${t.permCompareLabel}: ${t.permCompareSummary(appGrantedCount,
allScopes.length, t.noAuthLabel)} `);
422 |         }
423 |         else if (userGrantedCount < allScopes.length) {
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#258 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/commands/doctor.js:423](#)

High-risk permission pattern: else if (userGrantedCount < allScopes.length) {

```
421 |         lines.push(`${t.permCompareLabel}: ${t.permCompareSummary(appGrantedCount,
allScopes.length, t.noAuthLabel)} `);
422 |     }
> 423 |     else if (userGrantedCount < allScopes.length) {
424 |         lines.push(`${tableEmoji} ${t.permInsufficient}: ${t.permCompareSummary(appGrantedCount,
allScopes.length, `${userGrantedCount}/${allScopes.length} ${t.userCountLabel} `)} `);
425 |     }
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#259 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/commands/doctor.js:424](#)

High-risk permission pattern: lines.push(`\${tableEmoji} \${t.permInsufficient}: \${t.permCompareSummary(appGrant

```
422 |     }
423 |     else if (userGrantedCount < allScopes.length) {
> 424 |         lines.push(`${tableEmoji} ${t.permInsufficient}: ${t.permCompareSummary(appGrantedCount,
allScopes.length, `${userGrantedCount}/${allScopes.length} ${t.userCountLabel} `)} `);
425 |     }
426 |     else {
```


Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#260 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/commands/doctor.js:427](#)

High-risk permission pattern: lines.push(`\${tableEmoji} \${t.permCompareLabel}: \${t.permCompareSummary(appGranted

```
425 |         }
426 |     } else {
> 427 |         lines.push(`${tableEmoji} ${t.permCompareLabel}: ${t.permCompareSummary(appGrantedCount,
    |         allScopes.length, `${userGrantedCount}/${allScopes.length} ${t.userCountLabel}`)}');
428 |     }...
429 |     lines.push('');
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#261 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/commands/doctor.js:431](#)

High-risk permission pattern: if (appGrantedCount < allScopes.length) {

```
429 |         lines.push('');
430 |         // mÜR c _ Oá`o
> 431 |         if (appGrantedCount < allScopes.length) {
    |             // <i{-:Y1V,,^"u(gC-P
432 |             const appMissingScopes = allScopes.filter((s) => !appUserScopes.includes(s));
433 |         }
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#262 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/commands/doctor.js:440](#)

High-risk permission pattern: if (userGrantedCount < allScopes.length && validCount > 0) {

```
438 |         lines.push(`${t.appMissingUserPerms(appMissingScopes.length)} [${t.apply}]
    |         (${appApplyUrl})`);
439 |     }
> 440 |     if (userGrantedCount < allScopes.length && validCount > 0) {
    |         lines.push(t.userReauth);
441 |         lines.push('');
442 |     }
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#263 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/commands/doctor.js:14](#)

Dependency without integrity verification

```
12 | exports.runFeishuDoctor = runFeishuDoctor;  
13 | exports.runFeishuDoctorI18n = runFeishuDoctorI18n;  
> 14 | const accounts_1 = require("../core/accounts.js");  
15 | const lark_client_1 = require("../core/lark-client.js");...  
16 | /**
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#264 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/commands/doctor.js:15](#)

Dependency without integrity verification

```
13 | exports.runFeishuDoctorI18n = runFeishuDoctorI18n;  
14 | const accounts_1 = require("../core/accounts.js");  
> 15 | const lark_client_1 = require("../core/lark-client.js");  
16 | /**  
17 | * Resolve the global config for cross-account operations.
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#265 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/commands/doctor.js:27](#)

Dependency without integrity verification

```
25 |     return lark_client_1.LarkClient.globalConfig ?? config;  
26 | }  
> 27 | const app_scope_checker_1 = require("../core/app-scope-checker.js");  
28 | const app_owner_fallback_1 = require("../core/app-owner-fallback.js");  
29 | const token_store_1 = require("../core/token-store.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#266 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/commands/doctor.js:28](#)

Dependency without integrity verification

```
26 | }  
27 | const app_scope_checker_1 = require("../core/app-scope-checker.js");  
> 28 | const app_owner_fallback_1 = require("../core/app-owner-fallback.js");  
29 | const token_store_1 = require("../core/token-store.js");  
30 | const tool_scopes_1 = require("../core/tool-scopes.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#267 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/commands/doctor.js:29](#)

Dependency without integrity verification

```
27 | const app_scope_checker_1 = require("../core/app-scope-checker.js");
> 28 | const app_owner_fallback_1 = require("../core/app-owner-fallback.js");
    29 | const token_store_1 = require("../core/token-store.js");
    30 | const tool_scopes_1 = require("../core/tool-scopes.js");...
    31 | const probe_1 = require("../channel/probe.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#268 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/commands/doctor.js:30](#)

Dependency without integrity verification

```
28 | const app_owner_fallback_1 = require("../core/app-owner-fallback.js");
> 29 | const token_store_1 = require("../core/token-store.js");
    30 | const tool_scopes_1 = require("../core/tool-scopes.js");
    31 | const probe_1 = require("../channel/probe.js");
    32 | const tool_client_1 = require("../core/tool-client.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#269 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/commands/doctor.js:31](#)

Dependency without integrity verification

```
29 | const token_store_1 = require("../core/token-store.js");
> 30 | const tool_scopes_1 = require("../core/tool-scopes.js");
    31 | const probe_1 = require("../channel/probe.js");
    32 | const tool_client_1 = require("../core/tool-client.js");
    33 | const version_1 = require("../core/version.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#270 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/commands/doctor.js:32](#)

Dependency without integrity verification

```
30 | const tool_scopes_1 = require("../core/tool-scopes.js");
31 | const probe_1 = require("../channel/probe.js");
> 32 | const tool_client_1 = require("../core/tool-client.js");
33 | const version_1 = require("../core/version.js");...
34 | const domains_1 = require("../core/domains.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#271 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/commands/doctor.js:33](#)

Dependency without integrity verification

```
31 | const probe_1 = require("../channel/probe.js");
32 | const tool_client_1 = require("../core/tool-client.js");
> 33 | const version_1 = require("../core/version.js");
34 | const domains_1 = require("../core/domains.js");
35 | // -----
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#272 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/commands/doctor.js:34](#)

Dependency without integrity verification

```
32 | const tool_client_1 = require("../core/tool-client.js");
33 | const version_1 = require("../core/version.js");
> 34 | const domains_1 = require("../core/domains.js");
35 | // -----
36 | // I18n text map
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#273 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/commands/doctor.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
2 | /**
3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#274 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/commands/index.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
 2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates...
 3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#275 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/commands/index.js:14](#)

Dependency without integrity verification

```
12 | exports.getFeishuHelpI18n = getFeishuHelpI18n;
13 | exports.registerCommands = registerCommands;
> 14 | const version_1 = require("../core/version.js");
15 | const diagnose_1 = require("../diagnose.js");
16 | const doctor_1 = require("../doctor.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#276 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/commands/index.js:15](#)

Dependency without integrity verification

```
13 | exports.registerCommands = registerCommands;
14 | const version_1 = require("../core/version.js");
> 15 | const diagnose_1 = require("../diagnose.js");
16 | const doctor_1 = require("../doctor.js");
17 | const auth_1 = require("../auth.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#277 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/commands/index.js:16](#)

Dependency without integrity verification

```
14 | const version_1 = require("../core/version.js");
15 | const diagnose_1 = require("../diagnose.js");
> 16 | const doctor_1 = require("../doctor.js");
17 | const auth_1 = require("../auth.js");
18 | // -----
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#278 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/commands/index.js:17](#)

Dependency without integrity verification

```
15 | const diagnose_1 = require("./diagnose.js");
16 | const doctor_1 = require("./doctor.js");
17 | const auth_1 = require("./auth.js");
18 | // -----
19 | // I18n text map for /feishu start, help, and error messages
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#279 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/commands/index.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
  2 | /**
  3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#280 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/commands/locale.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
  2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
  3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#281 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/commands/locale.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
   2 | /**...
   3 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#282 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/core/accounts.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
   2 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
   3 | * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#283 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/core/accounts.js:20](#)

Dependency without integrity verification

```
18 | exports.getLarkCredentials = getLarkCredentials;
19 | exports.isConfigured = isConfigured;
> 20 | const account_id_1 = require("openclaw/plugin-sdk/account-id");
    21 | const normalizeAccountId = typeof account_id_1.normalizeAccountId === 'function'
    22 |   ? account_id_1.normalizeAccountId
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#284 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/core/accounts.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
   2 | /**
   3 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#285 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/core/agent-config.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
  2 |  * Agent configuration helpers for the Lark/Feishu channel plugin...
  3 |  */
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#286 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/core/agent-config.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
  2 | // SPDX-License-Identifier: MIT
  3 | /**
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#287 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/core/api-error.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
  2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
  3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#288 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/core/api-error.js:24](#)

Dependency without integrity verification

```
> 22 | exports.assertLarkOk = assertLarkOk;
    23 | exports.formatLarkError = formatLarkError;
    24 | const permission_url_1 = require("../permission-url.js");
    25 | const auth_errors_1 = require("../auth-errors.js");
    26 | // -----
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#289 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/core/api-error.js:25](#)

Dependency without integrity verification

```
23 | exports.formatLarkError = formatLarkError;
24 | const permission_url_1 = require("./permission-url.js");
> 25 | const auth_errors_1 = require("./auth-errors.js");
26 | // -----
27 | // Helpers
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#290 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/core/api-error.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
2 | /**
3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#291 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/core/app-owner-fallback.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#292 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/core/app-owner-fallback.js:13](#)

Dependency without integrity verification

```
11 | Object.defineProperty(exports, "__esModule", { value: true });
12 | exports.getAppOwnerFallback = getAppOwnerFallback;
> 13 | const app_scope_checker_1 = require("./app-scope-checker.js");
14 | const lark_logger_1 = require("./lark-logger.js");
15 | const log = (0, lark_logger_1.larkLogger)('core/app-owner-fallback');
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#293 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/core/app-owner-fallback.js:14](#)

Dependency without integrity verification

```
12 | exports.getAppOwnerFallback = getAppOwnerFallback;
13 | const app_scope_checker_1 = require("../app-scope-checker.js");
> 14 | const lark_logger_1 = require("../lark-logger.js");
15 | const log = (0, lark_logger_1.larkLogger)('core/app-owner-fallback');...
16 | // -----
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#294 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/core/app-scope-checker.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
2 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
3 | * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#295 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/core/app-scope-checker.js:32](#)

High-risk permission pattern: cache.delete(appId);

```
30 | /** n -dc [$ appId v,,* [X0 */
31 | function invalidateAppScopeCache(appId) {
> 32 |     cache.delete(appId);
33 | }
34 | // -----
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#296 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/core/app-scope-checker.js:22](#)

Dependency without integrity verification

```
20 | exports.missingScopes = missingScopes;
21 | exports.isAppScopeSatisfied = isAppScopeSatisfied;
> 22 | const lark_logger_1 = require("../lark-logger.js");
23 | const log = (0, lark_logger_1.larkLogger)('core/app-scope-checker');
24 | const auth_errors_1 = require("../auth-errors.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#297 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/core/app-scope-checker.js:24](#)

Dependency without integrity verification

```
22 | const lark_logger_1 = require("./lark-logger.js");
23 | const log = (0, lark_logger_1.larkLogger)('core/app-scope-checker');
> 24 | const auth_errors_1 = require("./auth-errors.js");
25 | // -----
26 | // Cache
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#298 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/core/auth-errors.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#299 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/core/auth-errors.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
2 | /**
3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#300 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/core/chat-info-cache.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
    2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates...
    3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#301 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/core/chat-info-cache.js:46](#)

High-risk permission pattern: this.map.delete(chatId);

```
> 44 |         return undefined;
    45 |         if (entry.expireAt <= Date.now()) {
    46 |             this.map.delete(chatId);
    47 |             return undefined;
    48 |         }
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#302 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/core/chat-info-cache.js:50](#)

High-risk permission pattern: this.map.delete(chatId);

```
> 48 |         }
    49 |         // LRU refresh
    50 |         this.map.delete(chatId);
    51 |         this.map.set(chatId, entry);
    52 |         return entry.info;
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#303 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/core/chat-info-cache.js:55](#)

High-risk permission pattern: this.map.delete(chatId);

```
> 53 |         }
    54 |         set(chatId, info) {
    55 |             this.map.delete(chatId);
    56 |             this.map.set(chatId, { info, expireAt: Date.now() + this.ttlMs });
    57 |             this.evict();
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#304 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/core/chat-info-cache.js:66](#)

High-risk permission pattern: **this.map.delete(oldest);**

```
64 |         const oldest = this.map.keys().next().value;
65 |         if (oldest !== undefined)
66 |             this.map.delete(oldest);
67 |     }...
68 | }
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#305 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/core/chat-info-cache.js:86](#)

High-risk permission pattern: **registry.delete(accountId);**

```
84 |         if (accountId !== undefined) {
85 |             registry.get(accountId)?.clear();
86 |             registry.delete(accountId);
87 |         }
88 |     } else {
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#306 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/core/chat-info-cache.js:21](#)

Dependency without integrity verification

```
19 | exports.getChatInfo = getChatInfo;
20 | exports.getChatTypeFeishu = getChatTypeFeishu;
21 | const lark_logger_1 = require("../lark-logger.js");
22 | let _LarkClient = null;
23 | /** @internal Called by lark-client.ts at module init time. */
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#307 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/core/comment-target.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
   2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates...
   3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#308 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/core/comment-target.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
   2 | /**
   3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#309 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/core/config-schema.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
   2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
   3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#310 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/core/config-schema.js:14](#)

Dangerous execution: Object.defineProperty(exports, "z", { enumerable: true, get: function () { retur

```
12 | exports.FEISHU_CONFIG_JSON_SCHEMA = exports.FeishuConfigSchema = exports.FeishuAccountConfigSchema =
    | exports.FeishuGroupSchema = exports.UATConfigSchema = exports.z = void 0;
13 | const zod_1 = require("zod");
> 14 | Object.defineProperty(exports, "z", { enumerable: true, get: function () { return zod_1.z; } });
    | // -----
15 | // Shared micro-schemas
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#311 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/core/config-schema.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
   2 | /**...
   3 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#312 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/core/device-flow.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
   2 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
   3 | * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#313 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[src/core/device-flow.js:33](#)

Potential secret: possible hardcoded secret

```
> 31 |         return {
   32 |             deviceAuthorization: 'https://accounts.feishu.cn/oauth/v1/device_authorization',
   33 |             token: 'https://open.feishu.cn/open-apis/authen/v2/oauth/token',
   34 |         };
   35 |     }
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#314 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[src/core/device-flow.js:39](#)

Potential secret: possible hardcoded secret

```
> 37 |         return {
   38 |             deviceAuthorization: 'https://accounts.larksuite.com/oauth/v1/device_authorization',
   39 |             token: 'https://open.larksuite.com/open-apis/authen/v2/oauth/token',
   40 |         };
   41 |     }
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#315 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/core/device-flow.js:20](#)

Dependency without integrity verification

```
18 | exports.requestDeviceAuthorization = requestDeviceAuthorization;
19 | exports.pollDeviceToken = pollDeviceToken;
> 20 | const lark_logger_1 = require("./lark-logger.js");
    21 | const log = (0, lark_logger_1.larkLogger)('core/device-flow');...
    22 | const feishu_fetch_1 = require("./feishu-fetch.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#316 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/core/device-flow.js:22](#)

Dependency without integrity verification

```
20 | const lark_logger_1 = require("./lark-logger.js");
21 | const log = (0, lark_logger_1.larkLogger)('core/device-flow');
> 22 | const feishu_fetch_1 = require("./feishu-fetch.js");
    23 | // -----
    24 | // Endpoint resolution
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#317 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/core/domains.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
    2 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
    3 | * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#318 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/core/domains.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
    2 | /**
    3 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#319 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/core/feishu-fetch.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
  2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates...
  3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#320 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/core/feishu-fetch.js:13](#)

Dependency without integrity verification

```
11 | Object.defineProperty(exports, "__esModule", { value: true });
12 | exports.feishuFetch = feishuFetch;
> 13 | const version_1 = require("./version.js");
14 | /**
15 |  * Drop-in replacement for `fetch()` that automatically injects
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#321 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/core/feishu-fetch.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
  2 | /**
  3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#322 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/core/footer-config.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
  2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
  3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#323 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/core/footer-config.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
   2 | /**...
   3 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#324 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/core/lark-client.js:17](#)

Dangerous execution: `var __createBinding = (this && this.__createBinding) || (Object.create ? (functi`

```
15 | */
16 | /* eslint-disable @typescript-eslint/no-explicit-any */
> 17 | var __createBinding = (this && this.__createBinding) || (Object.create ? (function(o, m, k, k2) {
18 |     if (k2 === undefined) k2 = k;
19 |     var desc = Object.getOwnPropertyDescriptor(m, k);
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#325 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/core/lark-client.js:21](#)

Dangerous execution: `desc = { enumerable: true, get: function() { return m[k]; } };`

```
19 |     var desc = Object.getOwnPropertyDescriptor(m, k);
20 |     if (!desc || ("get" in desc ? !m.__esModule : desc.writable || desc.configurable)) {
> 21 |         desc = { enumerable: true, get: function() { return m[k]; } };
22 |     }
23 |     Object.defineProperty(o, k2, desc);
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#326 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/core/lark-client.js:24](#)

Dangerous execution: `}} : (function(o, m, k, k2) {`

```
22 |     }
23 |     Object.defineProperty(o, k2, desc);
> 24 | }} : (function(o, m, k, k2) {
25 |     if (k2 === undefined) k2 = k;
26 |     o[k2] = m[k];
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#327 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/core/lark-client.js:28](#)

Dangerous execution: `var __setModuleDefault = (this && this.__setModuleDefault) || (Object.create ? (`

```
26 |         o[k2] = m[k];
27 |     });
> 28 |     var __setModuleDefault = (this && this.__setModuleDefault) || (Object.create ? (function(o, v) {
29 |         Object.defineProperty(o, "default", { enumerable: true, value: v });...
30 |     }) : function(o, v) {
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#328 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/core/lark-client.js:30](#)

Dangerous execution: `}) : function(o, v) {`

```
28 |     var __setModuleDefault = (this && this.__setModuleDefault) || (Object.create ? (function(o, v) {
29 |         Object.defineProperty(o, "default", { enumerable: true, value: v });
> 30 |     }) : function(o, v) {
31 |         o["default"] = v;
32 |     });
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#329 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/core/lark-client.js:33](#)

Dangerous execution: `var __importStar = (this && this.__importStar) || (function () {`

```
31 |         o["default"] = v;
32 |     });
> 33 |     var __importStar = (this && this.__importStar) || (function () {
34 |         var ownKeys = function(o) {
35 |             ownKeys = Object.getOwnPropertyNames || function (o) {
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#330 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/core/lark-client.js:34](#)

Dangerous execution: var ownKeys = function(o) {

```
32 | });
33 | var __importStar = (this && this.__importStar) || (function () {
> 34 |     var ownKeys = function(o) {
35 |         ownKeys = Object.getOwnPropertyNames || function (o) {...
36 |         var ar = [];
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#331 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/core/lark-client.js:35](#)

Dangerous execution: ownKeys = Object.getOwnPropertyNames || function (o) {

```
33 | var __importStar = (this && this.__importStar) || (function () {
34 |     var ownKeys = function(o) {
> 35 |         ownKeys = Object.getOwnPropertyNames || function (o) {
36 |             var ar = [];
37 |             for (var k in o) if (Object.prototype.hasOwnProperty.call(o, k)) ar[ar.length] = k;
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#332 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/core/lark-client.js:42](#)

Dangerous execution: return function (mod) {

```
40 |         return ownKeys(o);
41 |     };
> 42 |     return function (mod) {
43 |         if (mod && mod.__esModule) return mod;
44 |         var result = {};
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#333 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/core/lark-client.js:386](#)

High-risk permission pattern: cache.delete(this.accountId);

```
384 |     dispose() {
385 |         this.disconnect();
> 386 |         cache.delete(this.accountId);
387 |     }
388 |     // ---- Private helpers -----
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#334 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/core/lark-client.js:53](#)

Dependency without integrity verification

```
51 | exports.LarkClient = void 0;
52 | exports.getResolvedConfig = getResolvedConfig;
> 53 | const Lark = __importStar(require("@larksuiteoapi/node-sdk"));
54 | const user_name_cache_store_1 = require("../messaging/inbound/user-name-cache-store.js");...
55 | const accounts_1 = require("./accounts.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#335 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/core/lark-client.js:54](#)

Dependency without integrity verification

```
52 | exports.getResolvedConfig = getResolvedConfig;
53 | const Lark = __importStar(require("@larksuiteoapi/node-sdk"));
> 54 | const user_name_cache_store_1 = require("../messaging/inbound/user-name-cache-store.js");
55 | const accounts_1 = require("./accounts.js");
56 | const chat_info_cache_1 = require("./chat-info-cache.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#336 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/core/lark-client.js:55](#)

Dependency without integrity verification

```
53 | const Lark = __importStar(require("@larksuiteoapi/node-sdk"));
54 | const user_name_cache_store_1 = require("../messaging/inbound/user-name-cache-store.js");
> 55 | const accounts_1 = require("./accounts.js");
56 | const chat_info_cache_1 = require("./chat-info-cache.js");
57 | const lark_logger_1 = require("./lark-logger.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#337 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/core/lark-client.js:56](#)

Dependency without integrity verification

```
54 | const user_name_cache_store_1 = require("../messaging/inbound/user-name-cache-store.js");
55 | const accounts_1 = require("../accounts.js");
> 56 | const chat_info_cache_1 = require("../chat-info-cache.js");
    57 | const lark_logger_1 = require("../lark-logger.js");...
    58 | const runtime_store_1 = require("../runtime-store.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#338 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/core/lark-client.js:57](#)

Dependency without integrity verification

```
55 | const accounts_1 = require("../accounts.js");
56 | const chat_info_cache_1 = require("../chat-info-cache.js");
> 57 | const lark_logger_1 = require("../lark-logger.js");
    58 | const runtime_store_1 = require("../runtime-store.js");
    59 | const version_1 = require("../version.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#339 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/core/lark-client.js:58](#)

Dependency without integrity verification

```
56 | const chat_info_cache_1 = require("../chat-info-cache.js");
57 | const lark_logger_1 = require("../lark-logger.js");
> 58 | const runtime_store_1 = require("../runtime-store.js");
    59 | const version_1 = require("../version.js");
    60 | const log = (0, lark_logger_1.larkLogger)('core/lark-client');
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#340 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/core/lark-client.js:59](#)

Dependency without integrity verification

```
57 | const lark_logger_1 = require("../lark-logger.js");
58 | const runtime_store_1 = require("../runtime-store.js");
> 59 | const version_1 = require("../version.js");
    60 | const log = (0, lark_logger_1.larkLogger)('core/lark-client');
    61 | // -----
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#341 AS-005 -- INJECTION PATTERN

CRITICAL

OWASP: AA-02 | MITRE: T1055 | STRIDE: Tampering

Known prompt injection, SQL injection, XSS, or command injection patterns

[src/core/lark-logger.d.ts:16](#)

Known injection pattern detected

```
14 |  */
15 |  export interface LarkLogger {
16 |      readonly subsystem: string;
17 |      debug(message: string, meta?: Record<string, unknown>): void;...
18 |      info(message: string, meta?: Record<string, unknown>): void;
```

Remediation:

1. Validate and sanitize all inputs with strict allowlists. 2. Use parameterized queries for any database access (never string concatenation). 3. HTML-encode all agent output before rendering. 4. Implement content security policy (CSP) headers. 5. Block known injection patterns at the input boundary.

#342 AS-005 -- INJECTION PATTERN

CRITICAL

OWASP: AA-02 | MITRE: T1055 | STRIDE: Tampering

Known prompt injection, SQL injection, XSS, or command injection patterns

[src/core/lark-logger.d.ts:23](#)

Known injection pattern detected

```
21 |      child(name: string): LarkLogger;
22 |  }
23 |  export declare function larkLogger(subsystem: string): LarkLogger;
24 |
```

Remediation:

1. Validate and sanitize all inputs with strict allowlists. 2. Use parameterized queries for any database access (never string concatenation). 3. HTML-encode all agent output before rendering. 4. Implement content security policy (CSP) headers. 5. Block known injection patterns at the input boundary.

#343 AS-005 -- INJECTION PATTERN

CRITICAL

OWASP: AA-02 | MITRE: T1055 | STRIDE: Tampering

Known prompt injection, SQL injection, XSS, or command injection patterns

[src/core/lark-logger.js:49](#)

Known injection pattern detected

```
47 |      return null;
48 |      return runtime.logging.getChildLogger({
49 |          subsystem: `feishu/${subsystem}`,
50 |      });
51 |  }
```

Remediation:

1. Validate and sanitize all inputs with strict allowlists. 2. Use parameterized queries for any database access (never string concatenation). 3. HTML-encode all agent output before rendering. 4. Implement content security policy (CSP) headers. 5. Block known injection patterns at the input boundary.

#344 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/core/lark-logger.js:18](#)

Dependency without integrity verification

```
16 | Object.defineProperty(exports, "__esModule", { value: true });
17 | exports.larkLogger = larkLogger;
> 18 | const lark_ticket_1 = require("../lark-ticket.js");
19 | const runtime_store_1 = require("../runtime-store.js");...
20 | // -----
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#345 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/core/lark-logger.js:19](#)

Dependency without integrity verification

```
17 | exports.larkLogger = larkLogger;
18 | const lark_ticket_1 = require("../lark-ticket.js");
> 19 | const runtime_store_1 = require("../runtime-store.js");
20 | // -----
21 | // Console fallback (with ANSI colors)
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#346 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/core/lark-ticket.js:17](#)

Dependency without integrity verification

```
15 | exports.getTicket = getTicket;
16 | exports.ticketElapsed = ticketElapsed;
> 17 | const node_async_hooks_1 = require("node:async_hooks");
18 | // -----
19 | // Storage
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#347 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/core/message-unavailable.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#348 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/core/message-unavailable.js:31](#)

High-risk permission pattern: `unavailableMessageCache.delete(messageId);`

```
29 |     for (const [messageId, state] of unavailableMessageCache) {
30 |         if (nowMs - state.markedAtMs > UNAVAILABLE_CACHE_TTL_MS) {
31 |             unavailableMessageCache.delete(messageId);
32 |         }...
33 |     }
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#349 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/core/message-unavailable.js:59](#)

High-risk permission pattern: `unavailableMessageCache.delete(normalizedId);`

```
57 |     return undefined;
58 |     if (Date.now() - state.markedAtMs > UNAVAILABLE_CACHE_TTL_MS) {
59 |         unavailableMessageCache.delete(normalizedId);
60 |         return undefined;
61 |     }
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#350 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/core/message-unavailable.js:22](#)

Dependency without integrity verification

```
20 | exports.assertMessageAvailable = assertMessageAvailable;
21 | exports.runWithMessageUnavailableGuard = runWithMessageUnavailableGuard;
> 22 | const auth_errors_1 = require("./auth-errors.js");
23 | const api_error_1 = require("./api-error.js");
24 | const targets_1 = require("./targets.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use `>=` or `latest`. 3. Run `npm audit` / `pip-audit` in CI. 4. Use `pip install --require-hashes` for Python. 5. Verify package signatures where available.

#351 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/core/message-unavailable.js:23](#)

Dependency without integrity verification

```
21 | exports.runWithMessageUnavailableGuard = runWithMessageUnavailableGuard;
22 | const auth_errors_1 = require("./auth-errors.js");
> 23 | const api_error_1 = require("./api-error.js");
24 | const targets_1 = require("./targets.js");
25 | const UNAVAILABLE_CACHE_TTL_MS = 30 * 60 * 1000;
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#352 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/core/message-unavailable.js:24](#)

Dependency without integrity verification

```
22 | const auth_errors_1 = require("./auth-errors.js");
23 | const api_error_1 = require("./api-error.js");
> 24 | const targets_1 = require("./targets.js");
25 | const UNAVAILABLE_CACHE_TTL_MS = 30 * 60 * 1000;...
26 | const MAX_CACHE_SIZE_BEFORE_PRUNE = 512;
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#353 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/core/message-unavailable.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
  2 | /**
  3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#354 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/core/owner-policy.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
  2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
  3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#355 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/core/owner-policy.js:14](#)

Dependency without integrity verification

```
12 | exports.OwnerAccessDeniedError = void 0;  
13 | exports.assertOwnerAccessStrict = assertOwnerAccessStrict;  
> 14 | const app_owner_fallback_1 = require("./app-owner-fallback.js");  
15 | // -----  
16 | // Error class
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#356 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/core/owner-policy.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";  
2 | /**  
3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#357 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/core/permission-url.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**  
2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates  
3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#358 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/core/permission-url.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";  
2 | /**  
3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#359 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/core/raw-request.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
  2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates...
  3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#360 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/core/raw-request.js:14](#)

Dependency without integrity verification

```
12 | exports.resolveDomainUrl = resolveDomainUrl;
13 | exports.rawLarkRequest = rawLarkRequest;
> 14 | const feishu_fetch_1 = require("../feishu-fetch.js");
15 | // -----
16 | // Domain URL resolution
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#361 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/core/raw-request.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
  2 | /**
  3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#362 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/core/scope-manager.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
  2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
  3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#363 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/core/scope-manager.js:53](#)

Dangerous execution: Object.defineProperty(exports, "TOOL_SCOPES", { enumerable: true, get: function

```
51 | exports.getMissingUserScopes = getMissingUserScopes;
52 | const tool_scopes_1 = require("./tool-scopes.js");
> 53 | Object.defineProperty(exports, "TOOL_SCOPES", { enumerable: true, get: function () { return
    tool_scopes_1.TOOL_SCOPES; } });
54 | // ===== Q̇yeṗy Required Scopeṡy API – %*V,,gC-Ṗy =====
55 | /**
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#364 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/core/scope-manager.js:52](#)

Dependency without integrity verification

```
50 | exports.checkUserScopes = checkUserScopes;
51 | exports.getMissingUserScopes = getMissingUserScopes;
> 52 | const tool_scopes_1 = require("./tool-scopes.js");
53 | Object.defineProperty(exports, "TOOL_SCOPES", { enumerable: true, get: function () { return
    tool_scopes_1.TOOL_SCOPES; } });
54 | // ===== Q̇yeṗy Required Scopeṡy API – %*V,,gC-Ṗy =====
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#365 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/core/scope-manager.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
2 | /**
3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#366 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/core/sdk-compatible.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#367 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/core/sdk-compat.js:14](#)

Dangerous execution: Object.defineProperty(exports, "jsonResult", { enumerable: true, get: function (

```
12 | exports.readReactionParams = readReactionParams;
13 | var agent_runtime_1 = require("openclaw/plugin-sdk/agent-runtime");
> 14 | Object.defineProperty(exports, "jsonResult", { enumerable: true, get: function () { return
    agent_runtime_1.jsonResult; } });
15 | /**...
16 | * Extract reaction parameters from raw action params.
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#368 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/core/sdk-compat.js:13](#)

Dependency without integrity verification

```
11 | exports.jsonResult = void 0;
12 | exports.readReactionParams = readReactionParams;
> 13 | var agent_runtime_1 = require("openclaw/plugin-sdk/agent-runtime");
14 | Object.defineProperty(exports, "jsonResult", { enumerable: true, get: function () { return
    agent_runtime_1.jsonResult; } });
15 | /**
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#369 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/core/sdk-compat.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
  2 | /**
  3 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#370 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/core/shutdown-hooks.d.ts:7](#)

High-risk permission pattern: * @param cleanup - Async function to execute on shutdown.

```
5 | *  
> 6 | * @param key - Unique identifier for this hook (duplicate keys overwrite).  
7 | * @param cleanup - Async function to execute on shutdown.  
8 | * @returns An unregister function - call it when the resource is...  
9 | * released normally (e.g. card streaming completes).
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#371 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/core/shutdown-hooks.js:22](#)

High-risk permission pattern: * @param cleanup - Async function to execute on shutdown.

```
20 | *  
21 | * @param key - Unique identifier for this hook (duplicate keys overwrite).  
> 22 | * @param cleanup - Async function to execute on shutdown.  
23 | * @returns An unregister function - call it when the resource is  
24 | * released normally (e.g. card streaming completes).
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#372 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/core/shutdown-hooks.js:29](#)

High-risk permission pattern: hooks.delete(key);

```
27 |     hooks.set(key, cleanup);  
28 |     return () => {  
> 29 |         hooks.delete(key);  
30 |     };  
31 | }
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#373 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/core/targets.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**  
2 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates  
3 | * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#374 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/core/targets.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
   2 | /**...
   3 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#375 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/core/token-store.js:73](#)

High-risk permission pattern: // Delete first – `add-generic-password` fails if the item already exists.

```
71 |     },
72 |     async set(service, account, data) {
> 73 |         // Delete first – `add-generic-password` fails if the item already exists.
   74 |         try {
   75 |             await execFile('security', ['delete-generic-password', '-s', service, '-a', account]);
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#376 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/core/token-store.js:75](#)

High-risk permission pattern: await execFile('security', ['delete-generic-password', '-s', service, '-a', account])

```
73 |         // Delete first – `add-generic-password` fails if the item already exists.
74 |         try {
> 75 |             await execFile('security', ['delete-generic-password', '-s', service, '-a', account]);
   76 |         }
   77 |         catch {
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#377 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/core/token-store.js:84](#)

High-risk permission pattern: await execFile('security', ['delete-generic-password', '-s', service, '-a', account])

```
82 |         async remove(service, account) {
83 |             try {
> 84 |                 await execFile('security', ['delete-generic-password', '-s', service, '-a', account]);
   85 |             }
   86 |             catch {
```


Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#378 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/core/token-store.js:27](#)

Dependency without integrity verification

```
25 | exports.removeStoredToken = removeStoredToken;
26 | exports.tokenStatus = tokenStatus;
> 27 | const node_module_1 = require("node:module");
28 | const node_util_1 = require("node:util");...
29 | const promises_1 = require("node:fs/promises");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#379 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/core/token-store.js:28](#)

Dependency without integrity verification

```
26 | exports.tokenStatus = tokenStatus;
27 | const node_module_1 = require("node:module");
> 28 | const node_util_1 = require("node:util");
29 | const promises_1 = require("node:fs/promises");
30 | const node_path_1 = require("node:path");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#380 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/core/token-store.js:29](#)

Dependency without integrity verification

```
27 | const node_module_1 = require("node:module");
28 | const node_util_1 = require("node:util");
> 29 | const promises_1 = require("node:fs/promises");
30 | const node_path_1 = require("node:path");
31 | const node_os_1 = require("node:os");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#381 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/core/token-store.js:30](#)

Dependency without integrity verification

```
28 | const node_util_1 = require("node:util");
29 | const promises_1 = require("node:fs/promises");
> 30 | const node_path_1 = require("node:path");
    31 | const node_os_1 = require("node:os");...
    32 | const node_crypto_1 = require("node:crypto");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#382 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/core/token-store.js:31](#)

Dependency without integrity verification

```
29 | const promises_1 = require("node:fs/promises");
30 | const node_path_1 = require("node:path");
> 31 | const node_os_1 = require("node:os");
    32 | const node_crypto_1 = require("node:crypto");
    33 | const lark_logger_1 = require("../lark-logger.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#383 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/core/token-store.js:32](#)

Dependency without integrity verification

```
30 | const node_path_1 = require("node:path");
31 | const node_os_1 = require("node:os");
> 32 | const node_crypto_1 = require("node:crypto");
    33 | const lark_logger_1 = require("../lark-logger.js");
    34 | const log = (0, lark_logger_1.larkLogger)('core/token-store');
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#384 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/core/token-store.js:33](#)

Dependency without integrity verification

```
31 | const node_os_1 = require("node:os");
32 | const node_crypto_1 = require("node:crypto");
> 33 | const lark_logger_1 = require("../lark-logger.js");
    34 | const log = (0, lark_logger_1.larkLogger)('core/token-store');
    35 | // Dynamic require to avoid security scanner false positive (child-process).
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#385 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/core/token-store.js:39](#)

Dependency without integrity verification

```
37 | const _require = (0, node_module_1.createRequire)(typeof __filename !== 'undefined' ? __filename :
import.meta.url);
38 | const _cpMod = ['child', 'process'].join('_');
> 39 | const _cp = _require(`node:${_cpMod}`);
40 | const execFile = (0, node_util_1.promisify)(_cp.execFile);...
41 | // -----
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#386 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/core/tool-client.d.ts:61](#)

High-risk permission pattern: method?: 'GET' | 'POST' | 'PUT' | 'PATCH' | 'DELETE';

```
59 | /** invokeByPath() v„* ~y - W( InvokeOptions Wúx@N XŽR HTTP <÷lBSÂep0 */
60 | export type InvokeByPathOptions = InvokeOptions & {
> 61 |   method?: 'GET' | 'POST' | 'PUT' | 'PATCH' | 'DELETE';
62 |   body?: unknown;
63 |   query?: Record<string, string>;
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#387 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/core/tool-client.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
2 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
3 | * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#388 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/core/tool-client.js:31](#)

Dangerous execution: `var __createBinding = (this && this.__createBinding) || (Object.create ? (functi`

```
29 | * ` ` `
30 | */
> 31 | var __createBinding = (this && this.__createBinding) || (Object.create ? (function(o, m, k, k2) {
32 |     if (k2 === undefined) k2 = k;...
33 |     var desc = Object.getOwnPropertyDescriptor(m, k);
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#389 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/core/tool-client.js:35](#)

Dangerous execution: `desc = { enumerable: true, get: function() { return m[k]; } };`

```
33 |     var desc = Object.getOwnPropertyDescriptor(m, k);
34 |     if (!desc || ("get" in desc ? !m.__esModule : desc.writable || desc.configurable)) {
> 35 |         desc = { enumerable: true, get: function() { return m[k]; } };
36 |     }
37 |     Object.defineProperty(o, k2, desc);
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#390 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/core/tool-client.js:38](#)

Dangerous execution: `}} : (function(o, m, k, k2) {`

```
36 |     }
37 |     Object.defineProperty(o, k2, desc);
> 38 | }} : (function(o, m, k, k2) {
39 |     if (k2 === undefined) k2 = k;
40 |     o[k2] = m[k];
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#391 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/core/tool-client.js:42](#)

Dangerous execution: `var __setModuleDefault = (this && this.__setModuleDefault) || (Object.create ? (`

```
40 |     o[k2] = m[k];
41 | }));
> 42 | var __setModuleDefault = (this && this.__setModuleDefault) || (Object.create ? (function(o, v) {
43 |     Object.defineProperty(o, "default", { enumerable: true, value: v });
44 | }) : function(o, v) {
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#392 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/core/tool-client.js:44](#)

Dangerous execution: `}} : function(o, v) {`

```
42 | var __setModuleDefault = (this && this.__setModuleDefault) || (Object.create ? (function(o, v) {
43 |   Object.defineProperty(o, "default", { enumerable: true, value: v });
44 | }) : function(o, v) {
45 |   o["default"] = v;...
46 | });
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#393 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/core/tool-client.js:47](#)

Dangerous execution: `var __importStar = (this && this.__importStar) || (function () {`

```
45 |   o["default"] = v;
46 | });
47 | var __importStar = (this && this.__importStar) || (function () {
48 |   var ownKeys = function(o) {
49 |     ownKeys = Object.getOwnPropertyNames || function (o) {
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#394 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/core/tool-client.js:48](#)

Dangerous execution: `var ownKeys = function(o) {`

```
46 | });
47 | var __importStar = (this && this.__importStar) || (function () {
48 |   var ownKeys = function(o) {
49 |     ownKeys = Object.getOwnPropertyNames || function (o) {
50 |       var ar = [];
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#395 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/core/tool-client.js:49](#)

Dangerous execution: `ownKeys = Object.getOwnPropertyNames || function (o) {`

```
47 | var __importStar = (this && this.__importStar) || (function () {
48 |     var ownKeys = function(o) {
49 |         ownKeys = Object.getOwnPropertyNames || function (o) {
50 |             var ar = [];...
51 |             for (var k in o) if (Object.prototype.hasOwnProperty.call(o, k)) ar[ar.length] = k;
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#396 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/core/tool-client.js:56](#)

Dangerous execution: `return function (mod) {`

```
54 |         return ownKeys(o);
55 |     };
56 |     return function (mod) {
57 |         if (mod && mod.__esModule) return mod;
58 |         var result = {};
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#397 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/core/tool-client.js:80](#)

Dangerous execution: `Object.defineProperty(exports, "AppScopeCheckFailedError", { enumerable: true, get`

```
78 | const owner_policy_1 = require("./owner-policy.js");
79 | const auth_errors_1 = require("./auth-errors.js");
80 | Object.defineProperty(exports, "AppScopeCheckFailedError", { enumerable: true, get: function ()
{ return auth_errors_1.AppScopeCheckFailedError; } });
81 | Object.defineProperty(exports, "AppScopeMissingError", { enumerable: true, get: function () { return
auth_errors_1.AppScopeMissingError; } });
82 | Object.defineProperty(exports, "LARK_ERROR", { enumerable: true, get: function () { return
auth_errors_1.LARK_ERROR; } });
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#398 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/core/tool-client.js:81](#)

Dangerous execution: `Object.defineProperty(exports, "AppScopeMissingError", { enumerable: true, get:`

```
79 | const auth_errors_1 = require("./auth-errors.js");
80 | Object.defineProperty(exports, "AppScopeCheckFailedError", { enumerable: true, get: function ()
{ return auth_errors_1.AppScopeCheckFailedError; } });
81 | Object.defineProperty(exports, "AppScopeMissingError", { enumerable: true, get: function () { return
auth_errors_1.AppScopeMissingError; } });
82 | Object.defineProperty(exports, "LARK_ERROR", { enumerable: true, get: function () { return
auth_errors_1.LARK_ERROR; } });
83 | Object.defineProperty(exports, "NeedAuthorizationError", { enumerable: true, get: function ()
{ return auth_errors_1.NeedAuthorizationError; } });
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#399 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/core/tool-client.js:82](#)

Dangerous execution: `Object.defineProperty(exports, "LARK_ERROR", { enumerable: true, get: function (`

```
80 | Object.defineProperty(exports, "AppScopeCheckFailedError", { enumerable: true, get: function ()
{ return auth_errors_1.AppScopeCheckFailedError; } });
81 | Object.defineProperty(exports, "AppScopeMissingError", { enumerable: true, get: function () { return
auth_errors_1.AppScopeMissingError; } });
> 82 | Object.defineProperty(exports, "LARK_ERROR", { enumerable: true, get: function () { return
auth_errors_1.LARK_ERROR; } });
83 | Object.defineProperty(exports, "NeedAuthorizationError", { enumerable: true, get: function ()
{ return auth_errors_1.NeedAuthorizationError; } });
84 | Object.defineProperty(exports, "UserAuthRequiredError", { enumerable: true, get: function ()
{ return auth_errors_1.UserAuthRequiredError; } });
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#400 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/core/tool-client.js:83](#)

Dangerous execution: `Object.defineProperty(exports, "NeedAuthorizationError", { enumerable: true, get`

```
81 | Object.defineProperty(exports, "AppScopeMissingError", { enumerable: true, get: function () { return
auth_errors_1.AppScopeMissingError; } });
82 | Object.defineProperty(exports, "LARK_ERROR", { enumerable: true, get: function () { return
auth_errors_1.LARK_ERROR; } });
> 83 | Object.defineProperty(exports, "NeedAuthorizationError", { enumerable: true, get: function ()
{ return auth_errors_1.NeedAuthorizationError; } });
84 | Object.defineProperty(exports, "UserAuthRequiredError", { enumerable: true, get: function ()
{ return auth_errors_1.UserAuthRequiredError; } });
85 | Object.defineProperty(exports, "UserScopeInsufficientError", { enumerable: true, get: function ()
{ return auth_errors_1.UserScopeInsufficientError; } });
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#401 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/core/tool-client.js:84](#)

Dangerous execution: `Object.defineProperty(exports, "UserAuthRequiredError", { enumerable: true, get:`

```
82 | Object.defineProperty(exports, "LARK_ERROR", { enumerable: true, get: function () { return
auth_errors_1.LARK_ERROR; } });
83 | Object.defineProperty(exports, "NeedAuthorizationError", { enumerable: true, get: function ()
{ return auth_errors_1.NeedAuthorizationError; } });
> 84 | Object.defineProperty(exports, "UserAuthRequiredError", { enumerable: true, get: function ()
{ return auth_errors_1.UserAuthRequiredError; } });
85 | Object.defineProperty(exports, "UserScopeInsufficientError", { enumerable: true, get: function ()
{ return auth_errors_1.UserScopeInsufficientError; } });
86 | const tcLog = (0, lark_logger_1.larkLogger)('core/tool-client');
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#402 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/core/tool-client.js:85](#)

Dangerous execution: `Object.defineProperty(exports, "UserScopeInsufficientError", { enumerable: true,`

```
83 | Object.defineProperty(exports, "NeedAuthorizationError", { enumerable: true, get: function ()
{ return auth_errors_1.NeedAuthorizationError; } });
84 | Object.defineProperty(exports, "UserAuthRequiredError", { enumerable: true, get: function ()
{ return auth_errors_1.UserAuthRequiredError; } });
> 85 | Object.defineProperty(exports, "UserScopeInsufficientError", { enumerable: true, get: function ()
{ return auth_errors_1.UserScopeInsufficientError; } });
86 | const tcLog = (0, lark_logger_1.larkLogger)('core/tool-client');...
87 | // -----
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#403 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/core/tool-client.js:67](#)

Dependency without integrity verification

```
65 | exports.ToolClient = exports.UserScopeInsufficientError = exports.UserAuthRequiredError =
exports.AppScopeMissingError = exports.AppScopeCheckFailedError = exports.NeedAuthorizationError =
exports.LARK_ERROR = void 0;
66 | exports.createToolClient = createToolClient;
> 67 | const Lark = __importStar(require("@larksuiteoapi/node-sdk"));
68 | const accounts_1 = require("./accounts.js");
69 | const lark_client_1 = require("./lark-client.js");
```

Remediation:

1. Use lockfiles (`package-lock.json`, `poetry.lock`, `requirements.txt` with hashes). 2. Pin exact dependency versions — never use `>=` or `latest`. 3. Run `npm audit` / `pip-audit` in CI. 4. Use `pip install --require-hashes` for Python. 5. Verify package signatures where available.

#404 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/core/tool-client.js:68](#)

Dependency without integrity verification

```
66 | exports.createToolClient = createToolClient;
67 | const Lark = __importStar(require("@larksuiteoapi/node-sdk"));
> 68 | const accounts_1 = require("./accounts.js");
69 | const lark_client_1 = require("./lark-client.js");
70 | const lark_ticket_1 = require("./lark-ticket.js");
```

Remediation:

1. Use lockfiles (`package-lock.json`, `poetry.lock`, `requirements.txt` with hashes). 2. Pin exact dependency versions — never use `>=` or `latest`. 3. Run `npm audit` / `pip-audit` in CI. 4. Use `pip install --require-hashes` for Python. 5. Verify package signatures where available.

#405 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/core/tool-client.js:69](#)

Dependency without integrity verification

```
67 | const Lark = __importStar(require("@larksuiteoapi/node-sdk"));
68 | const accounts_1 = require("./accounts.js");
> 69 | const lark_client_1 = require("./lark-client.js");
70 | const lark_ticket_1 = require("./lark-ticket.js");...
71 | const uat_client_1 = require("./uat-client.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#406 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/core/tool-client.js:70](#)

Dependency without integrity verification

```
68 | const accounts_1 = require("./accounts.js");
69 | const lark_client_1 = require("./lark-client.js");
> 70 | const lark_ticket_1 = require("./lark-ticket.js");
71 | const uat_client_1 = require("./uat-client.js");
72 | const token_store_1 = require("./token-store.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#407 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/core/tool-client.js:71](#)

Dependency without integrity verification

```
69 | const lark_client_1 = require("./lark-client.js");
70 | const lark_ticket_1 = require("./lark-ticket.js");
> 71 | const uat_client_1 = require("./uat-client.js");
72 | const token_store_1 = require("./token-store.js");
73 | const app_scope_checker_1 = require("./app-scope-checker.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#408 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/core/tool-client.js:72](#)

Dependency without integrity verification

```
70 | const lark_ticket_1 = require("./lark-ticket.js");
71 | const uat_client_1 = require("./uat-client.js");
> 72 | const token_store_1 = require("./token-store.js");
73 | const app_scope_checker_1 = require("./app-scope-checker.js");
74 | const app_owner_fallback_1 = require("./app-owner-fallback.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#409 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/core/tool-client.js:73](#)

Dependency without integrity verification

```
71 | const uat_client_1 = require("./uat-client.js");
72 | const token_store_1 = require("./token-store.js");
> 73 | const app_scope_checker_1 = require("./app-scope-checker.js");
74 | const app_owner_fallback_1 = require("./app-owner-fallback.js");...
75 | const lark_logger_1 = require("./lark-logger.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#410 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/core/tool-client.js:74](#)

Dependency without integrity verification

```
72 | const token_store_1 = require("./token-store.js");
73 | const app_scope_checker_1 = require("./app-scope-checker.js");
> 74 | const app_owner_fallback_1 = require("./app-owner-fallback.js");
75 | const lark_logger_1 = require("./lark-logger.js");
76 | const scope_manager_1 = require("./scope-manager.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#411 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/core/tool-client.js:75](#)

Dependency without integrity verification

```
73 | const app_scope_checker_1 = require("./app-scope-checker.js");
74 | const app_owner_fallback_1 = require("./app-owner-fallback.js");
> 75 | const lark_logger_1 = require("./lark-logger.js");
76 | const scope_manager_1 = require("./scope-manager.js");
77 | const raw_request_1 = require("./raw-request.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#412 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/core/tool-client.js:76](#)

Dependency without integrity verification

```
74 | const app_owner_fallback_1 = require("./app-owner-fallback.js");
75 | const lark_logger_1 = require("./lark-logger.js");
> 76 | const scope_manager_1 = require("./scope-manager.js");
77 | const raw_request_1 = require("./raw-request.js");...
78 | const owner_policy_1 = require("./owner-policy.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#413 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/core/tool-client.js:77](#)

Dependency without integrity verification

```
75 | const lark_logger_1 = require("./lark-logger.js");
76 | const scope_manager_1 = require("./scope-manager.js");
> 77 | const raw_request_1 = require("./raw-request.js");
78 | const owner_policy_1 = require("./owner-policy.js");
79 | const auth_errors_1 = require("./auth-errors.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#414 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/core/tool-client.js:78](#)

Dependency without integrity verification

```
76 | const scope_manager_1 = require("./scope-manager.js");
77 | const raw_request_1 = require("./raw-request.js");
> 78 | const owner_policy_1 = require("./owner-policy.js");
79 | const auth_errors_1 = require("./auth-errors.js");
80 | Object.defineProperty(exports, "AppScopeCheckFailedError", { enumerable: true, get: function ()
{ return auth_errors_1.AppScopeCheckFailedError; } });
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#415 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/core/tool-client.js:79](#)

Dependency without integrity verification

```
77 | const raw_request_1 = require("./raw-request.js");
78 | const owner_policy_1 = require("./owner-policy.js");
> 79 | const auth_errors_1 = require("./auth-errors.js");
80 | Object.defineProperty(exports, "AppScopeCheckFailedError", { enumerable: true, get: function ()
{ return auth_errors_1.AppScopeCheckFailedError; } });
81 | Object.defineProperty(exports, "AppScopeMissingError", { enumerable: true, get: function () { return
auth_errors_1.AppScopeMissingError; } });
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#416 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/core/tool-scopes.d.ts:56](#)

High-risk permission pattern: export type ToolActionKey = 'feishu_bitable_app.copy' | 'feishu_bitable_app.crea

```
54 | * `;<iÿ 96 N*]âQwR`0\`  
55 | */  
> 56 | export type ToolActionKey = 'feishu_bitable_app.copy' | 'feishu_bitable_app.create' |  
'feishu_bitable_app.get' | 'feishu_bitable_app.list' | 'feishu_bitable_app.patch' |  
'feishu_bitable_app_table.batch_create' | 'feishu_bitable_app_table.create' | 'feishu_bitable_app_table.list'  
| 'feishu_bitable_app_table.patch' | 'feishu_bitable_app_table_field.create' |  
'feishu_bitable_app_table_field.delete' | 'feishu_bitable_app_table_field.list' |  
'feishu_bitable_app_table_field.update' | 'feishu_bitable_app_table_record.batch_create' |  
'feishu_bitable_app_table_record.batch_delete' | 'feishu_bitable_app_table_record.batch_update' |  
'feishu_bitable_app_table_record.create' | 'feishu_bitable_app_table_record.delete' |  
'feishu_bitable_app_table_record.list' | 'feishu_bitable_app_table_record.update' |  
'feishu_bitable_app_table_view.create' | 'feishu_bitable_app_table_view.get' |  
'feishu_bitable_app_table_view.list' | 'feishu_bitable_app_table_view.patch' | 'feishu_calendar_calendar.get'  
| 'feishu_calendar_calendar.list' | 'feishu_calendar_calendar.primary' | 'feishu_calendar_event.create' | ...
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#417 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/core/tool-scopes.d.ts:120](#)

High-risk permission pattern: * - space:document:delete - R -dN'eþhc

```
118 | * gC-P<ôf ÿ  
119 | * - im:message.send_as_user - Nâu(b7Ž«NýSÑ• m`öÿ š0~ĩ-iÿ Siëý^«nâu(SÑ• ""æ|b WfW>m`öÿ  
> 120 | * - space:document:delete - R -dN'eþhc  
121 | * - calendar:calendar.event:delete - R -deâz  
122 | * - base:table:delete - R -dY ~ô`hh<epcn`h
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#418 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/core/tool-scopes.d.ts:121](#)

High-risk permission pattern: * - calendar:calendar.event:delete - R -deâz

```
119 | * - im:message.send_as_user - Nâu(b7Ž«NýSÑ• m`öÿ š0~ĩ-iÿ Siëý^«nâu(SÑ• ""æ|b WfW>m`öÿ  
> 120 | * - space:document:delete - R -dN'eþhc  
121 | * - calendar:calendar.event:delete - R -deâz  
122 | * - base:table:delete - R -dY ~ô`hh<epcn`h  
123 | *
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#419 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/core/tool-scopes.d.ts:122](#)

High-risk permission pattern: * - base:table:delete - R -dY ~ô^hh<epcn^h

```
120 | * - space:document:delete - R -dN'e±hc
121 | * - calendar:calendar.event:delete - R -deâz
> 122 | * - base:table:delete - R -dY ~ô^hh<epcn^h
123 | ...
124 | * 0•u(W:foÿ
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#420 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/core/tool-scopes.d.ts:130](#)

High-risk permission pattern: export declare const SENSITIVE_SCOPES: readonly ["im:message.send_as_user", "spa

```
128 | * g T fôe°: 2026-03-17
129 | */
> 130 | export declare const SENSITIVE_SCOPES: readonly ["im:message.send_as_user", "space:document:delete",
    | "calendar:calendar.event:delete", "base:table:delete"];
131 | /**
132 | * š0e0a gC-P|{W<
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#421 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/core/tool-scopes.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
  2 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
  3 | * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#422 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/core/tool-scopes.js:82](#)

High-risk permission pattern: 'feishu_bitable_app_table_record.delete': ['base:record:delete'],

```
80 | 'feishu_bitable_app_table_record.create': ['base:record:create'],
81 | 'feishu_bitable_app_table_record.update': ['base:record:update'],
> 82 | 'feishu_bitable_app_table_record.delete': ['base:record:delete'],
83 | 'feishu_bitable_app_table_record.batch_create': ['base:record:create'],
84 | 'feishu_bitable_app_table_record.batch_update': ['base:record:update'],
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#423 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/core/tool-scopes.js:85](#)

High-risk permission pattern: **'feishu_bitable_app_table_record.batch_delete': ['base:record:delete'],**

```
83 |     'feishu_bitable_app_table_record.batch_create': ['base:record:create'],
84 |     'feishu_bitable_app_table_record.batch_update': ['base:record:update'],
> 85 |     'feishu_bitable_app_table_record.batch_delete': ['base:record:delete'],
86 |     'feishu_bitable_app_table_record.list': ['base:record:retrieve'],...
87 |     'feishu_bitable_app_table_field.create': ['base:field:create'],
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#424 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/core/tool-scopes.js:90](#)

High-risk permission pattern: **'feishu_bitable_app_table_field.delete': ['base:field:delete'],**

```
88 |     'feishu_bitable_app_table_field.list': ['base:field:read'],
89 |     'feishu_bitable_app_table_field.update': ['base:field:read', 'base:field:update'],
> 90 |     'feishu_bitable_app_table_field.delete': ['base:field:delete'],
91 |     'feishu_bitable_app_table_view.create': ['base:view:write_only'],
92 |     'feishu_bitable_app_table_view.get': ['base:view:read'],
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#425 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/core/tool-scopes.js:102](#)

High-risk permission pattern: **'feishu_calendar_event.delete': ['calendar:calendar.event:delete'],**

```
100 |     'feishu_calendar_event.get': ['calendar:calendar.event:read'],
101 |     'feishu_calendar_event.patch': ['calendar:calendar.event:update'],
> 102 |     'feishu_calendar_event.delete': ['calendar:calendar.event:delete'],
103 |     'feishu_calendar_event.search': ['calendar:calendar.event:read'],
104 |     'feishu_calendar_event.reply': ['calendar:calendar.event:reply'],
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#426 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/core/tool-scopes.js:137](#)

High-risk permission pattern: 'feishu_drive_file.delete': ['space:document:delete'],

```
135 |     'feishu_drive_file.copy': ['docs:document:copy'],
136 |     'feishu_drive_file.move': ['space:document:move'],
> 137 |     'feishu_drive_file.delete': ['space:document:delete'],
138 |     'feishu_drive_file.upload': ['drive:file:upload'],...
139 |     'feishu_drive_file.download': ['drive:file:download'],
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#427 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/core/tool-scopes.js:298](#)

High-risk permission pattern: * - space:document:delete - R -dN'eþhc

```
296 | * gC-P<ôf ÿ
297 | * - im:message.send_as_user - Nâu(b7Ž«NýSÑ• m`öy š0~î-iy Siëý^«nâu(SÑ• ""æ|b WfW>m``öy
> 298 | * - space:document:delete - R -dN'eþhc
299 | * - calendar:calendar.event:delete - R -deâz
300 | * - base:table:delete - R -dY ~ô`hh<epcn`h
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#428 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/core/tool-scopes.js:299](#)

High-risk permission pattern: * - calendar:calendar.event:delete - R -deâz

```
297 | * - im:message.send_as_user - Nâu(b7Ž«NýSÑ• m`öy š0~î-iy Siëý^«nâu(SÑ• ""æ|b WfW>m``öy
298 | * - space:document:delete - R -dN'eþhc
> 299 | * - calendar:calendar.event:delete - R -deâz
300 | * - base:table:delete - R -dY ~ô`hh<epcn`h
301 | *
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#429 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/core/tool-scopes.js:300](#)

High-risk permission pattern: * - base:table:delete - R -dY ~ô`hh<epcn`h

```
298 | * - space:document:delete - R -dN'eþhc
299 | * - calendar:calendar.event:delete - R -deâz
> 300 | * - base:table:delete - R -dY ~ô`hh<epcn`h
301 | *
302 | * O•u(W:foÿ
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#430 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/core/tool-scopes.js:310](#)

High-risk permission pattern: 'space:document:delete',

```
308 | exports.SENSITIVE_SCOPES = [  
309 |   'im:message.send_as_user',  
> 310 |   'space:document:delete',  
311 |   'calendar:calendar.event:delete', ...  
312 |   'base:table:delete',
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#431 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/core/tool-scopes.js:311](#)

High-risk permission pattern: 'calendar:calendar.event:delete',

```
309 |   'im:message.send_as_user',  
310 |   'space:document:delete',  
> 311 |   'calendar:calendar.event:delete',  
312 |   'base:table:delete',  
313 | ];
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#432 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/core/tool-scopes.js:312](#)

High-risk permission pattern: 'base:table:delete',

```
310 |   'space:document:delete',  
311 |   'calendar:calendar.event:delete',  
> 312 |   'base:table:delete',  
313 | ];  
314 | /**
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#433 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/core/tool-scopes.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
  2 | /**...
  3 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#434 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/core/tools-config.d.ts:18](#)

High-risk permission pattern: * permissions is a privileged operation that admins should opt into

```
> 16 | * By default every non-destructive capability is enabled. The `perm` flag
  17 | * (permission management) defaults to `false` because granting / revoking
  18 | * permissions is a privileged operation that admins should opt into
  19 | * explicitly.
  20 | */
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#435 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/core/tools-config.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
  2 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
  3 | * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#436 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/core/tools-config.js:25](#)

High-risk permission pattern: * permissions is a privileged operation that admins should opt into

```
> 23 | * By default every non-destructive capability is enabled. The `perm` flag
  24 | * (permission management) defaults to `false` because granting / revoking
  25 | * permissions is a privileged operation that admins should opt into
  26 | * explicitly.
  27 | */
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#437 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/core/tools-config.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
   2 | /**...
   3 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#438 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/core/types.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
   2 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
   3 | * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#439 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/core/types.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
   2 | /**
   3 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#440 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/core/uat-client.d.ts:40](#)

High-risk permission pattern: * Execute an API call with a valid UAT, retrying once on token-expiry errors.

```
38 | export declare function getValidAccessToken(opts: UATCallOptions): Promise<string>;
39 | /**
> 40 | * Execute an API call with a valid UAT, retrying once on token-expiry errors.
41 | */
42 | export declare function callWithUAT<T>(opts: UATCallOptions, apiCall: (accessToken: string) =>
Promise<T>): Promise<T>;
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#441 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/core/uat-client.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
  2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates...
  3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#442 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/core/uat-client.js:23](#)

Dangerous execution: Object.defineProperty(exports, "NeedAuthorizationError", { enumerable: true, get

```
21 | const feishu_fetch_1 = require("./feishu-fetch.js");
22 | const auth_errors_1 = require("./auth-errors.js");
> 23 | Object.defineProperty(exports, "NeedAuthorizationError", { enumerable: true, get: function ()
    |   { return auth_errors_1.NeedAuthorizationError; } });
24 | // -----
25 | // Per-user refresh lock
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#443 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/core/uat-client.js:125](#)

High-risk permission pattern: refreshLocks.delete(key);

```
123 |     }
124 |     finally {
> 125 |         refreshLocks.delete(key);
    |     }
126 | }
127 | }
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#444 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/core/uat-client.js:162](#)

High-risk permission pattern: * Execute an API call with a valid UAT, retrying once on token-expiry errors.

```
160 | }
161 | /**
> 162 |  * Execute an API call with a valid UAT, retrying once on token-expiry errors.
    |  */
163 |
164 | async function callWithUAT(opts, apiCall) {
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#445 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/core/version.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
  2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates...
  3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#446 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/core/version.js:14](#)

Dependency without integrity verification

```
12 | exports.getPlatform = getPlatform;
13 | exports.getUserAgent = getUserAgent;
> 14 | const node_url_1 = require("node:url");
15 | const node_path_1 = require("node:path");
16 | const node_fs_1 = require("node:fs");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#447 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/core/version.js:15](#)

Dependency without integrity verification

```
13 | exports.getUserAgent = getUserAgent;
14 | const node_url_1 = require("node:url");
> 15 | const node_path_1 = require("node:path");
16 | const node_fs_1 = require("node:fs");
17 | /** * [Xv,rHg,S÷ */
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#448 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/core/version.js:16](#)

Dependency without integrity verification

```
14 | const node_url_1 = require("node:url");
15 | const node_path_1 = require("node:path");
> 16 | const node_fs_1 = require("node:fs");
    17 | /** * [Xv,rHg,S÷ */...
    18 | let cachedVersion;
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#449 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/core/version.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
  2 | /**
  3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#450 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/converters/audio.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
  2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
  3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#451 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/converters/audio.js:10](#)

Dependency without integrity verification

```
8 | Object.defineProperty(exports, "__esModule", { value: true });
9 | exports.convertAudio = void 0;
> 10 | const utils_1 = require("./utils.js");
    11 | const convertAudio = (raw) => {
    12 |     const parsed = (0, utils_1.safeParse)(raw);
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#452 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/converters/audio.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
   2 | /**...
   3 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#453 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/converters/calendar.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
   2 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
   3 | * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#454 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/converters/calendar.js:13](#)

Dependency without integrity verification

```
11 | Object.defineProperty(exports, "__esModule", { value: true });
12 | exports.convertGeneralCalendar = exports.convertCalendar = exports.convertShareCalendarEvent = void
0;
> 13 | const utils_1 = require("./utils.js");
   14 | function formatCalendarContent(parsed) {
   15 |     const summary = parsed?.summary ?? '';

```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#455 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/converters/calendar.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
   2 | /**...
   3 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#456 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/converters/content-converter-helpers.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
    2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates...
    3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#457 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/converters/content-converter-helpers.js:12](#)

Dependency without integrity verification

```
10 | exports.buildConvertContextFromItem = buildConvertContextFromItem;
11 | exports.resolveMentions = resolveMentions;
> 12 | const user_name_cache_1 = require("../inbound/user-name-cache.js");
    13 | const utils_1 = require("./utils.js");
    14 | /** NÎ mention v,, id [WkµcÐSÖ open_idý Q|[^N<Nöc"• v,,[ù€ah<_ T€ API TÍ^"v,,[W{&N2h<_ ý */
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#458 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/converters/content-converter-helpers.js:13](#)

Dependency without integrity verification

```
11 | exports.resolveMentions = resolveMentions;
12 | const user_name_cache_1 = require("../inbound/user-name-cache.js");
> 13 | const utils_1 = require("./utils.js");
    14 | /** NÎ mention v,, id [WkµcÐSÖ open_idý Q|[^N<Nöc"• v,,[ù€ah<_ T€ API TÍ^"v,,[W{&N2h<_ ý */
    15 | function extractMentionOpenId(id) {
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#459 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/converters/content-converter-helpers.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
    2 | /**
    3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#460 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/converters/content-converter.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
 2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates...
 3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#461 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/messaging/converters/content-converter.js:20](#)

Dangerous execution: Object.defineProperty(exports, "buildConvertContextFromItem", { enumerable: true

```
18 | const index_1 = require("./index.js");
19 | var content_converter_helpers_1 = require("./content-converter-helpers.js");
> 20 | Object.defineProperty(exports, "buildConvertContextFromItem", { enumerable: true, get: function ()
{ return content_converter_helpers_1.buildConvertContextFromItem; } });
21 | Object.defineProperty(exports, "extractMentionOpenId", { enumerable: true, get: function () { return
content_converter_helpers_1.extractMentionOpenId; } });
22 | Object.defineProperty(exports, "resolveMentions", { enumerable: true, get: function () { return
content_converter_helpers_1.resolveMentions; } });
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#462 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/messaging/converters/content-converter.js:21](#)

Dangerous execution: Object.defineProperty(exports, "extractMentionOpenId", { enumerable: true, get:

```
19 | var content_converter_helpers_1 = require("./content-converter-helpers.js");
20 | Object.defineProperty(exports, "buildConvertContextFromItem", { enumerable: true, get: function ()
{ return content_converter_helpers_1.buildConvertContextFromItem; } });
> 21 | Object.defineProperty(exports, "extractMentionOpenId", { enumerable: true, get: function () { return
content_converter_helpers_1.extractMentionOpenId; } });
22 | Object.defineProperty(exports, "resolveMentions", { enumerable: true, get: function () { return
content_converter_helpers_1.resolveMentions; } });
23 | // -----
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#463 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/messaging/converters/content-converter.js:22](#)

Dangerous execution: `Object.defineProperty(exports, "resolveMentions", { enumerable: true, get: funct`

```
20 | Object.defineProperty(exports, "buildConvertContextFromItem", { enumerable: true, get: function ()
{ return content_converter_helpers_1.buildConvertContextFromItem; } });
21 | Object.defineProperty(exports, "extractMentionOpenId", { enumerable: true, get: function () { return
content_converter_helpers_1.extractMentionOpenId; } });
> 22 | Object.defineProperty(exports, "resolveMentions", { enumerable: true, get: function () { return
content_converter_helpers_1.resolveMentions; } });
23 | // -----
24 | // Convert
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#464 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/converters/content-converter.js:18](#)

Dependency without integrity verification

```
16 | exports.resolveMentions = exports.extractMentionOpenId = exports.buildConvertContextFromItem = void
0;
17 | exports.convertMessageContent = convertMessageContent;
> 18 | const index_1 = require("./index.js");
19 | var content_converter_helpers_1 = require("./content-converter-helpers.js");
20 | Object.defineProperty(exports, "buildConvertContextFromItem", { enumerable: true, get: function ()
{ return content_converter_helpers_1.buildConvertContextFromItem; } });
```

Remediation:

1. Use lockfiles (`package-lock.json`, `poetry.lock`, `requirements.txt` with hashes). 2. Pin exact dependency versions — never use `>=` or `latest`. 3. Run `npm audit` / `pip-audit` in CI. 4. Use `pip install --require-hashes` for Python. 5. Verify package signatures where available.

#465 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/converters/content-converter.js:19](#)

Dependency without integrity verification

```
17 | exports.convertMessageContent = convertMessageContent;
18 | const index_1 = require("./index.js");
> 19 | var content_converter_helpers_1 = require("./content-converter-helpers.js");
20 | Object.defineProperty(exports, "buildConvertContextFromItem", { enumerable: true, get: function ()
{ return content_converter_helpers_1.buildConvertContextFromItem; } });
21 | Object.defineProperty(exports, "extractMentionOpenId", { enumerable: true, get: function () { return
content_converter_helpers_1.extractMentionOpenId; } });
```

Remediation:

1. Use lockfiles (`package-lock.json`, `poetry.lock`, `requirements.txt` with hashes). 2. Pin exact dependency versions — never use `>=` or `latest`. 3. Run `npm audit` / `pip-audit` in CI. 4. Use `pip install --require-hashes` for Python. 5. Verify package signatures where available.

#466 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/converters/content-converter.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
  2 | /**...
  3 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#467 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/converters/file.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
  2 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
  3 | * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#468 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/converters/file.js:10](#)

Dependency without integrity verification

```
8 | Object.defineProperty(exports, "__esModule", { value: true });
9 | exports.convertFile = void 0;
> 10 | const utils_1 = require("./utils.js");
    11 | const convertFile = (raw) => {
    12 |     const parsed = (0, utils_1.safeParse)(raw);
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#469 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/converters/file.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
  2 | /**
  3 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#470 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/converters/folder.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
  2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates...
  3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#471 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/converters/folder.js:10](#)

Dependency without integrity verification

```
8 | Object.defineProperty(exports, "__esModule", { value: true });
9 | exports.convertFolder = void 0;
> 10 | const utils_1 = require("./utils.js");
    11 | const convertFolder = (raw) => {
    12 |     const parsed = (0, utils_1.safeParse)(raw);
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#472 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/converters/folder.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
  2 | /**
  3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#473 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/converters/hongbao.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
  2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
  3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#474 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/converters/hongbao.js:10](#)

Dependency without integrity verification

```
8 | Object.defineProperty(exports, "__esModule", { value: true });
9 | exports.convertHongbao = void 0;
> 10 | const utils_1 = require("./utils.js");
11 | const convertHongbao = (raw) => {...
12 |     const parsed = (0, utils_1.safeParse)(raw);
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#475 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/converters/hongbao.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
2 | /**
3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#476 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/converters/image.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#477 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/converters/image.js:10](#)

Dependency without integrity verification

```
8 | Object.defineProperty(exports, "__esModule", { value: true });
9 | exports.convertImage = void 0;
> 10 | const utils_1 = require("./utils.js");
11 | const convertImage = (raw) => {
12 |     const parsed = (0, utils_1.safeParse)(raw);
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#478 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/converters/image.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
  2 | /**...
  3 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#479 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/converters/index.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
  2 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
  3 | * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#480 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/converters/index.js:10](#)

Dependency without integrity verification

```
8 | Object.defineProperty(exports, "__esModule", { value: true });
9 | exports.converters = void 0;
> 10 | const text_1 = require("./text.js");
  11 | const post_1 = require("./post.js");
  12 | const image_1 = require("./image.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#481 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/converters/index.js:11](#)

Dependency without integrity verification

```
9 | exports.converters = void 0;
10 | const text_1 = require("./text.js");
> 11 | const post_1 = require("./post.js");
  12 | const image_1 = require("./image.js");
  13 | const file_1 = require("./file.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#482 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/converters/index.js:12](#)

Dependency without integrity verification

```
10 | const text_1 = require("../text.js");
11 | const post_1 = require("../post.js");
> 12 | const image_1 = require("../image.js");
    13 | const file_1 = require("../file.js");...
    14 | const audio_1 = require("../audio.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#483 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/converters/index.js:13](#)

Dependency without integrity verification

```
11 | const post_1 = require("../post.js");
12 | const image_1 = require("../image.js");
> 13 | const file_1 = require("../file.js");
    14 | const audio_1 = require("../audio.js");
    15 | const video_1 = require("../video.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#484 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/converters/index.js:14](#)

Dependency without integrity verification

```
12 | const image_1 = require("../image.js");
13 | const file_1 = require("../file.js");
> 14 | const audio_1 = require("../audio.js");
    15 | const video_1 = require("../video.js");
    16 | const sticker_1 = require("../sticker.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#485 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/converters/index.js:15](#)

Dependency without integrity verification

```
13 | const file_1 = require("../file.js");
14 | const audio_1 = require("../audio.js");
> 15 | const video_1 = require("../video.js");
    16 | const sticker_1 = require("../sticker.js");
    17 | const index_1 = require("../interactive/index.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#486 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/converters/index.js:16](#)

Dependency without integrity verification

```
14 | const audio_1 = require("./audio.js");
15 | const video_1 = require("./video.js");
> 16 | const sticker_1 = require("./sticker.js");
17 | const index_1 = require("./interactive/index.js");...
18 | const share_1 = require("./share.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#487 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/converters/index.js:17](#)

Dependency without integrity verification

```
15 | const video_1 = require("./video.js");
16 | const sticker_1 = require("./sticker.js");
> 17 | const index_1 = require("./interactive/index.js");
18 | const share_1 = require("./share.js");
19 | const location_1 = require("./location.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#488 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/converters/index.js:18](#)

Dependency without integrity verification

```
16 | const sticker_1 = require("./sticker.js");
17 | const index_1 = require("./interactive/index.js");
> 18 | const share_1 = require("./share.js");
19 | const location_1 = require("./location.js");
20 | const merge_forward_1 = require("./merge-forward.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#489 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/converters/index.js:19](#)

Dependency without integrity verification

```
17 | const index_1 = require("../interactive/index.js");
18 | const share_1 = require("../share.js");
> 19 | const location_1 = require("../location.js");
20 | const merge_forward_1 = require("../merge-forward.js");...
21 | const folder_1 = require("../folder.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#490 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/converters/index.js:20](#)

Dependency without integrity verification

```
18 | const share_1 = require("../share.js");
19 | const location_1 = require("../location.js");
> 20 | const merge_forward_1 = require("../merge-forward.js");
21 | const folder_1 = require("../folder.js");
22 | const system_1 = require("../system.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#491 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/converters/index.js:21](#)

Dependency without integrity verification

```
19 | const location_1 = require("../location.js");
20 | const merge_forward_1 = require("../merge-forward.js");
> 21 | const folder_1 = require("../folder.js");
22 | const system_1 = require("../system.js");
23 | const hongbao_1 = require("../hongbao.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#492 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/converters/index.js:22](#)

Dependency without integrity verification

```
20 | const merge_forward_1 = require("../merge-forward.js");
21 | const folder_1 = require("../folder.js");
> 22 | const system_1 = require("../system.js");
23 | const hongbao_1 = require("../hongbao.js");
24 | const calendar_1 = require("../calendar.js");
```


Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#493 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/converters/index.js:23](#)

Dependency without integrity verification

```
21 | const folder_1 = require("./folder.js");
> 22 | const system_1 = require("./system.js");
    23 | const hongbao_1 = require("./hongbao.js");
    24 | const calendar_1 = require("./calendar.js");...
    25 | const video_chat_1 = require("./video-chat.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#494 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/converters/index.js:24](#)

Dependency without integrity verification

```
22 | const system_1 = require("./system.js");
> 23 | const hongbao_1 = require("./hongbao.js");
    24 | const calendar_1 = require("./calendar.js");
    25 | const video_chat_1 = require("./video-chat.js");
    26 | const todo_1 = require("./todo.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#495 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/converters/index.js:25](#)

Dependency without integrity verification

```
23 | const hongbao_1 = require("./hongbao.js");
> 24 | const calendar_1 = require("./calendar.js");
    25 | const video_chat_1 = require("./video-chat.js");
    26 | const todo_1 = require("./todo.js");
    27 | const vote_1 = require("./vote.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#496 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/converters/index.js:26](#)

Dependency without integrity verification

```
24 | const calendar_1 = require("./calendar.js");
25 | const video_chat_1 = require("./video-chat.js");
> 26 | const todo_1 = require("./todo.js");
    27 | const vote_1 = require("./vote.js");...
    28 | const unknown_1 = require("./unknown.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#497 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/converters/index.js:27](#)

Dependency without integrity verification

```
25 | const video_chat_1 = require("./video-chat.js");
26 | const todo_1 = require("./todo.js");
> 27 | const vote_1 = require("./vote.js");
    28 | const unknown_1 = require("./unknown.js");
    29 | exports.converters = new Map([
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#498 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/converters/index.js:28](#)

Dependency without integrity verification

```
26 | const todo_1 = require("./todo.js");
27 | const vote_1 = require("./vote.js");
> 28 | const unknown_1 = require("./unknown.js");
    29 | exports.converters = new Map([
    30 |     ['text', text_1.convertText],
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#499 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/converters/index.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
    2 | /**
    3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#500 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/converters/interactive/card-converter.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
    2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates...
    3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#501 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/converters/interactive/card-converter.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
    2 | /**
    3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#502 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/converters/interactive/card-utils.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
    2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
    3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#503 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/messaging/converters/interactive/card-utils.js:36](#)

Dangerous execution: `const dtMatch = /^(ld{4}-ld{2}-ld{2})\s+(ld{2}:ld{2}(?:ld{2})?)$/`.exec(input);

```
34 |         return input;
35 |     }
> 36 |     const dtMatch = /^(ld{4}-ld{2}-ld{2})\s+(ld{2}:ld{2}(?:ld{2})?)$/
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#504 AS-006 -- SANDBOXING

HIGH

OWASP: AA-09 | MITRE: T1610 | STRIDE: Elevation of Privilege

Code execution without sandboxing or isolation mechanisms

[src/messaging/converters/interactive/card-utils.js:36](#)

Code execution without sandboxing

```
34 |         return input;
35 |     }
> 36 |     const dtMatch = /\d{4}-\d{2}-\d{2}\s+(\d{2}:\d{2}(?:\d{2})?)$/ .exec(input);
37 |     if (dtMatch) {...
38 |         const d = new Date(`${dtMatch[1]}T${dtMatch[2]}`);
```

Remediation:

1. Run all agent-generated code in Docker containers with `--network=none` and read-only filesystem. 2. Use gVisor/Firecracker for stronger isolation. 3. Set resource limits (CPU, memory, time) on execution. 4. Use E2B or Modal for managed sandboxed execution. 5. Never execute agent code in the host process.

MCPS Quick Fix: `npm install mcp-secure`

#505 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/converters/interactive/card-utils.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
2 | /**
3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#506 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/converters/interactive/index.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#507 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/converters/interactive/index.js:10](#)

Dependency without integrity verification

```
8 | Object.defineProperty(exports, "__esModule", { value: true });
9 | exports.convertInteractive = void 0;
> 10 | const utils_1 = require("../utils.js");
11 | const card_converter_1 = require("./card-converter.js");
12 | const legacy_1 = require("./legacy.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#508 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/converters/interactive/index.js:11](#)

Dependency without integrity verification

```
9 | exports.convertInteractive = void 0;
10 | const utils_1 = require("../utils.js");
> 11 | const card_converter_1 = require("./card-converter.js");
12 | const legacy_1 = require("./legacy.js");...
13 | const convertInteractive = (raw) => {
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#509 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/converters/interactive/index.js:12](#)

Dependency without integrity verification

```
10 | const utils_1 = require("../utils.js");
11 | const card_converter_1 = require("./card-converter.js");
> 12 | const legacy_1 = require("./legacy.js");
13 | const convertInteractive = (raw) => {
14 |     const parsed = (0, utils_1.safeParse)(raw);
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#510 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/converters/interactive/index.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
2 | /**
3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#511 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/converters/interactive/legacy.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
  2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates...
  3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#512 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/converters/interactive/legacy.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
  2 | /**
  3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#513 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/converters/interactive/types.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
  2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
  3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#514 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/converters/interactive/types.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
  2 | /**
  3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#515 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/converters/location.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
    2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates...
    3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#516 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/converters/location.js:10](#)

Dependency without integrity verification

```
8 | Object.defineProperty(exports, "__esModule", { value: true });
9 | exports.convertLocation = void 0;
> 10 | const utils_1 = require("../utils.js");
    11 | const convertLocation = (raw) => {
    12 |     const parsed = (0, utils_1.safeParse)(raw);
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#517 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/converters/location.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
    2 | /**
    3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#518 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/converters/merge-forward.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
    2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
    3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#519 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/converters/merge-forward.js:23](#)

Dependency without integrity verification

```
21 | Object.defineProperty(exports, "__esModule", { value: true });
22 | exports.convertMergeForward = void 0;
> 23 | const lark_logger_1 = require("../core/lark-logger.js");
    24 | const content_converter_helpers_1 = require("./content-converter-helpers.js");...
    25 | const log = (0, lark_logger_1.larkLogger)('converters/merge-forward');
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#520 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/converters/merge-forward.js:24](#)

Dependency without integrity verification

```
22 | exports.convertMergeForward = void 0;
23 | const lark_logger_1 = require("../core/lark-logger.js");
> 24 | const content_converter_helpers_1 = require("./content-converter-helpers.js");
    25 | const log = (0, lark_logger_1.larkLogger)('converters/merge-forward');
    26 | /**
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#521 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/converters/post.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
    2 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
    3 | * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#522 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/converters/post.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
    2 | /**
    3 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#523 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/converters/share.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
  2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates...
  3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#524 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/converters/share.js:10](#)

Dependency without integrity verification

```
8 | Object.defineProperty(exports, "__esModule", { value: true });
9 | exports.convertShareUser = exports.convertShareChat = void 0;
> 10 | const utils_1 = require("./utils.js");
  11 | const convertShareChat = (raw) => {
  12 |     const parsed = (0, utils_1.safeParse)(raw);
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#525 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/converters/share.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
  2 | /**
  3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#526 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/converters/sticker.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
  2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
  3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#527 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/converters/sticker.js:10](#)

Dependency without integrity verification

```
8 | Object.defineProperty(exports, "__esModule", { value: true });
9 | exports.convertSticker = void 0;
> 10 | const utils_1 = require("./utils.js");
11 | const convertSticker = (raw) => {...
12 |     const parsed = (0, utils_1.safeParse)(raw);
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#528 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/converters/sticker.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
2 | /**
3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#529 AS-005 -- INJECTION PATTERN

CRITICAL

OWASP: AA-02 | MITRE: T1055 | STRIDE: Tampering

Known prompt injection, SQL injection, XSS, or command injection patterns

[src/messaging/converters/system.d.ts:12](#)

Known injection pattern detected

```
10 | */
11 | import type { ContentConverterFn } from './types';
> 12 | export declare const convertSystem: ContentConverterFn;
13 |
```

Remediation:

1. Validate and sanitize all inputs with strict allowlists. 2. Use parameterized queries for any database access (never string concatenation). 3. HTML-encode all agent output before rendering. 4. Implement content security policy (CSP) headers. 5. Block known injection patterns at the input boundary.

#530 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/converters/system.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#531 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/converters/system.js:14](#)

Dependency without integrity verification

```
12 | Object.defineProperty(exports, "__esModule", { value: true });
13 | exports.convertSystem = void 0;
> 14 | const utils_1 = require("./utils.js");
    15 | const convertSystem = (raw) => {...
    16 |     const parsed = (0, utils_1.safeParse)(raw);
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#532 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/converters/system.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
  2 | /**
  3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#533 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/converters/text.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
  2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
  3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#534 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/converters/text.js:10](#)

Dependency without integrity verification

```
8 | Object.defineProperty(exports, "__esModule", { value: true });
9 | exports.convertText = void 0;
> 10 | const content_converter_helpers_1 = require("./content-converter-helpers.js");
    11 | const utils_1 = require("./utils.js");
    12 | const convertText = (raw, ctx) => {
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#535 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/converters/text.js:11](#)

Dependency without integrity verification

```
9 | exports.convertText = void 0;
10 | const content_converter_helpers_1 = require("../content-converter-helpers.js");
> 11 | const utils_1 = require("../utils.js");
12 | const convertText = (raw, ctx) => {...
13 |     const parsed = (0, utils_1.safeParse)(raw);
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#536 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/converters/text.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
2 | /**
3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#537 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/converters/todo.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#538 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/converters/todo.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
2 | /**
3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#539 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/converters/types.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
  2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates...
  3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#540 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/converters/types.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
  2 | /**
  3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#541 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/converters/unknown.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
  2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
  3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#542 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/converters/unknown.js:10](#)

Dependency without integrity verification

```
> 8 | Object.defineProperty(exports, "__esModule", { value: true });
  9 | exports.convertUnknown = void 0;
 10 | const utils_1 = require("../utils.js");
 11 | const convertUnknown = (raw) => {
 12 |     const parsed = (0, utils_1.safeParse)(raw);
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#543 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/converters/unknown.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
  2 | /**...
  3 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#544 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/converters/utils.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
  2 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
  3 | * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#545 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/converters/utils.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
  2 | /**
  3 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#546 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/converters/video-chat.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
  2 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
  3 | * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#547 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/converters/video-chat.js:10](#)

Dependency without integrity verification

```
8 | Object.defineProperty(exports, "__esModule", { value: true });
9 | exports.convertVideoChat = void 0;
> 10 | const utils_1 = require("./utils.js");
11 | const convertVideoChat = (raw) => {...
12 |     const parsed = (0, utils_1.safeParse)(raw);
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#548 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/converters/video-chat.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
2 | /**
3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#549 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/converters/video.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#550 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/converters/video.js:10](#)

Dependency without integrity verification

```
8 | Object.defineProperty(exports, "__esModule", { value: true });
9 | exports.convertVideo = void 0;
> 10 | const utils_1 = require("./utils.js");
11 | const convertVideo = (raw) => {
12 |     const parsed = (0, utils_1.safeParse)(raw);
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#551 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/converters/video.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
  2 | /**...
  3 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#552 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/converters/vote.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
  2 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
  3 | * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#553 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/converters/vote.js:10](#)

Dependency without integrity verification

```
8 | Object.defineProperty(exports, "__esModule", { value: true });
9 | exports.convertVote = void 0;
> 10 | const utils_1 = require("./utils.js");
    11 | const convertVote = (raw) => {
    12 |     const parsed = (0, utils_1.safeParse)(raw);
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#554 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/converters/vote.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
  2 | /**
  3 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#555 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/inbound/comment-context.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
  2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates...
  3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#556 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/inbound/comment-handler.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
  2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
  3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#557 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/messaging/inbound/comment-handler.js:15](#)

Dangerous execution: var __createBinding = (this && this.__createBinding) || (Object.create ? (functi

```
13 |  * bypasses the 7-stage message pipeline and dispatches directly.
14 |  */
> 15 | var __createBinding = (this && this.__createBinding) || (Object.create ? (function(o, m, k, k2) {
16 |     if (k2 === undefined) k2 = k;
17 |     var desc = Object.getOwnPropertyDescriptor(m, k);
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#558 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/messaging/inbound/comment-handler.js:19](#)

Dangerous execution: desc = { enumerable: true, get: function() { return m[k]; } };

```
17 |     var desc = Object.getOwnPropertyDescriptor(m, k);
18 |     if (!desc || ("get" in desc ? !m.__esModule : desc.writable || desc.configurable)) {
> 19 |         desc = { enumerable: true, get: function() { return m[k]; } };
20 |     }
21 |     Object.defineProperty(o, k2, desc);
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#559 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/messaging/inbound/comment-handler.js:22](#)

Dangerous execution: `}} : (function(o, m, k, k2) {`

```
20 |     }
21 |     Object.defineProperty(o, k2, desc);
> 22 |   }} : (function(o, m, k, k2) {
23 |     if (k2 === undefined) k2 = k;...
24 |     o[k2] = m[k];
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#560 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/messaging/inbound/comment-handler.js:26](#)

Dangerous execution: `var __setModuleDefault = (this && this.__setModuleDefault) || (Object.create ? (`

```
24 |     o[k2] = m[k];
25 |   }));
> 26 |   var __setModuleDefault = (this && this.__setModuleDefault) || (Object.create ? (function(o, v) {
27 |     Object.defineProperty(o, "default", { enumerable: true, value: v });
28 |   }) : function(o, v) {
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#561 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/messaging/inbound/comment-handler.js:28](#)

Dangerous execution: `}} : function(o, v) {`

```
26 |   var __setModuleDefault = (this && this.__setModuleDefault) || (Object.create ? (function(o, v) {
27 |     Object.defineProperty(o, "default", { enumerable: true, value: v });
> 28 |   }) : function(o, v) {
29 |     o["default"] = v;
30 |   });
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#562 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/messaging/inbound/comment-handler.js:31](#)

Dangerous execution: `var __importStar = (this && this.__importStar) || (function () {`

```
29 |     o["default"] = v;
30 |   });
> 31 |   var __importStar = (this && this.__importStar) || (function () {
32 |     var ownKeys = function(o) {
33 |       ownKeys = Object.getOwnPropertyNames || function (o) {
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#563 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/messaging/inbound/comment-handler.js:32](#)

Dangerous execution: `var ownKeys = function(o) {`

```
30 | });
31 | var __importStar = (this && this.__importStar) || (function () {
> 32 |     var ownKeys = function(o) {
33 |         ownKeys = Object.getOwnPropertyNames || function (o) {...
34 |         var ar = [];
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#564 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/messaging/inbound/comment-handler.js:33](#)

Dangerous execution: `ownKeys = Object.getOwnPropertyNames || function (o) {`

```
31 | var __importStar = (this && this.__importStar) || (function () {
32 |     var ownKeys = function(o) {
> 33 |         ownKeys = Object.getOwnPropertyNames || function (o) {
34 |             var ar = [];
35 |             for (var k in o) if (Object.prototype.hasOwnProperty.call(o, k)) ar[ar.length] = k;
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#565 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/messaging/inbound/comment-handler.js:40](#)

Dangerous execution: `return function (mod) {`

```
38 |         return ownKeys(o);
39 |     };
> 40 |     return function (mod) {
41 |         if (mod && mod.__esModule) return mod;
42 |         var result = {};
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#566 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/inbound/comment-handler.js:50](#)

Dependency without integrity verification

```
48 | Object.defineProperty(exports, "__esModule", { value: true });
49 | exports.handleFeishuCommentEvent = handleFeishuCommentEvent;
> 50 | const crypto = __importStar(require("node:crypto"));
    | const reply_history_1 = require("openclaw/plugin-sdk/reply-history");...
51 | const reply_history_1 = require("openclaw/plugin-sdk/reply-history");...
52 | const accounts_1 = require("../core/accounts.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#567 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/inbound/comment-handler.js:51](#)

Dependency without integrity verification

```
49 | exports.handleFeishuCommentEvent = handleFeishuCommentEvent;
50 | const crypto = __importStar(require("node:crypto"));
> 51 | const reply_history_1 = require("openclaw/plugin-sdk/reply-history");
    | const accounts_1 = require("../core/accounts.js");
52 | const accounts_1 = require("../core/accounts.js");
53 | const comment_target_1 = require("../core/comment-target.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#568 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/inbound/comment-handler.js:52](#)

Dependency without integrity verification

```
50 | const crypto = __importStar(require("node:crypto"));
51 | const reply_history_1 = require("openclaw/plugin-sdk/reply-history");
> 52 | const accounts_1 = require("../core/accounts.js");
    | const comment_target_1 = require("../core/comment-target.js");
53 | const comment_target_1 = require("../core/comment-target.js");
54 | const lark_client_1 = require("../core/lark-client.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#569 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/inbound/comment-handler.js:53](#)

Dependency without integrity verification

```
51 | const reply_history_1 = require("openclaw/plugin-sdk/reply-history");
52 | const accounts_1 = require("../core/accounts.js");
> 53 | const comment_target_1 = require("../core/comment-target.js");
    | const lark_client_1 = require("../core/lark-client.js");
54 | const lark_client_1 = require("../core/lark-client.js");
55 | const lark_logger_1 = require("../core/lark-logger.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#570 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/inbound/comment-handler.js:54](#)

Dependency without integrity verification

```
52 | const accounts_1 = require("../core/accounts.js");
> 53 | const comment_target_1 = require("../core/comment-target.js");
    54 | const lark_client_1 = require("../core/lark-client.js");
    55 | const lark_logger_1 = require("../core/lark-logger.js");...
    56 | const user_name_cache_1 = require("./user-name-cache.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#571 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/inbound/comment-handler.js:55](#)

Dependency without integrity verification

```
53 | const comment_target_1 = require("../core/comment-target.js");
> 54 | const lark_client_1 = require("../core/lark-client.js");
    55 | const lark_logger_1 = require("../core/lark-logger.js");
    56 | const user_name_cache_1 = require("./user-name-cache.js");
    57 | const dispatch_1 = require("./dispatch.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#572 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/inbound/comment-handler.js:56](#)

Dependency without integrity verification

```
54 | const lark_client_1 = require("../core/lark-client.js");
> 55 | const lark_logger_1 = require("../core/lark-logger.js");
    56 | const user_name_cache_1 = require("./user-name-cache.js");
    57 | const dispatch_1 = require("./dispatch.js");
    58 | const gate_1 = require("./gate.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#573 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/inbound/comment-handler.js:57](#)

Dependency without integrity verification

```
55 | const lark_logger_1 = require("../core/lark-logger.js");
56 | const user_name_cache_1 = require("../user-name-cache.js");
> 57 | const dispatch_1 = require("../dispatch.js");
58 | const gate_1 = require("../gate.js");...
59 | const policy_1 = require("../policy.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#574 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/inbound/comment-handler.js:58](#)

Dependency without integrity verification

```
56 | const user_name_cache_1 = require("../user-name-cache.js");
57 | const dispatch_1 = require("../dispatch.js");
> 58 | const gate_1 = require("../gate.js");
59 | const policy_1 = require("../policy.js");
60 | const gate_effects_1 = require("../gate-effects.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#575 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/inbound/comment-handler.js:59](#)

Dependency without integrity verification

```
57 | const dispatch_1 = require("../dispatch.js");
58 | const gate_1 = require("../gate.js");
> 59 | const policy_1 = require("../policy.js");
60 | const gate_effects_1 = require("../gate-effects.js");
61 | const comment_context_1 = require("../comment-context.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#576 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/inbound/comment-handler.js:60](#)

Dependency without integrity verification

```
58 | const gate_1 = require("../gate.js");
59 | const policy_1 = require("../policy.js");
> 60 | const gate_effects_1 = require("../gate-effects.js");
61 | const comment_context_1 = require("../comment-context.js");
62 | const logger = (0, lark_logger_1.larkLogger)('inbound/comment-handler');
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#577 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/inbound/comment-handler.js:61](#)

Dependency without integrity verification

```
59 | const policy_1 = require("./policy.js");
60 | const gate_effects_1 = require("./gate-effects.js");
> 61 | const comment_context_1 = require("./comment-context.js");
62 | const logger = (0, lark_logger_1.larkLogger)('inbound/comment-handler');...
63 | // -----
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#578 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/inbound/dedup.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#579 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/messaging/inbound/dedup.js:78](#)

High-risk permission pattern: this.store.delete(key);

```
76 |         }
77 |         // Expired – remove so we can re-insert at the tail (refresh position).
> 78 |         this.store.delete(key);
79 |     }
80 |     // Enforce capacity via FIFO: drop the oldest entry.
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#580 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/messaging/inbound/dedup.js:84](#)

High-risk permission pattern: `this.store.delete(oldest);`

```
82 |         const oldest = this.store.keys().next().value;
83 |         if (oldest !== undefined) {
84 |             this.store.delete(oldest);
85 |         }...
86 |     }
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#581 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/messaging/inbound/dedup.js:117](#)

High-risk permission pattern: `this.store.delete(key);`

```
115 |         if (now - ts < this.ttlMs)
116 |             break;
117 |         this.store.delete(key);
118 |     }
119 | }
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#582 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/inbound/dedup.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
   2 | /**
   3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#583 AS-005 -- INJECTION PATTERN

CRITICAL

OWASP: AA-02 | MITRE: T1055 | STRIDE: Tampering

Known prompt injection, SQL injection, XSS, or command injection patterns

[src/messaging/inbound/dispatch-builders.d.ts:16](#)

Known injection pattern detected

```
14 | import type { DispatchContext } from './dispatch-context';
15 | /**
16 |  * Build a `[System: ...]` mention annotation when the message @-mentions
17 |  * non-bot users. Returns `undefined` when there are no user mentions.
18 |  */
```


Remediation:

1. Validate and sanitize all inputs with strict allowlists. 2. Use parameterized queries for any database access (never string concatenation). 3. HTML-encode all agent output before rendering. 4. Implement content security policy (CSP) headers. 5. Block known injection patterns at the input boundary.

#584 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/inbound/dispatch-builders.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
  2 |    * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates...
  3 |    * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#585 AS-005 -- INJECTION PATTERN

CRITICAL

OWASP: AA-02 | MITRE: T1055 | STRIDE: Tampering

Known prompt injection, SQL injection, XSS, or command injection patterns

[src/messaging/inbound/dispatch-builders.js:25](#)

Known injection pattern detected

```
> 23 | // -----
  24 | /**
  25 |    * Build a `[System: ...]` mention annotation when the message @-mentions
  26 |    * non-bot users. Returns `undefined` when there are no user mentions.
  27 |    *
```

Remediation:

1. Validate and sanitize all inputs with strict allowlists. 2. Use parameterized queries for any database access (never string concatenation). 3. HTML-encode all agent output before rendering. 4. Implement content security policy (CSP) headers. 5. Block known injection patterns at the input boundary.

#586 AS-005 -- INJECTION PATTERN

CRITICAL

OWASP: AA-02 | MITRE: T1055 | STRIDE: Tampering

Known prompt injection, SQL injection, XSS, or command injection patterns

[src/messaging/inbound/dispatch-builders.js:38](#)

Known injection pattern detected

```
36 |         return undefined;
  37 |         const mentionDetails = mentions.map((t) => `${t.name} (open_id: ${t.openId})`).join(', ');
> 38 |         return `[System: This message @mentions the following users: ${mentionDetails}. Use these
  39 |         open_ids when performing actions involving these users.]`;
  40 |     } // -----
```

Remediation:

1. Validate and sanitize all inputs with strict allowlists. 2. Use parameterized queries for any database access (never string concatenation). 3. HTML-encode all agent output before rendering. 4. Implement content security policy (CSP) headers. 5. Block known injection patterns at the input boundary.

#587 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/inbound/dispatch-builders.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
  2 | /**...
  3 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#588 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/inbound/dispatch-commands.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
  2 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
  3 | * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#589 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/messaging/inbound/dispatch-commands.js:30](#)

High-risk permission pattern: const permissionNotifyBody = `[System: The bot encountered a Feishu API permissi

```
28 | async function dispatchPermissionNotification(dc, permissionError, replyToMessageId) {
29 |     const grantUrl = permissionError.grantUrl ?? '';
> 30 |     const permissionNotifyBody = `[System: The bot encountered a Feishu API permission error. Please
    inform the user about this issue and provide the permission grant URL for the admin to authorize. Permission
    grant URL: ${grantUrl}]`;
31 |     const permBody = dc.core.channel.reply.formatAgentEnvelope({
32 |         channel: 'Feishu',
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#590 AS-005 -- INJECTION PATTERN

CRITICAL

OWASP: AA-02 | MITRE: T1055 | STRIDE: Tampering

Known prompt injection, SQL injection, XSS, or command injection patterns

[src/messaging/inbound/dispatch-commands.js:30](#)

Known injection pattern detected

```
28 | async function dispatchPermissionNotification(dc, permissionError, replyToMessageId) {
29 |     const grantUrl = permissionError.grantUrl ?? '';
> 30 |     const permissionNotifyBody = `[System: The bot encountered a Feishu API permission error. Please
    inform the user about this issue and provide the permission grant URL for the admin to authorize. Permission
    grant URL: ${grantUrl}]`;
31 |     const permBody = dc.core.channel.reply.formatAgentEnvelope({
32 |         channel: 'Feishu',
```

Remediation:

1. Validate and sanitize all inputs with strict allowlists. 2. Use parameterized queries for any database access (never string concatenation). 3. HTML-encode all agent output before rendering. 4. Implement content security policy (CSP) headers. 5. Block known injection patterns at the input boundary.

#591 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/inbound/dispatch-context.js:16](#)

Dependency without integrity verification

```
14 | exports.buildDispatchContext = buildDispatchContext;
15 | exports.resolveThreadSessionKey = resolveThreadSessionKey;
> 16 | const routing_1 = require("openclaw/plugin-sdk/routing");
17 | const lark_client_1 = require("../core/lark-client.js");...
18 | const lark_logger_1 = require("../core/lark-logger.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#592 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/inbound/dispatch-context.js:17](#)

Dependency without integrity verification

```
15 | exports.resolveThreadSessionKey = resolveThreadSessionKey;
16 | const routing_1 = require("openclaw/plugin-sdk/routing");
> 17 | const lark_client_1 = require("../core/lark-client.js");
18 | const lark_logger_1 = require("../core/lark-logger.js");
19 | const chat_info_cache_1 = require("../core/chat-info-cache.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#593 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/inbound/dispatch-context.js:18](#)

Dependency without integrity verification

```
16 | const routing_1 = require("openclaw/plugin-sdk/routing");
17 | const lark_client_1 = require("../core/lark-client.js");
> 18 | const lark_logger_1 = require("../core/lark-logger.js");
19 | const chat_info_cache_1 = require("../core/chat-info-cache.js");
20 | const comment_target_1 = require("../core/comment-target.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#594 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/inbound/dispatch-context.js:19](#)

Dependency without integrity verification

```
17 | const lark_client_1 = require("../core/lark-client.js");
18 | const lark_logger_1 = require("../core/lark-logger.js");
> 19 | const chat_info_cache_1 = require("../core/chat-info-cache.js");
20 | const comment_target_1 = require("../core/comment-target.js");...
21 | const log = (0, lark_logger_1.larkLogger)('inbound/dispatch-context');
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#595 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/inbound/dispatch-context.js:20](#)

Dependency without integrity verification

```
18 | const lark_logger_1 = require("../core/lark-logger.js");
19 | const chat_info_cache_1 = require("../core/chat-info-cache.js");
> 20 | const comment_target_1 = require("../core/comment-target.js");
21 | const log = (0, lark_logger_1.larkLogger)('inbound/dispatch-context');
22 | // -----
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#596 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/messaging/inbound/dispatch.d.ts:36](#)

High-risk permission pattern: `/** When set, controls whether the sender is authorized to execute`

```
34 |      * instead of ctx.messageId (which may be a synthetic ID). */
35 |      replyToMessageId?: string;
> 36 |      /** When set, controls whether the sender is authorized to execute
37 |      * control commands. Computed by the handler via the SDK's access
38 |      * group command gating system. */
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#597 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/inbound/dispatch.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#598 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/inbound/enrich.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
  2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates...
  3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#599 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/inbound/enrich.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
  2 | /**
  3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#600 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/inbound/gate-effects.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
  2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
  3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#601 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/inbound/gate-effects.js:13](#)

Dependency without integrity verification

```
11 | Object.defineProperty(exports, "__esModule", { value: true });
12 | exports.sendPairingReply = sendPairingReply;
> 13 | const lark_client_1 = require("../core/lark-client.js");
    14 | const send_1 = require("../outbound/send.js");
    15 | // -----
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#602 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/inbound/gate-effects.js:14](#)

Dependency without integrity verification

```
12 | exports.sendPairingReply = sendPairingReply;
13 | const lark_client_1 = require("../core/lark-client.js");
> 14 | const send_1 = require("../outbound/send.js");
15 | // -----
16 | // Pairing reply
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#603 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/inbound/gate-effects.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
2 | /**
3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#604 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/inbound/gate.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#605 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/inbound/gate.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
2 | /**
3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#606 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/inbound/handler-registry.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
  2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates...
  3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#607 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/inbound/handler-registry.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
  2 | /**
  3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#608 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/inbound/handler.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
  2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
  3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#609 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/inbound/handler.js:19](#)

Dependency without integrity verification

```
17 | Object.defineProperty(exports, "__esModule", { value: true });
18 | exports.handleFeishuMessage = handleFeishuMessage;
> 19 | const reply_history_1 = require("openclaw/plugin-sdk/reply-history");
    |    ^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^
20 | const zalouser_1 = require("openclaw/plugin-sdk/zalouser");
21 | const allow_from_1 = require("openclaw/plugin-sdk/allow-from");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#610 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/inbound/handler.js:20](#)

Dependency without integrity verification

```
18 | exports.handleFeishuMessage = handleFeishuMessage;
19 | const reply_history_1 = require("openclaw/plugin-sdk/reply-history");
> 20 | const zalouser_1 = require("openclaw/plugin-sdk/zalouser");
    21 | const allow_from_1 = require("openclaw/plugin-sdk/allow-from");...
    22 | const accounts_1 = require("../core/accounts.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#611 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/inbound/handler.js:21](#)

Dependency without integrity verification

```
19 | const reply_history_1 = require("openclaw/plugin-sdk/reply-history");
20 | const zalouser_1 = require("openclaw/plugin-sdk/zalouser");
> 21 | const allow_from_1 = require("openclaw/plugin-sdk/allow-from");
    22 | const accounts_1 = require("../core/accounts.js");
    23 | const lark_client_1 = require("../core/lark-client.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#612 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/inbound/handler.js:22](#)

Dependency without integrity verification

```
20 | const zalouser_1 = require("openclaw/plugin-sdk/zalouser");
21 | const allow_from_1 = require("openclaw/plugin-sdk/allow-from");
> 22 | const accounts_1 = require("../core/accounts.js");
    23 | const lark_client_1 = require("../core/lark-client.js");
    24 | const lark_logger_1 = require("../core/lark-logger.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#613 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/inbound/handler.js:23](#)

Dependency without integrity verification

```
21 | const allow_from_1 = require("openclaw/plugin-sdk/allow-from");
22 | const accounts_1 = require("../core/accounts.js");
> 23 | const lark_client_1 = require("../core/lark-client.js");
    24 | const lark_logger_1 = require("../core/lark-logger.js");
    25 | const lark_ticket_1 = require("../core/lark-ticket.js");
```


Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#614 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/inbound/handler.js:24](#)

Dependency without integrity verification

```
22 | const accounts_1 = require("../core/accounts.js");
> 23 | const lark_client_1 = require("../core/lark-client.js");
    24 | const lark_logger_1 = require("../core/lark-logger.js");
    25 | const lark_ticket_1 = require("../core/lark-ticket.js");...
    26 | const chat_queue_1 = require("../channel/chat-queue.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#615 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/inbound/handler.js:25](#)

Dependency without integrity verification

```
23 | const lark_client_1 = require("../core/lark-client.js");
> 24 | const lark_logger_1 = require("../core/lark-logger.js");
    25 | const lark_ticket_1 = require("../core/lark-ticket.js");
    26 | const chat_queue_1 = require("../channel/chat-queue.js");
    27 | const parse_1 = require("./parse.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#616 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/inbound/handler.js:26](#)

Dependency without integrity verification

```
24 | const lark_logger_1 = require("../core/lark-logger.js");
> 25 | const lark_ticket_1 = require("../core/lark-ticket.js");
    26 | const chat_queue_1 = require("../channel/chat-queue.js");
    27 | const parse_1 = require("./parse.js");
    28 | const enrich_1 = require("./enrich.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#617 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/inbound/handler.js:27](#)

Dependency without integrity verification

```
25 | const lark_ticket_1 = require("../core/lark-ticket.js");
26 | const chat_queue_1 = require("../channel/chat-queue.js");
> 27 | const parse_1 = require("./parse.js");
    28 | const enrich_1 = require("./enrich.js");...
    29 | const gate_1 = require("./gate.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#618 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/inbound/handler.js:28](#)

Dependency without integrity verification

```
26 | const chat_queue_1 = require("../channel/chat-queue.js");
27 | const parse_1 = require("./parse.js");
> 28 | const enrich_1 = require("./enrich.js");
    29 | const gate_1 = require("./gate.js");
    30 | const handler_registry_1 = require("./handler-registry.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#619 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/inbound/handler.js:29](#)

Dependency without integrity verification

```
27 | const parse_1 = require("./parse.js");
28 | const enrich_1 = require("./enrich.js");
> 29 | const gate_1 = require("./gate.js");
    30 | const handler_registry_1 = require("./handler-registry.js");
    31 | const dispatch_1 = require("./dispatch.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#620 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/inbound/handler.js:30](#)

Dependency without integrity verification

```
28 | const enrich_1 = require("./enrich.js");
29 | const gate_1 = require("./gate.js");
> 30 | const handler_registry_1 = require("./handler-registry.js");
    31 | const dispatch_1 = require("./dispatch.js");
    32 | const policy_1 = require("./policy.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#621 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/inbound/handler.js:31](#)

Dependency without integrity verification

```
29 | const gate_1 = require("./gate.js");
> 30 | const handler_registry_1 = require("./handler-registry.js");
    31 | const dispatch_1 = require("./dispatch.js");
    32 | const policy_1 = require("./policy.js");...
    33 | const logger = (0, lark_logger_1.larkLogger)('inbound/handler');
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#622 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/inbound/handler.js:32](#)

Dependency without integrity verification

```
30 | const handler_registry_1 = require("./handler-registry.js");
> 31 | const dispatch_1 = require("./dispatch.js");
    32 | const policy_1 = require("./policy.js");
    33 | const logger = (0, lark_logger_1.larkLogger)('inbound/handler');
    34 | // -----
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#623 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/inbound/media-resolver.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
    2 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
    3 | * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#624 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/inbound/media-resolver.js:15](#)

Dependency without integrity verification

```
13 | exports.downloadResources = downloadResources;
14 | exports.buildFeishuMediaPayload = buildFeishuMediaPayload;
> 15 | const lark_client_1 = require("../core/lark-client.js");
    16 | const media_1 = require("../outbound/media.js");...
17 | // -----
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#625 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/inbound/media-resolver.js:16](#)

Dependency without integrity verification

```
14 | exports.buildFeishuMediaPayload = buildFeishuMediaPayload;
15 | const lark_client_1 = require("../core/lark-client.js");
> 16 | const media_1 = require("../outbound/media.js");
    17 | // -----
    18 | // Resource-descriptor-based download
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#626 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/inbound/media-resolver.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
   2 | /**
   3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#627 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/inbound/mention.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
   2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
   3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#628 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/inbound/mention.js:24](#)

Dependency without integrity verification

```
22 | exports.buildMentionedMessage = buildMentionedMessage;
23 | exports.buildMentionedCardContent = buildMentionedCardContent;
> 24 | const utils_1 = require("../converters/utils.js");
    25 | // -----
    26 | // Derive helpers (work on MentionInfo[])
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#629 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/inbound/mention.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
  2 | /**
  3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#630 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/inbound/parse-io.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
  2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
  3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#631 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/inbound/parse-io.js:15](#)

Dependency without integrity verification

```
13 | exports.createFetchSubMessages = createFetchSubMessages;
14 | exports.createParseResolveNames = createParseResolveNames;
> 15 | const lark_logger_1 = require("../core/lark-logger.js");
    16 | const user_name_cache_1 = require("./user-name-cache.js");
    17 | const log = (0, lark_logger_1.larkLogger)('inbound/parse-io');
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#632 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/inbound/parse-io.js:16](#)

Dependency without integrity verification

```
14 | exports.createParseResolveNames = createParseResolveNames;
15 | const lark_logger_1 = require("../core/lark-logger.js");
> 16 | const user_name_cache_1 = require("../user-name-cache.js");
17 | const log = (0, lark_logger_1.larkLogger)('inbound/parse-io');...
18 | // -----
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#633 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/inbound/parse.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#634 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/inbound/parse.js:18](#)

Dependency without integrity verification

```
16 | Object.defineProperty(exports, "__esModule", { value: true });
17 | exports.parseMessageEvent = parseMessageEvent;
> 18 | const content_converter_1 = require("../converters/content-converter.js");
19 | const accounts_1 = require("../core/accounts.js");
20 | const lark_client_1 = require("../core/lark-client.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#635 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/inbound/parse.js:19](#)

Dependency without integrity verification

```
17 | exports.parseMessageEvent = parseMessageEvent;
18 | const content_converter_1 = require("../converters/content-converter.js");
> 19 | const accounts_1 = require("../core/accounts.js");
20 | const lark_client_1 = require("../core/lark-client.js");
21 | const lark_logger_1 = require("../core/lark-logger.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#636 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/inbound/parse.js:20](#)

Dependency without integrity verification

```
18 | const content_converter_1 = require("../converters/content-converter.js");
> 19 | const accounts_1 = require("../core/accounts.js");
    20 | const lark_client_1 = require("../core/lark-client.js");
    21 | const lark_logger_1 = require("../core/lark-logger.js");...
    22 | const mention_1 = require("../mention.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#637 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/inbound/parse.js:21](#)

Dependency without integrity verification

```
19 | const accounts_1 = require("../core/accounts.js");
> 20 | const lark_client_1 = require("../core/lark-client.js");
    21 | const lark_logger_1 = require("../core/lark-logger.js");
    22 | const mention_1 = require("../mention.js");
    23 | const user_name_cache_1 = require("../user-name-cache.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#638 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/inbound/parse.js:22](#)

Dependency without integrity verification

```
20 | const lark_client_1 = require("../core/lark-client.js");
> 21 | const lark_logger_1 = require("../core/lark-logger.js");
    22 | const mention_1 = require("../mention.js");
    23 | const user_name_cache_1 = require("../user-name-cache.js");
    24 | const parse_io_1 = require("../parse-io.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#639 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/inbound/parse.js:23](#)

Dependency without integrity verification

```
21 | const lark_logger_1 = require("../core/lark-logger.js");
22 | const mention_1 = require("../mention.js");
> 23 | const user_name_cache_1 = require("../user-name-cache.js");
24 | const parse_io_1 = require("../parse-io.js");...
25 | const log = (0, lark_logger_1.larkLogger)('inbound/parse');
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#640 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/inbound/parse.js:24](#)

Dependency without integrity verification

```
22 | const mention_1 = require("../mention.js");
23 | const user_name_cache_1 = require("../user-name-cache.js");
> 24 | const parse_io_1 = require("../parse-io.js");
25 | const log = (0, lark_logger_1.larkLogger)('inbound/parse');
26 | // -----
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#641 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/inbound/permission.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
2 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
3 | * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#642 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/inbound/permission.js:14](#)

Dependency without integrity verification

```
12 | exports.permissionErrorNotifiedAt = exports.PERMISSION_ERROR_COOLDOWN_MS = void 0;
13 | exports.extractPermissionError = extractPermissionError;
> 14 | const permission_url_1 = require("../core/permission-url.js");
15 | const auth_errors_1 = require("../core/auth-errors.js");
16 | // -----
```


Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#643 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/inbound/permission.js:15](#)

Dependency without integrity verification

```
13 | exports.extractPermissionError = extractPermissionError;
14 | const permission_url_1 = require("../core/permission-url.js");
15 | const auth_errors_1 = require("../core/auth-errors.js");
16 | // -----
17 | // Permission error extraction
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#644 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/inbound/permission.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
   2 | /**
   3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#645 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/inbound/policy.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
   2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
   3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#646 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/inbound/policy.js:18](#)

Dependency without integrity verification

```
16 | exports.splitLegacyGroupAllowFrom = splitLegacyGroupAllowFrom;
17 | exports.resolveGroupSenderPolicyContext = resolveGroupSenderPolicyContext;
> 18 | const accounts_1 = require("../core/accounts.js");
    | /**...
19 |
20 | * Check whether a sender is permitted by a given allowlist.
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#647 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/inbound/policy.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
   2 | /**
   3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#648 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/inbound/reaction-handler.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
   2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
   3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#649 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/messaging/inbound/reaction-handler.js:17](#)

Dangerous execution: var __createBinding = (this && this.__createBinding) || (Object.create ? (functi

```
15 | * - ``all`` - reactions on any message in the chat are dispatched.
16 | */
> 17 | var __createBinding = (this && this.__createBinding) || (Object.create ? (function(o, m, k, k2) {
    |   if (k2 === undefined) k2 = k;
18 |   var desc = Object.getOwnPropertyDescriptor(m, k);
19 |
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#650 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/messaging/inbound/reaction-handler.js:21](#)

Dangerous execution: `desc = { enumerable: true, get: function() { return m[k]; } };`

```
19 |     var desc = Object.getOwnPropertyDescriptor(m, k);
20 |     if (!desc || ("get" in desc ? !m.__esModule : desc.writable || desc.configurable)) {
21 |       desc = { enumerable: true, get: function() { return m[k]; } };
22 |     }...
23 |     Object.defineProperty(o, k2, desc);
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#651 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/messaging/inbound/reaction-handler.js:24](#)

Dangerous execution: `}} : (function(o, m, k, k2) {`

```
22 |     }
23 |     Object.defineProperty(o, k2, desc);
24 |   }} : (function(o, m, k, k2) {
25 |     if (k2 === undefined) k2 = k;
26 |     o[k2] = m[k];
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#652 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/messaging/inbound/reaction-handler.js:28](#)

Dangerous execution: `var __setModuleDefault = (this && this.__setModuleDefault) || (Object.create ? (`

```
26 |     o[k2] = m[k];
27 |   }));
28 |   var __setModuleDefault = (this && this.__setModuleDefault) || (Object.create ? (function(o, v) {
29 |     Object.defineProperty(o, "default", { enumerable: true, value: v });
30 |   }) : function(o, v) {
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#653 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/messaging/inbound/reaction-handler.js:30](#)

Dangerous execution: `}} : function(o, v) {`

```
28 |   var __setModuleDefault = (this && this.__setModuleDefault) || (Object.create ? (function(o, v) {
29 |     Object.defineProperty(o, "default", { enumerable: true, value: v });
30 |   }) : function(o, v) {
31 |     o["default"] = v;
32 |   });
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#654 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/messaging/inbound/reaction-handler.js:33](#)

Dangerous execution: `var __importStar = (this && this.__importStar) || (function () {`

```
31 |         o["default"] = v;
32 |     });
> 33 |     var __importStar = (this && this.__importStar) || (function () {
34 |         var ownKeys = function(o) {...
35 |             ownKeys = Object.getOwnPropertyNames || function (o) {
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#655 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/messaging/inbound/reaction-handler.js:34](#)

Dangerous execution: `var ownKeys = function(o) {`

```
32 |     });
33 |     var __importStar = (this && this.__importStar) || (function () {
> 34 |         var ownKeys = function(o) {
35 |             ownKeys = Object.getOwnPropertyNames || function (o) {
36 |                 var ar = [];
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#656 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/messaging/inbound/reaction-handler.js:35](#)

Dangerous execution: `ownKeys = Object.getOwnPropertyNames || function (o) {`

```
33 |     var __importStar = (this && this.__importStar) || (function () {
34 |         var ownKeys = function(o) {
> 35 |             ownKeys = Object.getOwnPropertyNames || function (o) {
36 |                 var ar = [];
37 |                 for (var k in o) if (Object.prototype.hasOwnProperty.call(o, k)) ar[ar.length] = k;
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#657 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/messaging/inbound/reaction-handler.js:42](#)

Dangerous execution: return function (mod) {

```
40 |         return ownKeys(o);
41 |     };
> 42 |     return function (mod) {
43 |         if (mod && mod.__esModule) return mod;...
44 |         var result = {};
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#658 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/inbound/reaction-handler.js:53](#)

Dependency without integrity verification

```
51 | exports.resolveReactionContext = resolveReactionContext;
52 | exports.handleFeishuReaction = handleFeishuReaction;
> 53 | const crypto = __importStar(require("node:crypto"));
54 | const reply_history_1 = require("openclaw/plugin-sdk/reply-history");
55 | const accounts_1 = require("../core/accounts.js");
```

Remediation:

1. Use lockfiles (`package-lock.json`, `poetry.lock`, `requirements.txt` with hashes). 2. Pin exact dependency versions — never use `>=` or `latest`. 3. Run `npm audit` / `pip-audit` in CI. 4. Use `pip install --require-hashes` for Python. 5. Verify package signatures where available.

#659 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/inbound/reaction-handler.js:54](#)

Dependency without integrity verification

```
52 | exports.handleFeishuReaction = handleFeishuReaction;
53 | const crypto = __importStar(require("node:crypto"));
> 54 | const reply_history_1 = require("openclaw/plugin-sdk/reply-history");
55 | const accounts_1 = require("../core/accounts.js");
56 | const message_lookup_1 = require("../shared/message-lookup.js");
```

Remediation:

1. Use lockfiles (`package-lock.json`, `poetry.lock`, `requirements.txt` with hashes). 2. Pin exact dependency versions — never use `>=` or `latest`. 3. Run `npm audit` / `pip-audit` in CI. 4. Use `pip install --require-hashes` for Python. 5. Verify package signatures where available.

#660 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/inbound/reaction-handler.js:55](#)

Dependency without integrity verification

```
53 | const crypto = __importStar(require("node:crypto"));
54 | const reply_history_1 = require("openclaw/plugin-sdk/reply-history");
> 55 | const accounts_1 = require("../core/accounts.js");
56 | const message_lookup_1 = require("../shared/message-lookup.js");
57 | const chat_info_cache_1 = require("../core/chat-info-cache.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#661 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/inbound/reaction-handler.js:56](#)

Dependency without integrity verification

```
54 | const reply_history_1 = require("openclaw/plugin-sdk/reply-history");
> 55 | const accounts_1 = require("../core/accounts.js");
56 | const message_lookup_1 = require("../shared/message-lookup.js");
57 | const chat_info_cache_1 = require("../core/chat-info-cache.js");...
58 | const lark_logger_1 = require("../core/lark-logger.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#662 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/inbound/reaction-handler.js:57](#)

Dependency without integrity verification

```
55 | const accounts_1 = require("../core/accounts.js");
56 | const message_lookup_1 = require("../shared/message-lookup.js");
> 57 | const chat_info_cache_1 = require("../core/chat-info-cache.js");
58 | const lark_logger_1 = require("../core/lark-logger.js");
59 | const user_name_cache_1 = require("../user-name-cache.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#663 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/inbound/reaction-handler.js:58](#)

Dependency without integrity verification

```
56 | const message_lookup_1 = require("../shared/message-lookup.js");
57 | const chat_info_cache_1 = require("../core/chat-info-cache.js");
> 58 | const lark_logger_1 = require("../core/lark-logger.js");
59 | const user_name_cache_1 = require("../user-name-cache.js");
60 | const dispatch_1 = require("../dispatch.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#664 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/inbound/reaction-handler.js:59](#)

Dependency without integrity verification

```
57 | const chat_info_cache_1 = require("../core/chat-info-cache.js");
58 | const lark_logger_1 = require("../core/lark-logger.js");
> 59 | const user_name_cache_1 = require("./user-name-cache.js");
60 | const dispatch_1 = require("./dispatch.js");...
61 | const policy_1 = require("./policy.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#665 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/inbound/reaction-handler.js:60](#)

Dependency without integrity verification

```
58 | const lark_logger_1 = require("../core/lark-logger.js");
59 | const user_name_cache_1 = require("./user-name-cache.js");
> 60 | const dispatch_1 = require("./dispatch.js");
61 | const policy_1 = require("./policy.js");
62 | const logger = (0, lark_logger_1.larkLogger)('inbound/reaction-handler');
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#666 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/inbound/reaction-handler.js:61](#)

Dependency without integrity verification

```
59 | const user_name_cache_1 = require("./user-name-cache.js");
60 | const dispatch_1 = require("./dispatch.js");
> 61 | const policy_1 = require("./policy.js");
62 | const logger = (0, lark_logger_1.larkLogger)('inbound/reaction-handler');
63 | const REACTION_VERIFY_TIMEOUT_MS = 3_000;
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#667 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/inbound/synthetic-message.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#668 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/inbound/synthetic-message.js:13](#)

Dependency without integrity verification

```
11 | Object.defineProperty(exports, "__esModule", { value: true });
12 | exports.dispatchSyntheticTextMessage = dispatchSyntheticTextMessage;
> 13 | const chat_queue_1 = require("../channel/chat-queue.js");
    14 | const lark_ticket_1 = require("../core/lark-ticket.js");...
    15 | const handler_registry_1 = require("../handler-registry.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#669 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/inbound/synthetic-message.js:14](#)

Dependency without integrity verification

```
12 | exports.dispatchSyntheticTextMessage = dispatchSyntheticTextMessage;
13 | const chat_queue_1 = require("../channel/chat-queue.js");
> 14 | const lark_ticket_1 = require("../core/lark-ticket.js");
    15 | const handler_registry_1 = require("../handler-registry.js");
    16 | async function dispatchSyntheticTextMessage(params) {
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#670 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/inbound/synthetic-message.js:15](#)

Dependency without integrity verification

```
13 | const chat_queue_1 = require("../channel/chat-queue.js");
14 | const lark_ticket_1 = require("../core/lark-ticket.js");
> 15 | const handler_registry_1 = require("../handler-registry.js");
    16 | async function dispatchSyntheticTextMessage(params) {
    17 |     const handleFeishuMessage = (0, handler_registry_1.getInboundHandler)();
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#671 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/inbound/synthetic-message.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
   2 | /**
   3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#672 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/inbound/user-name-cache-store.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
    2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates...
    3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#673 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/messaging/inbound/user-name-cache-store.js:27](#)

High-risk permission pattern: `this.map.delete(openId)`;

```
> 25 |         return false;
    26 |         if (entry.expireAt <= Date.now()) {
    27 |             this.map.delete(openId);
    28 |             return false;
    29 |         }
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#674 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/messaging/inbound/user-name-cache-store.js:37](#)

High-risk permission pattern: `this.map.delete(openId)`;

```
> 35 |         return undefined;
    36 |         if (entry.expireAt <= Date.now()) {
    37 |             this.map.delete(openId);
    38 |             return undefined;
    39 |         }
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#675 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/messaging/inbound/user-name-cache-store.js:40](#)

High-risk permission pattern: `this.map.delete(openId)`;

```
> 38 |         return undefined;
    39 |     }
    40 |     this.map.delete(openId);
    41 |     this.map.set(openId, entry);
    42 |     return entry.name;
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#676 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/messaging/inbound/user-name-cache-store.js:45](#)

High-risk permission pattern: `this.map.delete(openId);`

```
43 |     }
44 |     set(openId, name) {
45 |         this.map.delete(openId);
46 |         this.map.set(openId, { name, expireAt: Date.now() + this.ttlMs });...
47 |         this.evict();
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#677 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/messaging/inbound/user-name-cache-store.js:51](#)

High-risk permission pattern: `this.map.delete(openId);`

```
49 |     setMany(entries) {
50 |         for (const [openId, name] of entries) {
51 |             this.map.delete(openId);
52 |             this.map.set(openId, { name, expireAt: Date.now() + this.ttlMs });
53 |         }
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#678 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/messaging/inbound/user-name-cache-store.js:75](#)

High-risk permission pattern: `this.map.delete(oldest);`

```
73 |         const oldest = this.map.keys().next().value;
74 |         if (oldest !== undefined)
75 |             this.map.delete(oldest);
76 |     }
77 | }
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#679 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/messaging/inbound/user-name-cache-store.js:92](#)

High-risk permission pattern: `registry.delete(accountId)`;

```
90 |         if (accountId !== undefined) {
91 |             registry.get(accountId)?.clear();
> 92 |             registry.delete(accountId);
93 |         }...
94 |     } else {
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#680 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/inbound/user-name-cache-store.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
2 | /**
3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#681 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/inbound/user-name-cache.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#682 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/messaging/inbound/user-name-cache.js:24](#)

Dangerous execution: `Object.defineProperty(exports, "UserNameCache", { enumerable: true, get: function`

```
22 | const permission_1 = require("./permission.js");
23 | var user_name_cache_store_2 = require("./user-name-cache-store.js");
> 24 | Object.defineProperty(exports, "UserNameCache", { enumerable: true, get: function () { return
user_name_cache_store_2.UserNameCache; } });
25 | Object.defineProperty(exports, "clearUserNameCache", { enumerable: true, get: function () { return
user_name_cache_store_2.clearUserNameCache; } });
26 | Object.defineProperty(exports, "getUserNameCache", { enumerable: true, get: function () { return
user_name_cache_store_2.getUserNameCache; } });
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#683 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/messaging/inbound/user-name-cache.js:25](#)

Dangerous execution: `Object.defineProperty(exports, "clearUserNameCache", { enumerable: true, get: fu`

```
23 | var user_name_cache_store_2 = require("../user-name-cache-store.js");
24 | Object.defineProperty(exports, "UserNameCache", { enumerable: true, get: function () { return
user_name_cache_store_2.UserNameCache; } });
> 25 | Object.defineProperty(exports, "clearUserNameCache", { enumerable: true, get: function () { return
user_name_cache_store_2.clearUserNameCache; } });
26 | Object.defineProperty(exports, "getUserNameCache", { enumerable: true, get: function () { return
user_name_cache_store_2.getUserNameCache; } });
27 | // -----
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#684 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/messaging/inbound/user-name-cache.js:26](#)

Dangerous execution: `Object.defineProperty(exports, "getUserNameCache", { enumerable: true, get: func`

```
24 | Object.defineProperty(exports, "UserNameCache", { enumerable: true, get: function () { return
user_name_cache_store_2.UserNameCache; } });
25 | Object.defineProperty(exports, "clearUserNameCache", { enumerable: true, get: function () { return
user_name_cache_store_2.clearUserNameCache; } });
> 26 | Object.defineProperty(exports, "getUserNameCache", { enumerable: true, get: function () { return
user_name_cache_store_2.getUserNameCache; } });
27 | // -----
28 | // Batch resolve via contact/v3/users/batch
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#685 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/inbound/user-name-cache.js:20](#)

Dependency without integrity verification

```
18 | exports.createBatchResolveNames = createBatchResolveNames;
19 | exports.resolveUserName = resolveUserName;
> 20 | const lark_client_1 = require("../core/lark-client.js");
21 | const user_name_cache_store_1 = require("../user-name-cache-store.js");
22 | const permission_1 = require("../permission.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use `>=` or `latest`. 3. Run `npm audit` / `pip-audit` in CI. 4. Use `pip install --require-hashes` for Python. 5. Verify package signatures where available.

#686 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/inbound/user-name-cache.js:21](#)

Dependency without integrity verification

```
19 | exports.resolveUserName = resolveUserName;
20 | const lark_client_1 = require("../core/lark-client.js");
> 21 | const user_name_cache_store_1 = require("./user-name-cache-store.js");
    22 | const permission_1 = require("./permission.js");...
23 | var user_name_cache_store_2 = require("./user-name-cache-store.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#687 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/inbound/user-name-cache.js:22](#)

Dependency without integrity verification

```
20 | const lark_client_1 = require("../core/lark-client.js");
21 | const user_name_cache_store_1 = require("./user-name-cache-store.js");
> 22 | const permission_1 = require("./permission.js");
    23 | var user_name_cache_store_2 = require("./user-name-cache-store.js");
24 | Object.defineProperty(exports, "UserNameCache", { enumerable: true, get: function () { return
    user_name_cache_store_2.UserNameCache; } });
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#688 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/inbound/user-name-cache.js:23](#)

Dependency without integrity verification

```
21 | const user_name_cache_store_1 = require("./user-name-cache-store.js");
22 | const permission_1 = require("./permission.js");
> 23 | var user_name_cache_store_2 = require("./user-name-cache-store.js");
    24 | Object.defineProperty(exports, "UserNameCache", { enumerable: true, get: function () { return
    user_name_cache_store_2.UserNameCache; } });
25 | Object.defineProperty(exports, "clearUserNameCache", { enumerable: true, get: function () { return
    user_name_cache_store_2.clearUserNameCache; } });
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#689 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/inbound/user-name-cache.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
   2 | /**
   3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#690 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/messaging/outbound/actions.d.ts:8](#)

High-risk permission pattern: * built-in `message` tool can route send, react, delete and other

```
6 | *
7 | * Implements the standard message-action interface so the framework's
> 8 | * built-in `message` tool can route send, react, delete and other
9 | * actions to Feishu...
10 | *
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#691 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/outbound/actions.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
2 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
3 | * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#692 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/messaging/outbound/actions.js:9](#)

High-risk permission pattern: * built-in `message` tool can route send, react, delete and other

```
7 | *
8 | * Implements the standard message-action interface so the framework's
> 9 | * built-in `message` tool can route send, react, delete and other
10 | * actions to Feishu.
11 | *
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#693 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/messaging/outbound/actions.js:47](#)

High-risk permission pattern: 'delete',

```
45 |     'react',
46 |     'reactions',
> 47 |     'delete',
    48 |     'unsend',...
    49 |     // "member-info",
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#694 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/messaging/outbound/actions.js:151](#)

High-risk permission pattern: case 'delete':

```
149 |         case 'reactions':
150 |             return await handleReactions(cfg, params, aid);
> 151 |         case 'delete':
    152 |             case 'unsend':
    153 |                 return await handleDelete(cfg, params, aid);
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#695 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/messaging/outbound/actions.js:308](#)

High-risk permission pattern: // Delete

```
306 |     }
307 |     // -----
> 308 |     // Delete
    309 |     // -----
    310 |     async function handleDelete(cfg, params, accountId) {
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#696 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/messaging/outbound/actions.js:312](#)

High-risk permission pattern: log.info('delete: messageId=\${messageId}');

```
310 |     async function handleDelete(cfg, params, accountId) {
311 |         const messageId = (0, param_readers_1.readStringParam)(params, 'messageId', { required: true });
> 312 |         log.info('delete: messageId=${messageId}');
    313 |         const client = lark_client_1.LarkClient.fromCfg(cfg, accountId).sdk;
    314 |         const res = await client.im.message.delete({
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#697 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/messaging/outbound/actions.js:314](#)

High-risk permission pattern: `const res = await client.im.message.delete({`

```
312 |     log.info(`delete: messageId=${messageId}`);
> 313 |     const client = lark_client_1.LarkClient.fromCfg(cfg, accountId).sdk;
    314 |     const res = await client.im.message.delete({
      |           path: { message_id: messageId },...
    315 |     });
    316 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#698 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/messaging/outbound/actions.js:317](#)

High-risk permission pattern: `assertLarkOk(res, `delete message ${messageId}`);`

```
315 |         path: { message_id: messageId },
316 |     });
> 317 |     assertLarkOk(res, `delete message ${messageId}`);
    318 |     log.info(`delete: done, messageId=${messageId}`);
    319 |     return (0, sdk_compat_1.jsonResult)({ ok: true, messageId, deleted: true });
    319 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#699 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/messaging/outbound/actions.js:318](#)

High-risk permission pattern: `log.info(`delete: done, messageId=${messageId}`);`

```
316 |     });
317 |     assertLarkOk(res, `delete message ${messageId}`);
> 318 |     log.info(`delete: done, messageId=${messageId}`);
    319 |     return (0, sdk_compat_1.jsonResult)({ ok: true, messageId, deleted: true });
    320 | }
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#700 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/outbound/actions.js:18](#)

Dependency without integrity verification

```
16 | Object.defineProperty(exports, "__esModule", { value: true });
17 | exports.feishuMessageActions = void 0;
> 18 | const tool_send_1 = require("openclaw/plugin-sdk/tool-send");
    19 | const param_readers_1 = require("openclaw/plugin-sdk/param-readers");...
    20 | const sdk_compat_1 = require("../core/sdk-compat.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#701 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/outbound/actions.js:19](#)

Dependency without integrity verification

```
17 | exports.feishuMessageActions = void 0;
18 | const tool_send_1 = require("openclaw/plugin-sdk/tool-send");
> 19 | const param_readers_1 = require("openclaw/plugin-sdk/param-readers");
    20 | const sdk_compat_1 = require("../core/sdk-compat.js");
    21 | const lark_client_1 = require("../core/lark-client.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#702 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/outbound/actions.js:20](#)

Dependency without integrity verification

```
18 | const tool_send_1 = require("openclaw/plugin-sdk/tool-send");
19 | const param_readers_1 = require("openclaw/plugin-sdk/param-readers");
> 20 | const sdk_compat_1 = require("../core/sdk-compat.js");
    21 | const lark_client_1 = require("../core/lark-client.js");
    22 | const accounts_1 = require("../core/accounts.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#703 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/outbound/actions.js:21](#)

Dependency without integrity verification

```
19 | const param_readers_1 = require("openclaw/plugin-sdk/param-readers");
20 | const sdk_compat_1 = require("../core/sdk-compat.js");
> 21 | const lark_client_1 = require("../core/lark-client.js");
    22 | const accounts_1 = require("../core/accounts.js");
    23 | const lark_logger_1 = require("../core/lark-logger.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#704 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/outbound/actions.js:22](#)

Dependency without integrity verification

```
20 | const sdk_compat_1 = require("../core/sdk-compat.js");
> 21 | const lark_client_1 = require("../core/lark-client.js");
    22 | const accounts_1 = require("../core/accounts.js");
    23 | const lark_logger_1 = require("../core/lark-logger.js");...
    24 | const reactions_1 = require("./reactions.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#705 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/outbound/actions.js:23](#)

Dependency without integrity verification

```
21 | const lark_client_1 = require("../core/lark-client.js");
> 22 | const accounts_1 = require("../core/accounts.js");
    23 | const lark_logger_1 = require("../core/lark-logger.js");
    24 | const reactions_1 = require("./reactions.js");
    25 | const deliver_1 = require("./deliver.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#706 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/outbound/actions.js:24](#)

Dependency without integrity verification

```
22 | const accounts_1 = require("../core/accounts.js");
> 23 | const lark_logger_1 = require("../core/lark-logger.js");
    24 | const reactions_1 = require("./reactions.js");
    25 | const deliver_1 = require("./deliver.js");
    26 | const media_1 = require("./media.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#707 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/outbound/actions.js:25](#)

Dependency without integrity verification

```
23 | const lark_logger_1 = require("../core/lark-logger.js");
24 | const reactions_1 = require("../reactions.js");
> 25 | const deliver_1 = require("../deliver.js");
    26 | const media_1 = require("../media.js");...
    27 | const log = (0, lark_logger_1.larkLogger)('outbound/actions');
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#708 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/outbound/actions.js:26](#)

Dependency without integrity verification

```
24 | const reactions_1 = require("../reactions.js");
25 | const deliver_1 = require("../deliver.js");
> 26 | const media_1 = require("../media.js");
    27 | const log = (0, lark_logger_1.larkLogger)('outbound/actions');
    28 | // -----
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#709 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/outbound/chat-manage.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
    2 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
    3 | * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#710 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/messaging/outbound/chat-manage.js:74](#)

High-risk permission pattern: const res = await client.im.v1.chatMembers.delete({

```
72 | const { cfg, chatId, memberIds, accountId } = params;
73 | const client = lark_client_1.LarkClient.fromCfg(cfg, accountId).sdk;
> 74 | const res = await client.im.v1.chatMembers.delete({
    75 |   path: { chat_id: chatId },
    76 |   data: { id_list: memberIds },
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#711 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/outbound/chat-manage.js:17](#)

Dependency without integrity verification

```
15 | exports.removeChatMembersFeishu = removeChatMembersFeishu;
16 | exports.listChatMembersFeishu = listChatMembersFeishu;
17 | const lark_client_1 = require("../core/lark-client.js");
18 | // -----
19 | // Helpers
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#712 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/outbound/chat-manage.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
   2 | /**
   3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#713 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/outbound/deliver.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
   2 |  * Standalone text and media delivery functions for the Lark/Feishu channel.
   3 |  *
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#714 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/outbound/deliver.js:8](#)

Dependency without integrity verification

```
6 | exports.sendMediaLark = sendMediaLark;  
7 | exports.sendCommentReplyLark = sendCommentReplyLark;  
> 8 | const accounts_1 = require("../core/accounts.js");  
9 | const lark_client_1 = require("../core/lark-client.js");...  
10 | const targets_1 = require("../core/targets.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#715 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/outbound/deliver.js:9](#)

Dependency without integrity verification

```
7 | exports.sendCommentReplyLark = sendCommentReplyLark;  
8 | const accounts_1 = require("../core/accounts.js");  
> 9 | const lark_client_1 = require("../core/lark-client.js");  
10 | const targets_1 = require("../core/targets.js");  
11 | const comment_target_1 = require("../core/comment-target.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#716 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/outbound/deliver.js:10](#)

Dependency without integrity verification

```
8 | const accounts_1 = require("../core/accounts.js");  
9 | const lark_client_1 = require("../core/lark-client.js");  
> 10 | const targets_1 = require("../core/targets.js");  
11 | const comment_target_1 = require("../core/comment-target.js");  
12 | const markdown_style_1 = require("../card/markdown-style.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#717 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/outbound/deliver.js:11](#)

Dependency without integrity verification

```
9 | const lark_client_1 = require("../core/lark-client.js");  
10 | const targets_1 = require("../core/targets.js");  
> 11 | const comment_target_1 = require("../core/comment-target.js");  
12 | const markdown_style_1 = require("../card/markdown-style.js");  
13 | const api_error_1 = require("../core/api-error.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#718 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/outbound/deliver.js:12](#)

Dependency without integrity verification

```
10 | const targets_1 = require("../core/targets.js");
> 11 | const comment_target_1 = require("../core/comment-target.js");
    12 | const markdown_style_1 = require("../card/markdown-style.js");
    13 | const api_error_1 = require("../core/api-error.js");...
    14 | const lark_logger_1 = require("../core/lark-logger.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#719 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/outbound/deliver.js:13](#)

Dependency without integrity verification

```
11 | const comment_target_1 = require("../core/comment-target.js");
12 | const markdown_style_1 = require("../card/markdown-style.js");
> 13 | const api_error_1 = require("../core/api-error.js");
    14 | const lark_logger_1 = require("../core/lark-logger.js");
    15 | const media_1 = require("../media.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#720 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/outbound/deliver.js:14](#)

Dependency without integrity verification

```
12 | const markdown_style_1 = require("../card/markdown-style.js");
13 | const api_error_1 = require("../core/api-error.js");
> 14 | const lark_logger_1 = require("../core/lark-logger.js");
    15 | const media_1 = require("../media.js");
    16 | const log = (0, lark_logger_1.larkLogger)('outbound/deliver');
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#721 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/outbound/deliver.js:15](#)

Dependency without integrity verification

```
13 | const api_error_1 = require("../core/api-error.js");
14 | const lark_logger_1 = require("../core/lark-logger.js");
> 15 | const media_1 = require("./media.js");
    16 | const log = (0, lark_logger_1.larkLogger)('outbound/deliver');...
17 | // -----
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#722 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/outbound/fetch.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
  2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
  3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#723 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/messaging/outbound/fetch.js:15](#)

Dangerous execution: Object.defineProperty(exports, "getMessageFeishu", { enumerable: true, get: func

```
13 | exports.getChatTypeFeishu = exports.getMessageFeishu = void 0;
14 | var message_lookup_1 = require("../shared/message-lookup.js");
> 15 | Object.defineProperty(exports, "getMessageFeishu", { enumerable: true, get: function () { return
    message_lookup_1.getMessageFeishu; } });
16 | var chat_info_cache_1 = require("../core/chat-info-cache.js");
17 | Object.defineProperty(exports, "getChatTypeFeishu", { enumerable: true, get: function () { return
    chat_info_cache_1.getChatTypeFeishu; } });
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#724 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/messaging/outbound/fetch.js:17](#)

Dangerous execution: Object.defineProperty(exports, "getChatTypeFeishu", { enumerable: true, get: fun

```
15 | Object.defineProperty(exports, "getMessageFeishu", { enumerable: true, get: function () { return
    message_lookup_1.getMessageFeishu; } });
16 | var chat_info_cache_1 = require("../core/chat-info-cache.js");
> 17 | Object.defineProperty(exports, "getChatTypeFeishu", { enumerable: true, get: function () { return
    chat_info_cache_1.getChatTypeFeishu; } });
18 |
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#725 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/outbound/fetch.js:14](#)

Dependency without integrity verification

```
12 | Object.defineProperty(exports, "__esModule", { value: true });
13 | exports.getChatTypeFeishu = exports.getMessageFeishu = void 0;
> 14 | var message_lookup_1 = require("../shared/message-lookup.js");
15 | Object.defineProperty(exports, "getMessageFeishu", { enumerable: true, get: function () { return
message_lookup_1.getMessageFeishu; } });
16 | var chat_info_cache_1 = require("../core/chat-info-cache.js");
```

Remediation:

1. Use lockfiles (`package-lock.json`, `poetry.lock`, `requirements.txt` with hashes). 2. Pin exact dependency versions — never use `>=` or `latest`. 3. Run `npm audit` / `pip-audit` in CI. 4. Use `pip install --require-hashes` for Python. 5. Verify package signatures where available.

#726 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/outbound/fetch.js:16](#)

Dependency without integrity verification

```
14 | var message_lookup_1 = require("../shared/message-lookup.js");
15 | Object.defineProperty(exports, "getMessageFeishu", { enumerable: true, get: function () { return
message_lookup_1.getMessageFeishu; } });
> 16 | var chat_info_cache_1 = require("../core/chat-info-cache.js");
17 | Object.defineProperty(exports, "getChatTypeFeishu", { enumerable: true, get: function () { return
chat_info_cache_1.getChatTypeFeishu; } });
18 |
```

Remediation:

1. Use lockfiles (`package-lock.json`, `poetry.lock`, `requirements.txt` with hashes). 2. Pin exact dependency versions — never use `>=` or `latest`. 3. Run `npm audit` / `pip-audit` in CI. 4. Use `pip install --require-hashes` for Python. 5. Verify package signatures where available.

#727 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/outbound/fetch.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
2 | /**
3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include `agent_id`, `timestamp`, `action`, `parameters`, and `outcome` in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#728 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/outbound/forward.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
  2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates...
  3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#729 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/outbound/forward.js:13](#)

Dependency without integrity verification

```
11 | Object.defineProperty(exports, "__esModule", { value: true });
12 | exports.forwardMessageFeishu = forwardMessageFeishu;
> 13 | const lark_client_1 = require("../core/lark-client.js");
14 | const targets_1 = require("../core/targets.js");
15 | // -----
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#730 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/outbound/forward.js:14](#)

Dependency without integrity verification

```
12 | exports.forwardMessageFeishu = forwardMessageFeishu;
13 | const lark_client_1 = require("../core/lark-client.js");
> 14 | const targets_1 = require("../core/targets.js");
15 | // -----
16 | // forwardMessageFeishu
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#731 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/outbound/forward.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
  2 | /**
  3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#732 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/outbound/media-url-utils.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
    2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates...
    3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#733 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/messaging/outbound/media-url-utils.js:6](#)

Dangerous execution: var __createBinding = (this && this.__createBinding) || (Object.create ? (functi

```
4 |  * SPDX-License-Identifier: MIT
5 |  */
> 6 | var __createBinding = (this && this.__createBinding) || (Object.create ? (function(o, m, k, k2) {
7 |   if (k2 === undefined) k2 = k;
8 |   var desc = Object.getOwnPropertyDescriptor(m, k);
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#734 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/messaging/outbound/media-url-utils.js:10](#)

Dangerous execution: desc = { enumerable: true, get: function() { return m[k]; } };

```
8 |   var desc = Object.getOwnPropertyDescriptor(m, k);
9 |   if (!desc || ("get" in desc ? !m.__esModule : desc.writable || desc.configurable)) {
> 10 |     desc = { enumerable: true, get: function() { return m[k]; } };
11 |   }
12 |   Object.defineProperty(o, k2, desc);
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#735 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/messaging/outbound/media-url-utils.js:13](#)

Dangerous execution: }) : (function(o, m, k, k2) {

```
11 |   }
12 |   Object.defineProperty(o, k2, desc);
> 13 | }) : (function(o, m, k, k2) {
14 |   if (k2 === undefined) k2 = k;
15 |   o[k2] = m[k];
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#736 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/messaging/outbound/media-url-utils.js:17](#)

Dangerous execution: `var __setModuleDefault = (this && this.__setModuleDefault) || (Object.create ? (`

```
15 |         o[k2] = m[k];
16 |     });
> 17 |     var __setModuleDefault = (this && this.__setModuleDefault) || (Object.create ? (function(o, v) {
18 |         Object.defineProperty(o, "default", { enumerable: true, value: v });...
19 |     }) : function(o, v) {
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#737 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/messaging/outbound/media-url-utils.js:19](#)

Dangerous execution: `}) : function(o, v) {`

```
17 |     var __setModuleDefault = (this && this.__setModuleDefault) || (Object.create ? (function(o, v) {
18 |         Object.defineProperty(o, "default", { enumerable: true, value: v });
> 19 |     }) : function(o, v) {
20 |         o["default"] = v;
21 |     });
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#738 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/messaging/outbound/media-url-utils.js:22](#)

Dangerous execution: `var __importStar = (this && this.__importStar) || (function () {`

```
20 |         o["default"] = v;
21 |     });
> 22 |     var __importStar = (this && this.__importStar) || (function () {
23 |         var ownKeys = function(o) {
24 |             ownKeys = Object.getOwnPropertyNames || function (o) {
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#739 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/messaging/outbound/media-url-utils.js:23](#)

Dangerous execution: var ownKeys = function(o) {

```
21 | });
22 | var __importStar = (this && this.__importStar) || (function () {
> 23 |     var ownKeys = function(o) {
24 |         ownKeys = Object.getOwnPropertyNames || function (o) {...
25 |         var ar = [];
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#740 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/messaging/outbound/media-url-utils.js:24](#)

Dangerous execution: ownKeys = Object.getOwnPropertyNames || function (o) {

```
22 | var __importStar = (this && this.__importStar) || (function () {
23 |     var ownKeys = function(o) {
> 24 |         ownKeys = Object.getOwnPropertyNames || function (o) {
25 |             var ar = [];
26 |             for (var k in o) if (Object.prototype.hasOwnProperty.call(o, k)) ar[ar.length] = k;
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#741 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/messaging/outbound/media-url-utils.js:31](#)

Dangerous execution: return function (mod) {

```
29 |         return ownKeys(o);
30 |     };
> 31 |     return function (mod) {
32 |         if (mod && mod.__esModule) return mod;
33 |         var result = {};
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#742 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/outbound/media-url-utils.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
2 | /**
3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#743 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/outbound/media.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
   2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates...
   3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#744 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/messaging/outbound/media.js:13](#)

Dangerous execution: `var __createBinding = (this && this.__createBinding) || (Object.create ? (functi`

```
11 |  */
12 |  /* eslint-disable @typescript-eslint/no-explicit-any */
> 13 |  var __createBinding = (this && this.__createBinding) || (Object.create ? (function(o, m, k, k2) {
14 |      if (k2 === undefined) k2 = k;
15 |      var desc = Object.getOwnPropertyDescriptor(m, k);
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#745 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/messaging/outbound/media.js:17](#)

Dangerous execution: `desc = { enumerable: true, get: function() { return m[k]; } };`

```
15 |      var desc = Object.getOwnPropertyDescriptor(m, k);
16 |      if (!desc || ("get" in desc ? !m.__esModule : desc.writable || desc.configurable)) {
> 17 |          desc = { enumerable: true, get: function() { return m[k]; } };
18 |      }
19 |      Object.defineProperty(o, k2, desc);
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#746 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/messaging/outbound/media.js:20](#)

Dangerous execution: `}} : (function(o, m, k, k2) {`

```
18 |      }
19 |      Object.defineProperty(o, k2, desc);
> 20 |  }} : (function(o, m, k, k2) {
21 |      if (k2 === undefined) k2 = k;
22 |      o[k2] = m[k];
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#747 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/messaging/outbound/media.js:24](#)

Dangerous execution: `var __setModuleDefault = (this && this.__setModuleDefault) || (Object.create ? (`

```
22 |         o[k2] = m[k];
23 |     });
> 24 |     var __setModuleDefault = (this && this.__setModuleDefault) || (Object.create ? (function(o, v) {
25 |         Object.defineProperty(o, "default", { enumerable: true, value: v });...
26 |     }) : function(o, v) {
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#748 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/messaging/outbound/media.js:26](#)

Dangerous execution: `}) : function(o, v) {`

```
24 |     var __setModuleDefault = (this && this.__setModuleDefault) || (Object.create ? (function(o, v) {
25 |         Object.defineProperty(o, "default", { enumerable: true, value: v });
26 |     }) : function(o, v) {
> 27 |         o["default"] = v;
28 |     });
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#749 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/messaging/outbound/media.js:29](#)

Dangerous execution: `var __importStar = (this && this.__importStar) || (function () {`

```
27 |         o["default"] = v;
28 |     });
> 29 |     var __importStar = (this && this.__importStar) || (function () {
30 |         var ownKeys = function(o) {
31 |             ownKeys = Object.getOwnPropertyNames || function (o) {
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#750 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/messaging/outbound/media.js:30](#)

Dangerous execution: var ownKeys = function(o) {

```
28 | });
29 | var __importStar = (this && this.__importStar) || (function () {
> 30 |     var ownKeys = function(o) {
31 |         ownKeys = Object.getOwnPropertyNames || function (o) {...
32 |         var ar = [];
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#751 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/messaging/outbound/media.js:31](#)

Dangerous execution: ownKeys = Object.getOwnPropertyNames || function (o) {

```
29 | var __importStar = (this && this.__importStar) || (function () {
30 |     var ownKeys = function(o) {
> 31 |         ownKeys = Object.getOwnPropertyNames || function (o) {
32 |             var ar = [];
33 |             for (var k in o) if (Object.prototype.hasOwnProperty.call(o, k)) ar[ar.length] = k;
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#752 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/messaging/outbound/media.js:38](#)

Dangerous execution: return function (mod) {

```
36 |         return ownKeys(o);
37 |     };
> 38 |     return function (mod) {
39 |         if (mod && mod.__esModule) return mod;
40 |         var result = {};
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#753 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/outbound/outbound.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | import type { ChannelOutboundAdapter } from 'openclaw/plugin-sdk/channel-send-result';
2 | /**
3 |  * Channel-specific payload for Feishu, carried in `ReplyPayload.channelData.feishu`.
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#754 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/outbound/outbound.js:5](#)

Dependency without integrity verification

```
3 | Object.defineProperty(exports, "__esModule", { value: true });
4 | exports.feishuOutbound = void 0;
> 5 | const lark_client_1 = require("../core/lark-client.js");
6 | const lark_logger_1 = require("../core/lark-logger.js");...
7 | const targets_1 = require("../core/targets.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#755 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/outbound/outbound.js:6](#)

Dependency without integrity verification

```
4 | exports.feishuOutbound = void 0;
5 | const lark_client_1 = require("../core/lark-client.js");
> 6 | const lark_logger_1 = require("../core/lark-logger.js");
7 | const targets_1 = require("../core/targets.js");
8 | const comment_target_1 = require("../core/comment-target.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#756 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/outbound/outbound.js:7](#)

Dependency without integrity verification

```
5 | const lark_client_1 = require("../core/lark-client.js");
6 | const lark_logger_1 = require("../core/lark-logger.js");
> 7 | const targets_1 = require("../core/targets.js");
8 | const comment_target_1 = require("../core/comment-target.js");
9 | const deliver_1 = require("./deliver.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#757 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/outbound/outbound.js:8](#)

Dependency without integrity verification

```
6 | const lark_logger_1 = require("../core/lark-logger.js");
7 | const targets_1 = require("../core/targets.js");
> 8 | const comment_target_1 = require("../core/comment-target.js");
9 | const deliver_1 = require("./deliver.js");
10 | const log = (0, lark_logger_1.larkLogger)('outbound/outbound');
```


Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#758 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/outbound/outbound.js:9](#)

Dependency without integrity verification

```
7 | const targets_1 = require("../core/targets.js");
> 8 | const comment_target_1 = require("../core/comment-target.js");
  9 | const deliver_1 = require("./deliver.js");
10 | const log = (0, lark_logger_1.larkLogger)('outbound/outbound');...
11 | /**
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#759 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/messaging/outbound/reactions.d.ts:97](#)

High-risk permission pattern: * @param params.reactionId - The platform-assigned reaction ID to delete.

```
95 | * @param params.cfg - Plugin configuration with Feishu credentials.
96 | * @param params.messageId - The message the reaction belongs to.
> 97 | * @param params.reactionId - The platform-assigned reaction ID to delete.
  98 | * @param params.accountId - Optional account identifier for multi-account setups.
99 | */
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#760 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/outbound/reactions.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
  2 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
  3 | * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#761 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/messaging/outbound/reactions.js:317](#)

High-risk permission pattern: * `@param params.reactionId` - The platform-assigned reaction ID to delete.

```
315 | * @param params.cfg - Plugin configuration with Feishu credentials.
316 | * @param params.messageId - The message the reaction belongs to.
> 317 | * @param params.reactionId - The platform-assigned reaction ID to delete.
318 | * @param params.accountId - Optional account identifier for multi-account setups...
319 | */
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#762 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/messaging/outbound/reactions.js:323](#)

High-risk permission pattern: `await client.im.messageReaction.delete({`

```
321 |     const { cfg, messageId, reactionId, accountId } = params;
322 |     const client = lark_client_1.LarkClient.fromCfg(cfg, accountId).sdk;
> 323 |     await client.im.messageReaction.delete({
324 |         path: {
325 |             message_id: messageId,
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#763 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/outbound/reactions.js:16](#)

Dependency without integrity verification

```
14 | exports.removeReactionFeishu = removeReactionFeishu;
15 | exports.listReactionsFeishu = listReactionsFeishu;
> 16 | const lark_client_1 = require("../core/lark-client.js");
17 | // -----
18 | // Feishu emoji constants
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use `>=` or `latest`. 3. Run `npm audit` / `pip-audit` in CI. 4. Use `pip install --require-hashes` for Python. 5. Verify package signatures where available.

#764 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/outbound/reactions.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
2 | /**
3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include `agent_id`, `timestamp`, `action`, `parameters`, and `outcome` in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#765 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/outbound/send.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
  2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates...
  3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#766 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/outbound/send.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
  2 | /**
  3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#767 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/outbound/typing.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
  2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
  3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#768 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/messaging/outbound/typing.js:117](#)

High-risk permission pattern: operation: 'im.messageReaction.delete(typing)',

```
115 |         await (0, message_unavailable_1.runWithMessageUnavailableGuard)({
116 |             messageId: state.messageId,
> 117 |             operation: 'im.messageReaction.delete(typing)',
118 |             fn: () => client.im.messageReaction.delete({
119 |                 path: {
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#769 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/messaging/outbound/typing.js:118](#)

High-risk permission pattern: `fn: () => client.im.messageReaction.delete({`

```
116 |         messageId: state.messageId,  
117 |         operation: 'im.messageReaction.delete(typing)',  
> 118 |         fn: () => client.im.messageReaction.delete({  
119 |             path: {...  
120 |                 message_id: state.messageId,
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#770 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/shared/message-lookup.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**  
2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates  
3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#771 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/shared/message-lookup.js:14](#)

Dependency without integrity verification

```
12 | Object.defineProperty(exports, "__esModule", { value: true });  
13 | exports.getMessageFeishu = getMessageFeishu;  
> 14 | const content_converter_1 = require("../converters/content-converter.js");  
15 | const lark_client_1 = require("../core/lark-client.js");  
16 | const lark_logger_1 = require("../core/lark-logger.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use `>=` or `latest`. 3. Run `npm audit` / `pip-audit` in CI. 4. Use `pip install --require-hashes` for Python. 5. Verify package signatures where available.

#772 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/shared/message-lookup.js:15](#)

Dependency without integrity verification

```
13 | exports.getMessageFeishu = getMessageFeishu;  
14 | const content_converter_1 = require("../converters/content-converter.js");  
> 15 | const lark_client_1 = require("../core/lark-client.js");  
16 | const lark_logger_1 = require("../core/lark-logger.js");  
17 | const log = (0, lark_logger_1.larkLogger)('shared/message-lookup');
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#773 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/shared/message-lookup.js:16](#)

Dependency without integrity verification

```
14 | const content_converter_1 = require("../converters/content-converter.js");
15 | const lark_client_1 = require("../core/lark-client.js");
> 16 | const lark_logger_1 = require("../core/lark-logger.js");
17 | const log = (0, lark_logger_1.larkLogger)('shared/message-lookup');...
18 | const user_name_cache_1 = require("../inbound/user-name-cache.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#774 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/shared/message-lookup.js:18](#)

Dependency without integrity verification

```
16 | const lark_logger_1 = require("../core/lark-logger.js");
17 | const log = (0, lark_logger_1.larkLogger)('shared/message-lookup');
> 18 | const user_name_cache_1 = require("../inbound/user-name-cache.js");
19 | const accounts_1 = require("../core/accounts.js");
20 | // -----
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#775 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/messaging/shared/message-lookup.js:19](#)

Dependency without integrity verification

```
17 | const log = (0, lark_logger_1.larkLogger)('shared/message-lookup');
18 | const user_name_cache_1 = require("../inbound/user-name-cache.js");
> 19 | const accounts_1 = require("../core/accounts.js");
20 | // -----
21 | // getMessageFeishu
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#776 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/types.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
  2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates...
  3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#777 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/messaging/types.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
  2 | /**
  3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#778 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/ask-user-question.d.ts:10](#)

High-risk permission pattern: * 3. JâQw execute() zËs•ÔVp { status: 'pending' }

```
8 | * 1. AI Æ u( AskUserQuestion JâQwÿ 0 Qe•î~~TÆ• ~y
9 | * 2. SÑ• form N=N' _ ~pNfSarg
> 10 | * 3. JâQw execute() zËs•ÔVp { status: 'pending' }
11 | * 4. u(b7XkQ™^hSU^vp¹QücDNpÿ form_value N k!`'Vp0
12 | * 5. handleAskUserAction %äg•{Thÿ lèQe synthetic message
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#779 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/ask-user-question.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
  2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
  3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#780 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/ask-user-question.js:11](#)

High-risk permission pattern: `* 3. JâQw execute() zËss•ÖVp { status: 'pending' }`

```
9 | * 1. AI Æ u( AskUserQuestion JâQwÿ 0 Qe•i~~TÆ• ~y
10 | * 2. SÑ• form NøN' _ ~bNfSarg
> 11 | * 3. JâQw execute() zËss•ÖVp { status: 'pending' }
12 | * 4. u(b7XkQ™~hSU^vp¹QücDNøÿ form_value N k!`'Vp0 ...
13 | * 5. handleAskUserAction %äg•{ThHÿ lèQe synthetic message
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#781 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/ask-user-question.js:98](#)

High-risk permission pattern: `pendingQuestions.delete(questionId);`

```
96 |         if (ctx) {
97 |             clearTimeout(ctx.ttlTimer);
> 98 |             pendingQuestions.delete(questionId);
99 |             const baseKey = (0, chat_queue_1.buildQueueKey)(ctx.accountId, ctx.chatId);
100 |             const set = byChatContext.get(baseKey);
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#782 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/ask-user-question.js:102](#)

High-risk permission pattern: `set.delete(questionId);`

```
100 |         const set = byChatContext.get(baseKey);
101 |         if (set) {
> 102 |             set.delete(questionId);
103 |             if (set.size === 0)
104 |                 byChatContext.delete(baseKey);
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#783 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/ask-user-question.js:104](#)

High-risk permission pattern: `byChatContext.delete(baseKey);`

```
102 |             set.delete(questionId);
103 |             if (set.size === 0)
> 104 |                 byChatContext.delete(baseKey);
105 |         }
106 |     }
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#784 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/ask-user-question.js:324](#)

High-risk permission pattern: // clicker). Per Feishu docs, delayed update must execute AFTER the callback

```
322 |         // Update card to "processing" state via API so ALL viewers see it (not just
323 |         // the clicking user — the callback-return card field only updates for the
> 324 |         // clicker). Per Feishu docs, delayed update must execute AFTER the callback
325 |         // response — since we're in setImmediate, the callback has already returned....
326 |         try {
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#785 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/ask-user-question.js:373](#)

High-risk permission pattern: // Wait for the task to actually execute (not just enqueue)

```
371 |         },
372 |         });
> 373 |         // Wait for the task to actually execute (not just enqueue)
374 |         await promise;
375 |         consumePendingQuestion(ctx.questionId);
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#786 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/ask-user-question.js:793](#)

High-risk permission pattern: async execute(_toolCallId, params) {

```
791 |         'For free-text input, set options to an empty array.',
792 |         parameters: AskUserQuestionSchema,
> 793 |         async execute(_toolCallId, params) {
794 |             const { questions } = params;
795 |             const ticket = (0, lark_ticket_1.getTicket)();
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#787 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/ask-user-question.js:22](#)

Dependency without integrity verification

```
20 | exports.handleAskUserAction = handleAskUserAction;
21 | exports.registerAskUserQuestionTool = registerAskUserQuestionTool;
> 22 | const node_crypto_1 = require("node:crypto");
    23 | const typebox_1 = require("@sinclair/typebox");...
    24 | const lark_ticket_1 = require("../core/lark-ticket.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#788 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/ask-user-question.js:23](#)

Dependency without integrity verification

```
21 | exports.registerAskUserQuestionTool = registerAskUserQuestionTool;
22 | const node_crypto_1 = require("node:crypto");
> 23 | const typebox_1 = require("@sinclair/typebox");
    24 | const lark_ticket_1 = require("../core/lark-ticket.js");
    25 | const lark_logger_1 = require("../core/lark-logger.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#789 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/ask-user-question.js:24](#)

Dependency without integrity verification

```
22 | const node_crypto_1 = require("node:crypto");
23 | const typebox_1 = require("@sinclair/typebox");
> 24 | const lark_ticket_1 = require("../core/lark-ticket.js");
    25 | const lark_logger_1 = require("../core/lark-logger.js");
    26 | const cardkit_1 = require("../card/cardkit.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#790 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/ask-user-question.js:25](#)

Dependency without integrity verification

```
23 | const typebox_1 = require("@sinclair/typebox");
24 | const lark_ticket_1 = require("../core/lark-ticket.js");
> 25 | const lark_logger_1 = require("../core/lark-logger.js");
    26 | const cardkit_1 = require("../card/cardkit.js");
    27 | const chat_queue_1 = require("../channel/chat-queue.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#791 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/ask-user-question.js:26](#)

Dependency without integrity verification

```
24 | const lark_ticket_1 = require("../core/lark-ticket.js");
> 25 | const lark_logger_1 = require("../core/lark-logger.js");
    26 | const cardkit_1 = require("../card/cardkit.js");
    27 | const chat_queue_1 = require("../channel/chat-queue.js");...
    28 | const handler_1 = require("../messaging/inbound/handler.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#792 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/ask-user-question.js:27](#)

Dependency without integrity verification

```
25 | const lark_logger_1 = require("../core/lark-logger.js");
> 26 | const cardkit_1 = require("../card/cardkit.js");
    27 | const chat_queue_1 = require("../channel/chat-queue.js");
    28 | const handler_1 = require("../messaging/inbound/handler.js");
    29 | const helpers_1 = require("../helpers.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#793 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/ask-user-question.js:28](#)

Dependency without integrity verification

```
26 | const cardkit_1 = require("../card/cardkit.js");
> 27 | const chat_queue_1 = require("../channel/chat-queue.js");
    28 | const handler_1 = require("../messaging/inbound/handler.js");
    29 | const helpers_1 = require("../helpers.js");
    30 | const log = (0, lark_logger_1.larkLogger)('tools/ask-user-question');
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#794 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/ask-user-question.js:29](#)

Dependency without integrity verification

```
27 | const chat_queue_1 = require("../channel/chat-queue.js");
28 | const handler_1 = require("../messaging/inbound/handler.js");
> 29 | const helpers_1 = require("../helpers.js");
30 | const log = (0, lark_logger_1.larkLogger)('tools/ask-user-question');...
31 | // -----
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#795 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[src/tools/auto-auth.js:433](#)

Potential secret: possible hardcoded secret

```
431 |         template: 'green',
432 |         padding: '12px 12px 12px 12px',
> 433 |         icon: { tag: 'standard_icon', token: 'yes_filled' },
434 |     },
435 |     body: {
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#796 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/auto-auth.js:181](#)

High-risk permission pattern: setTimeout() => authBatches.delete(bufferKey), AUTH_COOLDOWN_MS);

```
179 |         // 0 T}N- executing R e/^vY u( resultPromiseÿ N 0 R ^úe°Sarg0
180 |         // Q·Stg ~0g_T n t 0
> 181 |         setTimeout(() => authBatches.delete(bufferKey), AUTH_COOLDOWN_MS);
182 |     }
183 | }, debounceMs);
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#797 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/auto-auth.js:224](#)

High-risk permission pattern: deferredUserAuth.delete(deferKey);

```
222 |         if (flow.ticket?.senderOpenId) {
223 |             const deferKey = `${flow.accountId}:${flow.ticket.senderOpenId}:${flow.ticket.messageId}
> 224 |             deferredUserAuth.delete(deferKey);
225 |         }
226 |         this.flows.delete(operationId);
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#798 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/auto-auth.js:226](#)

High-risk permission pattern: `this.flows.delete(operationId);`

```
224 |         deferredUserAuth.delete(deferKey);
225 |     }
> 226 |     this.flows.delete(operationId);
227 |     // gANöR -dÿ -2kb<iR ]ð^«e° flow %†vöV„}" _ ...
228 |     if (this.dedupIndex.get(flow.dedupKey) === operationId) {
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#799 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/auto-auth.js:229](#)

High-risk permission pattern: `this.dedupIndex.delete(flow.dedupKey);`

```
227 |     // gANöR -dÿ -2kb<iR ]ð^«e° flow %†vöV„}" _
228 |     if (this.dedupIndex.get(flow.dedupKey) === operationId) {
> 229 |         this.dedupIndex.delete(flow.dedupKey);
230 |     }
231 |     if (this.activeCardIndex.get(flow.activeCardKey) === operationId) {
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#800 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/auto-auth.js:232](#)

High-risk permission pattern: `this.activeCardIndex.delete(flow.activeCardKey);`

```
230 |     }
231 |     if (this.activeCardIndex.get(flow.activeCardKey) === operationId) {
> 232 |         this.activeCardIndex.delete(flow.activeCardKey);
233 |     }
234 | }
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#801 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/auto-auth.js:246](#)

High-risk permission pattern: `this.flows.delete(oldOperationId);`

```
244 |         return undefined;
245 |         // n t e c }"
> 246 |         this.flows.delete(oldOperationId);
247 |         if (updates?.dedupKey) {...
248 |             if (this.dedupIndex.get(flow.dedupKey) === oldOperationId) {
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#802 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/auto-auth.js:249](#)

High-risk permission pattern: `this.dedupIndex.delete(flow.dedupKey);`

```
247 |         if (updates?.dedupKey) {
248 |             if (this.dedupIndex.get(flow.dedupKey) === oldOperationId) {
> 249 |                 this.dedupIndex.delete(flow.dedupKey);
250 |             }
251 |             flow.dedupKey = updates.dedupKey;
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#803 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/auto-auth.js:643](#)

High-risk permission pattern: `deferredUserAuth.delete(deferKey);`

```
641 |         const consumedDeferred = deferKey ? deferredUserAuth.get(deferKey) : undefined;
642 |         if (consumedDeferred && deferKey) {
> 643 |             deferredUserAuth.delete(deferKey);
644 |             log.info(`consumed deferred user auth scopes: [${[...consumedDeferred.scopes].join(', ')}]`);
645 |         }
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#804 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/auto-auth.js:35](#)

Dependency without integrity verification

```
33 |     exports.handleCardAction = handleCardAction;
34 |     exports.handleInvokeErrorWithAutoAuth = handleInvokeErrorWithAutoAuth;
> 35 |     const lark_ticket_1 = require("../core/lark-ticket.js");
36 |     const lark_logger_1 = require("../core/lark-logger.js");
37 |     const log = (0, lark_logger_1.larkLogger)('tools/auto-auth');
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#805 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/auto-auth.js:36](#)

Dependency without integrity verification

```
34 | exports.handleInvokeErrorWithAutoAuth = handleInvokeErrorWithAutoAuth;
> 35 | const lark_ticket_1 = require("../core/lark-ticket.js");
    36 | const lark_logger_1 = require("../core/lark-logger.js");
    37 | const log = (0, lark_logger_1.larkLogger)('tools/auto-auth');...
    38 | const api_error_1 = require("../core/api-error.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#806 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/auto-auth.js:38](#)

Dependency without integrity verification

```
36 | const lark_logger_1 = require("../core/lark-logger.js");
> 37 | const log = (0, lark_logger_1.larkLogger)('tools/auto-auth');
    38 | const api_error_1 = require("../core/api-error.js");
    39 | const accounts_1 = require("../core/accounts.js");
    40 | const tool_client_1 = require("../core/tool-client.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#807 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/auto-auth.js:39](#)

Dependency without integrity verification

```
37 | const log = (0, lark_logger_1.larkLogger)('tools/auto-auth');
> 38 | const api_error_1 = require("../core/api-error.js");
    39 | const accounts_1 = require("../core/accounts.js");
    40 | const tool_client_1 = require("../core/tool-client.js");
    41 | const app_scope_checker_1 = require("../core/app-scope-checker.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#808 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/auto-auth.js:40](#)

Dependency without integrity verification

```
38 | const api_error_1 = require("../core/api-error.js");
39 | const accounts_1 = require("../core/accounts.js");
> 40 | const tool_client_1 = require("../core/tool-client.js");
41 | const app_scope_checker_1 = require("../core/app-scope-checker.js");...
42 | const lark_client_1 = require("../core/lark-client.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#809 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/auto-auth.js:41](#)

Dependency without integrity verification

```
39 | const accounts_1 = require("../core/accounts.js");
40 | const tool_client_1 = require("../core/tool-client.js");
> 41 | const app_scope_checker_1 = require("../core/app-scope-checker.js");
42 | const lark_client_1 = require("../core/lark-client.js");
43 | const cardkit_1 = require("../card/cardkit.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#810 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/auto-auth.js:42](#)

Dependency without integrity verification

```
40 | const tool_client_1 = require("../core/tool-client.js");
41 | const app_scope_checker_1 = require("../core/app-scope-checker.js");
> 42 | const lark_client_1 = require("../core/lark-client.js");
43 | const cardkit_1 = require("../card/cardkit.js");
44 | const owner_policy_1 = require("../core/owner-policy.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#811 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/auto-auth.js:43](#)

Dependency without integrity verification

```
41 | const app_scope_checker_1 = require("../core/app-scope-checker.js");
42 | const lark_client_1 = require("../core/lark-client.js");
> 43 | const cardkit_1 = require("../card/cardkit.js");
44 | const owner_policy_1 = require("../core/owner-policy.js");
45 | const synthetic_message_1 = require("../messaging/inbound/synthetic-message.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#812 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/auto-auth.js:44](#)

Dependency without integrity verification

```
42 | const lark_client_1 = require("../core/lark-client.js");
> 43 | const cardkit_1 = require("../card/cardkit.js");
    44 | const owner_policy_1 = require("../core/owner-policy.js");
    45 | const synthetic_message_1 = require("../messaging/inbound/synthetic-message.js");...
    46 | const oauth_1 = require("../oauth.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#813 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/auto-auth.js:45](#)

Dependency without integrity verification

```
43 | const cardkit_1 = require("../card/cardkit.js");
44 | const owner_policy_1 = require("../core/owner-policy.js");
> 45 | const synthetic_message_1 = require("../messaging/inbound/synthetic-message.js");
    46 | const oauth_1 = require("../oauth.js");
    47 | const helpers_1 = require("../helpers.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#814 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/auto-auth.js:46](#)

Dependency without integrity verification

```
44 | const owner_policy_1 = require("../core/owner-policy.js");
45 | const synthetic_message_1 = require("../messaging/inbound/synthetic-message.js");
> 46 | const oauth_1 = require("../oauth.js");
    47 | const helpers_1 = require("../helpers.js");
    48 | const json = helpers_1.formatToolResult;
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#815 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/auto-auth.js:47](#)

Dependency without integrity verification

```
45 | const synthetic_message_1 = require("../messaging/inbound/synthetic-message.js");
46 | const oauth_1 = require("../oauth.js");
> 47 | const helpers_1 = require("../helpers.js");
48 | const json = helpers_1.formatToolResult;...
49 | /**
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#816 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/helpers.d.ts:68](#)

High-risk permission pattern: * `async execute(_toolCallId, params) {`

```
66 | *   api.registerTool({
67 | *     name: "my_tool",
> 68 | *     async execute(_toolCallId, params) {
69 | *       const client = getClient();
70 | *       const res = await client.im.message.create({ ... });
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#817 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/helpers.d.ts:113](#)

High-risk permission pattern: * `async execute(_toolCallId, params) {`

```
111 | *   api.registerTool({
112 | *     name: "my_tool",
> 113 | *     async execute(_toolCallId, params) {
114 | *       const client = getClient();
115 | *       log.info(`Processing action: ${params.action}`);
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#818 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/helpers.d.ts:235](#)

High-risk permission pattern: * `async execute(_toolCallId, params) {`

```
233 | *   @example
234 | *   ``typescript
> 235 | *   async execute(_toolCallId, params) {
236 | *     const error = validateRequiredParams(params, ["action", "user_id"]);
237 | *     if (error) return formatToolResult(error);
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#819 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/helpers.d.ts:257](#)

High-risk permission pattern: `* const error = validateEnum(params.action, ["create", "list", "delete"], "action")`

```
255 | * @example
256 | * ``typescript
> 257 | * const error = validateEnum(params.action, ["create", "list", "delete"], "action");
258 | * if (error) return formatToolResult(error);...
259 | *
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#820 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/helpers.js:33](#)

Dangerous execution: `Object.defineProperty(exports, "getResolvedConfig", { enumerable: true, get: function`

```
31 | // tool-client.ts and this file can use it without a circular dependency.
32 | var lark_client_2 = require("../core/lark-client.js");
> 33 | Object.defineProperty(exports, "getResolvedConfig", { enumerable: true, get: function () { return
lark_client_2.getResolvedConfig; } });
34 | // -----
35 | // [ b7zi{it
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#821 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/helpers.js:57](#)

High-risk permission pattern: `* async execute(_toolCallId, params) {`

```
55 | * api.registerTool({
56 | *   name: "my_tool",
> 57 | *   async execute(_toolCallId, params) {
58 | *     const client = getClient();
59 | *     const res = await client.im.message.create({ ... });
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#822 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/helpers.js:143](#)

High-risk permission pattern: `* async execute(_toolCallId, params) {`

```
141 | *   api.registerTool({
142 | *     name: "my_tool",
> 143 | *     async execute(_toolCallId, params) {
144 | *       const client = getClient();...
145 | *       log.info(`Processing action: ${params.action}`);
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#823 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/helpers.js:346](#)

High-risk permission pattern: `* async execute(_toolCallId, params) {`

```
344 | *   @example
345 | *   `typescript
> 346 | *   async execute(_toolCallId, params) {
347 | *     const error = validateRequiredParams(params, ["action", "user_id"]);
348 | *     if (error) return formatToolResult(error);
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#824 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/helpers.js:377](#)

High-risk permission pattern: `* const error = validateEnum(params.action, ["create", "list", "delete"], "action"`

```
375 | *   @example
376 | *   `typescript
> 377 | *   const error = validateEnum(params.action, ["create", "list", "delete"], "action");
378 | *   if (error) return formatToolResult(error);
379 | *
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#825 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/helpers.js:22](#)

Dependency without integrity verification

```
20 | exports.validateRequiredParams = validateRequiredParams;
21 | exports.validateEnum = validateEnum;
> 22 | const accounts_1 = require("../core/accounts.js");
23 | const lark_client_1 = require("../core/lark-client.js");
24 | const lark_ticket_1 = require("../core/lark-ticket.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#826 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/helpers.js:23](#)

Dependency without integrity verification

```
21 | exports.validateEnum = validateEnum;
> 22 | const accounts_1 = require("../core/accounts.js");
    23 | const lark_client_1 = require("../core/lark-client.js");
    24 | const lark_ticket_1 = require("../core/lark-ticket.js");...
    25 | const tool_client_1 = require("../core/tool-client.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#827 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/helpers.js:24](#)

Dependency without integrity verification

```
22 | const accounts_1 = require("../core/accounts.js");
> 23 | const lark_client_1 = require("../core/lark-client.js");
    24 | const lark_ticket_1 = require("../core/lark-ticket.js");
    25 | const tool_client_1 = require("../core/tool-client.js");
    26 | const tools_config_1 = require("../core/tools-config.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#828 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/helpers.js:25](#)

Dependency without integrity verification

```
23 | const lark_client_1 = require("../core/lark-client.js");
> 24 | const lark_ticket_1 = require("../core/lark-ticket.js");
    25 | const tool_client_1 = require("../core/tool-client.js");
    26 | const tools_config_1 = require("../core/tools-config.js");
    27 | // -----
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#829 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/helpers.js:26](#)

Dependency without integrity verification

```
24 | const lark_ticket_1 = require("../core/lark-ticket.js");
25 | const tool_client_1 = require("../core/tool-client.js");
> 26 | const tools_config_1 = require("../core/tools-config.js");
27 | // -----
28 | // 'M•n%ãg•
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#830 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/helpers.js:32](#)

Dependency without integrity verification

```
30 | // getResolvedConfig is defined in lark-client.ts (core layer) so that both
31 | // tool-client.ts and this file can use it without a circular dependency.
> 32 | var lark_client_2 = require("../core/lark-client.js");
33 | Object.defineProperty(exports, "getResolvedConfig", { enumerable: true, get: function () { return
lark_client_2.getResolvedConfig; } });
34 | // -----
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#831 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/mcp/doc/create.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
2 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
3 | * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#832 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/mcp/doc/create.js:11](#)

Dependency without integrity verification

```
9 | Object.defineProperty(exports, "__esModule", { value: true });
10 | exports.registerCreateDocTool = registerCreateDocTool;
> 11 | const typebox_1 = require("@sinclair/typebox");
12 | const shared_1 = require("../shared.js");
13 | // Schema [SNI
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#833 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/mcp/doc/create.js:12](#)

Dependency without integrity verification

```
10 | exports.registerCreateDocTool = registerCreateDocTool;
11 | const typebox_1 = require("@sinclair/typebox");
> 12 | const shared_1 = require("../shared.js");
13 | // Schema [SNI...
14 | const CreateDocSchema = typebox_1.Type.Object({
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#834 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/mcp/doc/create.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
2 | /**
3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#835 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/mcp/doc/fetch.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#836 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/mcp/doc/fetch.js:11](#)

Dependency without integrity verification

```
9 | Object.defineProperty(exports, "__esModule", { value: true });
10 | exports.registerFetchDocTool = registerFetchDocTool;
> 11 | const typebox_1 = require("@sinclair/typebox");
    12 | const shared_1 = require("../shared.js");...
13 | // Schema [$NI
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#837 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/mcp/doc/fetch.js:12](#)

Dependency without integrity verification

```
10 | exports.registerFetchDocTool = registerFetchDocTool;
11 | const typebox_1 = require("@sinclair/typebox");
> 12 | const shared_1 = require("../shared.js");
    13 | // Schema [$NI
14 | const FetchDocSchema = typebox_1.Type.Object({
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#838 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/mcp/doc/fetch.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
    2 | /**
    3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#839 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/mcp/doc/index.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
    2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
    3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#840 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/mcp/doc/index.js:11](#)

Dependency without integrity verification

```
9 | Object.defineProperty(exports, "__esModule", { value: true });
10 | exports.registerFeishuMcpDocTools = registerFeishuMcpDocTools;
> 11 | const accounts_1 = require("../../core/accounts.js");
    12 | const tools_config_1 = require("../../core/tools-config.js");...
    13 | const shared_1 = require("../shared.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#841 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/mcp/doc/index.js:12](#)

Dependency without integrity verification

```
10 | exports.registerFeishuMcpDocTools = registerFeishuMcpDocTools;
11 | const accounts_1 = require("../../core/accounts.js");
> 12 | const tools_config_1 = require("../../core/tools-config.js");
    13 | const shared_1 = require("../shared.js");
    14 | const fetch_1 = require("../fetch.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#842 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/mcp/doc/index.js:13](#)

Dependency without integrity verification

```
11 | const accounts_1 = require("../../core/accounts.js");
12 | const tools_config_1 = require("../../core/tools-config.js");
> 13 | const shared_1 = require("../shared.js");
    14 | const fetch_1 = require("../fetch.js");
    15 | const create_1 = require("../create.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#843 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/mcp/doc/index.js:14](#)

Dependency without integrity verification

```
12 | const tools_config_1 = require("../../core/tools-config.js");
13 | const shared_1 = require("../shared.js");
> 14 | const fetch_1 = require("../fetch.js");
    15 | const create_1 = require("../create.js");
    16 | const update_1 = require("../update.js");
```


Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#844 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/mcp/doc/index.js:15](#)

Dependency without integrity verification

```
13 | const shared_1 = require("../shared.js");
> 14 | const fetch_1 = require("../fetch.js");
    15 | const create_1 = require("../create.js");
    16 | const update_1 = require("../update.js");...
    17 | /**
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#845 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/mcp/doc/index.js:16](#)

Dependency without integrity verification

```
14 | const fetch_1 = require("../fetch.js");
15 | const create_1 = require("../create.js");
> 16 | const update_1 = require("../update.js");
    17 | /**
    18 | * lèQÈ MCP Doc ]âQwÿ NÃ0ÝuY create/fetch/updateÿ search/list ]òu1 OAPI fÿNãÿ
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#846 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/mcp/doc/update.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
    2 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
    3 | * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#847 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/mcp/doc/update.js:11](#)

Dependency without integrity verification

```
9 | Object.defineProperty(exports, "__esModule", { value: true });
10 | exports.registerUpdateDocTool = registerUpdateDocTool;
> 11 | const typebox_1 = require("@sinclair/typebox");
    12 | const shared_1 = require("../shared.js");...
13 | // Schema [$NI
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#848 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/mcp/doc/update.js:12](#)

Dependency without integrity verification

```
10 | exports.registerUpdateDocTool = registerUpdateDocTool;
11 | const typebox_1 = require("@sinclair/typebox");
> 12 | const shared_1 = require("../shared.js");
    13 | // Schema [$NI
14 | const UpdateDocSchema = typebox_1.Type.Object({
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#849 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/mcp/doc/update.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
    2 | /**
    3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#850 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/mcp/shared.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
    2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
    3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#851 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/mcp/shared.js:9](#)

Dangerous execution: `var __importDefault = (this && this.__importDefault) || function (mod) {`

```
7 | * S T+ÿ MCP [çb7zi0 |{W<[§NI0 • u(•...R@Qÿep
8 | */
> 9 | var __importDefault = (this && this.__importDefault) || function (mod) {
10 |     return (mod && mod.__esModule) ? mod : { "default": mod };...
11 | };
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#852 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/mcp/shared.js:185](#)

High-risk permission pattern: `async execute(toolCallId, params) {`

```
183 |         description: config.description,
184 |         parameters: config.schema,
> 185 |         async execute(toolCallId, params) {
186 |             const p = params;
187 |             try {
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#853 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/mcp/shared.js:19](#)

Dependency without integrity verification

```
17 | exports.callMcpTool = callMcpTool;
18 | exports.registerMcpTool = registerMcpTool;
> 19 | const node_fs_1 = __importDefault(require("node:fs"));
20 | const node_path_1 = __importDefault(require("node:path"));
21 | const helpers_1 = require("../helpers.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use `>=` or `latest`. 3. Run `npm audit` / `pip-audit` in CI. 4. Use `pip install --require-hashes` for Python. 5. Verify package signatures where available.

#854 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/mcp/shared.js:20](#)

Dependency without integrity verification

```
18 | exports.registerMcpTool = registerMcpTool;
19 | const node_fs_1 = __importDefault(require("node:fs"));
> 20 | const node_path_1 = __importDefault(require("node:path"));
21 | const helpers_1 = require("../helpers.js");
22 | const helpers_2 = require("../oapi/helpers.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#855 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/mcp/shared.js:21](#)

Dependency without integrity verification

```
19 | const node_fs_1 = __importDefault(require("node:fs"));
> 20 | const node_path_1 = __importDefault(require("node:path"));
    21 | const helpers_1 = require("../helpers.js");
    22 | const helpers_2 = require("../oapi/helpers.js");...
    23 | const version_1 = require("../core/version.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#856 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/mcp/shared.js:22](#)

Dependency without integrity verification

```
20 | const node_path_1 = __importDefault(require("node:path"));
> 21 | const helpers_1 = require("../helpers.js");
    22 | const helpers_2 = require("../oapi/helpers.js");
    23 | const version_1 = require("../core/version.js");
    24 | const domains_1 = require("../core/domains.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#857 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/mcp/shared.js:23](#)

Dependency without integrity verification

```
21 | const helpers_1 = require("../helpers.js");
> 22 | const helpers_2 = require("../oapi/helpers.js");
    23 | const version_1 = require("../core/version.js");
    24 | const domains_1 = require("../core/domains.js");
    25 | // -----
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#858 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/mcp/shared.js:24](#)

Dependency without integrity verification

```
22 | const helpers_2 = require("../oapi/helpers.js");
23 | const version_1 = require("../core/version.js");
> 24 | const domains_1 = require("../core/domains.js");
25 | // -----
26 | // *...R@Qyep
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#859 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/mcp/shared.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
2 | /**
3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#860 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/bitable/app-table-field.d.ts:7](#)

High-risk permission pattern: * P1 Actions: create, list, update, delete

```
5 | * feishu_bitable_app_table_field tool -- Manage Feishu Bitable fields (columns).
6 | *
> 7 | * P1 Actions: create, list, update, delete
8 | *
9 | * Uses the Feishu Bitable v1 API:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#861 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/bitable/app-table-field.d.ts:13](#)

High-risk permission pattern: * - delete: DELETE /open-apis/bitable/v1/apps/:app_token/tables/:table_id/fields/:field_id

```
11 | * - list: GET /open-apis/bitable/v1/apps/:app_token/tables/:table_id/fields
12 | * - update: PUT /open-apis/bitable/v1/apps/:app_token/tables/:table_id/fields/:field_id
> 13 | * - delete: DELETE /open-apis/bitable/v1/apps/:app_token/tables/:table_id/fields/:field_id
14 | */
15 | import type { OpenClawPluginApi } from 'openclaw/plugin-sdk';
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#862 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/bitable/app-table-field.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
   2 |    * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates...
   3 |    * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#863 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/bitable/app-table-field.js:8](#)

High-risk permission pattern: * P1 Actions: create, list, update, delete

```
> 6 | * feishu_bitable_app_table_field tool -- Manage Feishu Bitable fields (columns).
   7 | *
   8 | * P1 Actions: create, list, update, delete
   9 | *
  10 | * Uses the Feishu Bitable v1 API:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#864 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/bitable/app-table-field.js:14](#)

High-risk permission pattern: * - delete: DELETE /open-apis/bitable/v1/apps/:app_token/tables/:table_id/fields/:field_id

```
> 12 | * - list: GET /open-apis/bitable/v1/apps/:app_token/tables/:table_id/fields
   13 | * - update: PUT /open-apis/bitable/v1/apps/:app_token/tables/:table_id/fields/:field_id
   14 | * - delete: DELETE /open-apis/bitable/v1/apps/:app_token/tables/:table_id/fields/:field_id
   15 | */
   16 | Object.defineProperty(exports, "__esModule", { value: true });
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#865 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/bitable/app-table-field.js:59](#)

High-risk permission pattern: **// DELETE (P1)**

```
57 |         property: typebox_1.Type.Optional(typebox_1.Type.Any({ description: '[Wkµ\^`\'M•ňý Si• ý N O R •êR`gă<ây ' })),
58 |     }},
59 |     // DELETE (P1)
60 |     typebox_1.Type.Object({...
61 |         action: typebox_1.Type.Literal('delete'),
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#866 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/bitable/app-table-field.js:61](#)

High-risk permission pattern: **action: typebox_1.Type.Literal('delete'),**

```
59 |     // DELETE (P1)
60 |     typebox_1.Type.Object({
61 |         action: typebox_1.Type.Literal('delete'),
62 |         app_token: typebox_1.Type.String({ description: 'Y ~ô`hh< token' }),
63 |         table_id: typebox_1.Type.String({ description: 'epcn`h ID' })),
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#867 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/bitable/app-table-field.js:78](#)

High-risk permission pattern: **description: '0 Nău(b7Ž«Ný0 ~pNfY ~ô`hh<[Wkµý R ý {it ]ăQw0 \_Su(b7%•lBR ^ú/gă<â/fôe°/R -d[Wkµ0 Ę et`h~Óg,,eö0•**

```
76 |         name: 'feishu_bitable_app_table_field',
77 |         label: 'Feishu Bitable Fields',
78 |         description: '0 Nău(b7Ž«Ný0 ~pNfY ~ô`hh<[Wkµý R ý {it ]ăQw0 _Su(b7%•lBR ^ú/gă<â/fôe°/R -d[Wkµ0 Ę et`h~Óg,,eö0•
79 |         parameters: FeishuBitableAppTableFieldSchema,
80 |         async execute(_toolCallId, params) {
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#868 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/bitable/app-table-field.js:80](#)

High-risk permission pattern: **async execute(_toolCallId, params) {**

```
78 |         description: '0 Nău(b7Ž«Ný0 ~pNfY ~ô`hh<[Wkµý R ý {it ]ăQw0 _Su(b7%•lBR ^ú/gă<â/fôe°/R -d[Wkµ0 Ę et`h~Óg,,eö0•
79 |         parameters: FeishuBitableAppTableFieldSchema,
80 |         async execute(_toolCallId, params) {
81 |             const p = params;
82 |             try {
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#869 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/bitable/app-table-field.js:201](#)

High-risk permission pattern: **// DELETE**

```
199 |         }  
> 200 |         // -----  
    201 |         // DELETE  
    202 |         // -----  
    203 |         case 'delete': {
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#870 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/bitable/app-table-field.js:203](#)

High-risk permission pattern: **case 'delete': {**

```
201 |         // DELETE  
> 202 |         // -----  
    203 |         case 'delete': {  
    204 |             log.info(`delete: app_token=${p.app_token}, table_id=${p.table_id},  
field_id=${p.field_id}`);  
    205 |             const res = await client.invoke('feishu_bitable_app_table_field.delete',  
(sdk, opts) => sdk.bitable.appTableField.delete({
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#871 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/bitable/app-table-field.js:204](#)

High-risk permission pattern: **log.info(`delete: app_token=\${p.app_token}, table_id=\${p.table_id}, field_id=\${p**

```
202 |         // -----  
203 |         case 'delete': {  
> 204 |             log.info(`delete: app_token=${p.app_token}, table_id=${p.table_id},  
field_id=${p.field_id}`);  
    205 |             const res = await client.invoke('feishu_bitable_app_table_field.delete',  
(sdk, opts) => sdk.bitable.appTableField.delete({  
    206 |                 path: {
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#872 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/bitable/app-table-field.js:205](#)

High-risk permission pattern: `const res = await client.invoke('feishu_bitable_app_table_field.delete', (sdk, o`

```
203 |             case 'delete': {
204 |                 log.info('delete: app_token=${p.app_token}, table_id=${p.table_id},
    |                 field_id=${p.field_id}');
> 205 |                 const res = await client.invoke('feishu_bitable_app_table_field.delete',
    |                 (sdk, opts) => sdk.bitable.appTableField.delete({
206 |                     path: {...
207 |                     app_token: p.app_token,
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#873 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/bitable/app-table-field.js:213](#)

High-risk permission pattern: `log.info('delete: deleted field ${p.field_id}');`

```
211 |             }, opts), { as: 'user' });
212 |             (0, helpers_1.assertLarkOk)(res);
> 213 |             log.info('delete: deleted field ${p.field_id}');
214 |             return (0, helpers_1.json)({
215 |                 success: true,
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#874 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/bitable/app-table-field.js:18](#)

Dependency without integrity verification

```
16 | Object.defineProperty(exports, "__esModule", { value: true });
17 | exports.registerFeishuBitableAppTableFieldTool = registerFeishuBitableAppTableFieldTool;
> 18 | const typebox_1 = require("@sinclair/typebox");
19 | const helpers_1 = require("../helpers.js");
20 | // -----
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#875 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/bitable/app-table-field.js:19](#)

Dependency without integrity verification

```
17 | exports.registerFeishuBitableAppTableFieldTool = registerFeishuBitableAppTableFieldTool;
18 | const typebox_1 = require("@sinclair/typebox");
> 19 | const helpers_1 = require("../helpers.js");
20 | // -----
21 | // Schema
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#876 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/bitable/app-table-field.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
   2 | /**...
   3 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#877 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/bitable/app-table-record.d.ts:7](#)

High-risk permission pattern: * P0 Actions: create, list, update, delete

```
> 5 | * feishu_bitable_app_table_record tool -- Manage Feishu Bitable records.
   6 | *
   7 | * P0 Actions: create, list, update, delete
   8 | * P1 Actions: batch_create, batch_update, batch_delete
   9 | *
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#878 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/bitable/app-table-record.d.ts:14](#)

High-risk permission pattern: * - delete: DELETE /open-apis/bitable/v1/apps/:app_token/tables/:table_id/reco

```
- ) 12 | * - list: POST /open-apis/bitable/v1/apps/:app_token/tables/:table_id/records/search (eç list API ]ò^Ÿ
> 13 | * - update: PUT /open-apis/bitable/v1/apps/:app_token/tables/:table_id/records/:record_id
   14 | * - delete: DELETE /open-apis/bitable/v1/apps/:app_token/tables/:table_id/records/:record_id
   15 | * - batch_create: POST /open-apis/bitable/v1/apps/:app_token/tables/:table_id/records/batch_create
   16 | * - batch_update: POST /open-apis/bitable/v1/apps/:app_token/tables/:table_id/records/batch_update
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#879 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/bitable/app-table-record.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
    2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates...
    3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#880 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/bitable/app-table-record.js:8](#)

High-risk permission pattern: * P0 Actions: create, list, update, delete

```
> 6 | * feishu_bitable_app_table_record tool -- Manage Feishu Bitable records.
    7 |
    8 | * P0 Actions: create, list, update, delete
    9 | * P1 Actions: batch_create, batch_update, batch_delete
   10 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#881 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/bitable/app-table-record.js:15](#)

High-risk permission pattern: * - delete: DELETE /open-apis/bitable/v1/apps/:app_token/tables/:table_id/reco

```
- 13 | * - list: POST /open-apis/bitable/v1/apps/:app_token/tables/:table_id/records/search (eç list API ]ò^Ÿ
    14 | * - update: PUT /open-apis/bitable/v1/apps/:app_token/tables/:table_id/records/:record_id
> 15 | * - delete: DELETE /open-apis/bitable/v1/apps/:app_token/tables/:table_id/records/:record_id
    16 | * - batch_create: POST /open-apis/bitable/v1/apps/:app_token/tables/:table_id/records/batch_create
    17 | * - batch_update: POST /open-apis/bitable/v1/apps/:app_token/tables/:table_id/records/batch_update
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#882 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/bitable/app-table-record.js:50](#)

High-risk permission pattern: // DELETE (P0)

```
> 48 |     }},
    49 |     },
    50 |     // DELETE (P0)
    51 |     typebox_1.Type.Object({
    52 |       action: typebox_1.Type.Literal('delete'),
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#883 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/bitable/app-table-record.js:52](#)

High-risk permission pattern: `action: typebox_1.Type.Literal('delete'),`

```
50 | // DELETE (P0)
51 | typebox_1.Type.Object({
> 52 |   action: typebox_1.Type.Literal('delete'),
53 |   app_token: typebox_1.Type.String({ description: 'Y ~ô`hh< token' }),...
54 |   table_id: typebox_1.Type.String({ description: 'epcn`h ID' }),
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#884 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/bitable/app-table-record.js:134](#)

High-risk permission pattern: `'- deleteÿ R -d<°_Uÿ ln' +`

```
132 |         '- listÿ R Qú/d }"<°_Uÿ ln' +
133 |         '- updateÿ fôe°<°_Uÿ ln' +
> 134 |         '- deleteÿ R -d<°_Uÿ ln' +
135 |         '- batch_updateÿ by'İfôe°ÿ ln' +
136 |         '- batch_deleteÿ by'İR -dÿ lnln' +
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#885 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/bitable/app-table-record.js:141](#)

High-risk permission pattern: `async execute(_toolCallId, params) {`

```
139 |         "- batch_create 0•u( 'records' ep-Äÿ by'İÿ ",
140 |         parameters: FeishuBitableAppTableRecordSchema,
> 141 |         async execute(_toolCallId, params) {
142 |           const p = params;
143 |           try {
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#886 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/bitable/app-table-record.js:231](#)

High-risk permission pattern: **// DELETE**

```
229 |         }  
230 |         // -----  
> 231 |         // DELETE  
232 |         // -----  
233 |         case 'delete': {
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#887 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/bitable/app-table-record.js:233](#)

High-risk permission pattern: **case 'delete': {**

```
231 |         // DELETE  
232 |         // -----  
> 233 |         case 'delete': {  
234 |             log.info(`delete: app_token=${p.app_token}, table_id=${p.table_id},  
record_id=${p.record_id}`);  
235 |             const res = await client.invoke('feishu_bitable_app_table_record.delete',  
(sdk, opts) => sdk.bitable.appTableRecord.delete({
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#888 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/bitable/app-table-record.js:234](#)

High-risk permission pattern: **log.info(`delete: app\_token=\${p.app\_token}, table\_id=\${p.table\_id}, record\_id=\${p.record\_id}`);**

```
232 |         // -----  
233 |         case 'delete': {  
> 234 |             log.info(`delete: app_token=${p.app_token}, table_id=${p.table_id},  
record_id=${p.record_id}`);  
235 |             const res = await client.invoke('feishu_bitable_app_table_record.delete',  
(sdk, opts) => sdk.bitable.appTableRecord.delete({  
236 |                 path: {
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#889 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/bitable/app-table-record.js:235](#)

High-risk permission pattern: **const res = await client.invoke('feishu_bitable_app_table_record.delete', (sdk,**

```

233 |             case 'delete': {
234 |                 log.info('delete: app_token=${p.app_token}, table_id=${p.table_id},
record_id=${p.record_id}');
> 235 |                 const res = await client.invoke('feishu_bitable_app_table_record.delete',
(sdk, opts) => sdk.bitable.appTableRecord.delete({
236 |                     path: {

```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#890 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/bitable/app-table-record.js:243](#)

High-risk permission pattern: `log.info('delete: deleted record ${p.record_id}');`

```

241 |             }, opts), { as: 'user' });
242 |             (0, helpers_1.assertLarkOk)(res);
> 243 |             log.info('delete: deleted record ${p.record_id}');
244 |             return (0, helpers_1.json)({
245 |                 success: true,

```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#891 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/bitable/app-table-record.js:23](#)

Dependency without integrity verification

```

21 | Object.defineProperty(exports, "__esModule", { value: true });
22 | exports.registerFeishuBitableAppTableRecordTool = registerFeishuBitableAppTableRecordTool;
> 23 | const typebox_1 = require("@sinclair/typebox");
24 | const helpers_1 = require("../helpers.js");
25 | // -----

```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#892 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/bitable/app-table-record.js:24](#)

Dependency without integrity verification

```

22 | exports.registerFeishuBitableAppTableRecordTool = registerFeishuBitableAppTableRecordTool;
23 | const typebox_1 = require("@sinclair/typebox");
> 24 | const helpers_1 = require("../helpers.js");
25 | // -----
26 | // Schema

```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#893 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/bitable/app-table-record.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
  2 | /**...
  3 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#894 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/bitable/app-table-view.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
  2 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
  3 | * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#895 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/bitable/app-table-view.js:75](#)

High-risk permission pattern: async execute(_toolCallId, params) {

```
73 |         description: '0 Nâu(b7Ž«Ný0 ~pNfY ~ô^hh<%EVp{it ]âQw0 _Su(b7%•LBR ^ú/gâ<â/fôe°%EVp0 R cb\Uy:e¹_ eö0•u(0 Actio
74 |         parameters: FeishuBitableAppTableViewSchema,
> 75 |         async execute(_toolCallId, params) {
76 |             const p = params;
77 |             try {
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#896 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/bitable/app-table-view.js:18](#)

Dependency without integrity verification

```
16 | Object.defineProperty(exports, "__esModule", { value: true });
17 | exports.registerFeishuBitableAppTableViewTool = registerFeishuBitableAppTableViewTool;
> 18 | const typebox_1 = require("@sinclair/typebox");
19 | const helpers_1 = require("../helpers.js");
20 | // -----
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#897 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/bitable/app-table-view.js:19](#)

Dependency without integrity verification

```
17 | exports.registerFeishuBitableAppTableViewTool = registerFeishuBitableAppTableViewTool;
18 | const typebox_1 = require("@sinclair/typebox");
> 19 | const helpers_1 = require("../helpers.js");
    | // -----
21 | // Schema
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#898 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/bitable/app-table-view.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
  2 | /**
  3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#899 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/bitable/app-table.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
  2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
  3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#900 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/bitable/app-table.js:79](#)

High-risk permission pattern: async execute(_toolCallId, params) {

```
77 |         '\n\n0 [wkp[ŠNIe¹_0 e/c N$yİj!_ ŷ 1) f xn- lBeöŷ W( create N-• •Ç table.fields N k!`'[ŠNİb@g [wkpŷ Qİ\
78 |         parameters: FeishuBitableAppTableSchema,
> 79 |         async execute(_toolCallId, params) {
    |         const p = params;
80 |         try {
81 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#901 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/bitable/app-table.js:19](#)

Dependency without integrity verification

```
17 | Object.defineProperty(exports, "__esModule", { value: true });
18 | exports.registerFeishuBitableAppTableTool = registerFeishuBitableAppTableTool;
> 19 | const typebox_1 = require("@sinclair/typebox");
    20 | const helpers_1 = require("../helpers.js");...
21 | // -----
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#902 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/bitable/app-table.js:20](#)

Dependency without integrity verification

```
18 | exports.registerFeishuBitableAppTableTool = registerFeishuBitableAppTableTool;
19 | const typebox_1 = require("@sinclair/typebox");
> 20 | const helpers_1 = require("../helpers.js");
    21 | // -----
    22 | // Schema
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#903 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/bitable/app-table.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
    2 | /**
    3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#904 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/bitable/app.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
    2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
    3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#905 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/bitable/app.js:70](#)

High-risk permission pattern: description: '0 N u(b7  N   ~ NfY ~  hh<^"u({it J Qw0 _Su(b7%  lBR ^ /g   /it Y ~  hh<    u(  Actions: create

```
68 |         name: 'feishu_bitable_app',
69 |         label: 'Feishu Bitable Apps',
> 70 |         description: '0 N u(b7  N   ~ NfY ~  hh<^"u({it J Qw0 _Su(b7%  lBR ^ /g   /it Y ~  hh<    u(  Actions: create
71 |         parameters: FeishuBitableAppSchema, ...
72 |         async execute(_toolCallId, params) {
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#906 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/bitable/app.js:72](#)

High-risk permission pattern: async execute(_toolCallId, params) {

```
70 |         description: '0 N u(b7  N   ~ NfY ~  hh<^"u({it J Qw0 _Su(b7%  lBR ^ /g   /it Y ~  hh<    u(  Actions: create
71 |         parameters: FeishuBitableAppSchema,
> 72 |         async execute(_toolCallId, params) {
73 |             const p = params;
74 |             try {
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#907 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/bitable/app.js:20](#)

Dependency without integrity verification

```
18 | Object.defineProperty(exports, "__esModule", { value: true });
19 | exports.registerFeishuBitableAppTool = registerFeishuBitableAppTool;
> 20 | const typebox_1 = require("@sinclair/typebox");
21 | const helpers_1 = require("../helpers.js");
22 | // -----
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#908 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/bitable/app.js:21](#)

Dependency without integrity verification

```
19 | exports.registerFeishuBitableAppTool = registerFeishuBitableAppTool;
20 | const typebox_1 = require("@sinclair/typebox");
> 21 | const helpers_1 = require("../helpers.js");
22 | // -----
23 | // Schema
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#909 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/bitable/app.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
   2 | /**
   3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#910 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/bitable/index.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
   2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
   3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#911 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/oapi/bitable/index.js:9](#)

Dangerous execution: Object.defineProperty(exports, "registerFeishuBitableAppTool", { enumerable: true

```
7 | exports.registerFeishuBitableAppTableViewTool = exports.registerFeishuBitableAppTableFieldTool =
  exports.registerFeishuBitableAppTableRecordTool = exports.registerFeishuBitableAppTableTool =
  exports.registerFeishuBitableAppTool = void 0;
  8 | var app_1 = require("./app.js");
>  9 | Object.defineProperty(exports, "registerFeishuBitableAppTool", { enumerable: true, get: function ()
    { return app_1.registerFeishuBitableAppTool; } });
    10 | var app_table_1 = require("./app-table.js");
    11 | Object.defineProperty(exports, "registerFeishuBitableAppTableTool", { enumerable: true, get:
function () { return app_table_1.registerFeishuBitableAppTableTool; } });
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#912 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/oapi/bitable/index.js:11](#)

Dangerous execution: `Object.defineProperty(exports, "registerFeishuBitableAppTableTool", { enumerable`

```
9 | Object.defineProperty(exports, "registerFeishuBitableAppTool", { enumerable: true, get: function ()
{ return app_1.registerFeishuBitableAppTool; } });
10 | var app_table_1 = require("./app-table.js");
> 11 | Object.defineProperty(exports, "registerFeishuBitableAppTableTool", { enumerable: true, get:
function () { return app_table_1.registerFeishuBitableAppTableTool; } });
12 | var app_table_record_1 = require("./app-table-record.js");
13 | Object.defineProperty(exports, "registerFeishuBitableAppTableRecordTool", { enumerable: true, get:...
function () { return app_table_record_1.registerFeishuBitableAppTableRecordTool; } });
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#913 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/oapi/bitable/index.js:13](#)

Dangerous execution: `Object.defineProperty(exports, "registerFeishuBitableAppTableRecordTool", { enum`

```
11 | Object.defineProperty(exports, "registerFeishuBitableAppTableTool", { enumerable: true, get:
function () { return app_table_1.registerFeishuBitableAppTableTool; } });
12 | var app_table_record_1 = require("./app-table-record.js");
> 13 | Object.defineProperty(exports, "registerFeishuBitableAppTableRecordTool", { enumerable: true, get:
function () { return app_table_record_1.registerFeishuBitableAppTableRecordTool; } });
14 | var app_table_field_1 = require("./app-table-field.js");
15 | Object.defineProperty(exports, "registerFeishuBitableAppTableFieldTool", { enumerable: true, get:
function () { return app_table_field_1.registerFeishuBitableAppTableFieldTool; } });
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#914 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/oapi/bitable/index.js:15](#)

Dangerous execution: `Object.defineProperty(exports, "registerFeishuBitableAppTableFieldTool", { enum`

```
13 | Object.defineProperty(exports, "registerFeishuBitableAppTableRecordTool", { enumerable: true, get:
function () { return app_table_record_1.registerFeishuBitableAppTableRecordTool; } });
14 | var app_table_field_1 = require("./app-table-field.js");
> 15 | Object.defineProperty(exports, "registerFeishuBitableAppTableFieldTool", { enumerable: true, get:
function () { return app_table_field_1.registerFeishuBitableAppTableFieldTool; } });
16 | var app_table_view_1 = require("./app-table-view.js");
17 | Object.defineProperty(exports, "registerFeishuBitableAppTableViewTool", { enumerable: true, get:
function () { return app_table_view_1.registerFeishuBitableAppTableViewTool; } });
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#915 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/oapi/bitable/index.js:17](#)

Dangerous execution: Object.defineProperty(exports, "registerFeishuBitableAppTableViewTool", { enumerable

```
15 | Object.defineProperty(exports, "registerFeishuBitableAppTableFieldTool", { enumerable: true, get:
function () { return app_table_field_1.registerFeishuBitableAppTableFieldTool; } });
16 | var app_table_view_1 = require("./app-table-view.js");
> 17 | Object.defineProperty(exports, "registerFeishuBitableAppTableViewTool", { enumerable: true, get:
function () { return app_table_view_1.registerFeishuBitableAppTableViewTool; } });...
18 |
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#916 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[src/tools/oapi/bitable/index.js:11](#)

Potential secret: possible hardcoded secret

```
9 | Object.defineProperty(exports, "registerFeishuBitableAppTool", { enumerable: true, get: function ()
{ return app_1.registerFeishuBitableAppTool; } });
10 | var app_table_1 = require("./app-table.js");
> 11 | Object.defineProperty(exports, "registerFeishuBitableAppTableTool", { enumerable: true, get:
function () { return app_table_1.registerFeishuBitableAppTableTool; } });
12 | var app_table_record_1 = require("./app-table-record.js");
13 | Object.defineProperty(exports, "registerFeishuBitableAppTableRecordTool", { enumerable: true, get:
function () { return app_table_record_1.registerFeishuBitableAppTableRecordTool; } });
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#917 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[src/tools/oapi/bitable/index.js:13](#)

Potential secret: possible hardcoded secret

```
11 | Object.defineProperty(exports, "registerFeishuBitableAppTableTool", { enumerable: true, get:
function () { return app_table_1.registerFeishuBitableAppTableTool; } });
12 | var app_table_record_1 = require("./app-table-record.js");
> 13 | Object.defineProperty(exports, "registerFeishuBitableAppTableRecordTool", { enumerable: true, get:
function () { return app_table_record_1.registerFeishuBitableAppTableRecordTool; } });
14 | var app_table_field_1 = require("./app-table-field.js");
15 | Object.defineProperty(exports, "registerFeishuBitableAppTableFieldTool", { enumerable: true, get:
function () { return app_table_field_1.registerFeishuBitableAppTableFieldTool; } });
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#918 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[src/tools/oapi/bitable/index.js:15](#)

Potential secret: possible hardcoded secret

```
13 | Object.defineProperty(exports, "registerFeishuBitableAppTableRecordTool", { enumerable: true, get:
function () { return app_table_record_1.registerFeishuBitableAppTableRecordTool; } });
14 | var app_table_field_1 = require("./app-table-field.js");
> 15 | Object.defineProperty(exports, "registerFeishuBitableAppTableFieldTool", { enumerable: true, get:
function () { return app_table_field_1.registerFeishuBitableAppTableFieldTool; } });
16 | var app_table_view_1 = require("./app-table-view.js");
17 | Object.defineProperty(exports, "registerFeishuBitableAppTableViewTool", { enumerable: true, get:...
function () { return app_table_view_1.registerFeishuBitableAppTableViewTool; } });
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#919 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[src/tools/oapi/bitable/index.js:17](#)

Potential secret: possible hardcoded secret

```
15 | Object.defineProperty(exports, "registerFeishuBitableAppTableFieldTool", { enumerable: true, get:
function () { return app_table_field_1.registerFeishuBitableAppTableFieldTool; } });
16 | var app_table_view_1 = require("./app-table-view.js");
> 17 | Object.defineProperty(exports, "registerFeishuBitableAppTableViewTool", { enumerable: true, get:
function () { return app_table_view_1.registerFeishuBitableAppTableViewTool; } });
18 |
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#920 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/bitable/index.js:8](#)

Dependency without integrity verification

```
6 | Object.defineProperty(exports, "__esModule", { value: true });
7 | exports.registerFeishuBitableAppTableViewTool = exports.registerFeishuBitableAppTableFieldTool =
exports.registerFeishuBitableAppTableRecordTool = exports.registerFeishuBitableAppTableTool =
exports.registerFeishuBitableAppTool = void 0;
> 8 | var app_1 = require("./app.js");
9 | Object.defineProperty(exports, "registerFeishuBitableAppTool", { enumerable: true, get: function ()
{ return app_1.registerFeishuBitableAppTool; } });
10 | var app_table_1 = require("./app-table.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#921 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/bitable/index.js:10](#)

Dependency without integrity verification

```
8 | var app_1 = require("./app.js");
9 | Object.defineProperty(exports, "registerFeishuBitableAppTool", { enumerable: true, get: function ()
{ return app_1.registerFeishuBitableAppTool; } });
> 10 | var app_table_1 = require("./app-table.js");
    11 | Object.defineProperty(exports, "registerFeishuBitableAppTableTool", { enumerable: true, get:
function () { return app_table_1.registerFeishuBitableAppTableTool; } });...
    12 | var app_table_record_1 = require("./app-table-record.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#922 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/bitable/index.js:12](#)

Dependency without integrity verification

```
10 | var app_table_1 = require("./app-table.js");
11 | Object.defineProperty(exports, "registerFeishuBitableAppTableTool", { enumerable: true, get:
function () { return app_table_1.registerFeishuBitableAppTableTool; } });
> 12 | var app_table_record_1 = require("./app-table-record.js");
    13 | Object.defineProperty(exports, "registerFeishuBitableAppTableRecordTool", { enumerable: true, get:
function () { return app_table_record_1.registerFeishuBitableAppTableRecordTool; } });
    14 | var app_table_field_1 = require("./app-table-field.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#923 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/bitable/index.js:14](#)

Dependency without integrity verification

```
12 | var app_table_record_1 = require("./app-table-record.js");
13 | Object.defineProperty(exports, "registerFeishuBitableAppTableRecordTool", { enumerable: true, get:
function () { return app_table_record_1.registerFeishuBitableAppTableRecordTool; } });
> 14 | var app_table_field_1 = require("./app-table-field.js");
    15 | Object.defineProperty(exports, "registerFeishuBitableAppTableFieldTool", { enumerable: true, get:
function () { return app_table_field_1.registerFeishuBitableAppTableFieldTool; } });
    16 | var app_table_view_1 = require("./app-table-view.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#924 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/bitable/index.js:16](#)

Dependency without integrity verification

```
14 | var app_table_field_1 = require("./app-table-field.js");
15 | Object.defineProperty(exports, "registerFeishuBitableAppTableFieldTool", { enumerable: true, get:
function () { return app_table_field_1.registerFeishuBitableAppTableFieldTool; } });
> 16 | var app_table_view_1 = require("./app-table-view.js");
17 | Object.defineProperty(exports, "registerFeishuBitableAppTableViewTool", { enumerable: true, get:
function () { return app_table_view_1.registerFeishuBitableAppTableViewTool; } });...
18 |
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#925 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/bitable/index.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
2 | /**
3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#926 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/calendar/calendar.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#927 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/calendar/calendar.js:58](#)

High-risk permission pattern: async execute(_toolCallId, params) {

```
56 |         description: '0 Nâu(b7Z«Ny0 ~PNfeâS{it JâQw0 u(Nžgâ<âeâS†R ^h0 f.SöeâS†0â`o0 gâ<âN;eâS†0 Actions: listy gâ<â
57 |         parameters: FeishuCalendarCalendarSchema,
> 58 |         async execute(_toolCallId, params) {
59 |             const p = params;
60 |             try {
```


Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#928 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/calendar/calendar.js:17](#)

Dependency without integrity verification

```
15 | Object.defineProperty(exports, "__esModule", { value: true });
16 | exports.registerFeishuCalendarCalendarTool = registerFeishuCalendarCalendarTool;
> 17 | const typebox_1 = require("@sinclair/typebox");
18 | const helpers_1 = require("../helpers.js");...
19 | // -----
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#929 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/calendar/calendar.js:18](#)

Dependency without integrity verification

```
16 | exports.registerFeishuCalendarCalendarTool = registerFeishuCalendarCalendarTool;
17 | const typebox_1 = require("@sinclair/typebox");
> 18 | const helpers_1 = require("../helpers.js");
19 | // -----
20 | // Schema
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#930 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/calendar/calendar.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
2 | /**
3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#931 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/calendar/event-attendee.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
  2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates...
  3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#932 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/calendar/event-attendee.js:76](#)

High-risk permission pattern: `async execute(_toolCallId, params) {`

```
> 74 |         description: '~bNfeáz SÃO N°{it ]âQw0 _Su(b7%•lB•€÷/mûR SÃO N°0 gâw SÃO N°R ^heö0•u(0 Actions: createÿ mûR S
  75 |         parameters: FeishuCalendarEventAttendeeSchema,
  76 |         async execute(_toolCallId, params) {
  77 |             const p = params;
  78 |             try {
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#933 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/calendar/event-attendee.js:17](#)

Dependency without integrity verification

```
> 15 | Object.defineProperty(exports, "__esModule", { value: true });
  16 | exports.registerFeishuCalendarEventAttendeeTool = registerFeishuCalendarEventAttendeeTool;
  17 | const typebox_1 = require("@sinclair/typebox");
  18 | const helpers_1 = require("../helpers.js");
  19 | // -----
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#934 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/calendar/event-attendee.js:18](#)

Dependency without integrity verification

```
> 16 | exports.registerFeishuCalendarEventAttendeeTool = registerFeishuCalendarEventAttendeeTool;
  17 | const typebox_1 = require("@sinclair/typebox");
  18 | const helpers_1 = require("../helpers.js");
  19 | // -----
  20 | // Schema
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#935 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/calendar/event-attendee.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
   2 | /**...
   3 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#936 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/calendar/event.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
   2 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
   3 | * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#937 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/calendar/event.js:154](#)

High-risk permission pattern: // DELETE (P1)

```
152 |         })),
153 |     })),
> 154 |     // DELETE (P1)
155 |     typebox_1.Type.Object({
156 |         action: typebox_1.Type.Literal('delete'),
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#938 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/calendar/event.js:156](#)

High-risk permission pattern: action: typebox_1.Type.Literal('delete'),

```
154 | // DELETE (P1)
155 | typebox_1.Type.Object({
156 |   action: typebox_1.Type.Literal('delete'),
157 |   event_id: typebox_1.Type.String({...
158 |     description: 'Event ID',
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#939 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/calendar/event.js:305](#)

High-risk permission pattern: description: "0 N  (b7Z  N     Nfe   {it j  Qw   _Su(b7%  lBg  w e      R ^                  e       R -de      d }"e

```
303 |     name: 'feishu_calendar_event',
304 |     label: 'Feishu Calendar Events',
> 305 |     description: "0 N  (b7Z  N     Nfe   {it j  Qw   _Su(b7%  lBg  w e      R ^                  e       R -de      d }"e
instance_view   g  w \U_ T v  e   R   h        I    create e  _  {   user_open_id S  ep   P<N:m   oN N e  N-v   SenderId   h<   ou_xxx     
'2024-01-01T00:00:00+08:00'   ",
306 |     parameters: FeishuCalendarEventSchema,
307 |     async execute(_toolCallId, params) {
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#940 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/calendar/event.js:307](#)

High-risk permission pattern: async execute(_toolCallId, params) {

```
305 |     description: "0 N  (b7Z  N     Nfe   {it j  Qw   _Su(b7%  lBg  w e      R ^                  e       R -de      d }"e
instance_view   g  w \U_ T v  e   R   h        I    create e  _  {   user_open_id S  ep   P<N:m   oN N e  N-v   SenderId   h<   ou_xxx     
'2024-01-01T00:00:00+08:00'   ",
306 |     parameters: FeishuCalendarEventSchema,
> 307 |     async execute(_toolCallId, params) {
308 |       const p = params;
309 |       try {
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#941 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/calendar/event.js:561](#)

High-risk permission pattern: // DELETE EVENT (P1)

```

559 |         }
560 |         // -----
> 561 |         // DELETE EVENT (P1)
562 |         // -----

```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#942 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/calendar/event.js:563](#)

High-risk permission pattern: `case 'delete': {`

```

561 |         // DELETE EVENT (P1)
562 |         // -----
> 563 |         case 'delete': {
564 |             if (!p.event_id)
565 |                 return (0, helpers_1.json)({ error: 'event_id is required' });

```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#943 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/calendar/event.js:567](#)

High-risk permission pattern: `log.info(`delete: calendar_id=${calendarId}, event_id=${p.event_id}, notify=${p.`

```

565 |                 return (0, helpers_1.json)({ error: 'event_id is required' });
566 |                 const calendarId = await resolveCalendarIdOrFail(p.calendar_id, client);
> 567 |                 log.info(`delete: calendar_id=${calendarId}, event_id=${p.event_id},
notify=${p.need_notification ?? true}`);
568 |                 const res = await client.invoke('feishu_calendar_event.delete', (sdk, opts)
=> sdk.calendar.calendarEvent.delete({
569 |                     path: { calendar_id: calendarId, event_id: p.event_id },

```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#944 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/calendar/event.js:568](#)

High-risk permission pattern: `const res = await client.invoke('feishu_calendar_event.delete', (sdk, opts) => s`

```

566 |                 const calendarId = await resolveCalendarIdOrFail(p.calendar_id, client);
567 |                 log.info(`delete: calendar_id=${calendarId}, event_id=${p.event_id},
notify=${p.need_notification ?? true}`);
> 568 |                 const res = await client.invoke('feishu_calendar_event.delete', (sdk, opts)
=> sdk.calendar.calendarEvent.delete({
569 |                     path: { calendar_id: calendarId, event_id: p.event_id },
570 |                     params: {

```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#945 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/calendar/event.js:575](#)

High-risk permission pattern: `log.info(`delete: deleted event ${p.event_id}`);`

```
573 |                                     }, opts), { as: 'user' });  
574 |                                     (0, helpers_1.assertLarkOk)(res);  
> 575 |                                     log.info(`delete: deleted event ${p.event_id}`);  
576 |                                     return (0, helpers_1.json)({...  
577 |                                         success: true,
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#946 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/calendar/event.js:19](#)

Dependency without integrity verification

```
17 | Object.defineProperty(exports, "__esModule", { value: true });  
18 | exports.registerFeishuCalendarEventTool = registerFeishuCalendarEventTool;  
> 19 | const typebox_1 = require("@sinclair/typebox");  
20 | const helpers_1 = require("../helpers.js");  
21 | // -----
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use `>=` or `latest`. 3. Run `npm audit` / `pip-audit` in CI. 4. Use `pip install --require-hashes` for Python. 5. Verify package signatures where available.

#947 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/calendar/event.js:20](#)

Dependency without integrity verification

```
18 | exports.registerFeishuCalendarEventTool = registerFeishuCalendarEventTool;  
19 | const typebox_1 = require("@sinclair/typebox");  
> 20 | const helpers_1 = require("../helpers.js");  
21 | // -----  
22 | // Schema
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use `>=` or `latest`. 3. Run `npm audit` / `pip-audit` in CI. 4. Use `pip install --require-hashes` for Python. 5. Verify package signatures where available.

#948 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/calendar/event.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";  
2 | /**  
3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include `agent_id`, `timestamp`, `action`, `parameters`, and `outcome` in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#949 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/calendar/freebusy.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
    2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates...
    3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#950 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/calendar/freebusy.js:49](#)

High-risk permission pattern: `async execute(_toolCallId, params) {`

```
> 47 |         description: '0 Nău(b7Z«Ny0 ~pNfeâSt_Û•ôgâ<â]âQw0 _Su(b7%•lBgâ<âgĐeö•ôkµQ...gĐN°f/T&zz•ò0 gâw _Û•òr¶` eö0•u(0 e
    48 |         parameters: FeishuCalendarFreebusySchema,
    49 |         async execute(_toolCallId, params) {
    50 |             const p = params;
    51 |             log.info(`[FREEBUSY] Execute called with params: ${JSON.stringify(p)}`);
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#951 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/calendar/freebusy.js:51](#)

High-risk permission pattern: `log.info(`[FREEBUSY] Execute called with params: ${JSON.stringify(p)}`);`

```
> 49 |         async execute(_toolCallId, params) {
    50 |             const p = params;
    51 |             log.info(`[FREEBUSY] Execute called with params: ${JSON.stringify(p)}`);
    52 |             try {
    53 |                 const client = toolClient();
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#952 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/calendar/freebusy.js:15](#)

Dependency without integrity verification

```
> 13 | Object.defineProperty(exports, "__esModule", { value: true });
    14 | exports.registerFeishuCalendarFreebusyTool = registerFeishuCalendarFreebusyTool;
    15 | const typebox_1 = require("@sinclair/typebox");
    16 | const helpers_1 = require("../helpers.js");
    17 | // -----
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#953 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/calendar/freebusy.js:16](#)

Dependency without integrity verification

```
14 | exports.registerFeishuCalendarFreebusyTool = registerFeishuCalendarFreebusyTool;
15 | const typebox_1 = require("@sinclair/typebox");
16 | const helpers_1 = require("../helpers.js");
17 | // -----
18 | // Schema
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#954 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/calendar/freebusy.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
  2 | /**
  3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#955 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/calendar/index.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
  2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
  3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#956 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/oapi/calendar/index.js:9](#)

Dangerous execution: Object.defineProperty(exports, "registerFeishuCalendarCalendarTool", { enumerable:

```
7 | exports.registerFeishuCalendarFreebusyTool = exports.registerFeishuCalendarEventAttendeeTool =
  exports.registerFeishuCalendarEventTool = exports.registerFeishuCalendarCalendarTool = void 0;
8 | var calendar_1 = require("./calendar.js");
> 9 | Object.defineProperty(exports, "registerFeishuCalendarCalendarTool", { enumerable: true, get:
    function () { return calendar_1.registerFeishuCalendarCalendarTool; } });
  10 | var event_1 = require("./event.js");
  11 | Object.defineProperty(exports, "registerFeishuCalendarEventTool", { enumerable: true, get: function...
    () { return event_1.registerFeishuCalendarEventTool; } });
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#957 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/oapi/calendar/index.js:11](#)

Dangerous execution: Object.defineProperty(exports, "registerFeishuCalendarEventTool", { enumerable:

```
9 | Object.defineProperty(exports, "registerFeishuCalendarCalendarTool", { enumerable: true, get:
  function () { return calendar_1.registerFeishuCalendarCalendarTool; } });
10 | var event_1 = require("./event.js");
> 11 | Object.defineProperty(exports, "registerFeishuCalendarEventTool", { enumerable: true, get: function
    () { return event_1.registerFeishuCalendarEventTool; } });
  12 | var event_attendee_1 = require("./event-attendee.js");
  13 | Object.defineProperty(exports, "registerFeishuCalendarEventAttendeeTool", { enumerable: true, get:
    function () { return event_attendee_1.registerFeishuCalendarEventAttendeeTool; } });
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#958 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/oapi/calendar/index.js:13](#)

Dangerous execution: Object.defineProperty(exports, "registerFeishuCalendarEventAttendeeTool", { enum

```
11 | Object.defineProperty(exports, "registerFeishuCalendarEventTool", { enumerable: true, get: function
    () { return event_1.registerFeishuCalendarEventTool; } });
  12 | var event_attendee_1 = require("./event-attendee.js");
> 13 | Object.defineProperty(exports, "registerFeishuCalendarEventAttendeeTool", { enumerable: true, get:
    function () { return event_attendee_1.registerFeishuCalendarEventAttendeeTool; } });
  14 | var freebusy_1 = require("./freebusy.js");
  15 | Object.defineProperty(exports, "registerFeishuCalendarFreebusyTool", { enumerable: true, get:
    function () { return freebusy_1.registerFeishuCalendarFreebusyTool; } });
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#959 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/oapi/calendar/index.js:15](#)

Dangerous execution: Object.defineProperty(exports, "registerFeishuCalendarFreebusyTool", { enumerable:

```
13 | Object.defineProperty(exports, "registerFeishuCalendarEventAttendeeTool", { enumerable: true, get:
function () { return event_attendee_1.registerFeishuCalendarEventAttendeeTool; } });
14 | var freebusy_1 = require("./freebusy.js");
> 15 | Object.defineProperty(exports, "registerFeishuCalendarFreebusyTool", { enumerable: true, get:
function () { return freebusy_1.registerFeishuCalendarFreebusyTool; } });...
16 |
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#960 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[src/tools/oapi/calendar/index.js:9](#)

Potential secret: possible hardcoded secret

```
7 | exports.registerFeishuCalendarFreebusyTool = exports.registerFeishuCalendarEventAttendeeTool =
exports.registerFeishuCalendarEventTool = exports.registerFeishuCalendarCalendarTool = void 0;
8 | var calendar_1 = require("./calendar.js");
> 9 | Object.defineProperty(exports, "registerFeishuCalendarCalendarTool", { enumerable: true, get:
function () { return calendar_1.registerFeishuCalendarCalendarTool; } });
10 | var event_1 = require("./event.js");
11 | Object.defineProperty(exports, "registerFeishuCalendarEventTool", { enumerable: true, get: function
() { return event_1.registerFeishuCalendarEventTool; } });
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#961 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[src/tools/oapi/calendar/index.js:13](#)

Potential secret: possible hardcoded secret

```
11 | Object.defineProperty(exports, "registerFeishuCalendarEventTool", { enumerable: true, get: function
() { return event_1.registerFeishuCalendarEventTool; } });
12 | var event_attendee_1 = require("./event-attendee.js");
> 13 | Object.defineProperty(exports, "registerFeishuCalendarEventAttendeeTool", { enumerable: true, get:
function () { return event_attendee_1.registerFeishuCalendarEventAttendeeTool; } });
14 | var freebusy_1 = require("./freebusy.js");
15 | Object.defineProperty(exports, "registerFeishuCalendarFreebusyTool", { enumerable: true, get:
function () { return freebusy_1.registerFeishuCalendarFreebusyTool; } });
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#962 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[src/tools/oapi/calendar/index.js:15](#)

Potential secret: possible hardcoded secret

```
13 | Object.defineProperty(exports, "registerFeishuCalendarEventAttendeeTool", { enumerable: true, get:
function () { return event_attendee_1.registerFeishuCalendarEventAttendeeTool; } });
14 | var freebusy_1 = require("./freebusy.js");
> 15 | Object.defineProperty(exports, "registerFeishuCalendarFreebusyTool", { enumerable: true, get:
function () { return freebusy_1.registerFeishuCalendarFreebusyTool; } });...
16 |
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#963 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/calendar/index.js:8](#)

Dependency without integrity verification

```
6 | Object.defineProperty(exports, "__esModule", { value: true });
7 | exports.registerFeishuCalendarFreebusyTool = exports.registerFeishuCalendarEventAttendeeTool =
exports.registerFeishuCalendarEventTool = exports.registerFeishuCalendarCalendarTool = void 0;
> 8 | var calendar_1 = require("./calendar.js");
9 | Object.defineProperty(exports, "registerFeishuCalendarCalendarTool", { enumerable: true, get:
function () { return calendar_1.registerFeishuCalendarCalendarTool; } });
10 | var event_1 = require("./event.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#964 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/calendar/index.js:10](#)

Dependency without integrity verification

```
8 | var calendar_1 = require("./calendar.js");
9 | Object.defineProperty(exports, "registerFeishuCalendarCalendarTool", { enumerable: true, get:
function () { return calendar_1.registerFeishuCalendarCalendarTool; } });
> 10 | var event_1 = require("./event.js");
11 | Object.defineProperty(exports, "registerFeishuCalendarEventTool", { enumerable: true, get: function
() { return event_1.registerFeishuCalendarEventTool; } });
12 | var event_attendee_1 = require("./event-attendee.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#965 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/calendar/index.js:12](#)

Dependency without integrity verification

```
10 | var event_1 = require("./event.js");
11 | Object.defineProperty(exports, "registerFeishuCalendarEventTool", { enumerable: true, get: function
() { return event_1.registerFeishuCalendarEventTool; } });
> 12 | var event_attendee_1 = require("./event-attendee.js");
13 | Object.defineProperty(exports, "registerFeishuCalendarEventAttendeeTool", { enumerable: true, get:
function () { return event_attendee_1.registerFeishuCalendarEventAttendeeTool; } });...
14 | var freebusy_1 = require("./freebusy.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#966 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/calendar/index.js:14](#)

Dependency without integrity verification

```
12 | var event_attendee_1 = require("./event-attendee.js");
13 | Object.defineProperty(exports, "registerFeishuCalendarEventAttendeeTool", { enumerable: true, get:
function () { return event_attendee_1.registerFeishuCalendarEventAttendeeTool; } });
> 14 | var freebusy_1 = require("./freebusy.js");
15 | Object.defineProperty(exports, "registerFeishuCalendarFreebusyTool", { enumerable: true, get:
function () { return freebusy_1.registerFeishuCalendarFreebusyTool; } });
16 |
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#967 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/calendar/index.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
2 | /**
3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#968 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/chat/chat.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#969 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/chat/chat.js:65](#)

High-risk permission pattern: async execute(_toolCallId, params) {

```
63 |         description: 'Nău(b7Ž«NýŒ u(~PNf•¤EJ{it ]âQw0 Actions: searchÿ d }"•¤R ^hÿ e/c Qs•.‹İS9'M•¤T yð0 •¤b TXÿ , ge
64 |         parameters: FeishuChatSchema,
> 65 |         async execute(_toolCallId, params) {
66 |             const p = params;...
67 |             try {
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#970 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/chat/chat.js:18](#)

Dependency without integrity verification

```
16 | Object.defineProperty(exports, "__esModule", { value: true });
17 | exports.registerChatSearchTool = registerChatSearchTool;
> 18 | const typebox_1 = require("@sinclair/typebox");
19 | const helpers_1 = require("../helpers.js");
20 | // -----
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#971 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/chat/chat.js:19](#)

Dependency without integrity verification

```
17 | exports.registerChatSearchTool = registerChatSearchTool;
18 | const typebox_1 = require("@sinclair/typebox");
> 19 | const helpers_1 = require("../helpers.js");
20 | // -----
21 | // Schema
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#972 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/chat/chat.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
  2 | /**...
  3 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#973 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/chat/index.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
  2 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
  3 | * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#974 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/chat/index.js:12](#)

Dependency without integrity verification

```
10 | Object.defineProperty(exports, "__esModule", { value: true });
11 | exports.registerFeishuChatTools = registerFeishuChatTools;
> 12 | const chat_1 = require("./chat.js");
    13 | const members_1 = require("./members.js");
    14 | function registerFeishuChatTools(api) {
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#975 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/chat/index.js:13](#)

Dependency without integrity verification

```
11 | exports.registerFeishuChatTools = registerFeishuChatTools;
12 | const chat_1 = require("./chat.js");
> 13 | const members_1 = require("./members.js");
    14 | function registerFeishuChatTools(api) {
    15 |     const registered = [];
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#976 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/chat/members.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
 2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates...
 3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#977 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/chat/members.js:46](#)

High-risk permission pattern: `async execute(_toolCallId, params) {`

```
> 44 |         'lèa ÿ N 0 •0Vb•¤-ÄQ...v,,g:VhN°b TX0 ',
 45 |         parameters: ChatMembersSchema,
 46 |         async execute(_toolCallId, params) {
 47 |             const p = params;
 48 |             try {
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#978 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/chat/members.js:13](#)

Dependency without integrity verification

```
> 11 | Object.defineProperty(exports, "__esModule", { value: true });
 12 | exports.registerChatMembersTool = registerChatMembersTool;
 13 | const typebox_1 = require("@sinclair/typebox");
 14 | const helpers_1 = require("../helpers.js");
 15 | // -----
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use `>=` or `latest`. 3. Run `npm audit` / `pip-audit` in CI. 4. Use `pip install --require-hashes` for Python. 5. Verify package signatures where available.

#979 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/chat/members.js:14](#)

Dependency without integrity verification

```
> 12 | exports.registerChatMembersTool = registerChatMembersTool;
 13 | const typebox_1 = require("@sinclair/typebox");
 14 | const helpers_1 = require("../helpers.js");
 15 | // -----
 16 | // Schema
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#980 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/chat/members.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
   2 | /**
   3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#981 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/common/get-user.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
   2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
   3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#982 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/common/get-user.js:39](#)

High-risk permission pattern: async execute(_toolCallId, params) {

```
37 |         '•ÔVpu(b7YÓT 0 Y4PÍ0 •@{±0 bKg:S÷0 •è•è{IOá`o0 ',
38 |         parameters: GetUserSchema,
> 39 |         async execute(_toolCallId, params) {
   40 |             const p = params;
   41 |             try {
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#983 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/common/get-user.js:14](#)

Dependency without integrity verification

```
12 | Object.defineProperty(exports, "__esModule", { value: true });
13 | exports.registerGetUserTool = registerGetUserTool;
> 14 | const typebox_1 = require("@sinclair/typebox");
    15 | const helpers_1 = require("../helpers.js");...
16 | // -----
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#984 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/common/get-user.js:15](#)

Dependency without integrity verification

```
13 | exports.registerGetUserTool = registerGetUserTool;
14 | const typebox_1 = require("@sinclair/typebox");
> 15 | const helpers_1 = require("../helpers.js");
    16 | // -----
17 | // Schema
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#985 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/common/get-user.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
   2 | /**
   3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#986 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/common/index.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
   2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
   3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#987 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/oapi/common/index.js:9](#)

Dangerous execution: Object.defineProperty(exports, "registerGetUserTool", { enumerable: true, get: f

```
7 | exports.registerSearchUserTool = exports.registerGetUserTool = void 0;
8 | var get_user_1 = require("../get-user.js");
> 9 | Object.defineProperty(exports, "registerGetUserTool", { enumerable: true, get: function () { return
    get_user_1.registerGetUserTool; } });
10 | var search_user_1 = require("../search-user.js");
11 | Object.defineProperty(exports, "registerSearchUserTool", { enumerable: true, get: function ()...
    { return search_user_1.registerSearchUserTool; } });
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#988 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/oapi/common/index.js:11](#)

Dangerous execution: Object.defineProperty(exports, "registerSearchUserTool", { enumerable: true, get

```
9 | Object.defineProperty(exports, "registerGetUserTool", { enumerable: true, get: function () { return
    get_user_1.registerGetUserTool; } });
10 | var search_user_1 = require("../search-user.js");
> 11 | Object.defineProperty(exports, "registerSearchUserTool", { enumerable: true, get: function ()
    { return search_user_1.registerSearchUserTool; } });
12 |
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#989 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/common/index.js:8](#)

Dependency without integrity verification

```
6 | Object.defineProperty(exports, "__esModule", { value: true });
7 | exports.registerSearchUserTool = exports.registerGetUserTool = void 0;
> 8 | var get_user_1 = require("../get-user.js");
9 | Object.defineProperty(exports, "registerGetUserTool", { enumerable: true, get: function () { return
    get_user_1.registerGetUserTool; } });
10 | var search_user_1 = require("../search-user.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#990 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/common/index.js:10](#)

Dependency without integrity verification

```
8 | var get_user_1 = require("./get-user.js");
9 | Object.defineProperty(exports, "registerGetUserTool", { enumerable: true, get: function () { return
get_user_1.registerGetUserTool; } });
> 10 | var search_user_1 = require("./search-user.js");
11 | Object.defineProperty(exports, "registerSearchUserTool", { enumerable: true, get: function ()
{ return search_user_1.registerSearchUserTool; } });
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#991 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/common/index.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
2 | /**
3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#992 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/common/search-user.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#993 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/common/search-user.js:44](#)

High-risk permission pattern: async execute(_toolCallId, params) {

```
42 |         description: 'd }"TX]â0á`öý • •ÇQs•.çÍd }"YÓT 0 bKg:S÷0 •@{±ÿ 0 ' + '•ÔVpS9' Mv„TX]âR ^hÿ S T+YÓT 0 •è•è0 open
43 |         parameters: SearchUserSchema,
> 44 |         async execute(_toolCallId, params) {
45 |             const p = params;
46 |             try {
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#994 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/common/search-user.js:13](#)

Dependency without integrity verification

```
11 | Object.defineProperty(exports, "__esModule", { value: true });
12 | exports.registerSearchUserTool = registerSearchUserTool;
> 13 | const typebox_1 = require("@sinclair/typebox");
    14 | const helpers_1 = require("../helpers.js");...
15 | // -----
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#995 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/common/search-user.js:14](#)

Dependency without integrity verification

```
12 | exports.registerSearchUserTool = registerSearchUserTool;
13 | const typebox_1 = require("@sinclair/typebox");
> 14 | const helpers_1 = require("../helpers.js");
    15 | // -----
16 | // Schema
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#996 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/common/search-user.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
    2 | /**
    3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#997 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/drive/doc-comments.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
    2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
    3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#998 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[src/tools/oapi/drive/doc-comments.js:163](#)

Potential secret: possible hardcoded secret

```
161 |             let actualFileType = p.file_type;
162 |             if (p.file_type === 'wiki') {
163 |                 log.info(`doc_comments: detected wiki token="${p.file_token}", converting to
> 163 |                 obj_token...`);
164 |                 try {
165 |                     const wikiNodeRes = await client.invoke('feishu_wiki_space_node.get', (sdk,...
opts) => sdk.wiki.space.getNode({
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#999 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/drive/doc-comments.js:154](#)

High-risk permission pattern: async execute(_toolCallId, params) {

```
152 |             'e/c wiki token0 ',
153 |             parameters: DocCommentsSchema,
> 154 |             async execute(_toolCallId, params) {
155 |                 const p = params;
156 |                 try {
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#1000 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/drive/doc-comments.js:18](#)

Dependency without integrity verification

```
16 | Object.defineProperty(exports, "__esModule", { value: true });
17 | exports.registerDocCommentsTool = registerDocCommentsTool;
> 18 | const typebox_1 = require("@sinclair/typebox");
19 | const helpers_1 = require("../helpers.js");
20 | // -----
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1001 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/drive/doc-comments.js:19](#)

Dependency without integrity verification

```
17 | exports.registerDocCommentsTool = registerDocCommentsTool;
18 | const typebox_1 = require("@sinclair/typebox");
> 19 | const helpers_1 = require("../helpers.js");
20 | // -----
21 | // Schema
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1002 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/drive/doc-comments.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
   2 | /**...
   3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#1003 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/drive/doc-media.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
   2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
   3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#1004 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/oapi/drive/doc-media.js:20](#)

Dangerous execution: var __createBinding = (this && this.__createBinding) || (Object.create ? (functi

```
18 | */
19 | /* eslint-disable @typescript-eslint/no-explicit-any */
> 20 | var __createBinding = (this && this.__createBinding) || (Object.create ? (function(o, m, k, k2) {
21 |     if (k2 === undefined) k2 = k;
22 |     var desc = Object.getOwnPropertyDescriptor(m, k);
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#1005 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/oapi/drive/doc-media.js:24](#)

Dangerous execution: `desc = { enumerable: true, get: function() { return m[k]; } };`

```
22 |     var desc = Object.getOwnPropertyDescriptor(m, k);
23 |     if (!desc || ("get" in desc ? !m.__esModule : desc.writable || desc.configurable)) {
24 |       desc = { enumerable: true, get: function() { return m[k]; } };
25 |     }...
26 |     Object.defineProperty(o, k2, desc);
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#1006 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/oapi/drive/doc-media.js:27](#)

Dangerous execution: `}} : (function(o, m, k, k2) {`

```
25 |     }
26 |     Object.defineProperty(o, k2, desc);
27 |   }} : (function(o, m, k, k2) {
28 |     if (k2 === undefined) k2 = k;
29 |     o[k2] = m[k];
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#1007 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/oapi/drive/doc-media.js:31](#)

Dangerous execution: `var __setModuleDefault = (this && this.__setModuleDefault) || (Object.create ? (`

```
29 |     o[k2] = m[k];
30 |   }));
31 |   var __setModuleDefault = (this && this.__setModuleDefault) || (Object.create ? (function(o, v) {
32 |     Object.defineProperty(o, "default", { enumerable: true, value: v });
33 |   }) : function(o, v) {
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#1008 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/oapi/drive/doc-media.js:33](#)

Dangerous execution: `}} : function(o, v) {`

```
31 |   var __setModuleDefault = (this && this.__setModuleDefault) || (Object.create ? (function(o, v) {
32 |     Object.defineProperty(o, "default", { enumerable: true, value: v });
33 |   }) : function(o, v) {
34 |     o["default"] = v;
35 |   });
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#1009 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/oapi/drive/doc-media.js:36](#)

Dangerous execution: `var __importStar = (this && this.__importStar) || (function () {`

```
34 |     o["default"] = v;
35 | });
> 36 | var __importStar = (this && this.__importStar) || (function () {
37 |     var ownKeys = function(o) {...
38 |         ownKeys = Object.getOwnPropertyNames || function (o) {
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#1010 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/oapi/drive/doc-media.js:37](#)

Dangerous execution: `var ownKeys = function(o) {`

```
35 | });
36 | var __importStar = (this && this.__importStar) || (function () {
> 37 |     var ownKeys = function(o) {
38 |         ownKeys = Object.getOwnPropertyNames || function (o) {
39 |             var ar = [];
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#1011 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/oapi/drive/doc-media.js:38](#)

Dangerous execution: `ownKeys = Object.getOwnPropertyNames || function (o) {`

```
36 | var __importStar = (this && this.__importStar) || (function () {
37 |     var ownKeys = function(o) {
> 38 |         ownKeys = Object.getOwnPropertyNames || function (o) {
39 |             var ar = [];
40 |             for (var k in o) if (Object.prototype.hasOwnProperty.call(o, k)) ar[ar.length] = k;
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#1012 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/oapi/drive/doc-media.js:45](#)

Dangerous execution: return function (mod) {

```
43 |         return ownKeys(o);
44 |     };
> 45 |     return function (mod) {
46 |         if (mod && mod.__esModule) return mod;...
47 |         var result = {};
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#1013 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[src/tools/oapi/drive/doc-media.js:289](#)

Potential secret: possible hardcoded secret

```
287 |     }
288 |     async function handleDownload(p, client, log) {
> 289 |         log.info(`download: resource_type=${p.resource_type}, token="${p.resource_token}"`);
290 |         let res;
291 |         if (p.resource_type === 'media') {
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (`detect-secrets`, `trufflehog`) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add `.env` to `.gitignore`.

#1014 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/drive/doc-media.js:354](#)

High-risk permission pattern: async execute(_toolCallId, params) {

```
352 |         '\n\n0 'İ%*0 insert NÄe/c g,W0e$Nö•i_„0 URL VprG<÷0•u( create-doc/update-doc v„ <image url= "..."/> <il00
353 |         parameters: DocMediaSchema,
> 354 |         async execute(_toolCallId, params) {
355 |             const p = params;
356 |             try {
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#1015 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/drive/doc-media.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
2 | /**
3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include `agent_id`, `timestamp`, `action`, `parameters`, and `outcome` in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#1016 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/drive/file.d.ts:7](#)

High-risk permission pattern: * Actions: list, get_meta, copy, move, delete, upload, download

```
5 | * feishu_drive_file tool -- Manage Feishu Drive files.
6 | *
> 7 | * Actions: list, get_meta, copy, move, delete, upload, download
8 | *...
9 | * Uses the Feishu Drive API:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#1017 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/drive/file.d.ts:14](#)

High-risk permission pattern: * - delete: DELETE /open-apis/drive/v1/files/:file_token

```
12 | * - copy: POST /open-apis/drive/v1/files/:file_token/copy
13 | * - move: POST /open-apis/drive/v1/files/:file_token/move
> 14 | * - delete: DELETE /open-apis/drive/v1/files/:file_token
15 | * - upload: POST /open-apis/drive/v1/files/upload_all
16 | * - download: GET /open-apis/drive/v1/files/:file_token/download
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#1018 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/drive/file.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
2 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
3 | * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#1019 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/oapi/drive/file.js:20](#)

Dangerous execution: var __createBinding = (this && this.__createBinding) || (Object.create ? (functi

```
18 | */
19 | /* eslint-disable @typescript-eslint/no-explicit-any */
> 20 | var __createBinding = (this && this.__createBinding) || (Object.create ? (function(o, m, k, k2) {
21 |     if (k2 === undefined) k2 = k;
22 |     var desc = Object.getOwnPropertyDescriptor(m, k);
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#1020 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/oapi/drive/file.js:24](#)

Dangerous execution: `desc = { enumerable: true, get: function() { return m[k]; } };`

```
22 |     var desc = Object.getOwnPropertyDescriptor(m, k);
23 |     if (!desc || ("get" in desc ? !m.__esModule : desc.writable || desc.configurable)) {
> 24 |         desc = { enumerable: true, get: function() { return m[k]; } };
25 |     }...
26 |     Object.defineProperty(o, k2, desc);
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#1021 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/oapi/drive/file.js:27](#)

Dangerous execution: `}} : (function(o, m, k, k2) {`

```
25 |     }
26 |     Object.defineProperty(o, k2, desc);
> 27 | }} : (function(o, m, k, k2) {
28 |     if (k2 === undefined) k2 = k;
29 |     o[k2] = m[k];
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#1022 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/oapi/drive/file.js:31](#)

Dangerous execution: `var __setModuleDefault = (this && this.__setModuleDefault) || (Object.create ? (`

```
29 |         o[k2] = m[k];
30 |     }));
> 31 | var __setModuleDefault = (this && this.__setModuleDefault) || (Object.create ? (function(o, v) {
32 |     Object.defineProperty(o, "default", { enumerable: true, value: v });
33 | }) : function(o, v) {
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#1023 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/oapi/drive/file.js:33](#)

Dangerous execution: `}} : function(o, v) {`

```
31 | var __setModuleDefault = (this && this.__setModuleDefault) || (Object.create ? (function(o, v) {
32 |   Object.defineProperty(o, "default", { enumerable: true, value: v });
> 33 | }) : function(o, v) {
34 |   o["default"] = v;...
35 | });
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#1024 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/oapi/drive/file.js:36](#)

Dangerous execution: `var __importStar = (this && this.__importStar) || (function () {`

```
34 |   o["default"] = v;
35 | });
> 36 | var __importStar = (this && this.__importStar) || (function () {
37 |   var ownKeys = function(o) {
38 |     ownKeys = Object.getOwnPropertyNames || function (o) {
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#1025 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/oapi/drive/file.js:37](#)

Dangerous execution: `var ownKeys = function(o) {`

```
35 | });
36 | var __importStar = (this && this.__importStar) || (function () {
> 37 |   var ownKeys = function(o) {
38 |     ownKeys = Object.getOwnPropertyNames || function (o) {
39 |       var ar = [];
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#1026 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/oapi/drive/file.js:38](#)

Dangerous execution: `ownKeys = Object.getOwnPropertyNames || function (o) {`

```
36 | var __importStar = (this && this.__importStar) || (function () {
37 |   var ownKeys = function(o) {
> 38 |     ownKeys = Object.getOwnPropertyNames || function (o) {
39 |       var ar = [];
40 |       for (var k in o) if (Object.prototype.hasOwnProperty.call(o, k)) ar[ar.length] = k;
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#1027 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/oapi/drive/file.js:45](#)

Dangerous execution: return function (mod) {

```
43 |         return ownKeys(o);
44 |     };
> 45 |     return function (mod) {
46 |         if (mod && mod.__esModule) return mod;...
47 |         var result = {};
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#1028 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[src/tools/oapi/drive/file.js:106](#)

Potential secret: possible hardcoded secret

```
104 |         }},
105 |     }}, {
> 106 |         description: "%*gâ<âv,,e†hcR ^hÿ by'îgâ<âÿ g Y 50 N*ÿ 0 y:0<ÿ [{doc_token: 'Z1FjxxxxxxxxxxxxxxxxxtnAc',
107 |         minItems: 1,
108 |         maxItems: 50,
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add `.env` to `.gitignore`.

#1029 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/drive/file.js:8](#)

High-risk permission pattern: * Actions: list, get_meta, copy, move, delete, upload, download

```
6 | * feishu_drive_file tool -- Manage Feishu Drive files.
7 | *
> 8 | * Actions: list, get_meta, copy, move, delete, upload, download
9 | *
10 | * Uses the Feishu Drive API:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#1030 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/drive/file.js:15](#)

High-risk permission pattern: * - delete: DELETE /open-apis/drive/v1/files/:file_token

```
13 | * - copy: POST /open-apis/drive/v1/files/:file_token/copy
14 | * - move: POST /open-apis/drive/v1/files/:file_token/move
> 15 | * - delete: DELETE /open-apis/drive/v1/files/:file_token
16 | * - upload: POST /open-apis/drive/v1/files/upload_all...
17 | * - download: GET /open-apis/drive/v1/files/:file_token/download
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#1031 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/drive/file.js:161](#)

High-risk permission pattern: // DELETE FILE

```
159 |     },
160 | },
> 161 | // DELETE FILE
162 | typebox_1.Type.Object({
163 |   action: typebox_1.Type.Literal('delete'),
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#1032 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/drive/file.js:163](#)

High-risk permission pattern: action: typebox_1.Type.Literal('delete'),

```
161 | // DELETE FILE
162 | typebox_1.Type.Object({
> 163 |   action: typebox_1.Type.Literal('delete'),
164 |   file_token: typebox_1.Type.String({
165 |     description: 'e†Nö tokenŷ _AXkŷ ',
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#1033 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/drive/file.js:227](#)

High-risk permission pattern: 'ln- deleteŷ R -de†Nöŷ ŷ R -de†Nö' +

```
225 | 'ln- copyŷ Y R6e†Nöŷ ŷ Y R6e†NÖR0c [š0M•n' +
226 | 'ln- moveŷ yŮR`e†Nöŷ ŷ yŮR`e†NÖR0c [še†NöY9' +
> 227 | 'ln- deleteŷ R -de†Nöŷ ŷ R -de†Nö' +
228 | 'ln- uploadŷ N 0 e†Nöŷ ŷ N 0 g,W0e†NÖR0N'zz•00 c00> file_pathŷ g,W0e†Nö•i_„ŷ b file_content_base64ŷ Base
229 | 'ln- downloadŷ N •}e†Nöŷ ŷ N •}e†NÖR0g,W00 c00> output_pathŷ g,W00Y[X•i_„ŷ R 0Y[XR0g,W0ŷ T&R •0Vp Base64
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#1034 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/drive/file.js:230](#)

High-risk permission pattern: `'\n\n0 'Í%•0 copy/move/delete dÍOl— %• file_token TÆ type SÂep0 get_meta O•u( request_docs ep~ÄSÂ`

```
228 |           '\n- uploadÿ N 0 e†Nöÿ ÿ N 0 g,w0e†NöR0N'zz•ô0 cð0> file_pathÿ g,w0e†Nö•i_„ÿ b file_content_base64ÿ Base
> 229 |           '\n- downloadÿ N •}e†Nöÿ ÿ N •}e†NöR0g,w00 cð0> output_pathÿ g,w00ÿ[X•i_„ÿ R Oÿ[XR0g,w0ÿ T&R •ôVp Base64
230 |           '\n\n0 'Í%•0 copy/move/delete dÍOl— %• file_token TÆ type SÂep0 get_meta O•u( request_docs ep~ÄSÂep0 ' +
231 |           '\n0 'Í%•0 upload 0 QH0•u( file_pathÿ •êR`‹üS0e†Nö0 cðS0e†NöT TÆÿ'\ ÿ ÿ N_e/c file_content_base64ÿ — bKR
232 |           '\n0 'Í%•0 download cð0> output_path eðOÿ[XR0g,w0ÿ SiNâf/e†Nö•i_„b e†NöY9•i_„+file_nameÿ ÿ N cð0>R •ôVp B
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#1035 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/drive/file.js:234](#)

High-risk permission pattern: `async execute(_toolCallId, params) {`

```
232 |           '\n0 'Í%•0 download cð0> output_path eðOÿ[XR0g,w0ÿ SiNâf/e†Nö•i_„b e†NöY9•i_„+file_nameÿ ÿ N cð0>R •ôVp B
> 233 |           parameters: FeishuDriveFileSchema,
234 |           async execute(_toolCallId, params) {
235 |               const p = params;
236 |               try {
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#1036 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/drive/file.js:328](#)

High-risk permission pattern: `// DELETE FILE`

```
326 |           }
327 |           // -----
> 328 |           // DELETE FILE
329 |           // -----
330 |           case 'delete': {
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#1037 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/drive/file.js:330](#)

High-risk permission pattern: `case 'delete': {`

```
328 | // DELETE FILE
329 | // -----
> 330 | case 'delete': {
331 |     log.info(`delete: file_token=${p.file_token}, type=${p.type}`);
332 |     const res = await client.invoke('feishu_drive_file.delete', (sdk, opts) =>...
    sdk.drive.file.delete({
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#1038 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/drive/file.js:331](#)

High-risk permission pattern: `log.info(`delete: file_token=${p.file_token}, type=${p.type}`);`

```
329 | // -----
330 | case 'delete': {
> 331 |     log.info(`delete: file_token=${p.file_token}, type=${p.type}`);
332 |     const res = await client.invoke('feishu_drive_file.delete', (sdk, opts) =>
    sdk.drive.file.delete({
333 |         path: { file_token: p.file_token },
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#1039 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/drive/file.js:332](#)

High-risk permission pattern: `const res = await client.invoke('feishu_drive_file.delete', (sdk, opts) => sdk.d`

```
330 | case 'delete': {
331 |     log.info(`delete: file_token=${p.file_token}, type=${p.type}`);
> 332 |     const res = await client.invoke('feishu_drive_file.delete', (sdk, opts) =>
    sdk.drive.file.delete({
333 |         path: { file_token: p.file_token },
334 |         params: {
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#1040 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/drive/file.js:340](#)

High-risk permission pattern: `log.info(`delete: success${data?.task_id ? ``, task_id=${data.task_id}` : ''});`

```
338 | (0, helpers_1.assertLarkOk)(res);
339 | const data = res.data;
> 340 | log.info(`delete: success${data?.task_id ? ``, task_id=${data.task_id}` : ''}
    `);
341 | return (0, helpers_1.json)({
342 |     success: true,
```


Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#1041 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/drive/file.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
   2 | /**
   3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#1042 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/drive/index.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
   2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
   3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#1043 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/drive/index.js:11](#)

Dependency without integrity verification

```
9 | Object.defineProperty(exports, "__esModule", { value: true });
10 | exports.registerFeishuDriveTools = registerFeishuDriveTools;
> 11 | const accounts_1 = require("../../core/accounts.js");
   12 | const tools_config_1 = require("../../core/tools-config.js");
   13 | const file_1 = require("../file.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1044 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/drive/index.js:12](#)

Dependency without integrity verification

```
10 | exports.registerFeishuDriveTools = registerFeishuDriveTools;
11 | const accounts_1 = require("../../core/accounts.js");
> 12 | const tools_config_1 = require("../../core/tools-config.js");
    13 | const file_1 = require("../file.js");...
    14 | const doc_comments_1 = require("../doc-comments.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1045 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/drive/index.js:13](#)

Dependency without integrity verification

```
11 | const accounts_1 = require("../../core/accounts.js");
12 | const tools_config_1 = require("../../core/tools-config.js");
> 13 | const file_1 = require("../file.js");
    14 | const doc_comments_1 = require("../doc-comments.js");
    15 | const doc_media_1 = require("../doc-media.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1046 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/drive/index.js:14](#)

Dependency without integrity verification

```
12 | const tools_config_1 = require("../../core/tools-config.js");
13 | const file_1 = require("../file.js");
> 14 | const doc_comments_1 = require("../doc-comments.js");
    15 | const doc_media_1 = require("../doc-media.js");
    16 | /**
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1047 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/drive/index.js:15](#)

Dependency without integrity verification

```
13 | const file_1 = require("../file.js");
14 | const doc_comments_1 = require("../doc-comments.js");
> 15 | const doc_media_1 = require("../doc-media.js");
    16 | /**
    17 | * lèQEb@g Drive jâQw
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1048 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/helpers.d.ts:31](#)

High-risk permission pattern: `* async execute(_toolCallId, params) {`

```
29 | *   api.registerTool({
30 | *     name: "my_oapi_tool",
> 31 | *     async execute(_toolCallId, params) {
32 | *       const client = createFeishuClientFromConfig(api.config);...
33 | *       const res = await client.calendar.calendarEvent.list({ ... });
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#1049 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/oapi/helpers.js:26](#)

Dangerous execution: `Object.defineProperty(exports, "formatToolResult", { enumerable: true, get: func`

```
24 | // -----
25 | var helpers_1 = require("../helpers.js");
> 26 | Object.defineProperty(exports, "formatToolResult", { enumerable: true, get: function () { return
    helpers_1.formatToolResult; } });
27 | Object.defineProperty(exports, "formatToolError", { enumerable: true, get: function () { return
    helpers_1.formatToolError; } });
28 | Object.defineProperty(exports, "createToolLogger", { enumerable: true, get: function () { return
    helpers_1.createToolLogger; } });
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#1050 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/oapi/helpers.js:27](#)

Dangerous execution: `Object.defineProperty(exports, "formatToolError", { enumerable: true, get: funct`

```
25 | var helpers_1 = require("../helpers.js");
26 | Object.defineProperty(exports, "formatToolResult", { enumerable: true, get: function () { return
    helpers_1.formatToolResult; } });
> 27 | Object.defineProperty(exports, "formatToolError", { enumerable: true, get: function () { return
    helpers_1.formatToolError; } });
28 | Object.defineProperty(exports, "createToolLogger", { enumerable: true, get: function () { return
    helpers_1.createToolLogger; } });
29 | Object.defineProperty(exports, "createClientGetter", { enumerable: true, get: function () { return
    helpers_1.createClientGetter; } });
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#1051 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/oapi/helpers.js:28](#)

Dangerous execution: `Object.defineProperty(exports, "createToolLogger", { enumerable: true, get: func`

```
26 | Object.defineProperty(exports, "formatToolResult", { enumerable: true, get: function () { return
    helpers_1.formatToolResult; } });
27 | Object.defineProperty(exports, "formatToolError", { enumerable: true, get: function () { return
    helpers_1.formatToolError; } });
> 28 | Object.defineProperty(exports, "createToolLogger", { enumerable: true, get: function () { return
    helpers_1.createToolLogger; } });
29 | Object.defineProperty(exports, "createClientGetter", { enumerable: true, get: function () { return
    helpers_1.createClientGetter; } });
30 | Object.defineProperty(exports, "createToolContext", { enumerable: true, get: function () { return...
    helpers_1.createToolContext; } });
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#1052 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/oapi/helpers.js:29](#)

Dangerous execution: `Object.defineProperty(exports, "createClientGetter", { enumerable: true, get: fu`

```
27 | Object.defineProperty(exports, "formatToolError", { enumerable: true, get: function () { return
    helpers_1.formatToolError; } });
28 | Object.defineProperty(exports, "createToolLogger", { enumerable: true, get: function () { return
    helpers_1.createToolLogger; } });
> 29 | Object.defineProperty(exports, "createClientGetter", { enumerable: true, get: function () { return
    helpers_1.createClientGetter; } });
30 | Object.defineProperty(exports, "createToolContext", { enumerable: true, get: function () { return
    helpers_1.createToolContext; } });
31 | Object.defineProperty(exports, "getFirstAccount", { enumerable: true, get: function () { return
    helpers_1.getFirstAccount; } });
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#1053 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/oapi/helpers.js:30](#)

Dangerous execution: `Object.defineProperty(exports, "createToolContext", { enumerable: true, get: fun`

```
28 | Object.defineProperty(exports, "createToolLogger", { enumerable: true, get: function () { return
    helpers_1.createToolLogger; } });
29 | Object.defineProperty(exports, "createClientGetter", { enumerable: true, get: function () { return
    helpers_1.createClientGetter; } });
> 30 | Object.defineProperty(exports, "createToolContext", { enumerable: true, get: function () { return
    helpers_1.createToolContext; } });
31 | Object.defineProperty(exports, "getFirstAccount", { enumerable: true, get: function () { return
    helpers_1.getFirstAccount; } });
32 | Object.defineProperty(exports, "validateRequiredParams", { enumerable: true, get: function ()
    { return helpers_1.validateRequiredParams; } });
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#1054 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/oapi/helpers.js:31](#)

Dangerous execution: `Object.defineProperty(exports, "getFirstAccount", { enumerable: true, get: funct`

```
29 | Object.defineProperty(exports, "createClientGetter", { enumerable: true, get: function () { return
helpers_1.createClientGetter; } });
30 | Object.defineProperty(exports, "createToolContext", { enumerable: true, get: function () { return
helpers_1.createToolContext; } });
> 31 | Object.defineProperty(exports, "getFirstAccount", { enumerable: true, get: function () { return
helpers_1.getFirstAccount; } });
32 | Object.defineProperty(exports, "validateRequiredParams", { enumerable: true, get: function ()
{ return helpers_1.validateRequiredParams; } });
33 | Object.defineProperty(exports, "validateEnum", { enumerable: true, get: function () { return...
helpers_1.validateEnum; } });
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#1055 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/oapi/helpers.js:32](#)

Dangerous execution: `Object.defineProperty(exports, "validateRequiredParams", { enumerable: true, get`

```
30 | Object.defineProperty(exports, "createToolContext", { enumerable: true, get: function () { return
helpers_1.createToolContext; } });
31 | Object.defineProperty(exports, "getFirstAccount", { enumerable: true, get: function () { return
helpers_1.getFirstAccount; } });
> 32 | Object.defineProperty(exports, "validateRequiredParams", { enumerable: true, get: function ()
{ return helpers_1.validateRequiredParams; } });
33 | Object.defineProperty(exports, "validateEnum", { enumerable: true, get: function () { return
helpers_1.validateEnum; } });
34 | Object.defineProperty(exports, "checkToolRegistration", { enumerable: true, get: function ()
{ return helpers_1.checkToolRegistration; } });
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#1056 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/oapi/helpers.js:33](#)

Dangerous execution: `Object.defineProperty(exports, "validateEnum", { enumerable: true, get: function`

```
31 | Object.defineProperty(exports, "getFirstAccount", { enumerable: true, get: function () { return
helpers_1.getFirstAccount; } });
32 | Object.defineProperty(exports, "validateRequiredParams", { enumerable: true, get: function ()
{ return helpers_1.validateRequiredParams; } });
> 33 | Object.defineProperty(exports, "validateEnum", { enumerable: true, get: function () { return
helpers_1.validateEnum; } });
34 | Object.defineProperty(exports, "checkToolRegistration", { enumerable: true, get: function ()
{ return helpers_1.checkToolRegistration; } });
35 | Object.defineProperty(exports, "registerTool", { enumerable: true, get: function () { return
helpers_1.registerTool; } });
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#1057 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/oapi/helpers.js:34](#)

Dangerous execution: `Object.defineProperty(exports, "checkToolRegistration", { enumerable: true, get:`

```
32 | Object.defineProperty(exports, "validateRequiredParams", { enumerable: true, get: function ()
{ return helpers_1.validateRequiredParams; } });
33 | Object.defineProperty(exports, "validateEnum", { enumerable: true, get: function () { return
helpers_1.validateEnum; } });
> 34 | Object.defineProperty(exports, "checkToolRegistration", { enumerable: true, get: function ()
{ return helpers_1.checkToolRegistration; } });
35 | Object.defineProperty(exports, "registerTool", { enumerable: true, get: function () { return
helpers_1.registerTool; } });
36 | // -----
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#1058 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/oapi/helpers.js:35](#)

Dangerous execution: `Object.defineProperty(exports, "registerTool", { enumerable: true, get: function`

```
33 | Object.defineProperty(exports, "validateEnum", { enumerable: true, get: function () { return
helpers_1.validateEnum; } });
34 | Object.defineProperty(exports, "checkToolRegistration", { enumerable: true, get: function ()
{ return helpers_1.checkToolRegistration; } });
> 35 | Object.defineProperty(exports, "registerTool", { enumerable: true, get: function () { return
helpers_1.registerTool; } });
36 | // -----
37 | // ToolClientÿ ]âQw\B-ßN [çb7ziÿ
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#1059 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/oapi/helpers.js:40](#)

Dangerous execution: `Object.defineProperty(exports, "ToolClient", { enumerable: true, get: function (`

```
38 | // -----
39 | var tool_client_1 = require("../core/tool-client.js");
> 40 | Object.defineProperty(exports, "ToolClient", { enumerable: true, get: function () { return
tool_client_1.ToolClient; } });
41 | Object.defineProperty(exports, "createToolClient", { enumerable: true, get: function () { return
tool_client_1.createToolClient; } });
42 | Object.defineProperty(exports, "NeedAuthorizationError", { enumerable: true, get: function ()
{ return tool_client_1.NeedAuthorizationError; } });
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#1060 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/oapi/helpers.js:41](#)

Dangerous execution: `Object.defineProperty(exports, "createToolClient", { enumerable: true, get: func`

```
39 | var tool_client_1 = require("../core/tool-client.js");
40 | Object.defineProperty(exports, "ToolClient", { enumerable: true, get: function () { return
tool_client_1.ToolClient; } });
> 41 | Object.defineProperty(exports, "createToolClient", { enumerable: true, get: function () { return
tool_client_1.createToolClient; } });
42 | Object.defineProperty(exports, "NeedAuthorizationError", { enumerable: true, get: function ()
{ return tool_client_1.NeedAuthorizationError; } });
43 | Object.defineProperty(exports, "AppScopeMissingError", { enumerable: true, get: function () { return...
tool_client_1.AppScopeMissingError; } });
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#1061 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/oapi/helpers.js:42](#)

Dangerous execution: `Object.defineProperty(exports, "NeedAuthorizationError", { enumerable: true, get`

```
40 | Object.defineProperty(exports, "ToolClient", { enumerable: true, get: function () { return
tool_client_1.ToolClient; } });
41 | Object.defineProperty(exports, "createToolClient", { enumerable: true, get: function () { return
tool_client_1.createToolClient; } });
> 42 | Object.defineProperty(exports, "NeedAuthorizationError", { enumerable: true, get: function ()
{ return tool_client_1.NeedAuthorizationError; } });
43 | Object.defineProperty(exports, "AppScopeMissingError", { enumerable: true, get: function () { return
tool_client_1.AppScopeMissingError; } });
44 | Object.defineProperty(exports, "UserAuthRequiredError", { enumerable: true, get: function ()
{ return tool_client_1.UserAuthRequiredError; } });
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#1062 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/oapi/helpers.js:43](#)

Dangerous execution: `Object.defineProperty(exports, "AppScopeMissingError", { enumerable: true, get:`

```
41 | Object.defineProperty(exports, "createToolClient", { enumerable: true, get: function () { return
tool_client_1.createToolClient; } });
42 | Object.defineProperty(exports, "NeedAuthorizationError", { enumerable: true, get: function ()
{ return tool_client_1.NeedAuthorizationError; } });
> 43 | Object.defineProperty(exports, "AppScopeMissingError", { enumerable: true, get: function () { return
tool_client_1.AppScopeMissingError; } });
44 | Object.defineProperty(exports, "UserAuthRequiredError", { enumerable: true, get: function ()
{ return tool_client_1.UserAuthRequiredError; } });
45 | Object.defineProperty(exports, "UserScopeInsufficientError", { enumerable: true, get: function ()
{ return tool_client_1.UserScopeInsufficientError; } });
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#1063 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/oapi/helpers.js:44](#)

Dangerous execution: `Object.defineProperty(exports, "UserAuthRequiredError", { enumerable: true, get:`

```
42 | Object.defineProperty(exports, "NeedAuthorizationError", { enumerable: true, get: function ()
{ return tool_client_1.NeedAuthorizationError; } });
43 | Object.defineProperty(exports, "AppScopeMissingError", { enumerable: true, get: function () { return
tool_client_1.AppScopeMissingError; } });
> 44 | Object.defineProperty(exports, "UserAuthRequiredError", { enumerable: true, get: function ()
{ return tool_client_1.UserAuthRequiredError; } });
45 | Object.defineProperty(exports, "UserScopeInsufficientError", { enumerable: true, get: function ()
{ return tool_client_1.UserScopeInsufficientError; } });...
46 | // -----
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#1064 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/oapi/helpers.js:45](#)

Dangerous execution: `Object.defineProperty(exports, "UserScopeInsufficientError", { enumerable: true,`

```
43 | Object.defineProperty(exports, "AppScopeMissingError", { enumerable: true, get: function () { return
tool_client_1.AppScopeMissingError; } });
44 | Object.defineProperty(exports, "UserAuthRequiredError", { enumerable: true, get: function ()
{ return tool_client_1.UserAuthRequiredError; } });
> 45 | Object.defineProperty(exports, "UserScopeInsufficientError", { enumerable: true, get: function ()
{ return tool_client_1.UserScopeInsufficientError; } });
46 | // -----
47 | // OAPI N u(ÿ [¢b7zï0¿cwR ^ú
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#1065 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/oapi/helpers.js:348](#)

Dangerous execution: `Object.defineProperty(exports, "assertLarkOk", { enumerable: true, get: function`

```
346 | */
347 | var api_error_1 = require("../core/api-error.js");
> 348 | Object.defineProperty(exports, "assertLarkOk", { enumerable: true, get: function () { return
api_error_1.assertLarkOk; } });
349 | Object.defineProperty(exports, "formatLarkError", { enumerable: true, get: function () { return
api_error_1.formatLarkError; } });
350 | // -----
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#1066 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/oapi/helpers.js:349](#)

Dangerous execution: `Object.defineProperty(exports, "formatLarkError", { enumerable: true, get: funct`

```
347 | var api_error_1 = require("../core/api-error.js");
348 | Object.defineProperty(exports, "assertLarkOk", { enumerable: true, get: function () { return
api_error_1.assertLarkOk; } });
> 349 | Object.defineProperty(exports, "formatLarkError", { enumerable: true, get: function () { return
api_error_1.formatLarkError; } });
350 | // -----
351 | // OAPI N u(ÿ invoke() • <iR$e-
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#1067 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/oapi/helpers.js:372](#)

Dangerous execution: `Object.defineProperty(exports, "handleInvokeErrorWithAutoAuth", { enumerable: tr`

```
370 | // -----
371 | var auto_auth_1 = require("../auto-auth.js");
> 372 | Object.defineProperty(exports, "handleInvokeErrorWithAutoAuth", { enumerable: true, get: function ()
{ return auto_auth_1.handleInvokeErrorWithAutoAuth; } });
373 | // -----
374 | // Schema •...R@ÿ LLM SÊY}v„[W{&N2g$N>
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#1068 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/helpers.js:65](#)

High-risk permission pattern: `* async execute(_toolCallId, params) {`

```
63 | *   api.registerTool({
64 | *     name: "my_oapi_tool",
> 65 | *     async execute(_toolCallId, params) {
66 | *       const client = createFeishuClientFromConfig(api.config);
67 | *       const res = await client.calendar.calendarEvent.list({ ... });
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#1069 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/im/format-messages.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
2 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
3 | * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#1070 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/im/format-messages.js:16](#)

Dependency without integrity verification

```
14 | exports.formatMessageItem = formatMessageItem;
15 | exports.formatMessageList = formatMessageList;
> 16 | const lark_logger_1 = require("../../core/lark-logger.js");
17 | const content_converter_1 = require("../../messaging/converters/content-converter.js");...
18 | const user_name_uat_1 = require("../user-name-uat.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1071 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/im/format-messages.js:17](#)

Dependency without integrity verification

```
15 | exports.formatMessageList = formatMessageList;
16 | const lark_logger_1 = require("../../core/lark-logger.js");
> 17 | const content_converter_1 = require("../../messaging/converters/content-converter.js");
18 | const user_name_uat_1 = require("../user-name-uat.js");
19 | const time_utils_1 = require("../time-utils.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1072 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/im/format-messages.js:18](#)

Dependency without integrity verification

```
16 | const lark_logger_1 = require("../../core/lark-logger.js");
17 | const content_converter_1 = require("../../messaging/converters/content-converter.js");
> 18 | const user_name_uat_1 = require("../user-name-uat.js");
19 | const time_utils_1 = require("../time-utils.js");
20 | const log = {0, lark_logger_1.larkLogger}('oapi/im/format-messages');
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1073 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/im/format-messages.js:19](#)

Dependency without integrity verification

```
17 | const content_converter_1 = require("../../messaging/converters/content-converter.js");
18 | const user_name_uat_1 = require("../user-name-uat.js");
> 19 | const time_utils_1 = require("../time-utils.js");
20 | const log = (0, lark_logger_1.larkLogger)('oapi/im/format-messages');...
21 | // -----
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1074 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/im/index.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#1075 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/im/index.js:12](#)

Dependency without integrity verification

```
10 | Object.defineProperty(exports, "__esModule", { value: true });
11 | exports.registerFeishuImTools = registerFeishuImTools;
> 12 | const message_1 = require("../message.js");
13 | const resource_1 = require("../resource.js");
14 | const message_read_1 = require("../message-read.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1076 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/im/index.js:13](#)

Dependency without integrity verification

```
11 | exports.registerFeishuImTools = registerFeishuImTools;
12 | const message_1 = require("../message.js");
> 13 | const resource_1 = require("../resource.js");
14 | const message_read_1 = require("../message-read.js");
15 | function registerFeishuImTools(api) {
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1077 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/im/index.js:14](#)

Dependency without integrity verification

```
12 | const message_1 = require("./message.js");
13 | const resource_1 = require("./resource.js");
> 14 | const message_read_1 = require("./message-read.js");
15 | function registerFeishuImTools(api) {...
16 |     const registered = [];
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1078 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/im/message-read.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#1079 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/im/message-read.js:110](#)

High-risk permission pattern: async execute(_toolCallId, params) {

```
108 |         '\n\n•ÔVbm^`oR ^hÿ kİgam^`oS T+ message_id0 msg_type0 contentÿ AI Sİ<ûeİg,ÿ 0 sender0 create_time {I[wkμ0
109 |         parameters: GetMessagesSchema,
> 110 |         async execute(_toolCallId, params) {
111 |             const p = params;
112 |             try {
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#1080 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/im/message-read.js:179](#)

High-risk permission pattern: `async execute(_toolCallId, params) {`

```
177 |         '\n\n•ôVbm^`oR ^hÿ h<_ T feishu_im_user_get_messages0 ',
178 |         parameters: GetThreadMessagesSchema,
> 179 |         async execute(_toolCallId, params) {
180 |             const p = params;...
181 |             try {
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#1081 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/im/message-read.js:341](#)

High-risk permission pattern: `async execute(_toolCallId, params) {`

```
339 |         '\nd }"-ôgæN-v,, chat_id T& thread_id Si'MT feishu_im_user_get_messages / feishu_im_user_get_thread_messa
e±0 ',
340 |         parameters: SearchMessagesSchema,
> 341 |         async execute(_toolCallId, params) {
342 |             const p = params;
343 |             try {
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#1082 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/im/message-read.js:16](#)

Dependency without integrity verification

```
14 | Object.defineProperty(exports, "__esModule", { value: true });
15 | exports.registerMessageReadTools = registerMessageReadTools;
> 16 | const typebox_1 = require("@sinclair/typebox");
17 | const helpers_1 = require("../helpers.js");
18 | const time_utils_1 = require("../time-utils.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use `>=` or `latest`. 3. Run `npm audit` / `pip-audit` in CI. 4. Use `pip install --require-hashes` for Python. 5. Verify package signatures where available.

#1083 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/im/message-read.js:17](#)

Dependency without integrity verification

```
15 | exports.registerMessageReadTools = registerMessageReadTools;
16 | const typebox_1 = require("@sinclair/typebox");
> 17 | const helpers_1 = require("../helpers.js");
18 | const time_utils_1 = require("../time-utils.js");
19 | const format_messages_1 = require("../format-messages.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1084 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/im/message-read.js:18](#)

Dependency without integrity verification

```
16 | const typebox_1 = require("@sinclair/typebox");
> 17 | const helpers_1 = require("../helpers.js");
    18 | const time_utils_1 = require("../time-utils.js");
    19 | const format_messages_1 = require("../format-messages.js");...
    20 | const user_name_uat_1 = require("../user-name-uat.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1085 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/im/message-read.js:19](#)

Dependency without integrity verification

```
17 | const helpers_1 = require("../helpers.js");
> 18 | const time_utils_1 = require("../time-utils.js");
    19 | const format_messages_1 = require("../format-messages.js");
    20 | const user_name_uat_1 = require("../user-name-uat.js");
    21 | // =====
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1086 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/im/message-read.js:20](#)

Dependency without integrity verification

```
18 | const time_utils_1 = require("../time-utils.js");
> 19 | const format_messages_1 = require("../format-messages.js");
    20 | const user_name_uat_1 = require("../user-name-uat.js");
    21 | // =====
    22 | // Shared helpers
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1087 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/im/message-read.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
   2 | /**...
   3 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#1088 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/im/message.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
   2 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
   3 | * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#1089 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/im/message.js:213](#)

High-risk permission pattern: `async execute(_toolCallId, params)` {

```
211 |         'y•kbw(u(b7g*f xNT a v,,`ÄQµN •ê^LSÑ• m``o0 ',
212 |         parameters: FeishuImMessageSchema,
> 213 |         async execute(_toolCallId, params) {
214 |             const p = params;
215 |             try {
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#1090 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/im/message.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
   2 | /**...
   3 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#1091 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/im/resource.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
    2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates...
    3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#1092 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/oapi/im/resource.js:13](#)

Dangerous execution: var __createBinding = (this && this.__createBinding) || (Object.create ? (functi

```
11 |  * Qh•èNâu(b7Ž«Nýÿ user_access_tokenÿ æ u(ÿ scope ge•ê real-scope.json0
12 |  */
> 13 | var __createBinding = (this && this.__createBinding) || (Object.create ? (function(o, m, k, k2) {
14 |     if (k2 === undefined) k2 = k;
15 |     var desc = Object.getOwnPropertyDescriptor(m, k);
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#1093 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/oapi/im/resource.js:17](#)

Dangerous execution: desc = { enumerable: true, get: function() { return m[k]; } };

```
15 |     var desc = Object.getOwnPropertyDescriptor(m, k);
16 |     if (!desc || ("get" in desc ? !m.__esModule : desc.writable || desc.configurable)) {
> 17 |         desc = { enumerable: true, get: function() { return m[k]; } };
18 |     }
19 |     Object.defineProperty(o, k2, desc);
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#1094 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/oapi/im/resource.js:20](#)

Dangerous execution: }) : (function(o, m, k, k2) {

```
18 |     }
19 |     Object.defineProperty(o, k2, desc);
> 20 | }) : (function(o, m, k, k2) {
21 |     if (k2 === undefined) k2 = k;
22 |     o[k2] = m[k];
```


Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#1095 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/oapi/im/resource.js:24](#)

Dangerous execution: `var __setModuleDefault = (this && this.__setModuleDefault) || (Object.create ? (`

```
22 |         o[k2] = m[k];
23 |     });
> 24 |     var __setModuleDefault = (this && this.__setModuleDefault) || (Object.create ? (function(o, v) {
25 |         Object.defineProperty(o, "default", { enumerable: true, value: v });...
26 |     }) : function(o, v) {
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#1096 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/oapi/im/resource.js:26](#)

Dangerous execution: `}) : function(o, v) {`

```
24 |     var __setModuleDefault = (this && this.__setModuleDefault) || (Object.create ? (function(o, v) {
25 |         Object.defineProperty(o, "default", { enumerable: true, value: v });
26 |     }) : function(o, v) {
> 27 |         o["default"] = v;
28 |     });
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#1097 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/oapi/im/resource.js:29](#)

Dangerous execution: `var __importStar = (this && this.__importStar) || (function () {`

```
27 |         o["default"] = v;
28 |     });
> 29 |     var __importStar = (this && this.__importStar) || (function () {
30 |         var ownKeys = function(o) {
31 |             ownKeys = Object.getOwnPropertyNames || function (o) {
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#1098 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/oapi/im/resource.js:30](#)

Dangerous execution: var ownKeys = function(o) {

```
28 | });
29 | var __importStar = (this && this.__importStar) || (function () {
> 30 |     var ownKeys = function(o) {
31 |         ownKeys = Object.getOwnPropertyNames || function (o) {...
32 |         var ar = [];
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#1099 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/oapi/im/resource.js:31](#)

Dangerous execution: ownKeys = Object.getOwnPropertyNames || function (o) {

```
29 | var __importStar = (this && this.__importStar) || (function () {
30 |     var ownKeys = function(o) {
> 31 |         ownKeys = Object.getOwnPropertyNames || function (o) {
32 |             var ar = [];
33 |             for (var k in o) if (Object.prototype.hasOwnProperty.call(o, k)) ar[ar.length] = k;
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#1100 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/oapi/im/resource.js:38](#)

Dangerous execution: return function (mod) {

```
36 |         return ownKeys(o);
37 |     };
> 38 |     return function (mod) {
39 |         if (mod && mod.__esModule) return mod;
40 |         var result = {};
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#1101 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/im/resource.js:128](#)

High-risk permission pattern: async execute(_toolCallId, params) {

```
126 |         '\n-PR6ÿ e±NöY'\ N •...•Ç 100MB0 N e/c N •}^h`AS 0 T ^v•LSÑm^`o0 SarGN-v„•Dn•0 ',
127 |         parameters: FetchResourceSchema,
> 128 |         async execute(_toolCallId, params) {
129 |             const p = params;
130 |             try {
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#1102 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/im/resource.js:48](#)

Dependency without integrity verification

```
46 | Object.defineProperty(exports, "__esModule", { value: true });
47 | exports.registerFeishuImUserFetchResourceTool = registerFeishuImUserFetchResourceTool;
> 48 | const fs = __importStar(require("node:fs/promises"));
49 | const path = __importStar(require("node:path"));...
50 | const temp_path_1 = require("openclaw/plugin-sdk/temp-path");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1103 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/im/resource.js:49](#)

Dependency without integrity verification

```
47 | exports.registerFeishuImUserFetchResourceTool = registerFeishuImUserFetchResourceTool;
48 | const fs = __importStar(require("node:fs/promises"));
> 49 | const path = __importStar(require("node:path"));
50 | const temp_path_1 = require("openclaw/plugin-sdk/temp-path");
51 | const typebox_1 = require("@sinclair/typebox");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1104 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/im/resource.js:50](#)

Dependency without integrity verification

```
48 | const fs = __importStar(require("node:fs/promises"));
49 | const path = __importStar(require("node:path"));
> 50 | const temp_path_1 = require("openclaw/plugin-sdk/temp-path");
51 | const typebox_1 = require("@sinclair/typebox");
52 | const helpers_1 = require("../helpers.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1105 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/im/resource.js:51](#)

Dependency without integrity verification

```
49 | const path = __importStar(require("node:path"));
50 | const temp_path_1 = require("openclaw/plugin-sdk/temp-path");
> 51 | const typebox_1 = require("@sinclair/typebox");
52 | const helpers_1 = require("../helpers.js");...
53 | // -----
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1106 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/im/resource.js:52](#)

Dependency without integrity verification

```
50 | const temp_path_1 = require("openclaw/plugin-sdk/temp-path");
51 | const typebox_1 = require("@sinclair/typebox");
> 52 | const helpers_1 = require("../helpers.js");
53 | // -----
54 | // Helper: MIME type to extension mapping
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1107 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/im/resource.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
2 | /**
3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#1108 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/im/time-utils.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#1109 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/im/time-utils.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
   2 | /**...
   3 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#1110 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/im/user-name-uat.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
   2 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
   3 | * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#1111 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/im/user-name-uat.js:41](#)

High-risk permission pattern: cache.delete(oldest);

```
> 39 |         const oldest = cache.keys().next().value;
   40 |         if (oldest !== undefined)
   41 |             cache.delete(oldest);
   42 |     }
   43 | }
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#1112 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/im/user-name-uat.js:53](#)

High-risk permission pattern: cache.delete(openId);

```
> 51 |         return undefined;
   52 |         if (entry.expireAt <= Date.now()) {
   53 |             cache.delete(openId);
   54 |             return undefined;
   55 |         }
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#1113 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/im/user-name-uat.js:57](#)

High-risk permission pattern: `cache.delete(openId)`;

```
55 |     }  
56 |     // LRU refresh  
> 57 |     cache.delete(openId);  
58 |     cache.set(openId, entry);...  
59 |     return entry.name;
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#1114 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/im/user-name-uat.js:66](#)

High-risk permission pattern: `cache.delete(openId)`;

```
64 |     const now = Date.now();  
65 |     for (const [openId, name] of entries) {  
> 66 |         cache.delete(openId);  
67 |         cache.set(openId, { name, expireAt: now + UAT_TTL_MS });  
68 |     }
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#1115 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/im/user-name-uat.js:92](#)

High-risk permission pattern: `cache.delete(id)`;

```
90 |         else {  
91 |             if (entry)  
> 92 |                 cache.delete(id);  
93 |             missing.push(id);  
94 |         }
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#1116 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/im/user-name-uat.js:123](#)

High-risk permission pattern: `cache.delete(openId)`;

```
121 |         const name = typeof rawName === 'string' ? rawName : rawName?.value;  
122 |         if (openId && name) {  
> 123 |             cache.delete(openId);  
124 |             cache.set(openId, { name, expireAt: Date.now() + UAT_TTL_MS });  
125 |             result.set(openId, name);
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#1117 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/im/user-name-uat.js:22](#)

Dependency without integrity verification

```
20 | exports.setUATUserNames = setUATUserNames;
21 | exports.batchResolveUserNamesAsUser = batchResolveUserNamesAsUser;
> 22 | const helpers_1 = require("../helpers.js");
23 | // -----
24 | // rîzĖ* [Xÿ accountId !' Map<openId, { name, expireAt }>
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1118 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/im/user-name-uat.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
  2 | /**
  3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#1119 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/index.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
  2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
  3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#1120 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/index.js:13](#)

Dependency without integrity verification

```
11 | Object.defineProperty(exports, "__esModule", { value: true });
12 | exports.registerOapiTools = registerOapiTools;
> 13 | const index_1 = require("../tat/im/index.js");
    14 | const index_2 = require("../calendar/index.js");...
    15 | const index_3 = require("../task/index.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1121 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/index.js:14](#)

Dependency without integrity verification

```
12 | exports.registerOapiTools = registerOapiTools;
13 | const index_1 = require("../tat/im/index.js");
> 14 | const index_2 = require("../calendar/index.js");
    15 | const index_3 = require("../task/index.js");
    16 | const index_4 = require("../bitable/index.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1122 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/index.js:15](#)

Dependency without integrity verification

```
13 | const index_1 = require("../tat/im/index.js");
14 | const index_2 = require("../calendar/index.js");
> 15 | const index_3 = require("../task/index.js");
    16 | const index_4 = require("../bitable/index.js");
    17 | const index_5 = require("../common/index.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1123 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/index.js:16](#)

Dependency without integrity verification

```
14 | const index_2 = require("../calendar/index.js");
15 | const index_3 = require("../task/index.js");
> 16 | const index_4 = require("../bitable/index.js");
    17 | const index_5 = require("../common/index.js");
    18 | // import { registerFeishuMailTools } from "../mail/index";
```


Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1124 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/index.js:17](#)

Dependency without integrity verification

```
15 | const index_3 = require("./task/index.js");
> 16 | const index_4 = require("./bitable/index.js");
    17 | const index_5 = require("./common/index.js");
    18 | // import { registerFeishuMailTools } from "./mail/index";...
    19 | const index_6 = require("./search/index.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1125 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/index.js:19](#)

Dependency without integrity verification

```
17 | const index_5 = require("./common/index.js");
> 18 | // import { registerFeishuMailTools } from "./mail/index";
    19 | const index_6 = require("./search/index.js");
    20 | const index_7 = require("./drive/index.js");
    21 | const index_8 = require("./wiki/index.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1126 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/index.js:20](#)

Dependency without integrity verification

```
18 | // import { registerFeishuMailTools } from "./mail/index";
> 19 | const index_6 = require("./search/index.js");
    20 | const index_7 = require("./drive/index.js");
    21 | const index_8 = require("./wiki/index.js");
    22 | const index_9 = require("./sheets/index.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1127 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/index.js:21](#)

Dependency without integrity verification

```
19 | const index_6 = require("../search/index.js");
20 | const index_7 = require("../drive/index.js");
> 21 | const index_8 = require("../wiki/index.js");
    22 | const index_9 = require("../sheets/index.js");...
    23 | // import { registerFeishuOkrTools } from "../okr/index";
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1128 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/index.js:22](#)

Dependency without integrity verification

```
20 | const index_7 = require("../drive/index.js");
21 | const index_8 = require("../wiki/index.js");
> 22 | const index_9 = require("../sheets/index.js");
    23 | // import { registerFeishuOkrTools } from "../okr/index";
    24 | const index_10 = require("../chat/index.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1129 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/index.js:24](#)

Dependency without integrity verification

```
22 | const index_9 = require("../sheets/index.js");
23 | // import { registerFeishuOkrTools } from "../okr/index";
> 24 | const index_10 = require("../chat/index.js");
    25 | const index_11 = require("../im/index.js");
    26 | function registerOapiTools(api) {
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1130 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/index.js:25](#)

Dependency without integrity verification

```
23 | // import { registerFeishuOkrTools } from "../okr/index";
24 | const index_10 = require("../chat/index.js");
> 25 | const index_11 = require("../im/index.js");
    26 | function registerOapiTools(api) {
    27 |     // Common tools
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1131 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/sdk-types.d.ts:50](#)

High-risk permission pattern: `/** Drive async task response (move / delete). */`

```
48 |     };
49 |   }
> 50 |   /** Drive async task response (move / delete). */
    |   export interface DriveTaskData {...
51 |     task_id?: string;
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#1132 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/sdk-types.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
    | 2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
    | 3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#1133 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/sdk-types.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
    | 2 | /**
    | 3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#1134 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/search/doc-search.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
 2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates...
 3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#1135 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/search/doc-search.js:120](#)

High-risk permission pattern: `async execute(_toolCallId, params) {`

```
118 |         '0 'í%•0 •0Vb~0gæS T+h ~TædX%•$0N@ý <h>h {-S ^ùS9'MQs•.<íý 0 ',
119 |         parameters: FeishuSearchDocWikiSchema,
> 120 |         async execute(_toolCallId, params) {
121 |             const p = params;
122 |             try {
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#1136 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/search/doc-search.js:16](#)

Dependency without integrity verification

```
14 | Object.defineProperty(exports, "__esModule", { value: true });
15 | exports.registerFeishuSearchDocWikiTool = registerFeishuSearchDocWikiTool;
> 16 | const typebox_1 = require("@sinclair/typebox");
17 | const helpers_1 = require("../helpers.js");
18 | // -----
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use `>=` or `latest`. 3. Run `npm audit` / `pip-audit` in CI. 4. Use `pip install --require-hashes` for Python. 5. Verify package signatures where available.

#1137 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/search/doc-search.js:17](#)

Dependency without integrity verification

```
15 | exports.registerFeishuSearchDocWikiTool = registerFeishuSearchDocWikiTool;
16 | const typebox_1 = require("@sinclair/typebox");
> 17 | const helpers_1 = require("../helpers.js");
18 | // -----
19 | // Schema - Helper types
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1138 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/search/doc-search.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
  2 | /**...
  3 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#1139 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/search/index.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
  2 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
  3 | * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#1140 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/search/index.js:11](#)

Dependency without integrity verification

```
9 | Object.defineProperty(exports, "__esModule", { value: true });
10 | exports.registerFeishuSearchTools = registerFeishuSearchTools;
> 11 | const accounts_1 = require("../../core/accounts.js");
  12 | const tools_config_1 = require("../../core/tools-config.js");
  13 | const doc_search_1 = require("../doc-search.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1141 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/search/index.js:12](#)

Dependency without integrity verification

```
10 | exports.registerFeishuSearchTools = registerFeishuSearchTools;
11 | const accounts_1 = require("../../core/accounts.js");
> 12 | const tools_config_1 = require("../../core/tools-config.js");
13 | const doc_search_1 = require("../doc-search.js");...
14 | /**
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1142 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/search/index.js:13](#)

Dependency without integrity verification

```
11 | const accounts_1 = require("../../core/accounts.js");
12 | const tools_config_1 = require("../../core/tools-config.js");
> 13 | const doc_search_1 = require("../doc-search.js");
14 | /**
15 | * lèQEb@g Search ]âQw
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1143 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/sheets/index.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
2 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
3 | * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#1144 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/sheets/index.js:11](#)

Dependency without integrity verification

```
9 | Object.defineProperty(exports, "__esModule", { value: true });
10 | exports.registerFeishuSheetsTools = registerFeishuSheetsTools;
> 11 | const accounts_1 = require("../../core/accounts.js");
12 | const tools_config_1 = require("../../core/tools-config.js");
13 | const sheet_1 = require("../sheet.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1145 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/sheets/index.js:12](#)

Dependency without integrity verification

```
10 | exports.registerFeishuSheetsTools = registerFeishuSheetsTools;
> 11 | const accounts_1 = require("../core/accounts.js");
    12 | const tools_config_1 = require("../core/tools-config.js");
    13 | const sheet_1 = require("./sheet.js");...
    14 | /**
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1146 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/sheets/index.js:13](#)

Dependency without integrity verification

```
11 | const accounts_1 = require("../core/accounts.js");
12 | const tools_config_1 = require("../core/tools-config.js");
> 13 | const sheet_1 = require("./sheet.js");
    14 | /**
    15 |  * lèQ€ Sheets jâQw
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1147 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/sheets/sheet.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
    2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
    3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#1148 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/oapi/sheets/sheet.js:17](#)

Dangerous execution: `var __createBinding = (this && this.__createBinding) || (Object.create ? (functi`

```
15 | /*
16 |  */
> 17 | var __createBinding = (this && this.__createBinding) || (Object.create ? (function(o, m, k, k2) {
18 |     if (k2 === undefined) k2 = k;...
19 |     var desc = Object.getOwnPropertyDescriptor(m, k);
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#1149 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/oapi/sheets/sheet.js:21](#)

Dangerous execution: `desc = { enumerable: true, get: function() { return m[k]; } };`

```
19 |     var desc = Object.getOwnPropertyDescriptor(m, k);
20 |     if (!desc || ("get" in desc ? !m.__esModule : desc.writable || desc.configurable)) {
> 21 |         desc = { enumerable: true, get: function() { return m[k]; } };
22 |     }
23 |     Object.defineProperty(o, k2, desc);
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#1150 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/oapi/sheets/sheet.js:24](#)

Dangerous execution: `}} : (function(o, m, k, k2) {`

```
22 |     }
23 |     Object.defineProperty(o, k2, desc);
> 24 | }} : (function(o, m, k, k2) {
25 |     if (k2 === undefined) k2 = k;
26 |     o[k2] = m[k];
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#1151 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/oapi/sheets/sheet.js:28](#)

Dangerous execution: `var __setModuleDefault = (this && this.__setModuleDefault) || (Object.create ? (`

```
26 |     o[k2] = m[k];
27 | }));
> 28 | var __setModuleDefault = (this && this.__setModuleDefault) || (Object.create ? (function(o, v) {
29 |     Object.defineProperty(o, "default", { enumerable: true, value: v });
30 | }) : function(o, v) {
```


Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#1152 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/oapi/sheets/sheet.js:30](#)

Dangerous execution: `}} : function(o, v) {`

```
28 | var __setModuleDefault = (this && this.__setModuleDefault) || (Object.create ? (function(o, v) {
29 |   Object.defineProperty(o, "default", { enumerable: true, value: v });
30 | }) : function(o, v) {
31 |   o["default"] = v;...
32 | });
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#1153 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/oapi/sheets/sheet.js:33](#)

Dangerous execution: `var __importStar = (this && this.__importStar) || (function () {`

```
31 |   o["default"] = v;
32 | });
33 | var __importStar = (this && this.__importStar) || (function () {
34 |   var ownKeys = function(o) {
35 |     ownKeys = Object.getOwnPropertyNames || function (o) {
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#1154 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/oapi/sheets/sheet.js:34](#)

Dangerous execution: `var ownKeys = function(o) {`

```
32 | });
33 | var __importStar = (this && this.__importStar) || (function () {
34 |   var ownKeys = function(o) {
35 |     ownKeys = Object.getOwnPropertyNames || function (o) {
36 |       var ar = [];
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#1155 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/oapi/sheets/sheet.js:35](#)

Dangerous execution: ownKeys = Object.getOwnPropertyNames || function (o) {

```
33 | var __importStar = (this && this.__importStar) || (function () {
34 |     var ownKeys = function(o) {
35 |         ownKeys = Object.getOwnPropertyNames || function (o) {
36 |             var ar = [];...
37 |             for (var k in o) if (Object.prototype.hasOwnProperty.call(o, k)) ar[ar.length] = k;
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#1156 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/oapi/sheets/sheet.js:42](#)

Dangerous execution: return function (mod) {

```
40 |         return ownKeys(o);
41 |     };
42 |     return function (mod) {
43 |         if (mod && mod.__esModule) return mod;
44 |         var result = {};
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#1157 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/sheets/sheet.js:383](#)

High-risk permission pattern: async execute(_toolCallId, params) {

```
381 |         '\n- exportý [üQúN: xlsx b csvý csv _A~{c [š sheet_idý ',
382 |         parameters: FeishuSheetSchema,
383 |         async execute(_toolCallId, params) {
384 |             const p = params;
385 |             try {
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#1158 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/sheets/sheet.js:52](#)

Dependency without integrity verification

```
50 | Object.defineProperty(exports, "__esModule", { value: true });
51 | exports.registerFeishuSheetTool = registerFeishuSheetTool;
52 | const fs = __importStar(require("node:fs/promises"));
53 | const path = __importStar(require("node:path"));
54 | const typebox_1 = require("@sinclair/typebox");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1159 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/sheets/sheet.js:53](#)

Dependency without integrity verification

```
51 | exports.registerFeishuSheetTool = registerFeishuSheetTool;
> 52 | const fs = __importStar(require("node:fs/promises"));
    53 | const path = __importStar(require("node:path"));
    54 | const typebox_1 = require("@sinclair/typebox");...
    55 | const helpers_1 = require("../helpers.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1160 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/sheets/sheet.js:54](#)

Dependency without integrity verification

```
52 | const fs = __importStar(require("node:fs/promises"));
> 53 | const path = __importStar(require("node:path"));
    54 | const typebox_1 = require("@sinclair/typebox");
    55 | const helpers_1 = require("../helpers.js");
    56 | const domains_1 = require("../.../core/domains.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1161 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/sheets/sheet.js:55](#)

Dependency without integrity verification

```
53 | const path = __importStar(require("node:path"));
> 54 | const typebox_1 = require("@sinclair/typebox");
    55 | const helpers_1 = require("../helpers.js");
    56 | const domains_1 = require("../.../core/domains.js");
    57 | // -----
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1162 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/sheets/sheet.js:56](#)

Dependency without integrity verification

```
54 | const typebox_1 = require("@sinclair/typebox");
55 | const helpers_1 = require("../helpers.js");
> 56 | const domains_1 = require("../core/domains.js");
57 | // -----
58 | // Constants
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1163 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/sheets/sheet.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
2 | /**
3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#1164 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/task/comment.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#1165 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/task/comment.js:59](#)

High-risk permission pattern: async execute(_toolCallId, params) {

```
57 |         description: '0 Nâu(b7Z«Ný0 ~pNfNÛRi<Ä<°{it ]âQw0 _Su(b7%•lBmÛR /gâ<ânÛRi<Ä<°0 VpY <Ä<°eö0•u(0 Actions: creat
58 |         parameters: FeishuTaskCommentSchema,
> 59 |         async execute(_toolCallId, params) {
60 |             const p = params;
61 |             try {
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#1166 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/task/comment.js:17](#)

Dependency without integrity verification

```
15 | Object.defineProperty(exports, "__esModule", { value: true });
16 | exports.registerFeishuTaskCommentTool = registerFeishuTaskCommentTool;
> 17 | const typebox_1 = require("@sinclair/typebox");
    18 | const helpers_1 = require("../helpers.js");...
19 | // -----
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1167 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/task/comment.js:18](#)

Dependency without integrity verification

```
16 | exports.registerFeishuTaskCommentTool = registerFeishuTaskCommentTool;
17 | const typebox_1 = require("@sinclair/typebox");
> 18 | const helpers_1 = require("../helpers.js");
    19 | // -----
20 | // Schema
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1168 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/task/comment.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
    2 | /**
    3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#1169 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/task/index.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
    2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
    3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#1170 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/oapi/task/index.js:9](#)

Dangerous execution: `Object.defineProperty(exports, "registerFeishuTaskTaskTool", { enumerable: true,`

```
7 | exports.registerFeishuTaskSectionTool = exports.registerFeishuTaskSubtaskTool =
  exports.registerFeishuTaskCommentTool = exports.registerFeishuTaskTasklistTool =
  exports.registerFeishuTaskTaskTool = void 0;
8 | var task_1 = require("./task.js");
> 9 | Object.defineProperty(exports, "registerFeishuTaskTaskTool", { enumerable: true, get: function ()
  { return task_1.registerFeishuTaskTaskTool; } });
10 | var tasklist_1 = require("./tasklist.js");
11 | Object.defineProperty(exports, "registerFeishuTaskTasklistTool", { enumerable: true, get: function...
  () { return tasklist_1.registerFeishuTaskTasklistTool; } });
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#1171 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/oapi/task/index.js:11](#)

Dangerous execution: `Object.defineProperty(exports, "registerFeishuTaskTasklistTool", { enumerable: t`

```
9 | Object.defineProperty(exports, "registerFeishuTaskTaskTool", { enumerable: true, get: function ()
  { return task_1.registerFeishuTaskTaskTool; } });
10 | var tasklist_1 = require("./tasklist.js");
> 11 | Object.defineProperty(exports, "registerFeishuTaskTasklistTool", { enumerable: true, get: function
  () { return tasklist_1.registerFeishuTaskTasklistTool; } });
12 | var comment_1 = require("./comment.js");
13 | Object.defineProperty(exports, "registerFeishuTaskCommentTool", { enumerable: true, get: function ()
  { return comment_1.registerFeishuTaskCommentTool; } });
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#1172 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/oapi/task/index.js:13](#)

Dangerous execution: `Object.defineProperty(exports, "registerFeishuTaskCommentTool", { enumerable: tr`

```
11 | Object.defineProperty(exports, "registerFeishuTaskTasklistTool", { enumerable: true, get: function
  () { return tasklist_1.registerFeishuTaskTasklistTool; } });
12 | var comment_1 = require("./comment.js");
> 13 | Object.defineProperty(exports, "registerFeishuTaskCommentTool", { enumerable: true, get: function ()
  { return comment_1.registerFeishuTaskCommentTool; } });
14 | var subtask_1 = require("./subtask.js");
15 | Object.defineProperty(exports, "registerFeishuTaskSubtaskTool", { enumerable: true, get: function ()
  { return subtask_1.registerFeishuTaskSubtaskTool; } });
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#1173 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/oapi/task/index.js:15](#)

Dangerous execution: `Object.defineProperty(exports, "registerFeishuTaskSubtaskTool", { enumerable: tr`

```
13 | Object.defineProperty(exports, "registerFeishuTaskCommentTool", { enumerable: true, get: function ()
{ return comment_1.registerFeishuTaskCommentTool; } });
14 | var subtask_1 = require("./subtask.js");
> 15 | Object.defineProperty(exports, "registerFeishuTaskSubtaskTool", { enumerable: true, get: function ()
{ return subtask_1.registerFeishuTaskSubtaskTool; } });
16 | var section_1 = require("./section.js");
17 | Object.defineProperty(exports, "registerFeishuTaskSectionTool", { enumerable: true, get: function ()...
{ return section_1.registerFeishuTaskSectionTool; } });
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#1174 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/oapi/task/index.js:17](#)

Dangerous execution: `Object.defineProperty(exports, "registerFeishuTaskSectionTool", { enumerable: tr`

```
15 | Object.defineProperty(exports, "registerFeishuTaskSubtaskTool", { enumerable: true, get: function ()
{ return subtask_1.registerFeishuTaskSubtaskTool; } });
16 | var section_1 = require("./section.js");
> 17 | Object.defineProperty(exports, "registerFeishuTaskSectionTool", { enumerable: true, get: function ()
{ return section_1.registerFeishuTaskSectionTool; } });
18 |
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#1175 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/task/index.js:8](#)

Dependency without integrity verification

```
6 | Object.defineProperty(exports, "__esModule", { value: true });
7 | exports.registerFeishuTaskSectionTool = exports.registerFeishuTaskSubtaskTool =
exports.registerFeishuTaskCommentTool = exports.registerFeishuTaskTasklistTool =
exports.registerFeishuTaskTaskTool = void 0;
> 8 | var task_1 = require("./task.js");
9 | Object.defineProperty(exports, "registerFeishuTaskTaskTool", { enumerable: true, get: function ()
{ return task_1.registerFeishuTaskTaskTool; } });
10 | var tasklist_1 = require("./tasklist.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use `>=` or `latest`. 3. Run `npm audit` / `pip-audit` in CI. 4. Use `pip install --require-hashes` for Python. 5. Verify package signatures where available.

#1176 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/task/index.js:10](#)

Dependency without integrity verification

```
8 | var task_1 = require("./task.js");
9 | Object.defineProperty(exports, "registerFeishuTaskTaskTool", { enumerable: true, get: function ()
{ return task_1.registerFeishuTaskTaskTool; } });
> 10 | var tasklist_1 = require("./tasklist.js");
    11 | Object.defineProperty(exports, "registerFeishuTaskTasklistTool", { enumerable: true, get: function
() { return tasklist_1.registerFeishuTaskTasklistTool; } });...
    12 | var comment_1 = require("./comment.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1177 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/task/index.js:12](#)

Dependency without integrity verification

```
10 | var tasklist_1 = require("./tasklist.js");
11 | Object.defineProperty(exports, "registerFeishuTaskTasklistTool", { enumerable: true, get: function
() { return tasklist_1.registerFeishuTaskTasklistTool; } });
> 12 | var comment_1 = require("./comment.js");
    13 | Object.defineProperty(exports, "registerFeishuTaskCommentTool", { enumerable: true, get: function ()
{ return comment_1.registerFeishuTaskCommentTool; } });
    14 | var subtask_1 = require("./subtask.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1178 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/task/index.js:14](#)

Dependency without integrity verification

```
12 | var comment_1 = require("./comment.js");
13 | Object.defineProperty(exports, "registerFeishuTaskCommentTool", { enumerable: true, get: function ()
{ return comment_1.registerFeishuTaskCommentTool; } });
> 14 | var subtask_1 = require("./subtask.js");
    15 | Object.defineProperty(exports, "registerFeishuTaskSubtaskTool", { enumerable: true, get: function ()
{ return subtask_1.registerFeishuTaskSubtaskTool; } });
    16 | var section_1 = require("./section.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1179 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/task/index.js:16](#)

Dependency without integrity verification

```
14 | var subtask_1 = require("./subtask.js");
15 | Object.defineProperty(exports, "registerFeishuTaskSubtaskTool", { enumerable: true, get: function ()
{ return
subtask_1.registerFeishuTaskSubtaskTool; } });
> 16 | var section_1 = require("./section.js");
17 | Object.defineProperty(exports, "registerFeishuTaskSectionTool", { enumerable: true, get: function ()
{ return
section_1.registerFeishuTaskSectionTool; } });...
18 |
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1180 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/task/index.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
2 | /**
3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#1181 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/task/section.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#1182 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/task/section.js:121](#)

High-risk permission pattern: `async execute(_toolCallId, params) {`

```
119 |         description: '0 Nâu(b7Ž«Ny0 ~PNFNÜri•ê[šNIR ~Ä{it ]âQw0 u(NžR ^ú0 gâ<â0 f0e°•ê[šNIR ~Äy NâSÊR QÚR ~ÄQ...v„NÜRi0
120 |         parameters: FeishuTaskSectionSchema,
> 121 |         async execute(_toolCallId, params) {
122 |             const p = params;
123 |             try {
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#1183 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/task/section.js:20](#)

Dependency without integrity verification

```
18 | Object.defineProperty(exports, "__esModule", { value: true });
19 | exports.registerFeishuTaskSectionTool = registerFeishuTaskSectionTool;
> 20 | const typebox_1 = require("@sinclair/typebox");
21 | const helpers_1 = require("../helpers.js");...
22 | // -----
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1184 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/task/section.js:21](#)

Dependency without integrity verification

```
19 | exports.registerFeishuTaskSectionTool = registerFeishuTaskSectionTool;
20 | const typebox_1 = require("@sinclair/typebox");
> 21 | const helpers_1 = require("../helpers.js");
22 | // -----
23 | // Schema
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1185 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/task/section.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
2 | /**
3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#1186 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/task/subtask.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
    2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates...
    3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#1187 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/task/subtask.js:66](#)

High-risk permission pattern: `async execute(_toolCallId, params) {`

```
64 |         description: '0 Nâu(b7Ž«Ný0 ~pNfNûRiv„[PNûRi{it ]âQw0 _Su(b7%•lBR ^ú[PNûRi0 gâ<âNûRiv„[PNûRiR ^he00•u(0 Actio
65 |         parameters: FeishuTaskSubtaskSchema,
> 66 |         async execute(_toolCallId, params) {
    67 |             const p = params;
    68 |             try {
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#1188 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/task/subtask.js:16](#)

Dependency without integrity verification

```
14 | Object.defineProperty(exports, "__esModule", { value: true });
15 | exports.registerFeishuTaskSubtaskTool = registerFeishuTaskSubtaskTool;
> 16 | const typebox_1 = require("@sinclair/typebox");
    17 | const helpers_1 = require("../helpers.js");
    18 | // -----
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1189 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/task/subtask.js:17](#)

Dependency without integrity verification

```
15 | exports.registerFeishuTaskSubtaskTool = registerFeishuTaskSubtaskTool;
16 | const typebox_1 = require("@sinclair/typebox");
> 17 | const helpers_1 = require("../helpers.js");
    18 | // -----
    19 | // Schema
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1190 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/task/subtask.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
  2 | /**...
  3 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#1191 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/task/task.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
  2 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
  3 | * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#1192 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/task/task.js:156](#)

High-risk permission pattern: async execute(_toolCallId, params) {

```
154 |         description: "0 Nău(b7Z«Ný0 ~PnfNÜRi{it ]ăQw0 u(NŽR ^ú0 gă<ă0 fôe°NÜRi0 Actions: createÿ R ^úNÜRiÿ , getÿ f.S
'2024-01-01T00:00:00+08:00'0 ",
155 |         parameters: FeishuTaskTaskSchema,
> 156 |         async execute(_toolCallId, params) {
157 |             const p = params;
158 |             try {
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#1193 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/task/task.js:19](#)

Dependency without integrity verification

```
17 | Object.defineProperty(exports, "__esModule", { value: true });
18 | exports.registerFeishuTaskTaskTool = registerFeishuTaskTaskTool;
> 19 | const typebox_1 = require("@sinclair/typebox");
    20 | const helpers_1 = require("../helpers.js");...
21 | // -----
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1194 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/task/task.js:20](#)

Dependency without integrity verification

```
18 | exports.registerFeishuTaskTaskTool = registerFeishuTaskTaskTool;
19 | const typebox_1 = require("@sinclair/typebox");
> 20 | const helpers_1 = require("../helpers.js");
    21 | // -----
    22 | // Schema
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1195 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/task/task.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
    2 | /**
    3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#1196 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/task/tasklist.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
    2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
    3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#1197 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/task/tasklist.js:89](#)

High-risk permission pattern: `async execute(_toolCallId, params) {`

```
87 |         description: '0 Nâu(b7Ž«Ný0 ~pNfNÜR; n SU{it ]âQw0 _Su(b7%•LBR ^ú/gâ<â/{it n SU0 gâw n SUQ..v„NÜR;eô0•u(0 Actio
88 |         parameters: FeishuTaskTasklistSchema,
> 89 |         async execute(_toolCallId, params) {
90 |             const p = params;...
91 |             try {
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#1198 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/task/tasklist.js:22](#)

Dependency without integrity verification

```
20 | Object.defineProperty(exports, "__esModule", { value: true });
21 | exports.registerFeishuTaskTasklistTool = registerFeishuTaskTasklistTool;
> 22 | const typebox_1 = require("@sinclair/typebox");
23 | const helpers_1 = require("../helpers.js");
24 | // -----
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1199 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/task/tasklist.js:23](#)

Dependency without integrity verification

```
21 | exports.registerFeishuTaskTasklistTool = registerFeishuTaskTasklistTool;
22 | const typebox_1 = require("@sinclair/typebox");
> 23 | const helpers_1 = require("../helpers.js");
24 | // -----
25 | // Schema
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1200 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/task/tasklist.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
2 | /**
3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#1201 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/wiki/index.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
 2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates...
 3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#1202 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/wiki/index.js:11](#)

Dependency without integrity verification

```
9 | Object.defineProperty(exports, "__esModule", { value: true });
10 | exports.registerFeishuWikiTools = registerFeishuWikiTools;
> 11 | const accounts_1 = require("../..../core/accounts.js");
12 | const tools_config_1 = require("../..../core/tools-config.js");
13 | const space_1 = require("../space.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1203 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/wiki/index.js:12](#)

Dependency without integrity verification

```
10 | exports.registerFeishuWikiTools = registerFeishuWikiTools;
11 | const accounts_1 = require("../..../core/accounts.js");
> 12 | const tools_config_1 = require("../..../core/tools-config.js");
13 | const space_1 = require("../space.js");
14 | const space_node_1 = require("../space-node.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1204 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/wiki/index.js:13](#)

Dependency without integrity verification

```
11 | const accounts_1 = require("../..../core/accounts.js");
12 | const tools_config_1 = require("../..../core/tools-config.js");
> 13 | const space_1 = require("../space.js");
14 | const space_node_1 = require("../space-node.js");
15 | /**
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1205 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/wiki/index.js:14](#)

Dependency without integrity verification

```
12 | const tools_config_1 = require("../../core/tools-config.js");
13 | const space_1 = require("./space.js");
> 14 | const space_node_1 = require("./space-node.js");
15 | /**...
16 | * lèQEb@g Wiki jâQw
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1206 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/wiki/space-node.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
2 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
3 | * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#1207 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/wiki/space-node.js:119](#)

High-risk permission pattern: async execute(_toolCallId, params) {

```
117 |         'node_token f/,p¹v,,U/N h <Æ{&ÿ obj_token f/[ž-Ee#hcv,, token0 Si• •Ç get dÍ0\\ wiki |{W<v,, node_token •l
118 |         parameters: FeishuWikiSpaceNodeSchema,
> 119 |         async execute(_toolCallId, params) {
120 |             const p = params;
121 |             try {
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#1208 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/wiki/space-node.js:20](#)

Dependency without integrity verification

```
18 | Object.defineProperty(exports, "__esModule", { value: true });
19 | exports.registerFeishuWikiSpaceNodeTool = registerFeishuWikiSpaceNodeTool;
> 20 | const typebox_1 = require("@sinclair/typebox");
    21 | const helpers_1 = require("../helpers.js");...
22 | // -----
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1209 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/wiki/space-node.js:21](#)

Dependency without integrity verification

```
19 | exports.registerFeishuWikiSpaceNodeTool = registerFeishuWikiSpaceNodeTool;
20 | const typebox_1 = require("@sinclair/typebox");
> 21 | const helpers_1 = require("../helpers.js");
    22 | // -----
23 | // Schema
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1210 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/wiki/space-node.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
   2 | /**
   3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#1211 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/wiki/space.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
   2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
   3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#1212 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oapi/wiki/space.js:68](#)

High-risk permission pattern: `async execute(_toolCallId, params) {`

```
66 |           '0 'Í%•0 wă<Æzz•ôÿ Spaceÿ f/wă<Æ^"v„Wúg,~Äb SUOMÿ S T+Y N*Qwg \B~$Qs|ûv„e‡hc,,p¹0 ',
67 |           parameters: FeishuWikiSpaceSchema,
> 68 |           async execute(_toolCallId, params) {
69 |               const p = params;...
70 |               try {
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#1213 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/wiki/space.js:17](#)

Dependency without integrity verification

```
15 | Object.defineProperty(exports, "__esModule", { value: true });
16 | exports.registerFeishuWikiSpaceTool = registerFeishuWikiSpaceTool;
> 17 | const typebox_1 = require("@sinclair/typebox");
18 | const helpers_1 = require("../helpers.js");
19 | // -----
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1214 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oapi/wiki/space.js:18](#)

Dependency without integrity verification

```
16 | exports.registerFeishuWikiSpaceTool = registerFeishuWikiSpaceTool;
17 | const typebox_1 = require("@sinclair/typebox");
> 18 | const helpers_1 = require("../helpers.js");
19 | // -----
20 | // Schema
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1215 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oapi/wiki/space.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
2 | /**
3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#1216 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oauth-batch-auth.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
   2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates...
   3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#1217 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oauth-batch-auth.js:42](#)

High-risk permission pattern: async execute(_toolCallId, _params) {

```
> 40 |         "NÅw(u(b7f xn%•lB'c^gCb@g gC-P'0 'N k!`'c^g'e00•u(0 ",
   41 |         parameters: FeishuOAuthBatchAuthSchema,
   42 |         async execute(_toolCallId, _params) {
   43 |             try {
   44 |                 const ticket = (0, lark_ticket_1.getTicket)();
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#1218 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oauth-batch-auth.js:13](#)

Dependency without integrity verification

```
> 11 | Object.defineProperty(exports, "__esModule", { value: true });
   12 | exports.registerFeishuOAuthBatchAuthTool = registerFeishuOAuthBatchAuthTool;
   13 | const typebox_1 = require("@sinclair/typebox");
   14 | const app_scope_checker_1 = require("../core/app-scope-checker.js");
   15 | const tool_client_1 = require("../core/tool-client.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1219 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oauth-batch-auth.js:14](#)

Dependency without integrity verification

```
> 12 | exports.registerFeishuOAuthBatchAuthTool = registerFeishuOAuthBatchAuthTool;
   13 | const typebox_1 = require("@sinclair/typebox");
   14 | const app_scope_checker_1 = require("../core/app-scope-checker.js");
   15 | const tool_client_1 = require("../core/tool-client.js");
   16 | const token_store_1 = require("../core/token-store.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1220 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oauth-batch-auth.js:15](#)

Dependency without integrity verification

```
13 | const typebox_1 = require("@sinclair/typebox");
> 14 | const app_scope_checker_1 = require("../core/app-scope-checker.js");
    15 | const tool_client_1 = require("../core/tool-client.js");
    16 | const token_store_1 = require("../core/token-store.js");...
    17 | const accounts_1 = require("../core/accounts.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1221 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oauth-batch-auth.js:16](#)

Dependency without integrity verification

```
14 | const app_scope_checker_1 = require("../core/app-scope-checker.js");
> 15 | const tool_client_1 = require("../core/tool-client.js");
    16 | const token_store_1 = require("../core/token-store.js");
    17 | const accounts_1 = require("../core/accounts.js");
    18 | const lark_ticket_1 = require("../core/lark-ticket.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1222 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oauth-batch-auth.js:17](#)

Dependency without integrity verification

```
15 | const tool_client_1 = require("../core/tool-client.js");
> 16 | const token_store_1 = require("../core/token-store.js");
    17 | const accounts_1 = require("../core/accounts.js");
    18 | const lark_ticket_1 = require("../core/lark-ticket.js");
    19 | const lark_client_1 = require("../core/lark-client.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1223 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oauth-batch-auth.js:18](#)

Dependency without integrity verification

```
16 | const token_store_1 = require("../core/token-store.js");
17 | const accounts_1 = require("../core/accounts.js");
> 18 | const lark_ticket_1 = require("../core/lark-ticket.js");
19 | const lark_client_1 = require("../core/lark-client.js");...
20 | const api_error_1 = require("../core/api-error.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1224 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oauth-batch-auth.js:19](#)

Dependency without integrity verification

```
17 | const accounts_1 = require("../core/accounts.js");
18 | const lark_ticket_1 = require("../core/lark-ticket.js");
> 19 | const lark_client_1 = require("../core/lark-client.js");
20 | const api_error_1 = require("../core/api-error.js");
21 | const tool_scopes_1 = require("../core/tool-scopes.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1225 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oauth-batch-auth.js:20](#)

Dependency without integrity verification

```
18 | const lark_ticket_1 = require("../core/lark-ticket.js");
19 | const lark_client_1 = require("../core/lark-client.js");
> 20 | const api_error_1 = require("../core/api-error.js");
21 | const tool_scopes_1 = require("../core/tool-scopes.js");
22 | const domains_1 = require("../core/domains.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1226 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oauth-batch-auth.js:21](#)

Dependency without integrity verification

```
19 | const lark_client_1 = require("../core/lark-client.js");
20 | const api_error_1 = require("../core/api-error.js");
> 21 | const tool_scopes_1 = require("../core/tool-scopes.js");
22 | const domains_1 = require("../core/domains.js");
23 | const lark_logger_1 = require("../core/lark-logger.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1227 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oauth-batch-auth.js:22](#)

Dependency without integrity verification

```
20 | const api_error_1 = require("../core/api-error.js");
> 21 | const tool_scopes_1 = require("../core/tool-scopes.js");
    22 | const domains_1 = require("../core/domains.js");
    23 | const lark_logger_1 = require("../core/lark-logger.js");...
    24 | const helpers_1 = require("../oapi/helpers.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1228 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oauth-batch-auth.js:23](#)

Dependency without integrity verification

```
21 | const tool_scopes_1 = require("../core/tool-scopes.js");
> 22 | const domains_1 = require("../core/domains.js");
    23 | const lark_logger_1 = require("../core/lark-logger.js");
    24 | const helpers_1 = require("../oapi/helpers.js");
    25 | const oauth_1 = require("../oauth.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1229 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oauth-batch-auth.js:24](#)

Dependency without integrity verification

```
22 | const domains_1 = require("../core/domains.js");
> 23 | const lark_logger_1 = require("../core/lark-logger.js");
    24 | const helpers_1 = require("../oapi/helpers.js");
    25 | const oauth_1 = require("../oauth.js");
    26 | const log = (0, lark_logger_1.larkLogger)('tools/oauth-batch-auth');
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1230 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oauth-batch-auth.js:25](#)

Dependency without integrity verification

```
23 | const lark_logger_1 = require("../core/lark-logger.js");
24 | const helpers_1 = require("../oapi/helpers.js");
> 25 | const oauth_1 = require("../oauth.js");
26 | const log = (0, lark_logger_1.larkLogger)('tools/oauth-batch-auth');...
27 | const FeishuOAuthBatchAuthSchema = typebox_1.Type.Object({}, {
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1231 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oauth-cards.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#1232 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[src/tools/oauth-cards.js:164](#)

Potential secret: possible hardcoded secret

```
162 |             icon: {
163 |                 tag: 'standard_icon',
> 164 |                 token: 'lock-chat_filled',
165 |             },
166 |         },
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#1233 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[src/tools/oauth-cards.js:235](#)

Potential secret: possible hardcoded secret

```
233 |             icon: {
234 |                 tag: 'standard_icon',
> 235 |                 token: 'yes_filled',
236 |             },
237 |         },
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#1234 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[src/tools/oauth-cards.js:276](#)

Potential secret: possible hardcoded secret

```
274 |             icon: {
275 |                 tag: 'standard_icon',
276 |                 token: 'warning_filled',
277 |             },...
278 |         },
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#1235 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[src/tools/oauth-cards.js:311](#)

Potential secret: possible hardcoded secret

```
309 |             icon: {
310 |                 tag: 'standard_icon',
311 |                 token: 'close_filled',
312 |             },
313 |         },
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#1236 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oauth-cards.js:51](#)

High-risk permission pattern: batchAuthHint: "Ø=Ü; If you'd like to grant all permissions at

```
49 |         goAuth: 'Authorize Now',
50 |         expiresHint: (min) => `<font color='grey'>This link will time out in ${min} minutes, so
you'll need a new one if it expires.</font>`,
> 51 |         batchAuthHint: "<font color='grey'>Ø=Ü; If you'd like to grant all permissions at once, just say
\"Authorize all\", and I'll take care of it.</font>",
52 |         batchScopeMsg: (count, total, granted) => `The app requires ${count} additional user token
permissions (${granted} of ${total} granted).`,
53 |         scopePreviewLabel: '**Permissions to authorize**',
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#1237 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oauth-cards.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
  2 | /**...
  3 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#1238 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/oauth.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
  2 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
  3 | * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#1239 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oauth.js:106](#)

High-risk permission pattern: async execute(_toolCallId, params) {

```
104 |         'N - %*0 Qe user_open_idÿ |û-ß•êR`Nîm`oN N e†f·Sð_SRMu(b70 ',
105 |         parameters: FeishuOAuthSchema,
> 106 |         async execute(_toolCallId, params) {
107 |             const p = params;
108 |             // Resolve identity from trace context (set in monitor.ts).
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#1240 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oauth.js:265](#)

High-risk permission pattern: pendingFlows.delete(flowKey);

```
263 |         reuseCardId = oldFlow.cardId;
264 |         reuseSeq = oldFlow.sequence;
> 265 |         pendingFlows.delete(flowKey);
266 |         // scope T ^vÿ \ eç flow v,, scope N e°<÷lBT ^v
267 |         if (oldFlow.scope) {
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#1241 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oauth.js:280](#)

High-risk permission pattern: `pendingFlows.delete(flowKey);`

```
278 |         oldFlow.superseded = true;
279 |         oldFlow.controller.abort();
> 280 |         pendingFlows.delete(flowKey);
    281 |         log.info(`new message, cancelling old flow for user=${senderOpenId}, app=${appId}, old
      cardId=${oldFlow.cardId}`);...
282 |         // h <°eçSarGN:"c^gCg*[Æb "
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#1242 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oauth.js:463](#)

High-risk permission pattern: `pendingFlows.delete(flowKey);`

```
461 |         log.warn(`failed to update card for identity mismatch: ${e}`);
462 |     }
> 463 |     pendingFlows.delete(flowKey);
    464 |     pendingFlowDelete = true;
465 |     return;
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#1243 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oauth.js:496](#)

High-risk permission pattern: `pendingFlows.delete(flowKey);`

```
494 |     }
495 |     // R -d pending flow
> 496 |     pendingFlows.delete(flowKey);
    497 |     pendingFlowDelete = true;
498 |     // 2. Send synthetic message to notify AI that auth is
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#1244 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oauth.js:556](#)

High-risk permission pattern: `pendingFlows.delete(flowKey);`

```
554 |     }
555 |     // R -d pending flow
> 556 |     pendingFlows.delete(flowKey);
    557 |     pendingFlowDelete = true;
558 | }
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#1245 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/oauth.js:567](#)

High-risk permission pattern: `pendingFlows.delete(flowKey);`

```
565 | // SêW(_SRM flow Nif/lèQËv,,*ËN*eöbMR -dÿ **QMeçmA<iR e°mAv,, entry
> 566 | if (pendingFlows.get(flowKey) === currentFlow) {
567 |     pendingFlows.delete(flowKey);
568 | }...
569 | }
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#1246 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oauth.js:22](#)

Dependency without integrity verification

```
20 | exports.registerFeishu0AuthTool = registerFeishu0AuthTool;
21 | exports.executeAuthorize = executeAuthorize;
> 22 | const typebox_1 = require("@sinclair/typebox");
23 | const accounts_1 = require("../core/accounts.js");
24 | const owner_policy_1 = require("../core/owner-policy.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use `>=` or `latest`. 3. Run `npm audit` / `pip-audit` in CI. 4. Use `pip install --require-hashes` for Python. 5. Verify package signatures where available.

#1247 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oauth.js:23](#)

Dependency without integrity verification

```
21 | exports.executeAuthorize = executeAuthorize;
22 | const typebox_1 = require("@sinclair/typebox");
> 23 | const accounts_1 = require("../core/accounts.js");
24 | const owner_policy_1 = require("../core/owner-policy.js");
25 | const lark_client_1 = require("../core/lark-client.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use `>=` or `latest`. 3. Run `npm audit` / `pip-audit` in CI. 4. Use `pip install --require-hashes` for Python. 5. Verify package signatures where available.

#1248 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oauth.js:24](#)

Dependency without integrity verification

```
22 | const typebox_1 = require("@sinclair/typebox");
23 | const accounts_1 = require("../core/accounts.js");
> 24 | const owner_policy_1 = require("../core/owner-policy.js");
25 | const lark_client_1 = require("../core/lark-client.js");...
26 | const app_scope_checker_1 = require("../core/app-scope-checker.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1249 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oauth.js:25](#)

Dependency without integrity verification

```
23 | const accounts_1 = require("../core/accounts.js");
24 | const owner_policy_1 = require("../core/owner-policy.js");
> 25 | const lark_client_1 = require("../core/lark-client.js");
26 | const app_scope_checker_1 = require("../core/app-scope-checker.js");
27 | const lark_ticket_1 = require("../core/lark-ticket.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1250 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oauth.js:26](#)

Dependency without integrity verification

```
24 | const owner_policy_1 = require("../core/owner-policy.js");
25 | const lark_client_1 = require("../core/lark-client.js");
> 26 | const app_scope_checker_1 = require("../core/app-scope-checker.js");
27 | const lark_ticket_1 = require("../core/lark-ticket.js");
28 | const lark_logger_1 = require("../core/lark-logger.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1251 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oauth.js:27](#)

Dependency without integrity verification

```
25 | const lark_client_1 = require("../core/lark-client.js");
26 | const app_scope_checker_1 = require("../core/app-scope-checker.js");
> 27 | const lark_ticket_1 = require("../core/lark-ticket.js");
28 | const lark_logger_1 = require("../core/lark-logger.js");
29 | const log = (0, lark_logger_1.larkLogger)('tools/oauth');
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1252 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oauth.js:28](#)

Dependency without integrity verification

```
26 | const app_scope_checker_1 = require("../core/app-scope-checker.js");
> 27 | const lark_ticket_1 = require("../core/lark-ticket.js");
    28 | const lark_logger_1 = require("../core/lark-logger.js");
    29 | const log = (0, lark_logger_1.larkLogger)('tools/oauth');...
    30 | const api_error_1 = require("../core/api-error.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1253 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oauth.js:30](#)

Dependency without integrity verification

```
28 | const lark_logger_1 = require("../core/lark-logger.js");
> 29 | const log = (0, lark_logger_1.larkLogger)('tools/oauth');
    30 | const api_error_1 = require("../core/api-error.js");
    31 | const device_flow_1 = require("../core/device-flow.js");
    32 | const token_store_1 = require("../core/token-store.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1254 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oauth.js:31](#)

Dependency without integrity verification

```
29 | const log = (0, lark_logger_1.larkLogger)('tools/oauth');
> 30 | const api_error_1 = require("../core/api-error.js");
    31 | const device_flow_1 = require("../core/device-flow.js");
    32 | const token_store_1 = require("../core/token-store.js");
    33 | const uat_client_1 = require("../core/uat-client.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1255 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oauth.js:32](#)

Dependency without integrity verification

```
30 | const api_error_1 = require("../core/api-error.js");
31 | const device_flow_1 = require("../core/device-flow.js");
> 32 | const token_store_1 = require("../core/token-store.js");
33 | const uat_client_1 = require("../core/uat-client.js");...
34 | const cardkit_1 = require("../card/cardkit.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1256 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oauth.js:33](#)

Dependency without integrity verification

```
31 | const device_flow_1 = require("../core/device-flow.js");
32 | const token_store_1 = require("../core/token-store.js");
> 33 | const uat_client_1 = require("../core/uat-client.js");
34 | const cardkit_1 = require("../card/cardkit.js");
35 | const synthetic_message_1 = require("../messaging/inbound/synthetic-message.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1257 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oauth.js:34](#)

Dependency without integrity verification

```
32 | const token_store_1 = require("../core/token-store.js");
33 | const uat_client_1 = require("../core/uat-client.js");
> 34 | const cardkit_1 = require("../card/cardkit.js");
35 | const synthetic_message_1 = require("../messaging/inbound/synthetic-message.js");
36 | const oauth_cards_1 = require("../oauth-cards.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1258 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oauth.js:35](#)

Dependency without integrity verification

```
33 | const uat_client_1 = require("../core/uat-client.js");
34 | const cardkit_1 = require("../card/cardkit.js");
> 35 | const synthetic_message_1 = require("../messaging/inbound/synthetic-message.js");
36 | const oauth_cards_1 = require("../oauth-cards.js");
37 | const helpers_1 = require("../helpers.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1259 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oauth.js:36](#)

Dependency without integrity verification

```
34 | const cardkit_1 = require("../card/cardkit.js");
> 35 | const synthetic_message_1 = require("../messaging/inbound/synthetic-message.js");
    36 | const oauth_cards_1 = require("../oauth-cards.js");
    37 | const helpers_1 = require("../helpers.js");...
    38 | const json = helpers_1.formatToolResult;
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1260 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/oauth.js:37](#)

Dependency without integrity verification

```
35 | const synthetic_message_1 = require("../messaging/inbound/synthetic-message.js");
> 36 | const oauth_cards_1 = require("../oauth-cards.js");
    37 | const helpers_1 = require("../helpers.js");
    38 | const json = helpers_1.formatToolResult;
    39 | // -----
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1261 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/onboarding-auth.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
    2 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
    3 | * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#1262 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/onboarding-auth.js:16](#)

Dependency without integrity verification

```
14 | Object.defineProperty(exports, "__esModule", { value: true });
15 | exports.triggerOnboarding = triggerOnboarding;
> 16 | const accounts_1 = require("../core/accounts.js");
    17 | const lark_client_1 = require("../core/lark-client.js");...
    18 | const app_scope_checker_1 = require("../core/app-scope-checker.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1263 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/onboarding-auth.js:17](#)

Dependency without integrity verification

```
15 | exports.triggerOnboarding = triggerOnboarding;
16 | const accounts_1 = require("../core/accounts.js");
> 17 | const lark_client_1 = require("../core/lark-client.js");
    18 | const app_scope_checker_1 = require("../core/app-scope-checker.js");
    19 | const app_owner_fallback_1 = require("../core/app-owner-fallback.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1264 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/onboarding-auth.js:18](#)

Dependency without integrity verification

```
16 | const accounts_1 = require("../core/accounts.js");
17 | const lark_client_1 = require("../core/lark-client.js");
> 18 | const app_scope_checker_1 = require("../core/app-scope-checker.js");
    19 | const app_owner_fallback_1 = require("../core/app-owner-fallback.js");
    20 | const lark_logger_1 = require("../core/lark-logger.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1265 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/onboarding-auth.js:19](#)

Dependency without integrity verification

```
17 | const lark_client_1 = require("../core/lark-client.js");
18 | const app_scope_checker_1 = require("../core/app-scope-checker.js");
> 19 | const app_owner_fallback_1 = require("../core/app-owner-fallback.js");
    20 | const lark_logger_1 = require("../core/lark-logger.js");
    21 | const tool_scopes_1 = require("../core/tool-scopes.js");
```


Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1266 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/onboarding-auth.js:20](#)

Dependency without integrity verification

```
18 | const app_scope_checker_1 = require("../core/app-scope-checker.js");
> 19 | const app_owner_fallback_1 = require("../core/app-owner-fallback.js");
    20 | const lark_logger_1 = require("../core/lark-logger.js");
    21 | const tool_scopes_1 = require("../core/tool-scopes.js");...
    22 | const oauth_1 = require("../oauth.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1267 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/onboarding-auth.js:21](#)

Dependency without integrity verification

```
19 | const app_owner_fallback_1 = require("../core/app-owner-fallback.js");
> 20 | const lark_logger_1 = require("../core/lark-logger.js");
    21 | const tool_scopes_1 = require("../core/tool-scopes.js");
    22 | const oauth_1 = require("../oauth.js");
    23 | const log = (0, lark_logger_1.larkLogger)('tools/onboarding-auth');
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1268 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/onboarding-auth.js:22](#)

Dependency without integrity verification

```
20 | const lark_logger_1 = require("../core/lark-logger.js");
> 21 | const tool_scopes_1 = require("../core/tool-scopes.js");
    22 | const oauth_1 = require("../oauth.js");
    23 | const log = (0, lark_logger_1.larkLogger)('tools/onboarding-auth');
    24 | // -----
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1269 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/tat/im/index.d.ts:13](#)

High-risk permission pattern: *QvRŸËŸu1 ChannelMessageActionAdapter (actions.ts) v,, react/delete action ~BN %o†vÖ0

```
11 | *  
12 | * Note: feishu_im_message_reaction TÆ feishu_im_message_recall jöyü-dŸ  
> 13 | * QvRŸËŸu1 ChannelMessageActionAdapter (actions.ts) v,, react/delete action ~BN %†vÖ0  
14 | */...  
15 | export declare function registerFeishuImTools(api: OpenClawPluginApi): void;
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#1270 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/tat/im/index.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**  
2 | * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates  
3 | * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#1271 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/tat/im/index.js:16](#)

High-risk permission pattern: *QvRŸËŸu1 ChannelMessageActionAdapter (actions.ts) v,, react/delete action ~BN %o†vÖ0

```
14 | *  
15 | * Note: feishu_im_message_reaction TÆ feishu_im_message_recall jöyü-dŸ  
> 16 | * QvRŸËŸu1 ChannelMessageActionAdapter (actions.ts) v,, react/delete action ~BN %†vÖ0  
17 | */...  
18 | function registerFeishuImTools(api) {
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#1272 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/tat/im/index.js:11](#)

Dependency without integrity verification

```
9 | Object.defineProperty(exports, "__esModule", { value: true });  
10 | exports.registerFeishuImTools = registerFeishuImTools;  
> 11 | const resource_1 = require("./resource.js");  
12 | /**  
13 | * lèQEb@g IM jâQw
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1273 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/tat/im/resource.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | /**
    2 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates...
    3 |  * SPDX-License-Identifier: MIT
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#1274 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/tat/im/resource.js:15](#)

Dangerous execution: var __createBinding = (this && this.__createBinding) || (Object.create ? (functi

```
13 |  * Qi<Á: tenant_access_token
14 |  */
> 15 | var __createBinding = (this && this.__createBinding) || (Object.create ? (function(o, m, k, k2) {
16 |     if (k2 === undefined) k2 = k;
17 |     var desc = Object.getOwnPropertyDescriptor(m, k);
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#1275 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/tat/im/resource.js:19](#)

Dangerous execution: desc = { enumerable: true, get: function() { return m[k]; } };

```
17 |     var desc = Object.getOwnPropertyDescriptor(m, k);
18 |     if (!desc || ("get" in desc ? !m.__esModule : desc.writable || desc.configurable)) {
> 19 |         desc = { enumerable: true, get: function() { return m[k]; } };
20 |     }
21 |     Object.defineProperty(o, k2, desc);
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#1276 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/tat/im/resource.js:22](#)

Dangerous execution: `}} : (function(o, m, k, k2) {`

```
20 |     }
21 |     Object.defineProperty(o, k2, desc);
> 22 |   }} : (function(o, m, k, k2) {
23 |     if (k2 === undefined) k2 = k;...
24 |     o[k2] = m[k];
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#1277 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/tat/im/resource.js:26](#)

Dangerous execution: `var __setModuleDefault = (this && this.__setModuleDefault) || (Object.create ? (`

```
24 |     o[k2] = m[k];
25 |   }));
> 26 |   var __setModuleDefault = (this && this.__setModuleDefault) || (Object.create ? (function(o, v) {
27 |     Object.defineProperty(o, "default", { enumerable: true, value: v });
28 |   }) : function(o, v) {
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#1278 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/tat/im/resource.js:28](#)

Dangerous execution: `}} : function(o, v) {`

```
26 |   var __setModuleDefault = (this && this.__setModuleDefault) || (Object.create ? (function(o, v) {
27 |     Object.defineProperty(o, "default", { enumerable: true, value: v });
> 28 |   }) : function(o, v) {
29 |     o["default"] = v;
30 |   });
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#1279 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/tat/im/resource.js:31](#)

Dangerous execution: `var __importStar = (this && this.__importStar) || (function () {`

```
29 |     o["default"] = v;
30 |   });
> 31 |   var __importStar = (this && this.__importStar) || (function () {
32 |     var ownKeys = function(o) {
33 |       ownKeys = Object.getOwnPropertyNames || function (o) {
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#1280 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/tat/im/resource.js:32](#)

Dangerous execution: `var ownKeys = function(o) {`

```
30 | });
31 | var __importStar = (this && this.__importStar) || (function () {
> 32 |     var ownKeys = function(o) {
33 |         ownKeys = Object.getOwnPropertyNames || function (o) {...
34 |         var ar = [];
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#1281 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/tat/im/resource.js:33](#)

Dangerous execution: `ownKeys = Object.getOwnPropertyNames || function (o) {`

```
31 | var __importStar = (this && this.__importStar) || (function () {
32 |     var ownKeys = function(o) {
> 33 |         ownKeys = Object.getOwnPropertyNames || function (o) {
34 |             var ar = [];
35 |             for (var k in o) if (Object.prototype.hasOwnProperty.call(o, k)) ar[ar.length] = k;
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#1282 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/tools/tat/im/resource.js:40](#)

Dangerous execution: `return function (mod) {`

```
38 |         return ownKeys(o);
39 |     };
> 40 |     return function (mod) {
41 |         if (mod && mod.__esModule) return mod;
42 |         var result = {};
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#1283 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/tools/tat/im/resource.js:160](#)

High-risk permission pattern: `async execute(_toolCallId, params) {`

```
158 |         '\n\nne#Nö•êR`OÝ[XR0 /tmp/openssl/ N ÿ •ôVbP<N-v,, saved_path N:[ž-EOÝ[X•i_„0 ',
159 |         parameters: FeishuImBotImageSchema,
> 160 |         async execute(_toolCallId, params) {
161 |             const p = params;...
162 |             try {
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#1284 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/tat/im/resource.js:50](#)

Dependency without integrity verification

```
48 | Object.defineProperty(exports, "__esModule", { value: true });
49 | exports.registerFeishuImBotImageTool = registerFeishuImBotImageTool;
> 50 | const fsPromises = __importStar(require("node:fs/promises"));
51 | const path = __importStar(require("node:path"));
52 | const temp_path_1 = require("openssl/plugin-sdk/temp-path");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use `>=` or `latest`. 3. Run `npm audit` / `pip-audit` in CI. 4. Use `pip install --require-hashes` for Python. 5. Verify package signatures where available.

#1285 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/tat/im/resource.js:51](#)

Dependency without integrity verification

```
49 | exports.registerFeishuImBotImageTool = registerFeishuImBotImageTool;
50 | const fsPromises = __importStar(require("node:fs/promises"));
> 51 | const path = __importStar(require("node:path"));
52 | const temp_path_1 = require("openssl/plugin-sdk/temp-path");
53 | const typebox_1 = require("@sinclair/typebox");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use `>=` or `latest`. 3. Run `npm audit` / `pip-audit` in CI. 4. Use `pip install --require-hashes` for Python. 5. Verify package signatures where available.

#1286 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/tat/im/resource.js:52](#)

Dependency without integrity verification

```
50 | const fsPromises = __importStar(require("node:fs/promises"));
51 | const path = __importStar(require("node:path"));
> 52 | const temp_path_1 = require("openssl/plugin-sdk/temp-path");
53 | const typebox_1 = require("@sinclair/typebox");
54 | const helpers_1 = require("../oapi/helpers.js");
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1287 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/tat/im/resource.js:53](#)

Dependency without integrity verification

```
51 | const path = __importStar(require("node:path"));
> 52 | const temp_path_1 = require("openclaw/plugin-sdk/temp-path");
    53 | const typebox_1 = require("@sinclair/typebox");
    54 | const helpers_1 = require("../oapi/helpers.js");...
55 | // =====
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1288 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/tools/tat/im/resource.js:54](#)

Dependency without integrity verification

```
52 | const temp_path_1 = require("openclaw/plugin-sdk/temp-path");
53 | const typebox_1 = require("@sinclair/typebox");
> 54 | const helpers_1 = require("../oapi/helpers.js");
    55 | // =====
56 | // Shared constants
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1289 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/tools/tat/im/resource.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
   2 | /**
   3 |  * Copyright (c) 2026 ByteDance Ltd. and/or its affiliates
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#1290 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tsdown.config.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | declare const _default: import("tsdown/types-D2Jnze_i").d;
  2 | export default _default;...
  3 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#1291 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[tsdown.config.js:3](#)

Dependency without integrity verification

```
> 1 | "use strict";
  2 | Object.defineProperty(exports, "__esModule", { value: true });
  3 | const tsdown_1 = require("tsdown");
  4 | exports.default = (0, tsdown_1.defineConfig)({
  5 |   entry: { index: 'index.ts' },
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1292 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tsdown.config.js:1](#)

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
  2 | Object.defineProperty(exports, "__esModule", { value: true });
  3 | const tsdown_1 = require("tsdown");
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#1293 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[vitest.config.d.ts:1](#)

No logging, auditing, or monitoring detected

```
> 1 | declare const _default: UserConfig;
  2 | export default _default;
  3 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#1294 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

`vitest.config.js:3`

Dependency without integrity verification

```
> 1 | "use strict";
  2 | Object.defineProperty(exports, "__esModule", { value: true });
  3 | const config_1 = require("vitest/config");
  4 | exports.default = (0, config_1.defineConfig)({...
  5 |     test: {
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#1295 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`vitest.config.js:1`

No logging, auditing, or monitoring detected

```
> 1 | "use strict";
  2 | Object.defineProperty(exports, "__esModule", { value: true });
  3 | const config_1 = require("vitest/config");
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

Remediation Checklist

Prioritized by severity. Address CRITICAL items first.

Quick Win

`npm install mcp-secure`

Adds cryptographic passports, signed messages, tool verification, and audit logging.

CRITICAL (2)

- ☐ **AS-001: unsafe execution**
Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code).
- ☐ **AS-005: injection pattern**
Validate and sanitize all inputs with strict allowlists.

HIGH (2)

- ☐ **AS-002: secret scan**
Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv).
- ☐ **AS-006: sandboxing**
Run all agent-generated code in Docker containers with `--network=none` and read-only filesystem.

MEDIUM (2)

- ☐ **AS-010: logging monitoring**
Add structured logging (JSON) for every agent action, tool call, and decision.
- ☐ **AS-003: excessive permissions**
Apply principle of least privilege — grant only permissions the agent needs for its specific task.

LOW (1)

- ☐ **AS-007: supply chain**
Use lockfiles (`package-lock.json`, `poetry.lock`, `requirements.txt` with hashes).

Methodology & Standards

Scanner	mcps-audit v1.0.0
Rules Version	1.1.0
Scanned At	08/05/2026, 02:17:17
Report ID	MCPS-MOVT68EJ

Referenced Standards

- OWASP MCP Top 10**
Security risks for Model Context Protocol servers and clients.
owasp.org/www-project-mcp-top-10
- OWASP Agentic AI Top 10**
Security risks for autonomous AI agents.
owasp.org/www-project-agentic-ai-top-10
- MCPS -- IETF Internet-Draft**
Cryptographic security layer for MCP: draft-sharif-mcps-secure-mcp.
datatracker.ietf.org/doc/draft-sharif-mcps-secure-mcp
- MITRE ATT&CK**
Adversary tactics and techniques knowledge base.
attack.mitre.org
- STRIDE Threat Model**
Microsoft threat classification framework.
microsoft.com/en-us/security/blog/stride

AgentSign
Cryptographic identity and security for AI agents
agentsign.dev